

NIST SP 800-63-4 Conformance Criteria v0.1: 63Base

Control Identifier	Control Name	Control Text	Objective	Assessment Method	Index	Target	Profile/XAL Level	Discussion
DIRM-1	Digital Identity Risk Management - RP Process Implementation	Federal RPs SHALL implement the DIRM process for all online services.	Determine if all online services of the Federal RP are identified and ensure the DIRM process is implemented for those online services.	Examine DIRM policy to determine that it is intended to cover all organizational applications. If available, review the list of online services to ensure all services are identified and that DIRM documentation for each online service exists.	3.0 #1	RP	DIRM	For relying parties, the intent of [the DIRM] process is to determine the assurance levels and any tailoring required to protect all online services and the applications, transactions, and systems that comprise or are impacted by those services. This directly contributes to the selection, development, and procurement of CSP services.
DIRM-2	Digital Identity Risk Management - CSP/IdP Communication of Normative Deviations	Whenever a service offering deviates from normative guidance, those deviations SHALL be clearly communicated to the RPs that utilize the service.	Ensure that the CSP/IdP has a documented process for communicating when their services deviate from the established normative guidance of the applicable NIST SP 900-63 requirements.	Examine the CSP/IdP policy for communicating deviations from normative guidance. Interview relying party customers to confirm they are familiar with the policy and process for communication and determine if the process is being used.	3.0 #2	CSP/IdP	DIRM	For credential service providers and identity providers, the intent of [the DIRM] process is to design service offerings that meet the requirements of the defined assurance levels, continuously guard against compromises to the identity system, and meet the needs of RPs.
DIRM-3	Digital Identity Risk Management - Documentation	At a minimum, organizations SHALL execute and document each step and complete and document the normative mandates and outcomes of each step, regardless of any organization-specific processes or tools used in the overall DIRM process.	Determine that each step of the DIRM process is executed and documented.	Examine the DIRM process documentation to ensure the outcomes of each step are completed as applicable.	3.0 A	Organization	DIRM	This requirement is agnostic to any organization-specific processes or tools used in the overall DIRM process. (Ref. Sec. 3.0 #A)
DOS-1a	Define Online Services - Mission and Business	RPs SHALL develop a description of the online service that includes the organizational mission and business objectives supported by the online service.	Determine if a description of the online service has been developed that includes the organizational mission and business objectives that are supported by the online service.	Examine the organization's DIRM documentation for each online service to ensure it includes a description of its organizational mission and business objectives.	3.1 A	RP	DIRM Step 1	The purpose of this initial step is to establish a common understanding of the online service's context and functionality, which is essential for informing the subsequent risk assessment steps of the DIRM process.
DOS-1b	Define Online Services - Dependencies	RPs SHALL develop a description of the online service that includes the mission and business partner dependencies associated with the online service.	Determine if a description of the online service has been developed that includes the mission and business partner dependencies associated with the online service.	Examine the organization's DIRM documentation for each online service to ensure it includes its associated mission and business partner dependencies.	3.1 A	RP	DIRM Step 1	The purpose of this initial step is to establish a common understanding of the online service's context and functionality, which is essential for informing the subsequent risk assessment steps of the DIRM process.
DOS-1c	Define Online Services - Legal, Regulatory, Contractual	RPs SHALL develop a description of the online service that includes legal, regulatory, and contractual requirements, including privacy obligations that apply to the online service.	Determine if a description of the online service has been developed that includes the legal, regulatory, and contractual requirements, including obligations that apply to the online service.	Examine the organization's DIRM documentation for each online service to ensure it includes its legal, regulatory, and contractual requirements, including obligations that apply to the online service.	3.1 A	RP	DIRM Step 1	The purpose of this initial step is to establish a common understanding of the online service's context and functionality, which is essential for informing the subsequent risk assessment steps of the DIRM process.
DOS-1d	Define Online Services - Functionality and Data Processing	RPs SHALL develop a description of the online service that includes the functionality of the online service and the data that it is expected to process.	Determine if a description of the online service has been developed that includes the functionality of the online service and the data that it is expected to process.	Examine the organization's DIRM documentation for each online service to ensure it includes its functionality and the data that it is expected to process.	3.1 A	RP	DIRM Step 1	The purpose of this initial step is to establish a common understanding of the online service's context and functionality, which is essential for informing the subsequent risk assessment steps of the DIRM process.

NIST SP 800-63-4 Conformance Criteria v0.1: 63Base

Control Identifier	Control Name	Control Text	Objective	Assessment Method	Index	Target	Profile/XAL Level	Discussion
DOS-1e	Define Online Services - User Groups Transactions & Access Privileges	RPs SHALL develop a description of the online service that includes user groups that need to have access to the online service as well as the types of online transactions and access privileges available to each user group.	Determine if a description of the online service has been developed that includes the user groups that need to have access to the online service.	Examine the organization's DIRM documentation for each online service to ensure it identifies user groups and the transaction types and access privileges associated with each group.	3.1 A	RP	DIRM Step 1	The purpose of this initial step is to establish a common understanding of the online service's context and functionality, which is essential for informing the subsequent risk assessment steps of the DIRM process. The set of entities includes users of the online service, organizations, and populations served. It is crucial to differentiate between user groups and impacted entities. (a) User groups are users who are partitioned based on the specific functionality or access privileges offered to them (e.g., citizens checking tax status vs. tax preparers filing returns). (b) Impacted entities include everyone who could face negative consequences if the identity system fails. This group includes members of the user groups but also potentially those who never directly use the system.
DOS-1f	Define Online Services - Impacted Entities and Business Processes	RPs SHALL develop a description of the online service that includes the set of entities (to include users of the online service, organizations, and populations served) that will be impacted by the online service and the broader business process of which it is a part.	Determine if a description of the online service has been developed that includes the set of entities that will be impacted by the online service and the broader business process of which it is a part.	Examine the organization's DIRM documentation for each online service to ensure it includes the set of entities that will be impacted by the online service and the broader business process of which it is a part.	3.1 A	RP	DIRM Step 1	The purpose of this initial step is to establish a common understanding of the online service's context and functionality, which is essential for informing the subsequent risk assessment steps of the DIRM process. The set of entities includes users of the online service, organizations, and populations served.
DOS-1g	Define Online Services - Previous Assessment Results and Technologies	RPs SHALL develop a description of the online service that includes the results of any preexisting DIRM assessments (as an input) and the current state of any preexisting identity technologies (i.e., proofing, authentication, or federation).	Determine if a description of the online service has been developed that includes the results of any preexisting DIRM assessments and the current state of any preexisting identity technologies.	Examine the organization's DIRM documentation for each online service to ensure it includes the results of any preexisting DIRM assessments and/or a description of the current state of any preexisting identity technologies.	3.1 A	RP	DIRM Step 1	The purpose of this initial step is to establish a common understanding of the online service's context and functionality, which is essential for informing the subsequent risk assessment steps of the DIRM process.
DOS-1h	Define Online Services - Identity Evidence Availability	RPs SHALL develop a description of the online service that includes the estimated availability of the types of identity evidence required for identity proofing across all user groups served.	Determine if a description of the online service has been developed that includes the estimated availability of the types of identity evidence required for identity proofing across all user groups served.	Examine the organization's DIRM documentation for each online service to ensure it includes the estimated availability of the types of identity evidence required for identity proofing across all user groups served.	3.1 A	RP	DIRM Step 1	The purpose of this initial step is to establish a common understanding of the online service's context and functionality, which is essential for informing the subsequent risk assessment steps of the DIRM process.
DOS-2	Define Online Services - Impact Assessment Scope - Users and Organization	The scope of impact assessments SHALL include individuals who use the online service as well as the organization itself.	Determine if the scope of impact assessments includes impacts to individuals who use the online service and impacts to the organization.	Examine the organization's DIRM documentation for each online service to ensure the impact assessments address impacts to the individuals who use the online service and impacts to the organization.	3.1 B	Organization	DIRM Step 1, Impact assessment	Note: "online application" is the same as "online service".

NIST SP 800-63-4 Conformance Criteria v0.1: 63Base

Control Identifier	Control Name	Control Text	Objective	Assessment Method	Index	Target	Profile/XAL Level	Discussion
DOS-3	Define Online Services - Impact Assessment Scope - Entities included in Mission and Business Needs	The scope of impact assessments for organizations SHALL identify other entities (e.g., mission partners, communities, and those identified in [SP800-30]) that need to be specifically included based on mission and business needs.	Determine if the scope of impact assessments for organizations identify other entities that need to be specifically included based on mission and business needs.	Examine the organization's DIRM documentation for each online service to ensure the impact assessments address mission partners and other external organizations that may be impacted by the online service.	3.1 C	Organization	DIRM Step 1, Impact assessment	DOS-3 deals with user groups.
DOS-4	Define Online Services - Impact Assessment Scope - Impacted Entities	At a minimum, organizations SHALL document all impacted entities (both internal and external to the organization) when conducting their impact assessments.	Determine if the scope of impact assessments for organizations identify all internal and external impacted entities.	Examine the organization's DIRM documentation for each online service to ensure it includes a description of the scope of impact assessments for organizations that identifies all internal and external impacted entities.	3.1 D	Organization	DIRM Step 1, Impact assessment	DOS-4 deals with impacted entities.
CIA-1a	Impact Assessment - Potential Harms for Impact Categories	The impact assessment SHALL include a set of impact categories and the potential harms for each impact category.	Determine that the impact assessment includes a set of impact categories and the potential harms for each impact category.	Examine the organization's DIRM impact assessment documentation to establish that the impact assessment includes a set of impact categories and the potential harms for each impact category.	3.2 A	Organization	DIRM Step 2, Impact assessment	
CIA-1b	Impact Assessment - Levels of Impact Identification	The impact assessment SHALL include identifying the levels of impact.	Determine that the impact assessment includes the levels of impact.	Examine the organization's DIRM impact assessment documentation to establish that the impact assessment includes the levels of impact.	3.2 A	Organization	DIRM Step 2, Impact assessment	
CIA-1c	Impact Assessment - Levels of Impact - User Groups	The impact assessment SHALL include assessing the level of impact for each user group.	Determine that the impact assessment includes an assessment of the level of impact for each user group.	Examine the organization's DIRM impact assessment documentation to establish that the impact assessment includes an assessment for the level of impact for each user group.	3.2 A	Organization	DIRM Step 2, Impact assessment	
CIA-2	Impact Assessment - Levels of Impact - Transactions	The level of impact for each user group identified in Sec. 3.1 SHALL be considered separately based on the transactions available to that user group.	Determine if the levels of impact for each user group is considered separately based on the transactions available to that user group.	Examine the organization's DIRM impact assessment documentation to establish that the levels of impact for each user group is considered separately based on the transactions available to that user group.	3.2 B	Organization	DIRM Step 2, Impact assessment	
IC-1	Impact Categories	At a minimum, organizations SHALL include the following impact categories in their impact assessments: (a) Degradation of mission delivery. (b) Damage to trust, standing, or reputation. (c) Unauthorized access to information. (d) Financial loss or liability. (e) Loss of life or danger to human safety, human health, or environmental health.	Determine if the impact categories in the impact assessments include degradation of mission delivery, damage to trust, standing, or reputation, unauthorized access to information, financial loss or liability, and loss of life or danger to human safety, human health, or environmental health.	Examine the organization's DIRM impact assessment documentation to establish that the impact categories include degradation of mission delivery, damage to trust, standing, or reputation, unauthorized access to information, financial loss or liability, and loss of life or danger to human safety, human health, or environmental health.	3.2.1 A	Organization	Impact categories, Potential harms	
IC-2	Impact Categories - Documentation and Application	Each impact category SHALL be documented and consistently applied when implementing the DIRM process across different online services offered by the organization.	Determine if, for each online service offered by the organization, each impact category is documented and applied as part of the DIRM process.	Examine the organization's DIRM impact assessment documentation to establish that, for each online service, each impact category is documented and applied.	3.2.1 B	Organization	Impact categories, Potential harms	
IC-3	Impact Categories - Potential Harms	For each impact category, organizations SHALL consider potential harms for each of the impacted entities identified in Sec. 3.1	Determine if potential harms are identified for each impact category and each of the impacted entities.	Examine the organization's DIRM impact assessment documentation to establish that potential harms are identified for each impact category and each of the impacted entities.	3.2.1 C	Organization	Impact categories, Potential harms	

NIST SP 800-63-4 Conformance Criteria v0.1: 63Base

Control Identifier	Control Name	Control Text	Objective	Assessment Method	Index	Target	Profile/XAL Level	Discussion
PIL-1	Potential Impact Levels - Threshold Development, Examples, and Documentation	To provide a more objective basis for impact level assignments, organizations SHOULD develop thresholds and examples for the impact levels for each impact category. Where this is done, particularly with specifically defined quantifiable values, these thresholds SHALL be documented and used consistently in the DIRM assessments across an organization to allow for a common understanding of risks.	PIL-1Obj1: Determine if thresholds and examples for the impact levels for each impact category have been developed. (Optional) PIL-1Obj2: Determine if PIL-1Obj1 is documented and used consistently in the DIRM assessments. (conditional)	Examine the DIRM impact assessment documentation to verify that they are documented, including any specifically defined quantifiable values, and look for evidence of consistent use in the DIRM assessments.	3.2.2 A	Organization	Impact levels	Assessment is required when: thresholds and examples for the impact levels were developed.
IA-1	Impact Analysis - Impacts from Unauthorized Access	The impact analysis SHALL consider the level of impact for each impact category for each type of impacted entity if an intruder obtains unauthorized access as a member of each user group.	Determine if the impact analysis considers the level of impact resulting from unauthorized access, for each impact category for each type of impacted entity.	Examine the analysis of the organization's DIRM impact assessment to establish that it considers impacts from unauthorized access for each type of impacted entity,	3.2.3 A	Organization	Impact analysis	
IA-2	Impact Analysis - User Groups	The impact analysis SHALL be performed for each user group that has access to the online service.	Determine if the impact analysis is performed for each user group that has access to the online service.	Examine documentation for the impact analyses performed to determine that one exists for each user group that has access to the online service.	3.2.3 B	Organization	Impact analysis	
IA-3	Impact Analysis - Output Documentation	The output of this impact analysis is a set of impact levels for each user group that SHALL be documented for further analysis in accordance with Sec. 3.4.	Determine if the output of the impact analysis includes a documented set of impact levels.	Examine the output of the impact analysis to verify that it includes a documented set of impact levels.	3.2.3 C	Organization	Impact analysis	
CIL-1	Combined Impact - Overall Impact Level and Application	Organizations SHALL document the approach they use to combine their impact assessment into an overall impact level for each of their defined user groups and SHALL apply it consistently across all of its online services.	1. Determine if the approach used to combine the impact assessment into an overall impact level for each defined user group has been documented. 2. Determine if the approach used to combine the impact assessment into an overall impact level for each defined user group is applied consistently across all online services.	Examine the DIRM process documentation to ensure that the approach used to combine the impact assessment into an overall impact level for each defined user group has been documented. Interview the person/people responsible for implementing this approach to ensure they understand the approach and are implementing it consistently.	3.2.4 A	Organization	Impact levels, User groups	
CIL-2	Combined Impact Level - Impact Documentation	At the conclusion of the combinatorial analysis, organizations SHALL document the impact for each user group.	Determine if the overall impact levels for each user group have been documented.	Examine the completed combined impact assessments to ensure the approach and results for each user group have been documented.	3.2.4 B	Organization	Impact levels, User groups	

NIST SP 800-63-4 Conformance Criteria v0.1: 63Base

Control Identifier	Control Name	Control Text	Objective	Assessment Method	Index	Target	Profile/XAL Level	Discussion
AL-1	Assurance Levels - xAL Need Determination	The RP SHALL identify the types of assurance levels that apply to their online service from the following: (a) IAL: The robustness of the identity proofing process to determine the identity of an individual. The IAL is selected to mitigate risks that result from potential identity proofing failures. (b) AAL: The robustness of the authentication process itself and the binding between an authenticator and a specific individual's identifier. The AAL is selected to mitigate risks that result from potential authentication failures. (c) FAL: The robustness of the federation process used to communicate authentication and attribute information to an RP from an IdP. The FAL is selected to mitigate risks that result from potential federation failures.	Determine if the online service needs an IAL, AAL, or FAL.	Examine the documented needs of the identity service, the results of the DIRM documentation completed to date, and the IAL requirements from 800-63A, to determine if identity proofing is necessary. Examine the documented needs of the identity service, the results of the DIRM documentation completed to date, and the IAL requirements from 800-63B, to determine if authentication is needed. Examine the documented needs of the identity service, the results of the DIRM documentation completed to date, and the IAL requirements from 800-63C, to determine if federation is needed.	3.3.1 A	RP	IAL, AAL, FAL	
IALS-1	Initial Assurance Level Selection - Process and Governance Documentation	Organizations SHALL develop and document a process and governance model for selecting initial assurance levels and controls based on the potential impacts of failures in the digital identity system.	Determine if the process and governance model for selecting initial assurance levels and controls has been developed based on the potential impacts of failures in the digital identity system and has been documented.	Examine the DIRM documentation to verify that the process and governance model for selecting initial assurance levels and controls has been developed and documented. Examine the process and governance model documentation and identify the potential impacts of failures that the process and governance model were based on.	3.3.3 A	Organization	Assurance levels	
IIAL-1a	Initial IAL - Decision Documentation	The organization SHALL document whether identity proofing is required for their application.	Determine if the question of whether identity proofing is required for the online service has been documented.	Examine the online service documentation to verify that the results of the analysis to determine the need for identity proofing has been documented.	3.3.3.1 A	Organization	IAL	This documents the results of control AL-1.
IIAL-1b	Initial IAL - Selection	If identity proofing is required for their application, the organization SHALL select an initial IAL for each user group based on the effective impact level determination from Sec. 3.2.4.	Determine if an initial IAL for each user group was determined and is based on the impact level determination (see CIL requirements)	Examine the documentation to verify that the initial IAL has been determined for each user group and is based on the effective impact level determination (See CIL controls).	3.3.3.1 A	Organization	IAL	Assessment is required when: the online service requires identity proofing for their user groups. See AL-1. If identity proofing is required, see CIL controls for impact levels.
IAAL-1a	Initial AAL - Decision Documentation	The organization SHALL document whether authentication is required for their application.	Determine if the question of whether authentication is required for the online service has been documented.	Examine the online service documentation to verify that the results of the analysis to determine the need for authentication has been documented.	3.3.3.2 A	Organization	AAL	This documents the results of requirement AL-1.
IAAL-1b	Initial AAL - Selection	If authentication is required for their application, the organization SHALL select an initial AAL for each user group based on the effective impact level determination from Sec. 3.2.4.	Determine if an initial AAL for each user group was determined and is based on the impact level determination (see CIL requirements)	Examine the documentation to verify that the initial AAL has been determined for each user group and is based on the effective impact level determination (See CIL controls).	3.3.3.2 A	Organization	AAL	Assessment is required when: the online service requires authentication. See AL-1. If authentication is required, see CIL controls for impact levels.
IFAL-1a	Initial FAL - Decision Documentation	The organization SHALL document whether federation is required for their application.	Determine if the question of whether federation is required for the online service has been documented.	Examine the online service documentation to verify that the results of the analysis to determine the need for federation has been documented.	3.3.3.3 A	Organization	FAL	This documents the results of the FAL assessment in control AL-1. Assessment is required when: the organization will use federation.

NIST SP 800-63-4 Conformance Criteria v0.1: 63Base

Control Identifier	Control Name	Control Text	Objective	Assessment Method	Index	Target	Profile/XAL Level	Discussion
IFAL-1b	Initial FAL - Selection	If federation is required for their application, the organization SHALL select an initial FAL for each user group based on the effective impact level determination from Sec. 3.2.4.	Determine if an initial FAL for each user group was determined and is based on the impact level determination (see CIL requirements)	Examine the documentation to verify that the initial FAL has been determined for each user group and is based on the effective impact level determination (See CIL controls).	3.3.3.3 A	Organization	FAL	Assessment is required when: the online service requires federation. See AL-1. If federation will be used, see CIL controls for impact levels.
IFAL-2	Initial FAL - FAL2 or FAL3 Assessment	For online services that are assessed to be high impact, organizations SHALL conduct a further assessment to evaluate the risk of a compromised IdP to determine whether FAL2 or FAL3 is more appropriate for their use case.	If the online service is "high impact," determine if further assessment has been done to evaluate the risk of a compromised IdP and if FAL2 or FAL3 is more appropriate.	Examine the documentation for additional assessments that evaluate if FAL2 or FAL3 is more appropriate.	3.3.3.3 B	Organization	FAL	Dependent on the results from controls AL-1 and IFAL-1a. Assessment is required when: the online service is assessed to be "high-impact."
BC-1a	Baseline Controls - IAL Controls	Using the initial xALs selected in Sec. 3.3.3, the organization SHALL identify the applicable baseline controls for each user group for the Initial IAL and related technical and process controls from [SP800-63A].	Determine if the applicable baseline controls for the initial IAL and related technical and process controls have been identified for each user group in alignment with SP 800-63A.	Examine the initial IAL baseline controls and related technical and process controls to determine that they are in alignment with SP 800-63A for each user group.	3.3.3 A	Organization	Baseline Controls	See IIAL controls.
BC-1b	Baseline Controls - AAL Controls	Using the initial xALs selected in Sec. 3.3.3, the organization SHALL identify the applicable baseline controls for each user group for the Initial AAL and related technical and process controls from [SP800-63B].	Determine if the applicable baseline controls for the initial AAL and related technical and process controls have been identified for each user group in alignment with SP 800-63B.	Examine the initial AAL baseline controls and related technical and process controls to determine that they are in alignment with SP 800-63B for each user group.	3.3.3 A	Organization	Baseline Controls	See IAAL controls.
BC-1c	Baseline Controls - FAL Controls	Using the initial xALs selected in Sec. 3.3.3, the organization SHALL identify the applicable baseline controls for each user group for the Initial FAL and related technical and process controls from [SP800-63C].	Determine if the applicable baseline controls for the initial FAL and related technical and process controls have been identified for each user group in alignment with SP 800-63C.	Examine the initial FAL baseline controls and related technical and process controls to determine that they are in alignment with SP 800-63C for each user group	3.3.3 A	Organization	Baseline Controls	See IFAL controls.
TAL-1	Tailor Assurance Levels - Mission Impacts	Within the tailoring step, organizations SHALL focus on impacts to mission delivery due to the implementation of identity management controls.	Determine if the impacts to mission delivery are used as a focus for the tailoring step.	Examine the tailoring documentation to ensure impacts to mission are used as a focus.	3.4 A	Organization	Tailoring	Impacts include the possibility of legitimate users who are unable to access desired online services or experience sufficient friction or frustration with the identity system (and technology selection) that they abandon attempts to access the online service.(Ref. Sec. 3.4 A)
TAL-2	Tailor Assurance Levels - DIAS Review	As a part of the tailoring process, organizations SHALL review the Digital Identity Acceptance Statements (DIAS) and practice statements from CSPs and IdPs that they use or intend to use.	Determine if the DIAS and practice statements from CSPs and IdPs have been reviewed as part of the tailoring process.	Interview the person/team responsible for completing the tailoring step to ensure they reviewed the DIAS and practice statements.	3.4 B	Organization	Tailoring	
TAL-3	Tailor Assurance Levels - Analysis	Organizations SHALL also conduct their own analysis to ensure that their specific mission and the communities being served by the online service are given due consideration for tailoring purposes.	Determine if the tailoring process includes organizations' own analysis to ensure that their mission and communities served by the online services are given due consideration.	Examine the tailoring documentation to ensure analysis was done, and due consideration given, to the organization specific mission and the communities being served by the online service.	3.4 C	Organization	Tailoring	

NIST SP 800-63-4 Conformance Criteria v0.1: 63Base

Control Identifier	Control Name	Control Text	Objective	Assessment Method	Index	Target	Profile/XAL Level	Discussion
TAL-4	Tailor Assurance Levels - Tailoring Process	Organizations SHALL establish and document their xAL tailoring process.	(1) Determine if the xAL tailoring process has been documented. (2) Determine if the xAL tailoring process has been implemented.	Examine the tailoring process documentation for each xAL to verify its existence and completeness.	3.4 D	Organization	Tailoring	
TAL-5	Tailor Assurance Levels - Governance Approach	At a minimum, [the tailoring] process SHALL follow a documented governance approach to allow for decision-making.	Determine if the tailoring process follows a documented governance approach that allows for decision-making.	Examine the tailoring process documentation for information on the governance approach that allows for decision-making.	3.4 E	Organization	Tailoring	
TAL-6	Tailor Assurance Levels - Document Decisions	At a minimum, [the tailoring] process SHALL document all decisions in the tailoring process (see Sec. 3.4.4).	Determine if the tailoring process documents all decisions made during the tailoring process.	Examine the tailoring process documentation to determine that all decisions made during the tailoring process have been documented.	3.4 F	Organization	Tailoring	Examples of decisions include the assessed xALs, modified xALs, and supplemental and compensating controls in the Digital Identity Acceptance Statement
TAL-7	Tailor Assurance Levels - Document Risk-Based Decisions	At a minimum, the [tailoring] process SHALL justify and document all risk-based decisions or modifications to the initially assessed xALs in the Digital Identity Acceptance Statement (DIAS) (see Sec. 3.4.4).	Determine if the tailoring process justifies and documents all risk-based decisions or modifications to the initially selected xALs in the DIAS.	Examine the tailoring process documentation to ensure justifications are included in the documented risk-based decisions or modifications that apply to the initially selected xALs in the DIAS.	3.4 G	Organization	Tailoring	
PCT-1	Privacy, Customer Experience, Threat Resistance - Identify Impacts	When progressing from the initial assurance level selection in [the Baseline Controls requirements] (Sec. 3.3.4) to the final xAL selection and implementation, organizations SHALL conduct detailed assessments of the controls defined for the initially selected xALs to identify potential impacts in the operational environment.	As part of the selection of the final xALs, determine if a detailed assessment of the initial xAL controls was conducted and identified potential impacts in the operational environment.	Examine the DIRM documentation indicating the final xAL selection to ensure it includes a detailed assessment of the initial xAL controls and identifies potential impacts in the operational environment. Interview the person(s) responsible for conducting the assessment of the initial xAL controls for how they identified the potential impacts in the operational environment.	3.4.1 A	Organization	Privacy, Customer Experience, Threat Resistance	
PCT-2a	Privacy, Customer Experience, Threat Resistance - Privacy Impact Assessment	At a minimum, organizations SHALL assess the impacts and potential unintended consequences related to Privacy - Identify unintended consequences to the privacy of individuals who will be subject to the controls at an assessed xAL and of individuals affected by organizational or third-party practices related to the establishment, management, or federation of a digital identity. A privacy assessment SHOULD leverage an existing Privacy Threshold Analysis (PTA) or Privacy Impact Assessment (PIA) as inputs during the privacy assessment process.	Determine if the organization assessed the impacts and potential unintended consequences related to privacy.	Examine the DIRM documentation indicating the final xAL selection to ensure it includes an assessment of the impacts and potential unintended consequences related to privacy. Interview the person(s) responsible for assessing the impacts and potential consequences related to privacy to determine if they leveraged a PTA or PIA as part of their process. (optional)	3.4.1 B	Organization	Privacy	As the goal of the privacy assessment is to identify privacy risks that arise from the initial assurance level selection, additional assessments and evaluations that are specific to the baseline controls for the assurance levels may be required for the underlying information system. Leveraging an existing PTA or PIA is recommended.

NIST SP 800-63-4 Conformance Criteria v0.1: 63Base

Control Identifier	Control Name	Control Text	Objective	Assessment Method	Index	Target	Profile/XAL Level	Discussion
PCT-1b	Privacy, Customer Experience, Threat Resistance - Customer Experience Impact Assessment	At a minimum, organizations SHALL assess the impacts and potential unintended consequences related to Customer Experience - Determine whether implementation of the initial assurance levels may create substantial or unacceptable barriers to individuals seeking to access services. Customer experience assessments SHALL consider impacts that result from the identity management controls to ensure that they do not cause undue burdens, frustrations, or frictions for individuals and that there are pathways to provide service to users of all capabilities, resources, technology access, and economic statuses.	Determine if the organization assessed the impacts and potential unintended consequences related to customer experience.	Examine the DIRM documentation indicating the final xAL selection to ensure it includes an assessment of the impacts and potential unintended consequences related to customer experience, such as undue burdens, frustrations, or frictions for individuals, as well as pathways to provide service to users of all capabilities, resources, technology access, and economic statuses.	3.4.1 B	Organization	Customer Experience	Determine whether implementation of the initial assurance levels may create substantial or unacceptable barriers to individuals seeking to access services.
PCT-1c	Privacy, Customer Experience, Threat Resistance - Threat Resistance Impact Assessment	At a minimum, organizations SHALL assess the impacts and potential unintended consequences related to Threat Resistance - Determine whether the defined assurance level and related controls will address specific threats to the online service based on the operational environment, its threat actors, and known tactics, techniques, and procedures (TTPs). Threat assessments SHALL consider specific known and potential threats, threat actors, and TTPs within the implementation environment for the identity management functions.	Determine if the organization assessed the impacts and potential unintended consequences related to threat resistance.	Examine the DIRM documentation indicating the final xAL selection to ensure there is an assessment of the impacts and potential unintended consequences related to threat resistance showing that the defined assurance level and related controls address: 1) specific threats to the online service based on the operation environment, 2) the threat actors of those specific threats and known TTPs. Interview the person(s) responsible for assessing the impacts and potential consequences related to privacy to determine if and how they considered specific known and potential threats, threat actors, and TTPs within the implementation environment for the identity management functions.	3.4.1 B	Organization	Threat Resistance	For example, certain benefits programs may be more subject to familial threats or collusion. Based on their assessments, organizations MAY implement supplemental controls specific to the communities served by their online service. Conversely, organizations MAY tailor their assessed xAL down or modify their baseline controls if their threat assessment indicates that a reduced threat posture is appropriate based on their environment.
PCT-3	Privacy, Customer Experience, Threat Resistance - Compensating and Supplemental Controls	All assessments applied during the tailoring phase SHALL be extended to any compensating or supplemental controls, as defined in Sec. 3.4.2 and Sec. 3.4.3.	Determine if all assessments applied during the tailoring phase were extended to any identified compensating or supplemental controls.	Examine the DIRM documentation indicating the final xAL selection to ensure all assessments applied during the tailoring phase were extended to any compensating or supplemental controls identified in ICC-1 and ISC-1.	3.4.1 C	Organization	Privacy, Customer Experience, Threat Resistance	A compensating control is a management, operational, or technical control employed by an organization in lieu of a normative control (i.e., SHALL statements) in the defined xALs. (Ref. Sec. 3.4.2. A) The purpose of this requirement is to allow the RP to assess and determine the acceptability of the compensating controls for their use cases.(Ref. Sec. 3.4.2. C) Assessment is required when: compensating controls are implemented. Per section 3.4.2, "Organizations MAY choose to implement a compensating control if they are unable to implement a baseline control or when a risk assessment indicates that a compensating control sufficiently mitigates risk in alignment with organizational risk tolerance. This control MAY be a modification to the normative statements defined in these guidelines or MAY be applied elsewhere in an online service, digital transaction, or service life cycle."

NIST SP 800-63-4 Conformance Criteria v0.1: 63Base

Control Identifier	Control Name	Control Text	Objective	Assessment Method	Index	Target	Profile/XAL Level	Discussion
PCT-4	Privacy, Customer Experience, Threat Resistance - Cost-based Decision Documentation	Any cost-based decisions that result in modifications to assessed xALs or baseline controls SHALL be documented in the Digital Identity Acceptance Statement (see Sec. 3.4.4).	Determine if cost-based decisions that result in modification to assessed xALs or baseline controls are documented in the Digital Identity Acceptance Statement (DIAS).	Examine the DIAS to ensure cost-based decisions that resulted in modification to the assessed xALs or baseline controls are documented.	3.4.1 D	Organization	Privacy, Customer Experience, Threat Resistance	
ICC-1	Identify Compensating Controls - Documentation	Where compensating controls are implemented, organizations SHALL document the compensating control, the rationale for the deviation, comparability of the chosen alternative, and any resulting residual risks.	Determine if implemented compensating controls are documented, including the rationale for the deviation, comparability of the chosen alternative, and any resulting residual risks.	Examine the tailoring documentation to ensure implemented compensating controls are fully documented, including the rationale for the deviation, comparability of the chosen alternative, and any resulting residual risks.	3.4.2 B	Organization	Compensating controls, Conditional	A compensating control is a management, operational, or technical control employed by an organization in lieu of a normative control (i.e., SHALL statements) in the defined xALs. (Ref. Sec. 3.4.2. A) The purpose of this requirement is to allow the RP to assess and determine the acceptability of the compensating controls for their use cases.(Ref. Sec. 3.4.2. C) Assessment is required when: compensating controls are implemented. Per section 3.4.2, "Organizations MAY choose to implement a compensating control if they are unable to implement a baseline control or when a risk assessment indicates that a compensating control sufficiently mitigates risk in alignment with organizational risk tolerance. This control MAY be a modification to the normative statements defined in these guidelines or MAY be applied elsewhere in an online service, digital transaction, or service life cycle."
ICC-2	Identify Compensating Controls - Communication	CSPs and IdPs that implement compensating controls SHALL communicate this information to all potential RPs prior to integration.	Determine if CSPs and IdPs that implement compensating controls have communicated this information to all potential RPs prior to integration.	Examine CSP/IdP communications with all RPs and potential RPs to ensure the information regarding the implementation of those compensating controls was done prior to their integration.	3.4.2 C	CSP/IdP	Compensating controls, Conditional	A compensating control is a management, operational, or technical control employed by an organization in lieu of a normative control (i.e., SHALL statements) in the defined xALs. (Ref. Sec. 3.4.2. A) The purpose of this requirement is to allow the RP to assess and determine the acceptability of the compensating controls for their use cases.(Ref. Sec. 3.4.2. C) Assessment is required when: compensating controls are implemented. Per section 3.4.2, "Organizations MAY choose to implement a compensating control if they are unable to implement a baseline control or when a risk assessment indicates that a compensating control sufficiently mitigates risk in alignment with organizational risk tolerance. This control MAY be a modification to the normative statements defined in these guidelines or MAY be applied elsewhere in an online service, digital transaction, or service life cycle."
ISC-1	Identify Supplemental Controls - Impact Assessment	Any supplemental controls SHALL be assessed for impacts based on the same factors used to tailor the organization's assurance level.	Determine if supplemental controls are assessed for impacts based on the same factors used to tailor the organization's assurance level.	Examine the tailoring documentation to ensure any implemented supplemental controls have been assessed for impacts based on the same factors used to tailor the initial xALs. See TAL and PCT requirements.	3.4.3 A	Organization	Supplemental controls	Assessment is required when: supplemental controls are identified and implemented.

NIST SP 800-63-4 Conformance Criteria v0.1: 63Base

Control Identifier	Control Name	Control Text	Objective	Assessment Method	Index	Target	Profile/XAL Level	Discussion
ISC-2	Identify Supplemental Controls - Documentation	Any supplemental controls SHALL be documented.	Determine if supplemental controls are documented.	Examine the tailoring documentation to ensure implemented supplemental controls are fully documented.	3.4.3 A	Organization	Supplemental controls	Assessment is required when: supplemental controls are identified and implemented.
DIAS-1a	Digital Identity Acceptance Statement - Documentation - Managed Online Services	Organizations SHALL develop a Digital Identity Acceptance Statement (DIAS) to document the results of the DIRM process for each online service managed by the organization.	Determine if a DIAS was developed that documents the results of the DIRM process for each online service managed by the organization.	Examine the DIAS to verify documentation of the DIRM process results for each online service managed by the organization.	3.4.4 Aa	RP	Acceptance supplement	See DIRM-1.
DIAS-1b	Digital Identity Acceptance Statement - Documentation - External Online Services	Organizations SHALL develop a Digital Identity Acceptance Statement (DIAS) to document the results of the DIRM process for each external online service used to support the mission of the organization.	Determine if a DIAS was developed that documents the results of the DIRM process for each external online service used to support the mission of the organization.	Examine the DIAS to verify documentation of the DIRM process results for each external online service used to support the mission of the organization.	3.4.4 Ab	RP	Acceptance supplement	External online services include software-as-a-service offerings (e.g., social media platforms, email services, online marketing services). (Ref. Sec. 3.4.4.A) See DIRM-1
DIAS-2	Digital Identity Acceptance Statement - Incorporating External DIAS Information	RPs who intend to use a particular CSP/IdP SHALL review the latter's DIAS and incorporate relevant information into the organization's DIAS for each online service.	Determine if the RP reviewed the CSP/IdP's DIAS and incorporated relevant information into the RP's DIAS for each online service.	Examine each RP online service's DIAS for relevant information from the DIAS of the CSP/IdP the RP intends to use.	3.4.4 B	RP	Acceptance supplement	Assessment is required when: the CSP/IdP used by the RP has created a DIAS.
DIAS-3	Digital Identity Acceptance Statement - Online Service DIAS contents	Organizations SHALL prepare a DIAS for their online service that includes, at a minimum: (a) Initial impact assessment results; initially assessed xALs. (b) Tailored xALs and rationale if the tailored xALs differs from the initially assessed xALs. (c) All compensating controls with their comparability or residual risks. (d) All supplemental controls.	Determine if the organization's online service DIAS includes, at a minimum, initial impact assessment results, initially assessed xALs, tailored xALs and rationale if the tailored xALs differs from the initially assessed xALs, all compensating controls with their comparability or residual risks, and all supplemental controls.	Examine each DIAS to ensure it includes the initial impact assessment results, initially assessed xALs, tailored xALs and rationale if the tailored xALs differs from the initially assessed xALs, all compensating controls with their comparability or residual risks, and all supplemental controls.	3.4.4 C	RP, CSP/IdP	Acceptance supplement	Assessment is required for a CS/IdP when: the CSP/IdP deviates from normative guidance and creates a DIAS.
DIAS-4	Digital Identity Acceptance Statement - CSP DIAS Implementation	CSPs/IdPs SHALL implement the DIRM process and develop a DIAS for the services they offer if they deviate from the normative guidance in these guidelines, including when supplemental or compensating controls are added.	For CSP/IdPs that deviate from normative guidance, determine if the CSP/IdP has implemented the DIRM process and developed a DIAS for the services they offer.	Examine the documentation to ensure the DIRM process was implemented and a DIAS developed for their offered services.	3.4.4 D	CSP/IdP	Acceptance supplement	Assessment is required when: the CSP/IdP deviates from normative guidance, including when supplemental or compensating controls are added. To complete a DIRM of their offered assurance levels and controls, CSPs/IdPs MAY base their assessment on anticipated or representative digital identity services that they wish to support.
DIAS-5	Digital Identity Acceptance Statement - CSP DIAS Elements	The DIAS prepared by a CSP SHALL include, at a minimum: (a) Claimed xAL, related controls, and rationale for any deviations from normative guidance; (b) All compensating controls with their comparability or residual risks; and (c) All supplemental controls.	Determine if the CSP's DIAS includes the claimed xAL, related controls, and rationale for any deviations from normative guidance, all compensating controls with their comparability or residual risks, and all supplemental controls.	Examine the CSP's DIAS to ensure it includes claimed xAL, related controls, and rationale for any deviations from normative guidance, all compensating controls with their comparability or residual risks, and all supplemental controls.	3.4.4 E	CSP/IdP	Acceptance supplement	Assessment is required when: the CSP/IdP has created a DIAS (see DIAS-4).

NIST SP 800-63-4 Conformance Criteria v0.1: 63Base

Control Identifier	Control Name	Control Text	Objective	Assessment Method	Index	Target	Profile/XAL Level	Discussion
DIAS-6	Digital Identity Acceptance Statement - Documentation of Relevant Inputs	The DIRM process for external online services used by the organization SHALL consider relevant inputs from the provider of the service and document the results in a DIAS.	Determine if the DIRM process for external online services includes the results of inputs from the provider of the service are documented in a DIAS.	Examine the DIAS containing the results of the DIRM process for external online services used by the organization includes and documents relevant inputs from the provider of the service.	3.4.4 F	RP, CSP/IdP	Acceptance supplement	CSP's trying to meet this requirement should coordinate with the RP for the documentation.
DIAS-7	Digital Identity Acceptance Statement - External Online Services DIAS	The DIAS prepared by the organization for external online services SHALL include, at a minimum: (a) Assessed xAL, related controls, and rationale for any deviations from normative guidance; (b) All compensating controls with their comparability or residual risks; and (c) All supplemental controls.	Determine if the DIAS for external online services includes assessed xALs, related controls, and rationale for any deviations from normative guidance, all compensating controls with their comparability or residual risks, and all supplemental controls.	Examine the DIAS prepared for each external online services to ensure they include assessed xALs, related controls, and rationale for any deviations from normative guidance, all compensating controls with their comparability or residual risks, and all supplemental controls.	3.4.4 G	RP, CSP/IdP	Acceptance supplement	Assessment is required when: the CSP/IdP created a DIAS (see DIAS-4)
CEI-1	Continuously Evaluate and Improve - Implementation	Organizations SHALL implement a continuous evaluation and improvement program that leverages input from end users who have interacted with the identity management system as well as performance metrics for the online service.	Determine if the organization has implemented a continuous evaluation and improvement program that leverages input from end users who have interacted with the identity management system and performance metrics for the online service.	Examine documentation that describes the continuous evaluation and improvement program to ensure it leverages input from end users who have interacted with the identity management system. Examine documentation that describes the continuous evaluation and improvement program to ensure it leverages input from performance metrics for the online service.	3.5 A	CSP/IdP, RP	Continuous evaluation and improvement	The purpose of this control is to address the shifting environment in which they operate and more rapidly address service capability gaps.
CEI-2	Continuously Evaluate and Improve - Documentation	This program SHALL be documented, including the metrics that are collected, the sources of data required to enable performance evaluation, and the processes in place for taking timely actions based on the continuous improvement process.	Determine if the documentation includes: (a) the metrics that are collected, (b) the sources of data required to enable performance evaluation, and (c) the processes in place for taking timely actions based on the continuous improvement process.	Examine the continuous evaluation and improvement program documentation to ensure it includes all collected metrics. Examine the continuous evaluation and improvement program documentation to ensure it includes the sources of data required to enable performance evaluation. Examine the continuous evaluation and improvement program documentation to ensure it includes the processes in place for taking timely actions based on the continuous improvement process.	3.5 B	CSP/IdP, RP	Continuous evaluation and improvement	
CEI-3	Continuously Evaluate and Improve - Monitoring	Organizations SHALL monitor the evolving threat landscape.	Determine if the organization is monitoring the evolving threat landscape.	Examine the continuous evaluation and improvement program documentation to ensure it includes policies and procedures for monitoring the evolving threat landscape.	3.5 C	CSP/IdP, RP	Continuous evaluation and improvement	The purpose of monitoring the evolving threat landscape is to stay informed of the latest threats and fraud tactics.
CEI-4	Continuously Evaluate and Improve - Assessing	Organizations SHALL regularly assess the effectiveness of current security measures and fraud detection capabilities against the latest threats and fraud tactics.	Determine if the organization regularly assesses the effectiveness of current security measures and fraud detection capabilities against the latest threats and fraud tactics.	Examine the continuous evaluation and improvement program documentation (policy and logs) for evidence that the effectiveness of current security measures and fraud detection capabilities against the latest threats and fraud tactics is being assessed regularly.	3.5 D	CSP/IdP, RP	Continuous evaluation and improvement	

NIST SP 800-63-4 Conformance Criteria v0.1: 63Base

Control Identifier	Control Name	Control Text	Objective	Assessment Method	Index	Target	Profile/XAL Level	Discussion
EI-1	Evaluation Inputs	At a minimum, evaluation inputs SHALL include: (a) Integrated CSP, IdP, and authentication functions as well as validation, verification, and fraud management systems, as appropriate; (b) Customer feedback mechanisms, such as complaint processes, helpdesk statistics, and other user feedback (e.g., surveys, interviews, or focus groups); (c) Threat analysis, threat reporting, and threat intelligence feeds that are available; (d) Fraud trends, fraud investigation results, and fraud metrics as available; and (e) The results of ongoing customer experience assessments and privacy assessments.	Determine if the evaluation inputs include: (a) Integrated CSP, IdP, and authentication functions as well as validation, verification, and fraud management systems, as appropriate; (b) Customer feedback mechanisms, such as complaint processes, helpdesk statistics, and other user feedback (e.g., surveys, interviews, or focus groups); (c) Threat analysis, threat reporting, and threat intelligence feeds that are available; (d) Fraud trends, fraud investigation results, and fraud metrics as available; and (e) The results of ongoing customer experience assessments and privacy assessments.	Examine the continuous evaluation and improvement program documentation evaluation inputs to ensure they include: (a) Integrated CSP, IdP, and authentication functions as well as validation, verification, and fraud management systems, as appropriate; (b) Customer feedback mechanisms, such as complaint processes, helpdesk statistics, and other user feedback (e.g., surveys, interviews, or focus groups); (c) Threat analysis, threat reporting, and threat intelligence feeds that are available; (d) Fraud trends, fraud investigation results, and fraud metrics as available; and (e) The results of ongoing customer experience assessments and privacy assessments. Test the continuous evaluation and improvement program to ensure it can use all the following evaluation inputs: (a) Integrated CSP, IdP, and authentication functions as well as validation, verification, and fraud management systems, as appropriate; (b) Customer feedback mechanisms, such as complaint processes, helpdesk statistics, and other user feedback (e.g., surveys, interviews, or focus groups); (c) Threat analysis, threat reporting, and threat intelligence feeds that are available; (d) Fraud trends, fraud investigation results, and fraud metrics as available; and (e) The results of ongoing customer experience assessments and privacy assessments.	3.5.1 A	CSP/IdP, RP	Continuous evaluation and improvement	The purpose of control EI-1 is to fully understand the performance of their identity system, organizations will need to identify critical inputs to their continuous evaluation process.
EI-2	Evaluation Inputs - Documentation	RPs SHALL document their metrics, reporting requirements, and data inputs for any CSP, IdP, or other integrated identity service to ensure that expectations are appropriately communicated to partners and vendors.	Determine if the RP has documented their metrics, reporting requirements, and data inputs for any CSP, IdP, or other integrated identity service.	Examine the documents for the continuous evaluation and improvement process to ensure they include the RPs metrics, reporting requirements, and data inputs for any CSP, IdP, or other integrated identity service.	3.5.1 B	CSP/IdP, RP	Continuous evaluation and improvement	The documentation of metrics, reporting requirements, and data inputs for any CSP, IdP, or other integrated identity service is to ensure that expectations are appropriately communicated to partners and vendors.
RED-1	Redress - Issue Handling Process	RPs and CSPs SHALL enable individuals to convey grievances and seek redress through an issue handling process that is documented, accessible, trackable, and usable by all individuals and whose instructions are easy to find on a public-facing website.	(1) Determine if the RPs and CSPs issues handline process is: (a) Documented, (b) Accessible, (c) Trackable, (e) Usable by all individuals, and has instructions on an easy-to-find, public-facing website.	Test the issues handling process public-facing website to ensure the instructions are easy to find and follow, and the issues are documented, accessible, trackable, and usable (i.e., 508 compliant).	3.6 A	RP, CSP	Redress	

NIST SP 800-63-4 Conformance Criteria v0.1: 63Base

Control Identifier	Control Name	Control Text	Objective	Assessment Method	Index	Target	Profile/XAL Level	Discussion
RED-2	Redress - Governance Model	RPs and CSPs SHALL institute a governance model for implementing this issue handling process, including documented roles and responsibilities.	Determine if the RPs and CSPs instituted a governance model for implementing the issue handling process that includes documented roles and responsibilities.	Examine the issuance handling governance model documentation to ensure it includes documented roles and responsibilities.	3.6 B	RP, CSP	Redress	
RED-3a	Redress - Issue Handling Function - Evidence Review	The issue handling process SHALL be implemented as a dedicated function that includes procedures for impartially reviewing pertinent evidence.	Determine if the issue handling process is implemented as a dedicated function with procedures for impartially reviewing pertinent evidence.	Examine the issuance handling documentation for descriptions of how it is implemented to ensure it is implemented as a dedicated function that includes procedures for impartially reviewing pertinent evidence.	3.6 C	RP, CSP	Redress	
RED-3b	Redress - Issue Handling Function - Additional Evidence	The issue handling process SHALL be implemented as a dedicated function that includes procedures for requesting and collecting additional evidence that informs the issues.	Determine if the issue handling process is implemented as a dedicated function with procedures for requesting and collecting additional evidence that informs the issues.	Examine the issuance handling documentation for descriptions of how it is implemented to ensure it is implemented as a dedicated function that includes procedures for requesting and collecting additional evidence that informs the issues.	3.6 C	RP, CSP	Redress	
RED-3c	Redress - Issue Handling Function - Resolution	The issue handling process SHALL be implemented as a dedicated function that includes procedures for expeditiously resolving issues and determining corrective action.	Determine if the issue handling process is implemented as a dedicated function with procedures for expeditiously resolving issues and determining corrective action.	Examine the issuance handling documentation for descriptions of how it is implemented to ensure it is implemented as a dedicated function that includes procedures for expeditiously resolving issues and determining corrective action.	3.6 C	RP, CSP	Redress	
RED-4	Redress - Support Personnel	RPs and CSPs SHALL make human support personnel available to intervene and override issue adjudication outputs generated by algorithmic support mechanisms.	Determine if RPs and CSPs have made human support personnel available to intervene and override issue adjudication outputs generated by algorithmic support mechanisms.	Interview the human support personnel whose role is to intervene and override issue adjudication outputs generated by algorithmic support mechanisms to ensure they are available.	3.6 D	RP, CSP	Redress	
RED-5a	Redress - Support Personnel Education - Issue Handling	RPs and CSPs SHALL educate support personnel on issue handling procedures for the digital identity management system.	Determine if RPs and CSPs have educated support personnel on issue handling procedures for the digital identity management system.	Interview the support personnel to ensure they are educated on issue handling procedures for the digital identity management system. Examine the training materials used to train the support personnel in issue handling procedures for the digital identity management system.	3.6 E	RP, CSP	Redress	
RED-5b	Redress - Support Personnel Education - Redress	RPs and CSPs SHALL educate support personnel on the avenues for redress.	Determine if RPs and CSPs have educated support personnel on the avenues for redress.	Interview the support personnel to ensure they are educated on the avenues for redress. Examine the training materials used to train the support personnel on the avenues for redress.	3.6 E	RP, CSP	Redress	

NIST SP 800-63-4 Conformance Criteria v0.1: 63Base

Control Identifier	Control Name	Control Text	Objective	Assessment Method	Index	Target	Profile/XAL Level	Discussion
RED-5c	Redress - Support Personnel Education - Access Alternatives	RPs and CSPs SHALL educate support personnel on the alternatives available to gain access to services.	Determine if RPs and CSPs have educated support personnel on the alternatives available to gain access to services.	Interview the support personnel to ensure they are educated on the alternatives available to gain access to services. Examine the training materials used to train the support personnel on the alternatives available to gain access to services.	3.6 E	RP, CSP	Redress	
RED-6	Redress - Support Functions	RPs and CSPs SHALL implement a process for personnel and technologies that provides support functions to report and address major barriers that end users face and grievances they may have.	Determine if the RP/CSP has implemented a process for personnel and technologies that provides support functions to report and address major barriers that end users face and grievances they may have.	Examine the issues handling process documentation to ensure it includes processes for personnel and technologies that support functions to report and address major barriers that end users face and grievances they may have.	3.6 F	RP, CSP	Redress	
RED-7	Redress - Continuous Evaluation and Improvement	RPs and CSPs SHALL incorporate findings derived from the issue handling process into continuous evaluation and improvement activities.	Determine if the RP/CSP has incorporated findings derived from the issue handling process into continuous evaluation and improvement activities.	Examine the evaluation inputs for the continuous evaluation and improvement program to ensure they incorporate findings derived from the issue handling process.	3.6 G	RP, CSP	Redress	
RED-8a	Redress - Integrity and Performance	Organizations SHALL assess the integrity and performance of their redress mechanisms.	Determine if the integrity and performance of their redress mechanisms are being assessed.	Examine the issues handling process documentation for policies and practices that describe how to assess the integrity and performance of their redress mechanisms.	3.6 Ha	Organization	Redress	
RED-8b	Redress - Fraud Detection	Organizations SHALL implement controls to prevent, detect, and remediate attempted identity fraud involving those mechanisms.	Determine if controls to prevent, detect, and remediate attempted identity fraud involving the redress mechanisms have been implemented.	Examine the issues handling process documentation for policies and practices that describe the controls they implement to prevent, detect, and remediate attempted identity fraud involving those mechanisms.	3.6 Hb	Organization	Redress	
CFI-1	Cybersecurity, Fraud, and Identity Program Integrity - Information Exchange	Organizations SHALL establish consistent mechanisms for the exchange of information between stakeholders that are responsible for critical internal security and fraud prevention.	Determine if consistent mechanisms for the exchange of information between stakeholders that are responsible for critical internal security and fraud prevention have been established.	Examine mechanisms used for the exchange of information between stakeholders that are responsible for critical internal security and fraud prevention.	3.7 A	Organization	Program Integrity	
CFI-2	Cybersecurity, Fraud, and Identity Program Integrity - Privacy Assessment	All data collected, transmitted, or shared by the identity service provider SHALL be subject to a detailed privacy and legal assessment by either the entity generating the data (e.g., a CSP) or the related RP for whom the service is provided.	Determine if all data collected, transmitted, or shared by the identity service provider is subject to a detailed privacy and legal assessment.	Examine privacy and legal assessments to ensure one exists for all data collected, transmitted, or shared by the identity service provider.	3.7 B	CSP/IdP	Program Integrity	The privacy and legal assessment can be done by either the entity generating the data (e.g., a CSP) or the related RP for whom the service is provided.
AIML-1a	Artificial Intelligence and Machine Learning in Identity Systems - Documentation	All uses of AI/ML [in the identity system] SHALL be documented.	Determine if all uses of AI/ML in the identity system have been documented.	Examine documentation describing all uses of AI/ML.	3.8 A	Organization	AI, ML, Artificial Intelligence, Machine Learning	

NIST SP 800-63-4 Conformance Criteria v0.1: 63Base

Control Identifier	Control Name	Control Text	Objective	Assessment Method	Index	Target	Profile/XAL Level	Discussion
AIML-1b	Artificial Intelligence and Machine Learning in Identity Systems - Communication	All uses of AI/ML [in the identity system] SHALL be communicated to organizations that rely on these systems.	Determine if all uses of AI/ML in the identity system have been communicated to organizations that rely on these systems.	Examine communications to ensure all uses of AI/ML in the identity system have been communicated to organizations that rely on them.	3.8 A	Organization	AI, ML, Artificial Intelligence, Machine Learning	
AIML-2	Artificial Intelligence and Machine Learning in Identity Systems - Disclosure to RPs	The use of integrated technologies that leverage AI/ML by CSPs, IdPs, or verifiers SHALL be disclosed to all RPs that make access decisions based on information from these systems.	Determine if the use of integrated technologies that leverage AI/ML is disclosed to all RPs that make access decisions based on information from these systems.	Examine communications from CSP/IdPs to RPs that make access decisions based on information from systems to ensure disclosure of any use of integrated technologies that leverage AI/ML.	3.8 B	CSP, IdP, Verifier	AI, ML, Artificial Intelligence, Machine Learning	
AIML-3a	Artificial Intelligence and Machine Learning in Identity Systems - AI/ML Model Information - Training Methods	All organizations that use AI/ML SHALL provide information to any entities that use their technology [including] the methods and techniques used for training their models.	Determine if methods and techniques used for training AI/ML models have been provided to the entities using the AI/ML technology.	Examine AI/ML documentation that is shared with entities that use their technology to ensure it includes the methods and techniques used for training their AI/ML models.	3.8 C	Organization	AI, ML, Artificial Intelligence, Machine Learning	
AIML-3b	Artificial Intelligence and Machine Learning in Identity Systems - AI/ML Model Information - Training Data Sets	All organizations that use AI/ML SHALL provide information to any entities that use their technology [including] a description of the data sets used in training.	Determine if a description of the data sets used in training the AI/ML models have been provided to the entities using the AI/ML technology.	Examine AI/ML documentation that is shared with entities that use their technology to ensure it includes a description of the data sets used in training.	3.8 C	Organization	AI, ML, Artificial Intelligence, Machine Learning	
AIML-3c	Artificial Intelligence and Machine Learning in Identity Systems - AI/ML Model Information - Updates	All organizations that use AI/ML SHALL provide information to any entities that use their technology [including] the frequency of model updates.	Determine if the frequency of AI/ML model updates have been provided to the entities using the AI/ML technology.	Examine AI/ML documentation that is shared with entities that use their technology to ensure it includes the frequency of model updates.	3.8 C	Organization	AI, ML, Artificial Intelligence, Machine Learning	
AIMLIS-3d	Artificial Intelligence and Machine Learning in Identity Systems - AI/ML Model Information - Algorithm Testing	All organizations that use AI/ML SHALL provide information to any entities that use their technology [including] the results of all testing completed on their algorithms.	Determine if the results of all testing completed on their AI/ML algorithms have been provided to the entities using the AI/ML technology.	Examine AI/ML documentation that is shared with entities that use their technology to ensure it includes the results of all testing completed on their algorithms.	3.8 C	Organization	AI, ML, Artificial Intelligence, Machine Learning	

NIST SP 800-63-4 Conformance Criteria v0.1: 63A

Control Identifier	Control Name	Control Text	Objective	Assessment Method	Index	Target	Profile/XAL Level	Discussion
IDPRF-1	Risk Evaluation	CSPs SHALL evaluate the risks associated with each identity proofing option offered (e.g., identity proofing types, validation sources, assistance mechanisms) and implement mitigating fraud controls, as appropriate.	Confirm that the CSP has assessed the risks associated with each identity proofing option offered and that they have employed appropriate mitigations to address those risks.	Examine the CSP's risk assessment results and confirm it has assessed the risks associated with each identity proofing option offered and has implemented mitigating fraud controls, as appropriate.	2.0 A	CSP	ALL	CSPs are likely to provide different options for how applicants can complete the identity proofing process. This control ensures a risk assessment process is in place to evaluate these options and identify and address unique risks. It can be done as part of the DIRM process defined in NIST SP 800-63-4 or an organizational specific risk management process.
IDPRF-2	Design Options	At a minimum, CSPs SHALL design each option such that the options provide comparable assurance in aggregate.	Confirm that the CSP has designed its identity services so that no identity proofing pathway (sequence of actions) results in a lower level of assurance than another.	Examine the CSP's documentation to confirm that the risk assessment identifies the risks unique to each identity proofing option and that the risks have been mitigated sufficiently to provide comparable assurance.	2.0 B	CSP	ALL	
IDPRF-3	Identify Roles	CSPs SHALL identify which roles are applicable to their identity service.	Confirm that the CSP has identified the roles that are employed as part of its identity proofing service.	Examine the CSP's practices statement or other documentation to determine the roles it employs in its identity service.	2.1.2 A	CSP	ALL	Identity proofing roles are proofing agent, trusted referee, applicant reference, and process assistant.
IDPRF-4	Training	CSPs SHALL provide training and support resources consistent with the requirements and expectations provided in Sec. 3.	Confirm that individuals with defined identity proofing roles are properly trained and provided with the resources they need to be effective in performing their identity proofing roles.	Examine the CSP's documentation to confirm the CSP provides appropriate training and resources to persons performing identity proofing roles, consistent with the summary and references in SP 800-63A-4, Appendix B, Table 7. Interview persons performing identity proofing roles for the CSP to identify what training and resources have been provided, and verify they satisfy the summary and references in SP 800-63A-4, Appendix B, Table 7.	2.1.2 B	CSP	ALL	
IDPRF-5	Government Identifier	CSPs SHALL include a government identifier as a part of its core attributes.	Determine that CSPs require the collection of a government identifier.	Examine the CSP's documentation to confirm their set of core attributes includes a unique identifier that is associated with the applicant in government records.	2.2 A	CSP	ALL	A government identifier is a unique identifier that is associated with the applicant in government records (e.g., Social Security number, driver's license number, passport number).
IDPRF-6	Document	The CSP and RP SHALL document all core attributes in trust agreements and practice statements.	Confirm that agreements between CSPs and RPs include the CSP's set of core attributes so that an RP can make risk-based decisions about using a CSP's identity service.	Examine trust agreements, contracts, or practices statements to confirm they include the list of attributes a CSP considers as its core attributes.	2.2 B	CSP	ALL	
IDPRF-7	FAIR Evidence	To be considered FAIR, identity evidence SHALL meet all the requirements in Sec. 2.4.1.1.	Confirm that the CSP has documented the types of FAIR evidence it considers acceptable and provided justifications for each based on defined requirements.	Examine the CSP's practices statement or other documentation to determine that the CSP only accepts types of FAIR evidence that meet the requirements provided in Sec. 2.4.1.1.	2.4.1.1	CSP	ALL	

NIST SP 800-63-4 Conformance Criteria v0.1: 63A

Control Identifier	Control Name	Control Text	Objective	Assessment Method	Index	Target	Profile/XAL Level	Discussion
IDPRF-8	STRONG Evidence	To be considered STRONG, identity evidence SHALL meet all the requirements in Sec. 2.4.1.2.	Determine that the CSP has documented the types of STRONG evidence it considers acceptable and provided justifications for each based on defined requirements.	Examine the CSP's practices statement or other documentation to determine that the CSP only accepts types of STRONG evidence that meet the requirements provided in Sec. 2.4.1.2.	2.4.1.2	CSP	ALL	
IDPRF-9	SUPERIOR Evidence	To be considered SUPERIOR, identity evidence SHALL meet all the requirements in Sec. 2.4.1.3.	Determine that the CSP has documented the types of SUPERIOR evidence it considers acceptable and provided justifications for each based on defined requirements.	Examine the CSP's practices statement or other documentation to determine that the CSP only accepts types of SUPERIOR evidence that meet the requirements provided in Sec. 2.4.1.3.	2.4.1.3	CSP	ALL	
IDPRF-10	Evidence Validation	The CSP SHALL validate the authenticity, accuracy, and validity of presented evidence by confirming that: the evidence is in the correct format and includes complete information for the identity evidence type; the evidence does not show signs of being counterfeit or tampered with; the evidence contains physical or digital security features; and the core attributes and data fields necessary to determine authenticity on the evidence are accurate.	Determine that the CSP validates all collected evidence according to a systematic and repeatable process that ensures its authenticity, accuracy, and validity.	Examine the CSP's practices statement or other documentation to confirm that its process for validating identity evidence meets all the criteria provided in Sec. 2.4.2.1. Interview appropriate agents of the CSP to determine how presented identity evidence is validated.	2.4.2.1	CSP	ALL	
IDPRF-11	Attribute Validation	The CSP SHALL validate all core attributes, whether obtained from identity evidence or self-asserted by the applicant, with an authoritative or credible source.	All core attributes are validated against authoritative or credible sources to confirm they are accurate.	Examine the CSP's practices statement or other documentation to determine its processes and sources for validating the different types of core attributes.	2.4.2.3	CSP	ALL	
IDPRF-12	Validation Sources	The CSP SHALL use authoritative or credible sources that meet [the criteria provided in Sec. 2.4.2.4].	CSPs use appropriate sources to validate core attributes and identity evidence.	Examine the CSP's practices statement or other documentation to confirm all authoritative and credible sources meet the criteria provided in Sect. 2.4.2.4.	2.4.2.4	CSP	ALL	An authoritative source is the issuing source of identity evidence or attributes or has direct access to the information maintained by issuing sources. A credible source has access to attribute information that can be traced to an authoritative source or maintains identity attribute information obtained from multiple sources that is correlated for accuracy, consistency, and currency.
IDPRF-13	ID Verification Methods	The CSP SHALL verify the linkage between the claimed identity to the applicant engaged in the identity proofing process through one or more of the [methods provided in Sec. 2.5.1].	CSPs employ proven methods to perform identity verification.	Examine the CSP's documentation to determine the method or methods it uses to perform identity verification.	2.5.1 A	CSP	ALL	Acceptable identity verification methods include, Confirmation code verification, Authentication and federation protocols, Transaction verification, Visual facial image comparison for on-site attended, and Visual facial image comparison for remote attended or remote unattended. Additional requirements on acceptable methods are addressed per assurance level.

NIST SP 800-63-4 Conformance Criteria v0.1: 63A

Control Identifier	Control Name	Control Text	Objective	Assessment Method	Index	Target	Profile/XAL Level	Discussion
IDPRF-14	KBV	Knowledge-based verification (KBV) or knowledge-based authentication SHALL NOT be used for identity verification.	Confirm that the CSP does not employ KBV or KBA as part of its identity verification process.	Examine the CSP's documentation to determine it does not employ KBV or KBA during the identity verification process. Test the identity proofing workflow to confirm KBV or KBA is not employed for identity verification.	2.5.1 B	CSP	ALL	Because KBV can be easily subverted, it is not a suitable method for identity verification. However, CSPs may employ KBV as part of fraud management processes. Note that applicants may provide self-asserted attributes during the identity proofing process. Provided the CSP validates these self-asserted attributes with an authoritative or credible source, they may be used by the CSP as core attributes for identity resolution and communication with RPs. However, the CSP may not use the applicant's knowledge of these attributes as evidence the applicant is who they claim to be.
ISDR-1	Documented Procedures Policy	The CSP SHALL conduct its operations according to documented procedures or a practice statement that details all identity proofing processes as they are implemented to achieve the defined IAL.	Confirm that the CSP has documented its procedures to achieve the defined IALs.	Examine the CSP's practices statement or other documentation to determine the processes it employs to achieve a defined IAL.	3.1 A	CSP	ALL	
ISDR-2	Service Description Policy	The CSP's documented procedures SHALL include a complete service description including the particular steps that it follows to identity-proof applicants at each offered assurance level.	Confirm that the CSP has documented the particular steps it employs to identity proof applicants at each offered assurance level.	Examine the CSP's practices statement or other documentation to determine it has documented the steps it follows to identity proof applicants at a specified assurance level.	3.1 #1	CSP	ALL	Documentation of the complete service description allows CSPs to communicate to RPs and others the scope and components of their services and how they achieve specific IALs.
ISDR-3	Notice Policy	The CSP's documented procedures SHALL include its policy for providing notice to applicants about the types of identity proofing processes available, the evidence and attribute collection requirements for the IALs offered by the CSP, the purpose for collecting personal information, and the purposes for collecting, using, and retaining biometrics.	Confirm that the CSP has documented its procedures for providing notice to applicants, as specified in item #2 of Sec. 3.1.	Examine the CSP's practices statement or other documentation to determine its applicant notice policies.	3.1 #2	CSP	ALL	Notice is essential to promoting informed decision-making while conducting identity proofing processes. Since CSPs collect sensitive information, documented set of policies supports informed consent from applicants before engaging with the service.
ISDR-4	Timeliness Policy	The CSP's documented procedures SHALL include its policy for ensuring that the identity proofing process concludes in a timely manner once the applicant has met all of the requirements.	Confirm that the CSP has a documented policy for ensuring the identity proofing process concludes in a timely manner.	Examine the CSP's practices statement or other documentation to determine its policy for the timely conclusion of the identity proofing process.	3.1 #3	CSP	ALL	Lack of timeliness results in the degradation of mission delivery as it affects the ability of the organization to perform mission functions and increases burden on applicants seeking services. Providing policies for the timely completion of identity proofing services sets expectations for RPs and enables communication to applicants about the anticipated timing of the process.
ISDR-5	Evidence Policy	The CSP's documented procedures SHALL include the types of evidence that it accepts and the justification for how the evidence fulfills the strength requirements of the level at which it will be accepted by the CSP.	Confirm that the CSP has documented the types of evidence it accepts and the justification for how the evidence fulfills the strength requirements of the specified IAL.	Examine the CSP's practices statement or other documentation to determine the types of evidence it accepts and the justification for how the types fulfill the strength requirements for the specified IAL.	3.1 #4	CSP	ALL	The policy for identity evidence collection and classification of evidence acceptance allows open communication between the CSP and the RP, which can then be communicated to the applicant to build trust between the applicant and RP as the identity evidence collection is a sensitive process.
ISDR-6	Verification Policy	The CSP's documented procedures SHALL include its policy and process for validating and verifying identity evidence, including training and qualification requirements for personnel who serve in identity proofing roles.	Confirm that the CSP has documented its policy and process for validating and verifying evidence, including any training and qualification requirements for proofing agents.	Examine the CSP's practices statement or other documentation to determine its evidence validation and verification policies, and policies for training and qualifying proofing agents or other personnel.	3.1 #5	CSP	ALL	The CSP documenting policy and process for validating and verifying identity evidence offers knowledge for the RP that may be employed for communication to the applicant.

NIST SP 800-63-4 Conformance Criteria v0.1: 63A

Control Identifier	Control Name	Control Text	Objective	Assessment Method	Index	Target	Profile/XAL Level	Discussion
ISDR-7	Technology Policy	The CSP's documented procedures SHALL include the specific technologies that the CSP employs for evidence validation and verification.	Confirm that the CSP documents the technologies it uses for evidence validation and verification.	Examine the CSP's practices statement or other documentation to determine the technologies it uses for evidence validation and verification.	3.1 #6	CSP	ALL	Documenting the details of specific technologies that the CSP uses opens the doors for the RP to determine if they are adequate for them as well as communicating to the end-user what technology and services will have access to their identity evidence.
ISDR-8	Exception Handling Policy	The CSP's documented procedures SHALL include its policy and processes for supporting applicants who lack sufficient identity evidence for the required IAL and for addressing identity proofing exceptions and errors.	Confirm that the CSP has documented procedures for exception handling and identity proofing errors, including for the identity proofing of applicants who lack the required identity evidence.	Examine the CSP's practices statement or other documentation to determine its procedures for exception handling and identity proofing errors, including for the identity proofing of applicants who lack the required identity evidence.	3.1 #7	CSP	ALL	The CSPs outlining support mechanisms for applicants that lack evidence or have exceptions or errors allow the RPs to serve the end-user while ensuring that the identity is valid and informs them of what is required of them.
ISDR-9	Attributes Validation Policy	The CSP's documented procedures SHALL include the attributes that it considers to be core attributes and the authoritative and credible sources it uses for validating those attributes.	Confirm that the CSP has documented the attributes it considers to be core attributes and the validation sources it uses to validate those attributes.	Examine the CSP's practices statement or other documentation to determine the attributes it considers to be core attributes and the validation sources it uses to validate those attributes	3.1 #8	CSP	ALL	The CSPs outlining support mechanisms for applicants that lack evidence or have exceptions or errors allow the RPs to serve the end-user while ensuring that the identity is valid and informs them of what is required of them.
ISDR-10	Service Change Policy	The CSP's documented procedures SHALL include the CSP's policy for managing and communicating service changes to RPs, such as changes in data sources, integrated vendors, or biometric algorithms.	Confirm that the CSP has documented policies for managing and communicating service changes to the RPs that use its service.	Examine the CSP's practices statement or other documentation to determine its policy for managing and communicating changes to its service to its RPs.	3.1 #9	CSP	ALL	The CSPs outlining support mechanisms for applicants that lack evidence or have exceptions or errors allows the RPs to serve the end-user while ensuring that the identity is valid and informing them of what is required of them.
ISDR-11	Fraud Management Policy	The CSP's documented procedures SHALL include its approach to fraud management, including its policy and process for identifying and remediating suspected or confirmed fraudulent accounts and communicating such information to RPs and affected individuals.	Confirm the CSP has documented its fraud management procedures, including its policy and process for identifying and remediating suspected or confirmed fraudulent accounts and communicating such information to RPs and affected individuals.	Examine the CSP's practices statement or other documentation to determine its fraud management procedures, including its remediation and communication policies and processes.	3.1 #10	CSP	ALL	CSP documentation of the fraud management approach allows the RP to be informed on the status of its end users and policies that determine the state of its users' accounts, as well as allowing them to be informed and communicative of any effects that the fraud management process has on the end users' account.
ISDR-12	Reverification Policy	The CSP's documented procedures SHALL include its policy for any conditions that would require reverification of the user.	Confirm that the CSP has documented policies on any conditions that require the reverification of the subscriber already enrolled in its identity service.	Examine the CSP's practices statement or other documentation to determine its policies on subscriber reverification.	3.1 #11	CSP	ALL	Examples of reverification include account recovery, account abandonment, and regulatory "recertification" requirements. Documentation of this allows RPs to inform end-users of these processes, the status of the accounts, what triggers them, and enables the RP to communicate any changes desired to the CSP.
ISDR-13	Privacy Risk Policy	The CSP's documented procedures SHALL include its policy for conducting privacy risk assessments, including the timing of its periodic reviews and specific conditions that will trigger an updated privacy risk assessment.	Confirm the CSP has documented its policy for conducting risk assessments, including the timing of its periodic reviews and specific conditions that will trigger an updated privacy risk assessment.	Examine the CSP's practices statement or other documentation to determine its risk assessment policies.	3.1 #12	CSP	ALL	Communicating this policy ensures that the RPs are aware of the privacy risks that could affect end-users, potentially communicate to them those results, and allows the RPs and CSP to work together on changes based on the results.

NIST SP 800-63-4 Conformance Criteria v0.1: 63A

Control Identifier	Control Name	Control Text	Objective	Assessment Method	Index	Target	Profile/XAL Level	Discussion
ISDR-14	Customer Experience Assessment Policy	The CSP's documented procedures SHALL include its policy for assessing customer experience, including the testing methods employed, timing of its periodic reviews, and any specific conditions that will trigger an out-of-cycle review.	Confirm the CSP has a documented policy for assessing customer experience, including the testing methods employed, timing of its periodic reviews, and any specific conditions that will trigger an out-of-cycle review.	Examine the CSP's practices statement or other documentation to determine its policies for assessing customer experience.	3.1 #13	CSP	ALL	These procedures and the results of them can be used by the RP to determine if any changes need to be made to promote continuous improvement and address concerns, which ultimately improves the end-user experience.
ISDR-15	Data Deletion Policy	The CSP's documented procedures SHALL include its policy for the retention, protection, and deletion of all personal, sensitive, and biometric data, including the treatment of all such data if the CSP ceases operation or merges or transfers operations to another CSP.	Confirm the CSP has documented policies for the retention, protection, and deletion of all personal, sensitive, and biometric data, including the treatment of all such data if the CSP ceases operation or merges or transfers operations to another CSP.	Examine the CSP's practices statement or other documentation to determine its data management policies.	3.1 #14	CSP	ALL	
ISDR-16	Continuous Assessment Policy	The CSP's documented procedures SHALL include its policy for reporting and updating performance metrics.	Confirm that the CSP has documented policies for reporting and updating performance metrics.	Examine the CSP's practices statement or other documentation to determine its policies for reporting and updating performance metrics.	3.1 #15	CSP	ALL	Meeting performance metrics starts with standardizing how it is reported and updated, as it is critical to RPs in being able to provide an adequate system and interface to the end-user, and communicate any changes as a result.
ISDR-17	Digital Estate Policy	The CSP's documented procedures SHALL include its policy for accessing or removing a subscriber's account in the event of their death or incapacitation.	Confirm that the CSP has documented policies for the access or removal of a subscriber's account in the event of their death or incapacitation.	Examine the CSP's practices statement or other documentation to determine its digital estate policies.	3.1 #16	CSP	ALL	
ISDR-18	Documentation Availability	CSPs SHALL make their documented procedures or practice statements available to RPs that use their identity service.	Confirm that the CSP makes its practices statement or other documentation available to the RPs that use its services.	Examine the CSP's practices statement or other documentation to determine its policy on communicating its procedures with the RPs that use its service. Interview RPs to determine if the appropriate documentation has been made available.	3.1 B	CSP	ALL	CSPs maintaining the transparency and availability of their statements and procedures creates a proactive environment between CSPs and RPs where the end-users are served.
FRAUD-1	Fraud Mgmt Program	CSPs SHALL establish and maintain a fraud management program that provides fraud identification, detection, investigation, reporting, and resolution capabilities. The specific capabilities and details of this program SHALL be documented within their CSP practice statement.	Determine that CSPs proactively manage risks associated with fraud.	Examine the CSP's practices statement or other documentation for details about its fraud management program. Interview appropriate personnel to obtain details about the CSP's fraud management program.	3.2.1 #1	CSP	ALL	A critical aspect of the identity proofing process is to mitigate fraudulent attempts to gain access to benefits, services, data, or assets that are protected by identity management systems. Resolution, validation, and verification processes are designed to mitigate many types of attacks. However, with the constantly changing threat environment, layering additional checks and controls can provide increased confidence in proofing identities and additional protections against advanced and emerging types of attacks. The ability to identify, detect, and resolve instances of potential fraud is a critical functionality for CSPs and RPs.

NIST SP 800-63-4 Conformance Criteria v0.1: 63A

Control Identifier	Control Name	Control Text	Objective	Assessment Method	Index	Target	Profile/XAL Level	Discussion
FRAUD-2	Fraud Privacy Risk Assessment	CSPs SHALL conduct a privacy risk assessment of all fraud checks and fraud mitigation technologies prior to implementation.	Determine that the CSP assesses the privacy risks associated with employing fraud management mechanisms.	Examine the documented results of CSP's privacy risk assessment of the fraud checks and mitigation technologies it employs as part of its identity service.	3.2.1 #2	CSP	ALL	
FRAUD-3	Fraud Self-Reporting	The CSP SHALL establish a self-reporting mechanism and investigation capability for subjects who believe they have been the victim of fraud or an attempt to compromise their involvement in the identity proofing processes.	Confirm that the CSP provides a mechanism for users to self-report if they believe they have been a victim of fraud or an attempt to compromise their involvement in the identity proofing process.	Examine the CSP's design document or documented procedures for details about how users can self-report potential fraud. Interview appropriate personnel to obtain details about the CSP's fraud self-reporting mechanisms.	3.2.1 #3	CSP	ALL	
FRAUD-4	High Risk Channels	CSPs SHALL analyze all remote proofing communication channels to look for high-risk indicators (e.g., blocklisted proxies and IP addresses).	Confirm that the CSP monitors ID proofing communication channels for indicators of fraud or attacks.	Examine the CSP's design documentation or its documented procedures to determine that it monitors and analyzes all remote ID proofing communication channels for evidence of fraudulent activity or attacks. Interview appropriate personnel to determine how the CSP monitors its remote ID proofing channels for indicators of fraud or attacks.	3.2.1 #4	CSP	ALL	
FRAUD-5	Data Washing	The CSP SHALL take measures to prevent unsuccessful applicants from inferring the accuracy of any self-asserted information with that confirmed by authoritative or credible sources.	Determine the measures a CSP takes to prevent attackers from determining the accuracy of self-asserted information that has been compared to authoritative or credible sources as part of the validation step.	Examine the CSP's design documentation or practices statement to determine the measures a CSP employs to prevent attackers from determining the accuracy of self-asserted information that has been compared to authoritative or credible sources as part of the validation step. Test by initiating an identity proofing session and self-asserting attributes. Confirm that no information is revealed that can aid in determining the accuracy of submitted attributes.	3.2.1 #5	CSP	ALL	This is often called "data washing" and typically occurs when an attacker manipulates or cleans up stolen attribute information to make it appear legitimate by removing inconsistencies or red flags that might trigger fraud detection systems. Data washing can be prevented through a number of methods, depending on the interfaces deployed by a CSP. As such, these guidelines do not dictate specific mechanisms to prevent this practice.
FRAUD-6	Fraud Check Monitoring	CSPs SHALL monitor the performance of their fraud checks and fraud mitigation technologies to ensure continued effectiveness in mitigating fraud risks.	Determine that the CSP monitors the effectiveness of their fraud mitigation measures in addressing new and changing types of fraud and attacks.	Examine the CSP's design documentation or other documentation to determine that the CSP monitors the performance of its fraud management measures. Interview appropriate personnel to determine the CSP's approach to monitoring the effectiveness of its fraud management measures.	3.2.1 #6	CSP	ALL	
FRAUD-7	Fraud Communication	CSPs SHALL establish a technical or process-based mechanism to communicate suspected and confirmed fraudulent events to RPs.	Determine that the CSP has a process for communicating incidents of suspected or confirmed fraud to its RPs.	Examine the CSP's practices statement or other documentation to determine the CSP's process for communicating instances of suspected or confirmed fraud to its RPs. Interview appropriate personnel to determine the CSP's process for communicating instances of suspected or confirmed fraud to its RPs.	3.2.1 #7	CSP	ALL	

NIST SP 800-63-4 Conformance Criteria v0.1: 63A

Control Identifier	Control Name	Control Text	Objective	Assessment Method	Index	Target	Profile/XAL Level	Discussion
FRAUD-8	Death Records Check	CSPs SHALL implement a death records check for all identity proofing processes by confirming with a credible, authoritative, or issuing source that the applicant is not deceased.	Determine that the CSP checks against a death record repository to confirm that an applicant is not claiming to be someone who has died.	Examine the CSP's practices statement or other documentation to determine how the CSP conducts its death records check.	3.2.1 #8	CSP	ALL	Death records are typically maintained by state and local vital records offices. The Social Security Administration (SSA) also collects and manages death information for its programs, but it does not hold comprehensive records of all deaths in the country. Checking against these repositories can aid in preventing synthetic identity fraud, the use of stolen identity information, and exploitation by a close associate or relative.
FRAUD-9	Detect Fraud Indicators	For attended proofing processes, CSPs SHALL train proofing agents to detect indicators of fraud and SHALL provide proofing agents and trusted referees with tools to flag suspected fraudulent events for further treatment and investigation.	[If a CSP provides an attended identity proofing process,] confirm that its agents are trained to detect potential fraud and are provided with mechanisms to flag incidents of suspected fraud.	Examine the CSP's practices statement or other documentation to determine that the CSP trains its agents to identify potential fraud and provides them with a way to flag suspected fraud for further investigation and treatment. Interview appropriate personnel to determine how the CSP trains its agents to identify potential fraud and how it provides them with a way to flag suspected fraud for further investigation and treatment.	3.2.1 #12	CSP	ALL	
FRAUD-10	Insider Threat Controls	CSPs SHALL implement insider threat controls to detect and prevent collusion involving CSP representatives that are directly involved with or can intervene in proofing processes or decisions.	Determine that the CSP has implemented appropriate insider threat controls to help detect and prevent collusion.	Examine the CSP's practices statement or other documentation to determine if the CSP employs insider threat controls to prevent collusion.	3.2.1 #13	CSP	ALL	Collusion is possible whenever CSP representatives are directly involved in proofing processes or decisions.
FRAUD-11	Compensating Controls	If fraud mitigation measures are employed as compensating controls, they SHALL be documented as deviations from the normative guidance of these guidelines and SHALL be conveyed to all RPs through a Digital Identity Acceptance Statement (DIAS) prior to integration.	Determine if a CSP employs fraud mitigation measures as compensating controls, and if it does, determine that the CSP has documented these controls as deviations from the normative guidance of these guidelines and conveys this information to its RPs through a Digital Identity Acceptance Statement (DIAS).	Examine the CSP's practices statement or Digital Identity Acceptance Statement to determine that the CSP has documented any compensating controls and has a process for communicating these deviations to its CSPs through DIASs.	3.2.1 #16	CSP	ALL	See SP 800-63-4, section 3.4.4, for more information about DIAS.
FRAUD-12	AI and ML	CSPs that employ artificial intelligence (AI) or machine learning (ML) as part of their identity service SHALL adhere to the requirements provided in Sec. 3.8 of [SP800-63], as applicable.	Determine if the CSP employs AI or ML as part of its identity service and if it does, confirm that it adheres to all the requirements provided in Section 8 of NIST SP 800-63-4.	Examine the CSP's design documentation or other documentation to determine that any AI or ML it employs adheres to the requirements provided in Section 8 of NIST SP 800-63-4.	3.2.1 A	CSP	ALL	
FRAUD-13	Fraud POC	RPs SHALL establish a point of contact with whom CSPs can interact and communicate fraud data.	Confirm the RP has established a point of contact to receive fraud and other information from its CSPs.	Examine an example agreement or contract to determine that the RP has an identified point of contact (POC) to interact with and receive fraud and other information for CSPs. Interview appropriate personnel to determine that the RP has an identified POC to interact with and receive fraud and other information for CSPs.	3.2.2 #1	RPs	RPs	

NIST SP 800-63-4 Conformance Criteria v0.1: 63A

Control Identifier	Control Name	Control Text	Objective	Assessment Method	Index	Target	Profile/XAL Level	Discussion
FRAUD-14	Fraud PRA	RP's SHALL conduct a privacy risk assessment (see Sec. 3.3.1) of any CSP fraud checks and mitigation technologies to identify potential privacy risks or unintended harms.	Determine that the RP has conducted a privacy risk assessment of all fraud checks or mitigations used by CSPs.	Examine the results of the privacy risk assessment the RP conducted of all fraud checks and mitigations used by its CSPs.	3.2.2 #2a	RP's	RP's	
FRAUD-15	Fed Fraud PRA	Federal agency RP's SHALL implement the privacy risk assessment consistent with the requirements contained in Sec. 3.7.	Determine that the Federal agency RP has conducted a privacy risk assessment for all fraud checks and mitigations used by its CSPs in accordance with the requirements provided in section 3.7 of SP 800-63A-4.	Examine the documented results of any privacy risk assessments conducted for fraud checks and mitigations used by its CSPs.	3.2.2 #2b	Federal Agency	FedAgen	
FRAUD-16	Fraud Reviews	RP's SHALL conduct periodic reviews of their CSP's fraud management program, fraud checks, and fraud technologies to adjust thresholds, review investigations into fraud events, and evaluate the effectiveness and efficacy of fraud controls.	Confirm the RP conducts periodic re-reviews of its fraud management program activities to ensure its ongoing effectiveness against existing and emerging risks and threats.	Examine the documented process and results of any periodic reviews and assessments of the RP's fraud management program and activities. Interview appropriate personnel for information about the RP's ongoing reviews and assessments of its fraud management program activities.	3.2.2 #4	RP's	RP's	
FRAUD-17	Risk Tolerance	RP's SHALL review all fraud mitigation measures that have been deployed as compensating or supplemental controls by CSPs to align with their internal risk tolerance and acceptance.	Determine that the RP has reviewed and accepted all risks associated with fraud mitigation measures employed by its CSP as compensating controls and confirmed they align with the RP's own risk acceptance profile.	Examine the documented results of any reviews of the risks associated with any fraud mitigation measures used as compensating controls by its CSPs. Interview appropriate personnel to determine that the RP has reviewed and accepted the risks associated with any fraud mitigation measures used as compensating controls by its CSPs.	3.2.2 #5a	RP's	RP's	
FRAUD-18	RP DIAS	The RP SHALL record the CSP's compensating controls in their own DIAS prior to integration.	Determine if the CSP employs any compensating controls and, if so, determine that the RP as included the controls from the CSP's DIAS into its own DIAS.	Examine the RP's DIAS to determine if it has integrated compensating controls from the CSP's DIAS into its own DIAS.	3.2.2 #5b	RP's	RP's	From NIST SP 800-63-4: Organizations SHALL develop a Digital Identity Acceptance Statement (DIAS) to document the results of the DIRM process for (i) each online service managed by the organization, and (ii) each external online service used to support the mission of the organization, including software-as-a-service offerings (e.g., social media platforms, email services, online marketing services). RP's who intend to use a particular CSP/IdP SHALL review the latter's DIAS and incorporate relevant information into the organization's DIAS for each online service.
FRAUD-19	Fraud Check Practices	CSP's SHALL establish and document actions and practices related to each of their fraud checks and provide these actions and practices to RP's.	Confirm that the CSP has established and documented actions and practices associated with its fraud checks, and that it communicates this information to its RP's.	Examine the CSP's practice statements and/or other documentation to determine that the CSP has established and documented actions and practices associated with its fraud checks, and that it communicates this information to its RP's.	3.2.3 #1	RP's	RP's	

NIST SP 800-63-4 Conformance Criteria v0.1: 63A

Control Identifier	Control Name	Control Text	Objective	Assessment Method	Index	Target	Profile/XAL Level	Discussion
FRAUD-20	Redress	CSPs SHALL establish procedures for redress to allow applicants to resolve issues associated with fraud checks and mitigation technologies.	Determine that the CSP has established redress procedures specific to issues associated with its fraud checks and mitigation measures.	Examine the CSP's practices statement or other documentation to confirm it provides a way for applicants to seek redress to resolve issues associated with the CSP's fraud checks or other fraud mitigation measures. Interview appropriate personnel to determine how the CSP provides a way for applicants to seek redress to resolve issues associated with the CSP's fraud checks or other fraud mitigation measures.	3.2.3 #2	CSP	ALL	See Sec. 3.6 of [SP800-63] for more information about redress.
FRAUD-21	Failed Fraud Checks	If trusted referees are offered to applicants who fail fraud checks in unattended remote processes, the trusted referees SHALL be provided with a summary of the results of the fraud failures to inform their risk-based decision-making processes.	Determine if the CSP offers Trusted Referee services to applicants who fail fraud checks and, if it does, confirm that these Trusted Referees are provided with the results of the fraud checks.	Examine the CSP's practices statement or other documentation to determine that it provides the results of any failed fraud checks for an applicant to Trusted Referees. Interview Trusted Referees to confirm that they are provided with the results of any failed fraud checks for an applicant.	3.2.3 #3	CSP	ALL	The CSP SHOULD offer trusted referee services to applicants who fail fraud checks in unattended remote processes.
PRIVACY-1	Privacy Risk Assessment	The CSP SHALL conduct and document a privacy risk assessment for the processes used for identity proofing and enrollment.	Determine that the CSP has conducted a privacy risk assessment of its identity service processes.	Examine the results of the CSP's privacy risk assessment.	3.3 #1a	CSP	ALL	For more information about privacy risk assessments, refer to the NIST Privacy Framework: A Tool for Improving Privacy through Enterprise Risk Management at https://nvlpubs.nist.gov/nistpubs/CSWP/NIST.CSWP.01162020.pdf .
PRIVACY-2	Min Privacy Risk Assessment Requirements	At a minimum, the privacy risk assessment SHALL assess the risks associated with: (a) Processing personal information for the purposes of identity proofing, enrollment, or fraud management, including identity attributes, biometrics, images, video, scans, or copies of identity evidence. (b) Additional steps that the CSP takes to verify the identity of an applicant beyond the mandatory requirements specified herein. (c) Processing of personal information for purposes outside of the scope of identity proofing and enrollment, except to comply with law or legal processes. (d) The retention schedule for identity records and personal information. (e) Processing non-personal information that could be used to identify a person when aggregated or processed by an algorithm. (f) Personal information that is processed by a third-party service on behalf of the CSP.	Determine that the CSP has assessed the privacy risks associated with all the aspects of its identity service, as specified in item #1 of section 3.3.1.	Examine the results of the CSP's privacy risk assessment.	3.3.1 #1b	CSP	ALL	
PRIVACY-3	Privacy Mgmt	Based on the results of its privacy risk assessment, the CSP SHALL document the measures it takes to maintain the disassociability, predictability, manageability, confidentiality, integrity, and availability of any personal information it collects or processes.	Determine that the CSP has documented the measures it takes to manage its privacy risks, as identified by the CSP's privacy risk assessment.	Examine the CSP's privacy risk or other documentation to determine what measures it takes to manage its privacy risks.	3.3.1 #2	CSP	ALL	NIST IR 8062 provides an overview of predictability, manageability, and disassociability, including examples of how these objectives can be met.

NIST SP 800-63-4 Conformance Criteria v0.1: 63A

Control Identifier	Control Name	Control Text	Objective	Assessment Method	Index	Target	Profile/XAL Level	Discussion
PRIVACY-4	Reassess Privacy Risks	The CSP SHALL reassess privacy risks and update its privacy risk assessment any time it makes changes to its identity service that affect the processing of personal information.	Determine that the CSP has a policy and/or procedure for reassessing its associated privacy risks anytime changes to its identity service affect the processing of personal information.	Examine the CSP's practices statement or other documentation to determine that it has a policy and/or procedure for reassessing its associated privacy risks anytime changes to its identity service affect the processing of personal information.	3.3.1 #3	CSP	ALL	
PRIVACY-5	PIA Review	The CSP SHALL review its privacy risk assessment periodically, as documented in its practice statement, to ensure that it accurately reflects the current risks associated with the collection and processing of personal information.	Determine that the CSP reviews its privacy risk assessment process and/or results to ensure that it accurately reflects the current privacy risks associated with operating its identity service.	Examine the CSP's practices statement or other document to determine that it has a policy or procedure for periodically reviewing its privacy risk assessment process and/or results.	3.3.1 #4	CSP	ALL	
PRIVACY-6	PIA Summary	The CSP SHALL make a summary of its privacy risk assessment available to any RPs that use its services. The summary SHALL be in sufficient detail to enable such RPs to make reasonable determinations about privacy risks associated with the CSP's services and to complete their own privacy risk assessments.	Determine that the CSP has a process for communicating summarized results of its privacy risk assessment to its RPs and that such summaries are in sufficient detail to allow those RPs to determine if the risks of using the CSP's identity services are acceptable.	Examine the CSP's privacy risk or other documentation, such as agreements or contracts, to determine how it communicates the results of its risk assessment to the RPs that use its services.	3.3.1 #5	CSP	ALL	
PRIVACY-7	Sub Account PIA	The CSP SHALL perform a privacy risk assessment for the processing of any personal information maintained in subscriber accounts.	Determine that the CSP performed a privacy risk assessment of its subscriber accounts.	Examine the CSP's privacy risk or other documentation to determine it has conducted a privacy risk assessment of its subscriber accounts.	3.3.1 #6	CSP	ALL	
PRIVACY-8	Min Personal Info	The processing of personal information SHALL be limited to the minimum necessary to validate the existence of the claimed identity, associate the claimed identity with the applicant, mitigate fraud, and provide RPs with attributes that they may use to make authorization decisions.	Determine that the CSP applies the privacy-protecting principle of data minimization.	Examine the CSP's practices statement, privacy risk documentation, or other documentation to determine that the CSP limits the personal information it collects to the minimum necessary.	3.3.2 #1	CSP	ALL	
PRIVACY-9	Privacy Training	The CSP SHALL provide privacy training to all personnel and any third-party service providers who have access to sensitive information associated with the CSP's identity service.	Determine that the CSP provides privacy training to all its personnel and to those third-party service providers who have access to any personal or sensitive information associated with the CSP's identity service operations.	Examine the CSP's applicable documentation to determine that it provides privacy training to all its personnel and to any third-parties that have access to personal information processed by the CSP's identity service.	3.3.2 #2	CSP	ALL	
PRIVACY-10	SSN Collection	[If the SSN is collected on behalf of a federal, state, or local government agency,] the CSP SHALL provide notice to the applicant for the collection in accordance with applicable laws.	Determine if the CSP collects SSNs, and if it does, confirm that it provides notice to the applicant for the collection.	Examine the CSP's practices statement or other documentation to determine that it provides notice to applicants for the collection in accordance with applicable laws if the CSP collects a social security number (SSN) from applicants.	3.3.2 #3	CSP	ALL	The CSP MAY collect a Social Security number (SSN) as an attribute when necessary for identity resolution. Knowledge of an SSN is not sufficient to act as evidence of identity, nor is it considered an acceptable method of verifying possession of the Social Security card when used as evidence.

NIST SP 800-63-4 Conformance Criteria v0.1: 63A

Control Identifier	Control Name	Control Text	Objective	Assessment Method	Index	Target	Profile/XAL Level	Discussion
PRIVACY-11	Explicit Notice	At the time of collection, the CSP SHALL provide explicit notice to the applicant regarding the purpose for collecting any attributes and personal information. Such a notice SHALL include whether the personal information and attributes are voluntary or mandatory to complete the identity proofing process; the specific attributes and other sensitive data that the CSP intends to store in the applicant's subsequent subscriber account; the consequences of not providing the attributes; and the details of any records retention requirement if one is in place, including an applicant's right to request data deletion or engage in other forms of redress.	Determine that the CSP provides explicit notice to the applicant for the collection of attributes and personal information and that such notice includes all the elements provided in item #4 of section 3.3.2.	Examine a sample of the notice the CSP provides to applicants for the collection of personal information.	3.3.2 #4	CSP	ALL	
CUSTOMER-1	CX Challenges	The CSP SHALL assess the elements of its identity proofing processes to identify processes or technologies that can result in customer experience challenges, particularly if those challenges prevent the CSP from consistently delivering identity proofing services to all users served by an RP.	Determine that the CSP has assessed its identity proofing process and identified any potential customer experience challenges.	Examine the CSP's practices statement or other documentation to determine that the CSP has assessed its identity service for potential customer experience challenges. Interview appropriate personnel to determine that the CSP has assessed its identity service for potential customer experience challenges.	3.4 #1	CSP	ALL	CSPs assess the elements of their identity services to identify processes and technologies that may result in customer experience challenges for the populations they serve. If risks to customer experience are identified, CSPs proactively employ mitigations that will reduce or eliminate these issues consistent with their assurance levels and risk posture.
CUSTOMER-2	CX Assessments	CSPs SHALL provide RPs with a summary of their customer experience assessments that includes information about common challenges or issues faced by users.	Determine that the CSP has a process for communicating the results of its customer experience assessments to the RPs that use its service.	Examine the CSP's practices statement or other documentation to determine how the CSP communicates the results of its customer experience assessment to its RPs.	3.4 #2	CSP	ALL	
CUSTOMER-3	CX Mitigations	Based on the results of its assessment, the CSP SHALL document any measures it takes to mitigate the possible access challenges.	Determine that the CSP has documented any measures it takes to mitigate the potential customer experience challenges it identified through its customer experience assessment.	Examine the CSP's practices statement or other documentation to determine any measures it takes to mitigate the potential customer experience challenges it identified through its customer experience assessment.	3.4 #3	CSP	ALL	
CUSTOMER-4	Periodic CX Reassessment	The CSP SHALL reassess the customer experience risks periodically and any time the CSP makes changes to its identity service that affect the processes or technologies that impact customer experience.	Determine that the CSP periodically reassesses its customer experience risks (challenges) and any time it makes changes to its identity service that could impact the customer experience.	Examine the CSP's practices statement or other documentation to determine its stated policy or practice of reassessing customer experience challenges and risks associated with its identity services.	3.4 #4	CSP	ALL	
CUSTOMER-5	Applicant Participation	The CSP SHALL NOT make applicant participation in these risk assessments mandatory.	Confirm that the CSP does not make applicant participation in customer experience risk assessments mandatory.	Examine the CSP's practices statement or other documentation to confirm its policy on applicant participation in customer experience risk assessments. Test the customer experience risk assessment workflow.	3.4 #5	CSP	ALL	

NIST SP 800-63-4 Conformance Criteria v0.1: 63A

Control Identifier	Control Name	Control Text	Objective	Assessment Method	Index	Target	Profile/XAL Level	Discussion
SECURITY-1	Protected Channel	Each online transaction within the identity proofing process, including transactions that involve third parties, SHALL occur over an authenticated, protected channel.	Determine that all communications are protected by approved cryptography.	Examine the CSP's identity service design document or other documentation, to determine that all communications occur via authenticated, protected channels. Test identity service transactions to determine that they are protected by approved cryptography.	3.5 #1	CSP	ALL	An authenticated protected channel is an encrypted communication channel that uses approved cryptography in which the connection initiator (client) has authenticated the recipient (server). Authenticated protected channels are encrypted to provide confidentiality and protection against active intermediaries and are frequently used in the user authentication process. Transport Layer Security (TLS) and Datagram Transport Layer Security (DTLS) [RFC9325] are examples of authenticated protected channels in which the certificate presented by the recipient is verified by the initiator. Unless otherwise specified, authenticated protected channels do not require the server to authenticate the client. Authentication of the server is often accomplished through a certificate chain that leads to a trusted root rather than individually with each server.
SECURITY-2	Auto Attack Protections	The CSP SHALL implement automated attack protections for the identity proofing process, such as bot detection, mitigation, and management solutions; behavioral analytics; web application firewall settings; and network traffic analysis.	Confirm that the CSP has identified which automated attacks its identity service is vulnerable to and has implemented appropriate attack detection mechanisms.	Examine the CSP's identity service design document, or other documentation, to determine that it employs appropriate automated attack detection mechanisms. Test whether the identity service is able to detect automated attacks.	3.5 #2	CSP	ALL	Behavioral analytics in this context is used to determine whether an interaction is indicative of an automated attack and not an effort to identify or authenticate a specific user based on a captured reference template for that user.
SECURITY-3	Data Protection	All personal information that is collected as part of the identity proofing process SHALL be protected to maintain the confidentiality and integrity of the information, including the encryption of data at rest and the exchange of information using authenticated, protected channels.	Determine that the CSP protects all identity service data.	Examine the CSP's identity service design document, certification information, or other documentation, to determine that it employs data protection mechanisms for data at rest and during transmission.	3.5 #3	CSP	ALL	
SECURITY-4	Risk Assessment	The CSP SHALL assess the information security and privacy risks associated with operating its identity service, according to the NIST Risk Management Framework or equivalent risk management guidelines. At a minimum, the CSP SHALL apply appropriate controls consistent with the NIST SP 800-53 moderate baseline, regardless of IAL.	Determine that the CSP has conducted a risk assessment and that it employs appropriate security controls consistent with the NIST SP 800-53 MODERATE baseline or greater.	Examine the CSP's risk assessment results document, or other documentation, to confirm it has conducted a security risk assessment. Examine the CSP's identity service design document, certification information, or other documentation, to determine if it employs MODERATE baseline controls or greater.	3.5 #4	CSP	ALL	
SECURITY-5	Third-Party Risk	The CSP SHALL assess risks associated with its use of third-party services and apply appropriate controls, as provided in the Cybersecurity Supply Chain Risk Management Practices for Systems and Organizations.	Determine that the CSP has assessed the risks associated with its user of third-party services and has applied appropriate controls.	Examine the results of the CSP's supply chain risk assessment.	3.5 #5	CSP	ALL	

NIST SP 800-63-4 Conformance Criteria v0.1: 63A

Control Identifier	Control Name	Control Text	Objective	Assessment Method	Index	Target	Profile/XAL Level	Discussion
REDIP-1	Redress Mechanisms	The CSP SHALL provide mechanisms for the redress of applicant complaints and problems that arise from the identity proofing process, including proofing failures; delays; difficulties; and the recovery of a compromised subscriber account (e.g., as a result of a scam or fraud).	Determine that the CSP provides a mechanism for applicants to seek redress for errors or harms associated with their use of the CSP's identity service.	Examine the CSP's practices statement, or other documentation, to determine its redress mechanism(s). Interview appropriate personnel to determine the CSP's redress mechanism(s).	3.6 #1	CSP	ALL	See section 3.6 of NIST SP 800-63-4 for more information about redress.
REDIP-2	Easy Redress	These redress mechanisms SHALL be easy for applicants to find and use.	Determine that the CSP's redress mechanisms are easy to find and use.	Examine the CSP's website to determine how easy it is to find information about its redress process.	3.6 #2	CSP	ALL	
REDIP-3	Redress Efficacy	The CSP SHALL assess the mechanisms for their efficacy in achieving a resolution of complaints or problems.	Determine that the CSP assesses its redress process and mechanisms to confirm they are effective.	Examine the CSP's practices statement, or other documentation, to determine that it assesses the efficacy of its redress process.	3.6 #3	CSP	ALL	
FED-1	SAOP Consult	The agency SHALL consult with their Senior Agency Official for Privacy (SAOP) to determine whether the collection of personal information, including biometrics, to conduct identity proofing triggers Privacy Act requirements.	Confirm that the Federal Agency has consulted with its SAOP to determine if the collection of personal information in association with the use of the identity service triggers Privacy Act requirements.	Examine the Federal Agency's documentation to determine if it has consulted with its SAOP whether its use of an identity service triggers requirements under the Privacy Act. Interview appropriate personnel to determine whether the Federal Agency has consulted with its SAOP whether its use of an identity service triggers requirements under the Privacy Act.	3.7 #1	Federal Agency	ALL	
FED-2	E-Gov Act	The agency SHALL consult with their SAOP to determine whether the collection of personal information, including biometrics, to conduct identity proofing triggers E-Government Act of 2002 requirements.	Confirm that the Federal Agency has consulted with its SAOP to determine if the collection of personal information in association with the use of the identity service triggers E-Government Act of 2002 requirements.	Examine the Federal Agency's documentation to determine if it has consulted with its SAOP whether its use of an identity service triggers requirements under the E-Government Act of 2002. Interview appropriate personnel to determine whether the Federal Agency has consulted with its SAOP and whether its use of an identity service triggers requirements under the E-Government Act of 2002.	3.7 #2	Federal Agency	ALL	
FED-3	SORN	The agency SHALL publish a System of Records Notice (SORN) to cover such collections, as applicable.	Determine that the Federal Agency has published a SORN, as applicable, for its use of an identity service.	Examine the Federal Agency's documentation to determine that it has published a SORN for its identity service(s). Interview appropriate personnel to determine that it has published a SORN for its identity service(s).	3.7 #3	Federal Agency	ALL	For more information about SORNs, see OPM's System of Records Notice (SORN) Guide(https://www.opm.gov/information-management/privacy-policy/privacy-references/sornguide.pdf).
FED-4	Fed PIA	The agency SHALL publish a Privacy Impact Assessment (PIA) to cover such collections, as applicable.	Determine that the Federal Agency has conducted a PIA for its identity service.	Examine the Federal Agency's PIA document to determine if it has conducted a privacy assessment of its identity service(s).	3.7 #4	Federal Agency	ALL	
FED-5	PIA Input	If the agency uses a third-party CSP, the agency SHALL conduct its own PIA and use the CSP's privacy risk assessment as input.	Determine if the Federal Agency uses a third-party CSP and, if it does, confirm it has conducted a PIA and included the CSP's PIA as an input.	Examine the agency PIA documentation to determine it has included the results of the CSP's privacy assessment into its own PIA.	3.7 #6	Federal Agency	ALL	

NIST SP 800-63-4 Conformance Criteria v0.1: 63A

Control Identifier	Control Name	Control Text	Objective	Assessment Method	Index	Target	Profile/XAL Level	Discussion
CONFIRM-1	Confirm Codes	Confirmation codes SHALL include at least 6 decimal digits (or equivalent) from an approved random bit generator (see Sec. 3.2.12 of SP800-63B).	Determine if the CSP uses confirmation codes and, if it does, confirm that these codes are comprised of at least 6 digits (or equivalent) from a random bit generator.	Examine the CSP's practices statement or other documentation to determine its confirmation codes include at least 6 decimal digits (or equivalent) from an approved random bit generator.	3.8 A	CSP	ALL	Confirmation codes are used to confirm that an applicant has access to a postal address, email address, or phone number for the purposes of future communications. A random bit generator (RGB) is a device or algorithm that can produce a sequence of bits that appear to be both statistically independent and unbiased.
CONFIRM-2	Confirm Code Validity	Confirmation codes SHALL be valid for at most 21 days when sent to a validated postal address within the contiguous United States; 30 days when sent to a validated postal address outside of the contiguous United States; 10 minutes when sent to a validated telephone number (SMS or voice); and 24 hours when sent to a validated email address.	Determine if the CSP uses confirmation codes and, if it does, confirm that they meet the validity requirements specified in section 3.8.	Examine the CSP's practices statement or other documentation to determine its confirmation codes meet the validity requirements specified in Section 3.8.	3.8 B	CSP	ALL	
CONFIRM-3	Invalidate Confirm Code	Upon its use, the CSP SHALL invalidate the confirmation code.	Determine if the CSP uses confirmation codes and, if it does, confirm the codes are invalidated upon use.	Examine the CSP's practices statement or other documentation to determine confirmation codes are invalidated upon use. Test by requesting confirmation codes and attempting to use them after their validity period has expired.	3.8 C	CSP	ALL	
CONTINUE-1	Continue Codes	Continuation codes SHALL include at least 64 bits from an approved random bit generator (see Sec. 3.2.12 of [SP800-63B]).	Determine if the CSP uses continuation codes and, if it does, confirm that these codes are comprised of at least 64 bits from a random bit generator.	Examine the CSP's practices statement or other documentation to determine its confirmation codes include at least 64 bits from an approved random bit generator.	3.9 #2	CSP	ALL	Continuation codes are used to reestablish an applicant's linkage to an incomplete identity proofing or enrollment process. The continuation code provides a temporary secret that can connect one session to another. A random bit generator (RGB) is a device or algorithm that can produce a sequence of bits that appear to be both statistically independent and unbiased.
CONTINUE-2	Continue Code Throttling	The verification of continuation codes SHALL be subject to throttling requirements, as provided in Sec. 3.2.2 of [SP800-63B].	Determine if the CSP uses continuation codes and, if it does, confirm that the use of these codes is subject to throttling requirements provided in NIST SP 800-63B-4, Sec. 3.2.2.	Examine the CSP's practices statement or other documentation to determine the use of continuation codes is subject to the throttling requirements provided in NIST SP 9800-63B-4 Sec. 3.2.2. Test by attempting to submit invalid continuation codes at a rate that would trigger throttling requirements.	3.9 #4	CSP	ALL	In the case of continuation codes, throttling is a mechanism that limits the number of failed attempts at entering a continuation code.
CONTINUE-3	Hashed Continue Codes	Continuation codes SHALL be stored in hashed form using a Federal Information Processing Standards (FIPS)-approved or NIST-recommended one-way function.	Determine if the CSP uses continuation codes and, if it does, confirm that these codes are stored in hashed form, as specified in item #5 of Sec. 3.9.	Examine the CSP's practices statement or other documentation to determine that these codes are stored in hashed form, as specified in item #5 of Sec. 3.9.	3.9 #5	CSP	ALL	

NIST SP 800-63-4 Conformance Criteria v0.1: 63A

Control Identifier	Control Name	Control Text	Objective	Assessment Method	Index	Target	Profile/XAL Level	Discussion
CONTINUE-4	Invalidate Continue Code	Upon its use, the CSP SHALL invalidate the continuation code.	Determine if the CSP uses continuation codes and, if it does, confirm that the codes are invalidated upon use.	Examine the CSP's practices statement or other documentation to determine that these codes are invalidated upon use. Test by requesting several continuation codes and attempting to use them after their validity period has expired.	3.9 #6	CSP	ALL	Since substantial time may elapse between when an applicant receives their continuation code and when they are able to complete the proofing process, expiry is not defined in these guidelines. Expiry will need to be defined by the CSP based on their processes, technologies, and partnerships.
NOTIFS-1	Validated Addresses	Notifications of proofing SHALL be sent to a validated postal address or phone number at all IALs or MAY be sent to a validated email address at IAL1.	Confirm that the CSP sends notifications of proofing at IALs 2 and 3 to validated postal addresses or phone numbers.	Examine the CSP's practices statement or other documentation to determine that, for IALs 2 or 3, it only sends notifications of proofing to validated postal addresses and/or phone numbers.	3.10 #1	CSP	ALL	Notifications of proofing are sent to the applicant's validated address to inform them that they have been successfully identity-proofed and provide them with information about the identity proofing event and subsequent enrollment. Additionally, the notification explains how the recipient can dispute their involvement in the identity proofing events. Per Sec. 2.4.2.3, validated postal addresses or phone numbers are those that have been confirmed (validated) with an authoritative source or credible source, such as a mobile network operator or AAMVA.
NOTIFS-2	ID Proofing Details	Notifications of proofing SHALL include details about the identity proofing event, including the name of the identity service and the date on which the identity proofing was completed.	Confirm that the CSP includes appropriate details about the identity proofing event in its notifications of proofing.	Examine an example of the CSP's notification of proofing to determine it includes adequate details about the identity proofing event.	3.10 #2	CSP	ALL	
NOTIFS-3	Repudiation Instructions	Notifications of proofing SHALL provide clear instructions, including contact information, on actions for the recipient to take if they repudiate their participation in the identity proofing event.	Confirm that the CSP's notifications of proofing include clear instructions for how recipients can deny their participation in an identity proofing event with the CSP.	Examine an example of the CSP's notification of proofing to determine it includes clear and easy-to-follow instructions to the recipient for repudiating their participation in the identity proofing event with the CSP.	3.10 #3	CSP	ALL	
NOTIFS-4	Security Protections	Notifications of proofing SHALL provide information about how the organization or CSP protects the security and confidentiality of the information it collects.	Confirm that the CSP's notifications of proofing include information about how it protects the security and confidentiality of the recipient's personal information.	Examine an example of the CSP's notification of proofing to determine it includes information about how the CSP protects the security and confidentiality of the information it collects and processes.	3.10 #4	CSP	ALL	
NOTIFS-5	Subscriber Responsibilities	Notifications of proofing SHALL provide information about any responsibilities that the recipient has as a subscriber of the identity service.	Confirm that the CSP's notifications of proofing include information about any responsibilities that the recipient has as a subscriber of the identity service.	Examine an example of the CSP's notification of proofing to determine it includes information about any responsibilities that the recipient has as a subscriber of the identity service.	3.10 #5	CSP	ALL	Examples of subscriber responsibilities may be to not share their account information with anyone else or to report any suspected fraud associated with their account to the CSP as soon as possible.
NOTIFS-6	Subscriber Repudiation Response	If a subscriber repudiates having been identity-proofed by the identity service, the CSP or RP SHALL respond in accordance with its established fraud management and redress policies.	Confirm that the CSP or RP has a defined policy for responding to subscriber repudiations.	Examine the CSP's or RP's policies or other documentation to determine if it has a defined policy for responding to situations where a subscriber repudiates having been identity proofed by the CSP.	3.10 A	CSP	ALL	

NIST SP 800-63-4 Conformance Criteria v0.1: 63A

Control Identifier	Control Name	Control Text	Objective	Assessment Method	Index	Target	Profile/XAL Level	Discussion
BIO-1	Bio Disclosure	CSPs SHALL provide clear, publicly available information about all uses of biometrics, including what biometric data is collected, how it is stored and protected, and how to remove biometric data consistent with applicable laws and regulations.	Confirm that the CSP discloses complete information about its uses of biometrics in a way that is clear and understandable to the general public.	Examine the CSP's practices statement or other documentation to determine its policy about publicly disclosing information about its uses of biometrics. Examine the CSP's website and user facing privacy policies to confirm biometric disclosure is addressed.	3.11 #1	CSP	ALL	
BIO-2	Bio Consent	CSPs SHALL obtain explicit informed consent to collect and use biometrics from all applicants.	Confirm that the CSP obtains informed consent from applicants prior to the collection and use of their biometric attributes.	Examine the CSP's practices statement or other documentation to determine its policy about obtaining consent from applicants prior to collecting and using biometrics. Test the CSP's identity proofing workflow to determine how it obtains consent from applicants prior to collecting and using biometrics.	3.11 #2	CSP	ALL	
BIO-3	Stored Consent	CSPs SHALL store a record of the subscriber's consent for biometric use and associate it with the subscriber's account.	Confirm that the CSP stores a record of the subscriber's consent for biometric use and that it is associated with the subscriber's account.	Examine the CSP's practices statement or other documentation to determine its policy for associating a record of the subscriber's consent for biometric use with their account. Examine and test the subscriber account to determine that it includes a record of the subscriber's consent for biometric use.	3.11 #3	CSP	ALL	
BIO-4	BIO Deletion Process	CSPs SHALL have a documented and publicly available deletion process and default retention period for all biometric information. Retention periods SHALL be consistent with applicable regulations, policies, and statutes for the regions and sectors that the CSP serves.	Determine the applicable biometric retention regulations, policies, and statutes applicable to the CSP's identity service and confirm that the CSP has documented and made publicly available its process and default retention period(s) for all biometric information, in accordance with these requirements.	Examine the CSP's practices statement or other documentation to determine 1) which regulations, policies, and statutes are applicable to its identity service and 2) that it has documented and made publicly available its deletion process and default retention period(s) for all biometric information. Examine the CSP's website to confirm that information about the availability of deletion processes are available to the public.	3.11 #4	CSP	ALL	
BIO-5	Non-Deletion Justification	If a CSP does not support biometric deletion requests, it SHALL publicly document the regulatory, statutory, or risk-based justification for their policy.	If the CSP DOES NOT support biometric deletion request, confirm that it has publicly disclosed the regulatory, statutory, and risk-based justification for their policy.	Examine the CSP's public notice justifying why it does not support biometric deletion requests. Examine the CSP's website to confirm it includes an explanation as to why it does not support biometric deletion requests.	3.11 #5	CSP	ALL	CSPs SHOULD support the deletion of all of a subscriber's biometric information upon the subscriber's request, except where otherwise restricted by regulation, law, or policy.
BIO-6	Biometric Algorithm Testing	CSPs SHALL have their biometric recognition and attack detection algorithms periodically tested by independent entities for their performance characteristics, including performance across demographic groups.	Confirm that the CSP periodically employs independent organizations to test its biometric algorithms testing for their performance characteristics, including performance across demographic groups.	Examine the CSP's practices statement or other documentation to determine: 1) that it employs independent organizations to test its biometric algorithms, and 2) how often or under what conditions it employs these organizations.	3.11 #6	CSP	ALL	In addition, the CSP SHOULD conduct internal testing on biometric algorithms based on the update schedule of the provider.(Ref.Sec.3.11 #6A)

NIST SP 800-63-4 Conformance Criteria v0.1: 63A

Control Identifier	Control Name	Control Text	Objective	Assessment Method	Index	Target	Profile/XAL Level	Discussion
BIO-7	Demographic Impacts	CSPs SHALL assess the performance and demographic impacts of employed biometric technologies in conditions that are substantially similar to the operational environment and user base of the system.	Confirm that the CSP assesses the performance of any employed biometric technologies under conditions that are substantially similar to the operational environment and the user base(s) of the identity service.	Examine the CSP's practices statement or other documentation to determine the conditions under which it assesses the performance of its employed biometric technologies.	3.11 #7A	CSP	ALL	The user base is defined by both the expected users and the devices they are expected to use.
BIO-8	Voluntary Participation	When biometric performance assessments include real-world users, participation by users SHALL be voluntary.	Determine if the CSP's biometric performance assessments include real-world users and, if so, confirm that participation by these users is entirely voluntary.	Examine the CSP's practices statement or other documentation to determine its policy for assessing biometric performance using real-world users.	3.11 #7B	CSP	ALL	
BIO-9	1:1 Comparison Performance	CSPs SHALL meet the following performance thresholds if one-to-one (1:1) comparison algorithms are used for verification against a claimed identity: false match rate: 1:10,000 or better; and false non-match rate: 1:100 or better.	Determine if the CSP employs 1:1 comparison algorithms as part of the identity verification process and, if it does, confirm the algorithms meet the required performance thresholds.	Examine the CSP's biometric testing results to determine that the performance of 1:1 biometric comparison algorithms meet or surpass the required thresholds.	3.11 #8	CSP	ALL	
BIO-10	1:N Minimum Performance	If a CSP uses one-to-many (1:N) scenarios, it SHALL meet a minimum performance threshold for false positive identification of 1:1,000 or better.	Determine if the CSP employs 1:N identification and, if it does, confirm the algorithms meet or surpass the stated performance threshold.	Examine the CSP's biometric testing results to determine that use of any 1:N scenarios meet or surpass the stated performance threshold.	3.11 #9	CSP	ALL	CSPs MAY use one-to-many (1:N) identification in support of resolution or deduplication, pursuant to a privacy risk assessment.
BIO-11	FPIR Test Gallery	Tests that demonstrate this requirement SHALL employ a gallery no smaller than 90% of the current or intended operational size (N).	Confirm that the tests the CSP uses to test FPIR for 1:N comparisons employs a gallery of at least 90% of the current intended operational size (N).	Examine the CSP's biometric testing procedures and results to determine that the tests to determine the FPIR for 1:N comparisons employs a gallery of at least 90% of the current intended operational size (N).	3.11 #10	CSP	ALL	A 1:N search of an applicant's collected biometric characteristics against a database is done to determine whether the applicant is already present in the database, possibly under a different name. The false positive identification rate (FPIR) refers to the proportion of 1:N searches in which a biometric system incorrectly identifies another person as a match, which is a false positive result. The performance metric of 1:1,000 means that a false positive outcome occurs for no more than 1 in every 1,000 searches.
BIO-12	1:N Manual Review	CSPs that make use of 1:N biometric identification for resolution, deduplication, or fraud detection purposes SHALL NOT decline a user's enrollment without a manual review to confirm the automated search results and confirm that the results are not a false positive identification.	If a CSP employs 1:N biometric identification, confirm that it does not decline a user's enrollment into an identity service based on a positive 1:N comparison match.	Examine the CSP's practices statement or other documentation to determine that the CSP employs a manual review of any positive 1:N matches.	3.11 #11	CSP	ALL	One possible reason for a false positive result is twins submitting face photographs for different accounts with the same CSP.
BIO-13	Demographic Performance	Biometric verification technologies SHALL provide performance for applicants of different demographic types that is no more than 25% worse than the performance for the overall population.	Confirm that the CSP employs biometric verification technologies that have been tested across different demographic groups and whose demonstrated performance differences do not exceed 25%.	Examine the CSP's biometric testing results to determine the performance characteristics of any biometric verification technologies across demographic groups.	3.11 #12A	CSP	ALL	For example, if the measured false nonmatch rate (FNMR) for the overall population is 0.006, the FNMR for a specific demographic group cannot exceed 0.0075. Similarly, if the false match rate (FMR) for the overall population is 0.0001, the FMR for each demographic group cannot exceed 0.000125.

NIST SP 800-63-4 Conformance Criteria v0.1: 63A

Control Identifier	Control Name	Control Text	Objective	Assessment Method	Index	Target	Profile/XAL Level	Discussion
BIO-14	Biometric Threshold	The biometric system SHALL be configured with a fixed threshold; it is not feasible to change the threshold for each demographic group.	Confirm that the CSP employs a biometric threshold that is consistent across all demographic groups.	Examine the CSP's design or other documentation to determine that the biometric threshold is fixed and consistent across all demographic groups.	3.11 #12B	CSP	ALL	
BIO-15	Demographic Categories	Demographic categories to be considered SHALL include sex, age, and skin tone when these factors affect biometric performance.	Confirm that the CSP considers sex, age, and skin tone as demographic categories for its biometric performance testing.	Examine the CSP's design or other documentation to determine that its biometric performance testing includes categories for sex, age, and skin tone.	3.11 #12C	CSP	ALL	
BIO-16	Biometric Testing Standards	All biometric performance tests SHALL be conformant to ISO/IEC 19795-1:2021 and ISO/IEC 19795-10:2024, including demographics testing.	Confirm that all biometric performance testing, including demographics testing, employed by the CSP adheres to ISO/IEC 19795-1:2021 and ISO/IEC 19795-10:2024.	Examine the CSP's biometric test procedures to determine all its biometric performance testing adheres to ISO/IEC 19795-1:2021 and ISO/IEC 19795-10:2024.	3.11 #13A	CSP	ALL	
BIO-17	Testing Results Availability	CSPs SHALL make the results of their biometric algorithm performance and biometric system operational test results publicly available.	Confirm that the CSP makes the results of its biometric algorithm performance and biometric system operational test publicly available.	Examine the CSP's practices statement or other documentation to determine that it makes the results of all its biometric systems testing publicly available. Examine a public website or other platform where the CSP has made the results of all biometric systems testing available.	3.11 #14	CSP	ALL	The CSP MAY provide these test results in summary form if the results indicate performance against the defined metrics in these guidelines and across the tested demographic groups.
BIO-18	Reasonable Assurance	If a CSP collects biometric samples from applicants, it SHALL collect them in a way that provides reasonable assurance that the biometric characteristic is collected from the applicant and not another subject.	Determine if the CSP collects biometric samples from applicants and, if it does, confirm that it has employed mechanisms to increase the assurance that the sample is being collected from the applicant and not a different subject.	Examine the CSP's design or other documentation to determine that it employs mechanisms, such as liveness detection and presentation attack detection, to increase the assurance that the sample being collected is from the applicant and not another subject. Test the biometric collection system by employing a spoofing attack.	3.11 #1	CSP	ALL	Mechanisms that mitigate risks associated with biometric collection fraud include liveness detection, and digital injection and other types of presentation attack detection (such as mechanisms to detect the presence of a foreign object).
BIO-19	Remote Biometric Collection	When collecting and comparing biometric characteristics remotely, the CSP SHALL implement presentation attack detection (PAD) capabilities that meet the impostor attack presentation accept rate (IAPAR) performance metric of <0.07 to confirm the genuine presence of a live human being and to mitigate spoofing and impersonation attempts.	Confirm that the CSP has employed PAD capabilities that meet the specified IAPAR performance metric for its remote biometric collection or comparison functions.	Examine the CSP's PAD testing results to determine that any remote biometric collection and comparison functions meet the specific IAPAR performance metric.	3.11 #2a	CSP	ALL	
BIO-20	PAD Tests	All biometric presentation attack detection tests SHALL be conformant to ISO/IEC 30107-3:2023.	Confirm that all biometric PAD tests employed by the CSP conform to ISO/IEC 30107-3:2023.	Examine the CSP's PAD testing procedures to determine that its biometric PAD tests conform to ISO/IEC 30107-3:2023.	3.11 #2b	CSP	ALL	

NIST SP 800-63-4 Conformance Criteria v0.1: 63A

Control Identifier	Control Name	Control Text	Objective	Assessment Method	Index	Target	Profile/XAL Level	Discussion
BIO-21	On-Site Biometric Collection	When collecting biometric characteristics on-site, the CSP SHALL have the operator view the biometric source (e.g., fingers, face) for the presence of unexpected non-natural materials and perform such inspections as part of the proofing process.	Confirm that, for on-site biometric collection as part of the identity proofing process, human agents of the CSP examine the source of the biometric (e.g., fingers, face) for the presence of any unexpected, non-natural materials.	Examine the CSP's practices statement or other documentation to determine that, for during on-site identity proofing processes, it has human operators view the source of any collected biometrics for the source of unexpected foreign materials.	3.11 #3	CSP	ALL	
VISUAL-1	Image Comparison Training	Proofing agents and trusted referees SHALL be trained to conduct visual facial image comparison.	Confirm that the CSP trains its proofing agents and trusted referees in how to effectively conduct visual comparisons of facial images.	Examine the CSP's practices statement or other documentation to determine the training it provides to its agents that conduct visual comparison of facial images. Interview one or more proofing agents or trusted referees to determine the training they received on the visual comparison of facial images.	3.12 #1A	CSP	ALL	
VISUAL-2	Visual Match Training	This training SHALL include techniques and methods for identifying facial characteristics, unique traits, and other indicators of matches or non-matches between an applicant and their presented evidence.	Confirm that the training the CSP provides for its proofing agents and trusted referees includes methods for identifying facial characteristics, unique traits, and other indicators of matches or non-matches between an applicant and their presented evidence.	Examine the CSP's practices statement or other documentation to determine that its proofing agents and trusted referees have been trained in methods for identifying facial characteristics, unique traits, and other indicators of matches or non-matches between an applicant and their presented evidence. Interview one or more proofing agents or trusted referees to determine that they have been trained in methods for identifying facial characteristics, unique traits, and other indicators of matches or non-matches between an applicant and their presented evidence.	3.12 #1B	CSP	ALL	
VISUAL-3	Agent Assessment	Proofing agents and trusted referees SHALL be assessed on their ability to conduct visual facial image comparisons.	Confirm that the CSP assesses its proofing agents and trusted referees on their ability to conduct visual facial image comparisons.	Examine the CSP's practices statement or other documentation to determine that it assesses its proofing agents and/or trusted referees on their ability to conduct visual facial image comparisons. Interview one or more proofing agents or trusted referees to determine that they have been assessed on their ability to conduct visual facial image comparisons.	3.12 #2A	CSP	ALL	
VISUAL-4	Annual Reassessment	Additionally, proofing agents and trusted referees SHALL be reassessed on an annual basis and remedially trained, if needed.	Confirm that the CSP annually reassesses its proofing agents and trusted referees on their ability to conduct visual facial image comparisons and provides remedial training, if needed.	Examine the CSP's practices statement or other documentation to determine its policy for annually reassessing, and remedially training if needed, its proofing agents and/or trusted referees on their ability to conduct visual facial image comparisons.	3.12 #2B	CSP	ALL	

NIST SP 800-63-4 Conformance Criteria v0.1: 63A

Control Identifier	Control Name	Control Text	Objective	Assessment Method	Index	Target	Profile/XAL Level	Discussion
VISUAL-5	Attack Training	Training SHALL be designed to reflect potential real-world attack scenarios, such as comparing applicants to images of relatives, twins, and individuals with a similar appearance.	Confirm that the CSP designs its visual image comparison training to address real-world scenarios that might result in incorrect visual comparison determinations.	Examine the CSP's design or other documentation to determine that it has designed its visual image comparison training to reflect potential real-world scenarios.	3.12 #2C	CSP	ALL	
VISUAL-6	Visual Comparison Resources	CSPs SHALL provide proofing agents and trusted referees that conduct visual facial comparisons during remote attended transactions with resources that support accurate comparisons, such as high-quality image feeds, high-definition monitors, and image analysis software.	Confirm that the CSP provides its proofing agents and trusted referees that conduct visual facial comparisons during remote transactions with resources that support the accuracy of those comparisons.	Examine the CSP's practices statement or other documentation to determine that it provides its agents with resources that support the accurate visual comparison of facial images during remote transactions. Interview one or more proofing agents or trusted referees to determine that the CSP has provided them with resources that support the accurate visual comparison of facial images during remote transactions.	3.12 #3	CSP	ALL	
VISUAL-7	Documented Training Procedures	CSPs SHALL document their training and assessment procedures for visual image comparisons and make them available to RPs upon request.	Confirm that the CSP has documented its visual image comparison training and assessment procedures and makes them available to their RPs upon request.	Examine the CSP's practices statement or other documentation to determine it has documented its training and assessment procedures for its agents that perform visual image comparisons AND its policy for providing this information to its RPs if requested. Examine an example of the information it provides to RPs about its visual image comparison training and assessment procedures.	3.12 #4	CSP	ALL	
VISUAL-8	Manual Review Training	These requirements SHALL apply for visual facial image comparisons done as manual reviews for failures of automated biometric comparisons (e.g., failure of 1:N checks conducted for resolution or deduplication).	Confirm that the CSP trains and assesses its proofing agents and trusted referees who conduct manual reviews for failures of automated biometric comparisons, in accordance with the requirements provided in Sec. 3.12.	Examine the CSP's practices statement or other documentation to determine that it trains and assesses its proofing agents and trusted referees who conduct manual reviews for failures of automated biometric comparisons, in accordance with the requirements provided in Sec. 3.12.	3.12 #5	CSP	ALL	Also see Sec. 3.11 #11 and Sec. 3.15.2 #2.
PHYS-1	Auto Evidence Validation	Automated evidence validation technology SHALL meet the following performance measures: document false acceptance rate (DFAR) of 0.1 or less; and document false rejection rate (DFRR) of 0.1 or less.	If the CSP employs automated evidence validation technology, confirm that it meets the specified performance metrics.	Examine the CSP's evidence validation technology testing results to confirm that any automated evidence validation technology it employs meets the following performance metrics: document false acceptance rate (DFAR) of 0.1 or less; and document false rejection rate (DFRR) of 0.1 or less.	3.13 A #1	CSP	ALL	For the purposes of this document, the DFAR is the proportion of processed, fraudulent documents that the document validation system determined to be valid divided by the number of processed fraudulent documents. For the purposes of this document, DFRR is the proportion of processed, genuine documents that the document validation system determined to be invalid divided by the number of processed genuine documents.

NIST SP 800-63-4 Conformance Criteria v0.1: 63A

Control Identifier	Control Name	Control Text	Objective	Assessment Method	Index	Target	Profile/XAL Level	Discussion
PHYS-2	MRZ Data	If a Machine Readable Zone (MRZ) or barcode is present on the evidence, the optical capture and inspection SHALL compare the MRZ data to the printed data on the evidence for consistency.	For evidence with MRZs or barcodes, confirm that the CSP employs optical capture and inspection capabilities that compare the MRZ data with the printed data on the evidence.	Examine the CSP's design or other documentation to determine that it employs optical capture and inspection capabilities that are able to compare evidence MRZ data to printed data. Test the CSPs implemented evidence validation technology to confirm it compares the MRZ to the printed data.	3.13 A #2	CSP	ALL	
PHYS-3	Live Document Capture	CSPs SHALL implement live capture of documents during the validation process and SHALL implement passive or active document presence checks (also called document liveness).	Confirm that the CSP employs live capture of documents during its validation process and that the live capture capabilities include document presence checks.	Examine the CSP's design or other documentation to determine that it employs the live capture capabilities, including document presence checks. Test the CSPs evidence validation technologies to confirm that only live capture of documents is used and that images cannot be directly uploaded to the service.	3.13 A #3	CSP	ALL	Live capture techniques confirm that the document is physically present and that the image captured during the identity proofing session is not a manipulated digital copy. For additional requirements to prevent the injection of modified media (i.e., digitally generated video or images of evidence), see Sec. 3.14.
PHYS-4	Optical Capture Performance 1	CSPs SHALL assess the performance of employed optical capture and inspection technologies in conditions that are substantially similar to the operational environment and the types of evidence presented by the user base of the system.	Confirm that the CSP assesses the performance of any employed optical capture and inspection technologies under conditions that are substantially similar to the operational environment and the types of evidence presented by the user base of the system.	Examine the CSP's practices statement or other documentation to determine the conditions under which it assesses the performance of any employed optical capture and inspection technologies.	3.13 A #4a	CSP	ALL	
PHYS-5	Optical Capture Performance 2	These tests SHALL account for all available identity evidence types that the CSPs allow to be validated using optical capture and inspection technology.	Confirm that the CSP's optical capture and inspection performance testing incorporates all the types of evidence it accepts to be validated using optical capture and inspection capabilities.	Examine the CSP's practices statement or other documentation to determine the types of evidence it includes in its performance assessments of optical capture and inspection technologies.	3.13 A #4b	CSP	ALL	
PHYS-6	Optical Capture Performance 3	If subscribers' documents, personal information, or images are used as part of the testing, it SHALL be on a voluntary basis and with subscriber notification and consent.	If the CSP uses documents, personal information, or images belonging to real users as part of its image capture performance testing, confirm that participation by the user is entirely voluntary and that the CSP first provides notification to the user and obtains their consent.	Examine the CSP's practices statement or other documentation to determine its policy on using documents, personal information, and/or images from real users as part of its image capture performance testing.	3.13 A #4c	CSP	ALL	These requirements apply to technologies that capture and validate images of physical identity evidence. They do not apply to validation techniques that rely on PKI or other cryptographic technologies that are embedded in the evidence itself.
PHYS-7	Capture Assessment Results	CSPs SHALL make the results of their testing publicly available.	Confirm that the CSP makes publicly available the results of any performance assessments it conducts on its image capture and validation technologies.	Examine the CSP's practices statement or other documentation to determine that it makes publicly available the results of any performance assessments it conducts on its image capture and validation technologies. Examine the CSP's performance assessment results on a publicly available website or platform.	3.13 A #6	CSP	ALL	CSPs SHOULD have their evidence validation technology periodically tested by independent entities (e.g., accredited laboratories or research institutions) for their performance characteristic.

NIST SP 800-63-4 Conformance Criteria v0.1: 63A

Control Identifier	Control Name	Control Text	Objective	Assessment Method	Index	Target	Profile/XAL Level	Discussion
PHYS-8	Visual Inspection Training	Proofing agents and trusted referees SHALL be trained and provided with the resources to visually inspect all forms of evidence supported by the CSP. This training SHALL include: authentic layouts and topography of evidence types; physical security features (e.g., raised letters, holographic features, microprinting); techniques for assessing features (e.g., tools to be used, where tactile inspection is needed, manipulation required to view specific features); and common indications of tampering (e.g., damage to the lamination, image modification).	Confirm that the CSP trains its proofing agents and trusted referees and provides them with the resources they need to visually inspect all forms of evidence supported by the CSP and confirm that this training includes all the specified elements.	Examine the CSP's practices statement or other documentation to determine that it trains its proofing agents and trusted referees and provides them with the resources they need to effectively visually inspect all forms of supported evidence. Interview one or more proofing agents or trusted referees to determine what training and resources the CSP has provided to them on visually inspecting all forms of supported evidence.	3.13 B #1	CSP	ALL	
PHYS-9	Visual Inspection Assessment	Proofing agents and trusted referees SHALL be assessed regarding their ability to visually inspect evidence based on their training. Additionally, proofing agents and trusted referees SHALL be reassessed on an annual basis or whenever significant new threats to the evidence validation process are identified and remedially trained as needed.	Confirm that the CSP (1) assesses the ability of its trained proofing agents and trusted referees to visually inspect all types of supported evidence, (2) re-assesses these agents on an annual basis, and (3) provides remedial training as needed.	Examine the CSP's practices statement or other documentation to determine its policy for assessing and annually reassessing its proofing agents and trusted referees on their ability to visually inspect all types of supported evidence.	3.13 B #2	CSP	ALL	
PHYS-10	Visual Inspection Tools	Proofing agents and trusted referees SHALL be provided with specialized tools and equipment to support the visual inspection of evidence as appropriate for the identity evidence type.	Confirm that the CSP provides its proofing agents and trusted referees with specialized tools that support the visual inspection of supported evidence types.	Examine the CSP's practices statement or other documentation to determine the types of tools it provides to its proofing agents and trusted referees to support the visual inspection of supported evidence types. Interview one or more of the CSP's proofing agents and/or trusted referee to determine that they are provided with the specialized tools they need to effectively conduct visual inspection of supported evidence types.	3.13 B #3	CSP	ALL	Specialized tools may include magnifiers, ultraviolet lights, barcode readers, etc.
PHYS-11	Remote Visual Inspections	Proofing agents and trusted referees who conduct visual inspections via remote means SHALL be provided with devices and internet connections that support sufficiently high-quality imagery to be able to effectively inspect presented evidence.	Confirm that the CSP provides its proofing agents and trusted referees who conduct visual inspections in remote scenarios with devices and internet connections that support sufficiently high-quality imagery.	Examine the CSP's practices statement or other documentation to determine that it provides its proofing agents and trusted referees who conduct visual inspection in remote scenarios with devices and internet connections that support high-quality imagery. Interview one or more of the CSP's proofing agents and/or trusted referee who conduct visual inspection in remote scenarios to determine the types of devices and internet connections the CSP has provided them with.	3.13 B #4	CSP	ALL	

NIST SP 800-63-4 Conformance Criteria v0.1: 63A

Control Identifier	Control Name	Control Text	Objective	Assessment Method	Index	Target	Profile/XAL Level	Discussion
PHYS-12	Documented Inspection Training	CSPs SHALL document their training and assessment procedures for visual inspections of evidence and make them available to RPs upon request.	Confirm the CSP has documented its training and assessment procedures for visual inspections of evidence and makes them available to its RPs upon request.	Examine the CSP's practices statement or other documentation to determine it has documented its training and assessment procedures for visual inspection of evidence AND its policy for providing this information to its RPs if requested. Examine an example of the information it provides to RPs about its evidence visual inspection training and assessment procedures.	3.13 B #5	CSP	ALL	
DIGINJ-1	Media Technical Controls	CSPs SHALL implement technical controls to increase confidence that digital media is being produced by a genuine sensor during the proofing process.	Confirm that the CSP has implemented technical controls that check for the use of genuine sensors during the identity proofing process.	Examine the CSP's design or other documentation to determine the types of checks it employs to determine that sensors used during the identity proofing process are genuine.	3.14 A #1	CSP	ALL	Many emerging attacks on both attended and unattended remote identity proofing processes pair digital injection attacks with increasingly effective and available generative AI tools. These AI tools are used to create or modify media that contain images or videos of applicants and evidence (i.e., deepfakes) to defeat automated document validation processes, biometric operations, and visual comparisons done by proofing agents. Injection attacks insert modified or forged media between the capture point (e.g., a device) and the element conducting the comparison or other operation (e.g., a server running the algorithms, a workstation used by a proofing agent).
DIGINJ-2	Analyze Digital Media	CSPs SHALL analyze all digital media submitted during the identity proofing process for artifacts and indicators of potential modification, manipulation, tampering, or forgery.	Confirm that the CSP employs a mechanism to analyze whether submitted digital media contains artifacts or other indicators of having been modified or forged.	Examine the CSP's design or other documentation to determine that it employs mechanisms for detecting indicators of digital media tampering or forgery. Test the CSP's identity proofing workflow by attempting to submit an image or other type of media that has been digitally modified or forged.	3.14 A #2a	CSP	ALL	
DIGINJ-3	Image Analysis Algorithms	Automated image analysis algorithms SHALL be tested against available attack artifacts and genuine media to provide a baseline of performance and to determine the expected rate of false positives and false negatives generated by the system.	If a CSP employs automated image analysis algorithms, confirm that these algorithms has been tested against available attack artifacts and genuine media and that expected rates of false positives and false negatives have been determined.	Examine the CSP's practices statement or other documentation to determine that any automated image analysis algorithms have been tested and the expected rates of false positives and false negatives have been determined. Examine the results of automated image analysis testing.	3.14 A #2b	CSP	ALL	
DIGINJ-4	Attack Artifact Testing	The kinds of available attack artifacts that were tested and the corresponding false negative rates SHALL be documented and made available to RPs upon request.	If a CSP employs automated image analysis algorithms, confirm that is has documented the types of attack artifacts that were tested and the corresponding false negatives and that this information has been made available to any of its RPs that request it.	Examine the CSP's testing procedures and results to determine which attack artifacts were tested and the corresponding false negative rates. Examine an example contract for an RP to determine it includes the option for RPs to request this information.	3.14 A #2c	CSP	ALL	

NIST SP 800-63-4 Conformance Criteria v0.1: 63A

Control Identifier	Control Name	Control Text	Objective	Assessment Method	Index	Target	Profile/XAL Level	Discussion
DIGINJ-5	Authenticated Protected Channels	CSPs SHALL only use authenticated protected channels for the exchange of data during remote identity proofing processes.	Confirm that the CSP always employs authenticated protected channels for the exchange of data during remote identity proofing processes.	Examine the CSP's design or other documentation to determine that it uses authenticated protected channels for all exchanges of data.	3.14 A #3	CSP	ALL	
DIGINJ-6	Manipulated Media Detection	For remote attended scenarios, CSPs SHALL train proofing agents and trusted referees to look for indications of manipulated media.	Confirm that the CSP trains its proofing agents and trusted referees how to look for indications of digital media fraud in remote attended scenarios.	Examine the CSP's practices statement or other documentation to determine that it trains its proofing agents and trusted referees on how to look for indications that digital media has been manipulated. Interview one or more proofing agents and/or trusted referees to determine they have been trained how to look for manipulated digital media during attended remote scenarios.	3.14 B #1	CSP	ALL	
DIGINJ-7	Human In The Loop	For remote attended scenarios, CSPs SHALL introduce random "human-in-the-loop" cues into their capture processes to increase the possibility of forged or manipulated media being detected.	Confirm that the CSP introduces random "human-in-the-loop" cues into its capture processes during remote attended scenarios	Examine the CSP's design or other documentation to determine that it incorporates random "human-in-the-loop" cues into its digital media capture processes in remote attended scenarios. Interview one or more proofing agents or other personnel to determine that the CSP incorporates random "human-in-the-loop" cues into its digital media capture processes.	3.14 B #2	CSP	ALL	Examples of "human-in-the-loop" cues include requesting user movements or requesting that the user move objects between the capture sensor and their face.
EXCEPT-1	Documented Exception Handling	CSPs SHALL document their operational processes for dealing with errors and handling exceptions.	Confirm that the CSP has documented its error and exception handling processes.	Examine the CSP's practices statement or other documentation to determine its operational processes for dealing with errors and handling exceptions.	3.15 A	CSP	ALL	Throughout the identity proofing process, there are many points at which errors or failures may occur. Such exceptions to a standard identity proofing workflow include process failures (e.g., when a user does not possess the required evidence), technical failures (e.g., when an integrated service is not available), and failures due to user error (e.g., when an applicant is unable to capture a clear image of their identity evidence using remote validation tools). These documented processes SHOULD include providing trusted referees to support applicants who are otherwise unable to meet the requirements of IALs 1 and 2. Additionally, CSPs SHOULD support the use of applicant references who can vouch for an applicant's attributes, conditions, or identity.

NIST SP 800-63-4 Conformance Criteria v0.1: 63A

Control Identifier	Control Name	Control Text	Objective	Assessment Method	Index	Target	Profile/XAL Level	Discussion
EXCEPT-2	Trusted Referee Notification	The CSP SHALL notify the public of the availability of trusted referee services and how such services are obtained.	[If the CSP provides trusted referees], confirm that it notifies the public of their availability and how to obtain their services.	Examine the CSP's practices statement or other documentation to determine how it notifies the public about the availability of trusted referee services. Examine the information about the availability and use of trusted referees on the CSPs website or identity system.	3.15.1 #1	CSP	ALL	Trusted referees are used to increase access to online services by facilitating the identity proofing and enrollment of individuals who are otherwise unable to prove their identities using the usual identity proofing process for a specific IAL. A non-exhaustive list of examples of individuals who may need the assistance of trusted referees includes those who do not possess and cannot obtain the required identity evidence, persons with disabilities, older individuals, persons experiencing homelessness, individuals with limited access to online services or computing devices, persons without a bank account or with limited credit history, victims of identity theft, individuals displaced or affected by natural disasters, and children under 18. Trusted referees can be provided by the CSP, a third party, or an RP.
EXCEPT-3	Trusted Referee Policies	The CSP SHALL establish written policies and procedures for the use of trusted referees as part of its practice statement, as specified in Sec. 3.1.	Confirm that the CSP has established written policies and procedures for the use of trusted referees.	Examine the CSP's practices statement or other documentation to determine is has established written procedures for the use of trusted referees.	3.15.1 #2	CSP	ALL	
EXCEPT-4	Trusted Referee Training	The CSP SHALL train and certify its trusted referees to make risk-based decisions that allow applicants to be successfully identity-proofed based on their unique circumstances. At a minimum, such training SHALL include: (a) Document identification and validation, such as common templates, security features, layouts, and topography (see Sec. 3.13). (b) Indicators of fraudulent documents, such as damage, tampering, modification, fabrication, or forgery (see Sec. 3.13). (c) Facial image comparisons to verify applicants against presented documents (see Sec. 3.12). (d) Indicators of social engineering exhibited by an applicant, such as distress, confusion, or coercion. (e) An annual review of the trusted referee's abilities to visually inspect evidence and make visual facial image comparisons (see Sec. 3.12).	Confirm that the CSP trains and certifies its trusted referees in accordance to the specified requirements.	Examine the CSP's practices statement or other documentation to determine the training and certification it provides to its trusted referees. Interview one or more of the CSP's trusted referees to determine that they were certified by the CSP and received the specified training.	3.15.1 #3	CSP	ALL	
EXCEPT-5	TR Usage Record	The CSP SHALL establish a record of any identity proofing session that involves a trusted referee, including the reasons why a trusted referee was used (e.g., automated process failure, applicant request, established exception policy), the identity of the trusted referee, what evidence was presented, which processes were completed (e.g., validation or verification), and the trusted referee's decision and, if negative, their rationale.	Confirm that the CSP establishes a record whenever a trusted referee is involved in the identity proofing of an applicant, and that this record includes, at the minimum, the details specified in this requirement.	Examine the CSP's practices statement or other documentation to determine that it establishes detailed records of identity proofing transactions that involve a trusted referee.	3.15.1 #4	CSP	ALL	While the details of trusted referee usage will necessarily be associated with the subject being identity proofed, it is expected that some or all of this information will not be visible to the subject through in subscriber account.

NIST SP 800-63-4 Conformance Criteria v0.1: 63A

Control Identifier	Control Name	Control Text	Objective	Assessment Method	Index	Target	Profile/XAL Level	Discussion
EXCEPT-6	ALL Applicable Requirements	These sessions SHALL be consistent with the requirements of these proofing types based on the IAL of the proofing event.	Confirm the CSP's policy on meeting all applicable requirements for identity proofing transactions, regardless of whether or not a trusted referee is involved.	Examine the CSP's practices statement or other documentation to determine that all applicable requirements for identity proofing transactions, regardless of whether or not a trusted referee is involved.	3.15.1 #5	CSP	ALL	All applicable requirements must be met, regardless of the use of trusted referees.
EXCEPT-7	Trusted Referee Use	CSPs SHALL document which types of exceptions and failures are eligible for the use of a trusted referee.	Confirm the CSP has documented the scenarios that are eligible for trusted referee involvement in an identity proofing transaction.	Examine the CSP's practices statement or other documentation to determine which scenarios are eligible for the use of a trusted referee.	3.15.2 #1	CSP	ALL	
EXCEPT-8	Automated Validation Failures	If a CSP offers trusted referees [are offered for failures in completing automated validation processes], the following requirements apply: (a) CSPs SHALL provide a policy for additional evidence types that may be used to corroborate core attributes or changes in core attributes. (b) Trusted referees SHALL review additional evidence types for authenticity to the greatest degree allowed by the evidence. (c) If no authoritative or credible records are available to support validation, the trusted referee MAY compare the attributes on additional pieces of evidence with the strongest piece of evidence available to corroborate the consistency of core attributes. (d) If there is a partial mismatch of core attributes to authoritative records, the trusted referee SHALL review evidence that supports the legitimacy of the asserted attribute value (e.g., recent move or change of name).	Determine if the CSP offers trusted referees to assist with automated validation failures and, if it does, confirm that their involvement in these scenarios adheres to the specified requirements.	Examine the CSP's practices statement or other documentation to determine its policy on trusted referee involvement in automated validation failures.	3.15.2 #3	CSP	ALL	CSPs SHOULD offer trusted referee services for failures in completing automated validation processes, such as mismatched core attributes or the absence of the applicant in a record source.
EXCEPT-9	Applicant Reference Notification	The CSP SHALL notify the public of the allowability of applicant references and any requirements for the relationship between the reference and an applicant.	Confirm if the CSP provides a notice to the public about the allowability of applicant references to assist in identity proofing transactions along with any requirements for their use.	Examine the CSP's practices statement or other documentation to determine that it notifies the public about the allowability of applicant references and the requirements for their use. Examine the information about the allowability of and requirements for applicant reference use on the CSP's public website or identity system.	3.15.3 #1	CSP	ALL	Applicant references are individuals who participate in the identity proofing of an applicant in order to vouch for the applicant's identity, attributes, or circumstances related to the applicant's ability to complete identity proofing. Applicant references are not agents of the CSP, but rather representatives of the applicant who have sufficient knowledge to aid in the completion of identity proofing when other forms of evidence, validation, and verification are not available. Applicant references are permissible at IAL 1 and IAL 2 only.
EXCEPT-10	Applicant Reference Policy	The CSP SHALL establish written policies and procedures for the use of applicant references as part of its practice statement, as specified in Sec. 3.1.	Confirm that the CSP has written policies and procedures for the use of applicant references.	Examine the CSP's practices statement or other documentation to determine it has written policies for the use of applicant references.	3.15.3 #2	CSP	ALL	

NIST SP 800-63-4 Conformance Criteria v0.1: 63A

Control Identifier	Control Name	Control Text	Objective	Assessment Method	Index	Target	Profile/XAL Level	Discussion
EXCEPT-11	Applicant Reference Proofing	The CSP SHALL identity-proof an applicant reference to the same or higher IAL intended for the applicant.	Determine if the CSP allows the use of applicant references and, if it does, confirm that all applicant references are identity-proofed to the same or higher IAL as the applicant or applicants they are supporting.	Examine the CSP's practices statement or other documentation to determine that it identity proofs applicant reference to the same or higher IAL as the applicants. Examine one or more sample records of subscribers who were identity proofed using an applicant reference and determine the IAL associated with both the subscriber and their reference.	3.15.3 #3	CSP	ALL	
EXCEPT-12	AR Privacy Assessment	The CSP SHALL include the information collected, recorded, and retained for identity proofing the applicant references in its privacy risk assessment, as required in section Sec. 3.3.1.	Confirm that the CSP included all personal data associated with the use of applicant references in its privacy risk assessment.	Examine the CSP's privacy risk assessment documentation to determine it has included data associated with the use of applicant references.	3.15.3 #3	CSP	ALL	
EXCEPT-13	Applicant Reference Record	The CSP SHALL record the use of an applicant reference in the subscriber account and maintain a record of the applicant reference and their relationship to the applicant.	Confirm that the CSP records the use of applicant references in the associated subscriber accounts, including their relationship to the applicant.	Examine the CSP's practices statement or other documentation to determine how it records the use of applicant references. Examine one or more subscriber accounts to determine how it records the use of an applicant reference.	3.15.3 #4	CSP	ALL	
EXCEPT-14	RP Risk Assessment	The RP SHALL conduct a risk assessment to determine the applicability, business requirements, and potential risks associated with excluding or including applicant references for proofing events.	Confirm that the RP has conducted a risk assessment that considers the impacts of both allowing and not allowing the use of applicant references.	Examine the results of the RP's risk assessment to determine it has thoroughly considered whether or not to allow the acceptance of users whose identity proofing process was supported by applicant references.	3.15.3 #5	CSP	ALL	
EXCEPT-15	Acceptable AR Uses	If CSPs allow the use of applicant references, the CSPs and the RPs that use their services SHALL document all acceptable uses for applicant references in their contracts or trust agreements.	If CSPs allow for the use of applicant references, confirm that acceptable uses of their services are documented in any contracts or trust agreements with RPs.	Examine a sample RP contract or trust agreement and determine that the CSP has included acceptable uses, if any, for applicant references. Interview appropriate personnel to determine that the CSP includes information about the acceptable uses of applicant references in its contracts or trust agreements with the RPs that use its service.	3.15.4 A	CSP	ALL	
EXCEPT-16	AR Legal Requirements	In all instances, the CSP SHALL establish a record of the role that the applicant reference played in the process and document these actions sufficient to support any applicable legal and regulatory requirements.	Determine that the CSP has identified any legal or regulatory requirements associated with the use of applicant references, and confirm that it records sufficient details about the use of an applicant reference to support those requirements.	Examine the CSP's practices statement or other documentation to determine any legal or regulatory requirements that apply to the use of applicant references, and determine that the CSP records sufficient details about each use of an applicant reference to meet these requirements.	3.15.4 B	CSP	ALL	
EXCEPT-17	Applicant Reference Liability	CSPs SHALL make available to the applicant reference clear and understandable information relative to the legal and liability impacts that may result from their participation as an applicant reference.	Confirm that the CSP makes information available to potential applicant references about any legal or liability implications associated with their participation in the identity proofing of an applicant.	Examine the CSP's practices statement or other documentation to determine the information it provides to potential applicant references. Examine the actual information it provides to applicant references.	3.15.4 C	CSP	ALL	

NIST SP 800-63-4 Conformance Criteria v0.1: 63A

Control Identifier	Control Name	Control Text	Objective	Assessment Method	Index	Target	Profile/XAL Level	Discussion
EXCEPT-18	AR Relationship Requirements	The CSP and RP SHALL establish requirements for applicant reference relationship confirmation processes and document them in any contracts or trust agreements.	Confirm that the requirements and process for confirming the relationship between an applicant and their applicant reference is documented in any contracts or trust agreements between CSPs and RPs.	Examine a sample contract or trust agreement to determine that it includes information about the requirements and process for confirming the relationship between an applicant and their applicant reference.	3.15.5 #1	CSP	ALL	
EXCEPT-19	Applicant Reference Evidence	The CSP SHALL make a list of acceptable evidence of relationship available to the applicant reference prior to initiating the relationship confirmation process.	Confirm that the CSP provides a list of acceptable evidence of the relationship between an applicant and their applicant reference prior to initiating the relationship confirmation process.	Examine the CSP's practices statement or other documentation to determine that the CSP provides a list of acceptable evidence of the relationship between an applicant and their applicant reference prior to initiating the relationship confirmation process. Test the applicant reference workflow to determine that the CSP provides a list of acceptable evidence of the relationship between an applicant and their reference prior to initiating the relationship confirmation process.	3.15.5 #2	CSP	ALL	
EXCEPT-20	AR Relationship Evidence	The CSP SHALL request evidence of the applicant's relationship (e.g., notarized power of attorney, a professional certification).	Confirm that the CSP collects evidence supporting the relationship between an applicant and their applicant reference.	Examine the CSP's practices statement or other documentation to determine that the CSP collects evidence supporting the relationship between an applicant and their applicant reference. Test the applicant reference workflow to determine that the CSP collects evidence supporting the relationship between an applicant and their applicant reference.	3.15.5 #3	CSP	ALL	
EXCEPT-21	Record Relationship Evidence	Upon successfully identity proofing an applicant, the CSP SHALL record the evidence used to confirm the applicant reference's relationship to the applicant in the subscriber account.	Confirm that the CSP records the evidence used to confirm the relationship between an applicant and their applicant reference and associates it with the subscriber's account.	Examine the CSP's practices statement or other documentation to determine that records the evidence used to confirm the relationship between an applicant and their applicant reference in the subscriber's account. Examine one or more sample records of subscribers who were identity proofed using an applicant reference and determine that it includes information about the type(s) of evidence used to confirm the relationship between the applicant and their applicant reference.	3.15.5 #4	CSP	ALL	
EXCEPT-22	Minors Evidence Policy	The CSP SHALL establish a written policy and procedures as part of its practice statement for identity proofing minors who may not be able to meet the evidence requirements for a given IAL.	Confirm that the CSP has documented its policy and procedures for the identity proofing of minors who are unable to meet the evidence requirements for a given IAL.	Examine the CSP's practices statement or other documentation to determine its policy and procedures for identity proofing minors who are unable to meet the IAL evidence requirements.	3.15.6 #1	CSP	ALL	

NIST SP 800-63-4 Conformance Criteria v0.1: 63A

Control Identifier	Control Name	Control Text	Objective	Assessment Method	Index	Target	Profile/XAL Level	Discussion
EXCEPT-23	COPPA	When interacting with persons under the age of 13, the CSP SHALL ensure compliance with the Children's Online Privacy Protection Act of 1998 [COPPA] or other laws and regulations that deal with the protection of minors, as applicable.	Confirm that the CSP complies with COPPA and any other laws and regulations that deal with the protection of minors.	Examine the CSP's practices statement or other documentation to determine its policy for complying with COPPA and any other applicable laws and regulations that deal with the protection of minors.	3.15.6 #2	CSP	ALL	
EXCEPT-24	Minors' Applicant References	CSPs SHALL support the use of applicant references when interacting with individuals under the age of 18.	Confirm that the CSP allows for the use of applicant references for the identity proofing of individuals under the age of 18.	Examine the CSP's practices statement or other documentation to determine its policy for complying for supporting the use of applicant references for the identity proofing of individuals under the age of 18.	3.15.6 #3	CSP	ALL	
ELEVATE-1	Elevating Assurance Levels	CSPs SHALL document their approved approaches for elevating assurance levels in their practice statements.	If the CSP supports the elevation of subscriber assurance levels, confirm that the CSP has documented its policy and approved approaches for this process.	Examine the CSP's practices statement or other documentation to determine its policy and approaches for elevating subscriber assurance levels.	3.16 #1	CSP	ALL	CSPs SHOULD allow subscribers to elevate IALs related to their subscriber accounts to support higher assurance transactions with RPs.
ELEVATE-2	Account Upgrade Authentication	CSPs SHALL require subscribers to authenticate at the highest authentication assurance level (AAL) available on their account prior to initiating the upgrade process.	If the CSP supports the elevation of subscriber assurance levels, confirm that it requires subscribers to authenticate at the highest AAL available on their account prior to initiating the upgrade process.	Examine the CSP's practices statement or other documentation to determine it subscribers to authenticate at the highest AAL available on their account prior to initiating the upgrade process.	3.16 #2	CSP	ALL	
ELEVATE-3	Additional Evidence Requirements	CSPs SHALL collect, validate, and verify additional evidence, as mandated to achieve the higher IAL.	If the CSP supports the elevation of subscriber assurance levels, confirm that it collects, validates, and verifies additional evidence, as needed to meet the requirements of the higher IAL.	Examine the CSP's practices statement or other documentation to determine that it collects, validates, and verifies additional evidence, as needed to meet the requirements of the higher IAL.	3.16 #3	CSP	ALL	
IAL1-1	IAL1 Documented Process	CSPs that combine elements of different proofing types SHALL document their hybrid process and state how the applicable requirements for each of the employed proofing types are met.	If the CSP employs a hybrid process, confirm that it is documented, and such documentation includes details about how the applicable requirements for each proofing type are met.	Examine the CSP's practices statement or other documentation to determine how its hybrid identity proofing process meets the applicable requirements.	4.1.1 #2	CSP	IAL1	IAL1 identity proofing MAY be delivered through any proofing type, as described in Sec. 2.1.3. CSPs MAY combine proofing types and their stated requirements to create hybrid processes. For example, a CSP might leverage remote unattended identity proofing validation processes in advance of a remote attended session where the verification will take place.
IAL1-2	IAL1 Evidence Collection	For identity proofing at IAL1, the CSP SHALL collect: one piece of FAIR evidence that can be digitally validated or that includes a facial portrait or other biometric; OR, one piece of STRONG evidence; OR, one piece of SUPERIOR evidence.	Confirm that the CSP collects the specified evidence for identity proofing at IAL 1.	Examine the CSP's practice statement or other documentation to determine its evidence collection requirements for IAL 1. Test the CSP's identity proofing workflow to determine that documented evidence collection processes are followed.	4.1.2	CSP	IAL1	

NIST SP 800-63-4 Conformance Criteria v0.1: 63A

Control Identifier	Control Name	Control Text	Objective	Assessment Method	Index	Target	Profile/XAL Level	Discussion
IAL1-3	IAL1 Attribute Collection	The CSP SHALL collect all core attributes, including at least one government identifier.	Confirm that the CSP collects all core attributes, including at least one government identifier.	Examine the CSP's practices statement or other documentation to determine its policy for collecting core attributes. Test the CSP's identity proofing workflow to determine that all documented core attribute collection processes are followed.	4.1.3	CSP	IAL1	Validated evidence is the preferred source of identity attributes. If the presented identity evidence does not provide all of the attributes that the CSP considers to be core attributes, it MAY collect attributes that are self-asserted by the applicant.
IAL1-4	IAL1 Evidence Validation	Each piece of evidence presented SHALL be validated using one of the methods [provided in Sec. 4.1.4].	Confirm that the CSP validates all collected evidence as specified.	Examine the CSP's practices statement or other documentation to determine its evidence validation policy and processes. Test the CSP's identity proofing workflow to determine that all documented validation processes are followed.	4.1.4	CSP	IAL1	
IAL1-5	IAL1 Attribute Validation	The CSP SHALL validate all core attributes and the government identifier against an authoritative or credible source to determine accuracy.	Confirm that the CSP validates all collected core attributes as specified.	Examine the CSP's practices statement or other documentation to determine its core attribute validation policy and processes. Test the CSP's identity proofing workflow to determine that all core attribute validation processes are followed.	4.1.5 #1	CSP	IAL1	CSPs SHOULD evaluate attributes obtained from different sources (e.g., presented evidence, self-asserted, authoritative or credible sources) for consistency. CSPs SHOULD validate any reference numbers on the presented identity evidence, if available.
IAL1-6	IAL1 Verification Requirements	The CSP SHALL verify the applicant's ownership of one piece of evidence using one of the methods [provided in 4.1.6].	Confirm that the CSP verifies the applicant's ownership of at least one piece of collected evidence using one of the specified methods.	Examine the CSP's practices statement or other documentation to determine its policy and processes for performing verification. Test the CSP's identity proofing workflow to determine that all documented verification processes are followed.	4.1.6 A	CSP	IAL1	
IAL1-7	Async Visual Comparison	If the visual comparison is performed asynchronously at a later time, the CSP SHALL implement PAD and passive or active document presence checks to increase confidence that both the live applicant and physical documents are present during the submission or capture event.	Confirm that the CSP has implemented PAD and passive and active document liveness checks for the asynchronous visual comparison of an applicant to their identity evidence.	Examine the CSP's practices statement or other documentation to determine it has implemented PAD and passive and active document liveness checks for the asynchronous visual comparison of an applicant to their identity evidence.	4.1.6 B	CSP	IAL1	
IAL1-8	IAL1 Video Session	For Remote Attended identity proofing, the applicant SHALL remain in view of the proofing agent during each step of the proofing process.	For remote attended video sessions, confirm the CSP requires that the applicant is visible to the proofing agent for each step of the identity proofing process.	Examine the CSP's practices statement or other documentation to determine its requirements for applicant visibility during remote attended identity proofing sessions. Interview appropriate personnel to determine the process for viewing applicants during each step of remote attended identity proofing sessions.	4.1.8 #1	CSP	IAL1	
IAL1-9	IAL1 Video Quality	For Remote Attended identity proofing, the video quality SHALL be sufficient to support the necessary steps in the validation and verification processes, such as inspecting evidence and comparing the applicant to the evidence.	For remote attended video sessions, confirm the video quality is sufficient to support the needs of the identity proofing process.	Examine the CSP's practices statement or other documentation to determine it employs video technologies of sufficient quality to support the identity proofing processes.	4.1.8 #2	CSP	IAL1	

NIST SP 800-63-4 Conformance Criteria v0.1: 63A

Control Identifier	Control Name	Control Text	Objective	Assessment Method	Index	Target	Profile/XAL Level	Discussion
IAL1-10	IAL1 Remote Attended Coercion Training	For Remote Attended identity proofing, the proofing agent SHALL be trained to identify signs of manipulation, coercion, or social engineering occurring during the session.	Confirm the CSP trains its agents to identify signs that an applicant has been coerced or manipulated into participating in the identity proofing process.	Examine the CSP's practices statement or other documentation to determine its policy for training its agents to identify signs of coercion, manipulation, or social engineering. Interview one or more agents of the CSP to determine the training they've received to identify these signs.	4.1.8 #3	CSP	IAL1	
IAL1-11	IAL1 Remote Attended Recorded Video	For Remote Attended identity proofing, if the CSP records a video session, the following further requirements apply: (a) The CSP SHALL notify the applicant of the recording prior to initiating a recorded session. (b) The CSP SHALL gain consent from the applicant prior to initiating a recorded session. (c) The CSP SHALL publish their retention schedule and deletion processes for all video records.	If the CSP records remote attended video identity proofing sessions, confirm that the specified requirements are met.	Examine the CSP's practices statement or other documentation to determine that it meets all the specified requirements for recording remote attended identity proofing sessions. Test the remote attended identity proofing process and determine that all the specified requirements for recording remote attended identity proofing sessions are met.	4.1.8 #4	CSP	IAL1	
IAL1-12	IAL1 Injection Protection	For Remote Attended identity proofing, the CSP SHALL implement injection protection and modified media controls, as defined in Sec. 3.14.	Confirm that the CSP employs injection protection and controls against modified media.	Examine the CSP's practices statement or other documentation to determine it has implemented injection project and modified media controls.	4.1.8 #5	CSP	IAL1	
IAL1-13	IAL1 Remote Attended Fraud Flags	For Remote Attended identity proofing, the CSP SHALL provide proofing agents with a method or mechanism to flag events for potential fraud.	Confirm the CSP provides its proofing agents with a mechanism to flag potential fraud.	Examine the CSP's practices statement or other documentation to determine it provides its proofing agents with a mechanism to flag incidents of potential fraud. Interview one or more agents of the CSP to determine the mechanism they use to flag incidents of potential fraud.	4.1.8 #6	CSP	IAL1	
IAL1-14	IAL1 On-Site Attended Physical Setting	For On-site Attended identity proofing, the CSP SHALL provide a physical setting in which on-site identity proofing sessions are conducted.	Confirm the CSP provides physical location in for on-site attended identity proofing.	Examine the CSP's practices statement or other documentation to determine that it provides a physical setting for on-site attended identity proofing sessions. Examine a location where the CSPs conducts on-site identity proofing.	4.1.9 #1	CSP	IAL1	
IAL1-15	IAL1 On-Site Attended Security Controls	For On-site Attended identity proofing, all devices SHALL be protected by appropriate baseline security features comparable to FISMA moderate controls, including malware protection, administrator-specific access controls, and software update processes.	Confirm that the CSP employs security controls comparable to FISMA moderate or higher for all equipment used for on-site attended identity proofing.	Examine the CSP's practices statement, certification information, or other documentation to confirm it protects the equipment used in on-site attended identity proofing by security controls comparable to FISMA moderate or higher.	4.1.9 #2	CSP	IAL1	
IAL1-16	IAL1 On-Site Attended Coercion Training	For On-site Attended identity proofing, CSP proofing agents SHALL be trained to identify signs of manipulation, coercion, or social engineering occurring during the on-site session.	Confirm the CSP trains its agents to identify signs that an applicant has been coerced or manipulated into participating in the identity proofing process.	Examine the CSP's practices statement or other documentation to determine its policy for training its agents to identify signs of coercion, manipulation, or social engineering. Interview one or more agents of the CSP to determine the training they've received to identify these signs.	4.1.9 #3	CSP	IAL1	

NIST SP 800-63-4 Conformance Criteria v0.1: 63A

Control Identifier	Control Name	Control Text	Objective	Assessment Method	Index	Target	Profile/XAL Level	Discussion
IAL1-17	IAL1 On-Site Attended Recorded Video	For On-site Attended identity proofing, if the CSP records a video session, the following additional requirements apply: (a) The CSP SHALL notify the applicant of the recording prior to initiating a recorded session. (b) The CSP SHALL gain consent from the applicant prior to initiating a recorded session. (c) The CSP SHALL publish their retention schedule and deletion processes for all video records.	If the CSP records remote attended video identity proofing sessions, confirm that the specified requirements are met.	Examine the CSP's practices statement or other documentation to determine that it meets all the specified requirements for recording on-site attended identity proofing sessions. Test the on-site attended identity proofing process to determine that all the requirements for recording video sessions are met.	4.1.9 #4	CSP	IAL1	
IAL1-18	IAL1 On-Site Attended Fraud Flags	For On-site Attended identity proofing, the CSP SHALL provide proofing agents with a method or mechanism to covertly flag events for potential fraud.	Confirm the CSP provides its proofing agents with a mechanism to flag potential fraud.	Examine the CSP's practices statement or other documentation to determine it provides its proofing agents with a mechanism to flag incidents of potential fraud. Interview one or more agents of the CSP to determine the mechanism they use to flag incidents of potential fraud.	4.1.9 #5	CSP	IAL1	
IAL1-19	IAL1 On-Site Unattended Physical Setting	For On-site Unattended identity proofing, the CSP SHALL provide a physical setting in which on-site identity proofing sessions are conducted.	Confirm the CSP provides physical location in for on-site attended identity proofing.	Examine the CSP's practices statement or other documentation to determine that it provides a physical setting for on-site attended identity proofing sessions. Examine a location where the CSPs conducts on-site identity proofing.	4.1.10 #1	CSP	IAL1	
IAL1-20	IAL1 On-Site Unattended Security Controls	For On-site Unattended identity proofing, all devices SHALL be protected by appropriate baseline security features comparable to FISMA moderate controls, including malware protection, administrator-specific access controls, and software update processes.	Confirm that the CSP employs security controls comparable to FISMA moderate or higher for all equipment used for on-site attended identity proofing.	Examine the CSP's practices statement, certification information, or other documentation to confirm it protects the equipment used in on-site attended identity proofing by security controls comparable to FISMA moderate or higher.	4.1.10 #2	CSP	IAL1	
IAL1-21	IAL1 Device Inspection	For On-site Unattended identity proofing, all devices SHALL be inspected periodically by trained technicians to deter tampering, modification, or damage.	Confirm that the CSP has a policy for ensuring that all equipment used for on-site attended identity proofing is periodically inspected by technicians who are trained to detect tampering, modification, and damage.	Examine the CSP's practices statement or other documentation to determine its policy for inspecting equipment used for on-site attended identity proofing.	4.1.10 #3	CSP	IAL1	
IAL1-22	IAL1 On-Site Unattended Recorded Video	For On-site Unattended identity proofing, if the CSP records a video session, the following additional requirements apply: (a) The CSP SHALL notify the applicant of the recording prior to initiating a recorded session. (b) The CSP SHALL gain consent from the applicant prior to initiating a recorded session. (c) The CSP SHALL publish their retention schedule and deletion processes for all video records.	If the CSP records remote attended video identity proofing sessions, confirm that the specified requirements are met.	Examine the CSP's practices statement or other documentation to determine that it meets all the specified requirements for recording on-site unattended identity proofing sessions. Test the on-site unattended identity proofing process to determine that all the requirements for recording video sessions are met.	4.1.10 #4	CSP	IAL1	

NIST SP 800-63-4 Conformance Criteria v0.1: 63A

Control Identifier	Control Name	Control Text	Objective	Assessment Method	Index	Target	Profile/XAL Level	Discussion
IAL1-23	IAL1 Proofing Notification	Upon the successful completion of identity proofing at IAL1, the CSP SHALL send a notification of proofing to a validated address for the applicant, as specified in Sec. 3.10.	Confirm that the CSP sends notifications of proofing to validated addresses for applicants after they have successfully complete identity proofing.	Examine the CSP's practices statement or other documentation to determine that it sends notifications of proofing to applicant's validated addresses, upon successful completion of identity proofing. Test the identity proofing workflow to confirm that appropriate notifications are delivered to a validated address.	4.1.11	CSP	IAL1	Notifications can be delivered to test accounts and addresses as appropriate based on the capabilities of the assessor or the testing environment available to them and any privacy restrictions on the use of legitimate addresses.
IAL1-24	IAL1 Authenticator Binding	The CSP SHALL provide the ability for the applicant to bind an authenticator using one of the following methods: (a) Remote enrollment of a subscriber-provided authenticator consistent with the requirements for the authenticator type, as defined in Sec. 4.1.3 of [SP800-63B]. (b) Distribution of a physical authenticator to a validated address. (c) Distribution or on-site enrollment of an authenticator.	Confirm that the CSP provides the ability for an applicant to bind an authenticator using one of the specified methods.	Examine the CSP's practices statement or other documentation to determine its policy and process for allowing an applicant to bind one or more authenticators to their subscriber account. Test the identity proofing workflow to confirm that the applicants are able to bind authenticators using one or more of the specified methods.	4.1.12 #1	CSP	IAL1	
IAL1-25	IAL1 Subscriber Verification	If authenticators are bound outside of a single protected session with the user, the CSP SHALL confirm the presence of the intended subscriber through one of the following methods: (a) Return of a continuation code. (b) Comparison against a biometric collected at the time of proofing.	For authenticators that are bound outside of a single, protection session, confirm that the CSP validates the presence of the intended subscriber through using one of the specified methods.	Examine the CSP's practices statement or other documentation to determine its process for confirming the presence of the intended subscriber prior to binding authenticators that were issued after the identity proofing session. Test the identity proofing workflow to confirm that the CSP employs its documented processes for using continuation codes or biometrics for confirming the presence of the intended subscriber prior to binding authenticators that were issued outside of the original identity proofing session.	4.1.12 #2	CSP	IAL1	
IAL2-1	IAL2 Documented Process	If such steps are combined, CSPs SHALL document their hybrid process and state how the applicable requirements for each of the employed proofing types are met.	[If the CSP employs a hybrid process], confirm that it is documented, and such documentation includes details about how the applicable requirements for each proofing type are met.	Examine the CSP's practices statement or other documentation to determine how its hybrid identity proofing process meets the applicable requirements.	4.2.1 #2	CSP	IAL2	IAL2 identity proofing MAY be delivered through any proofing type, as described in Sec. 2.1.3. CSPs MAY combine proofing types and their stated requirements to create hybrid processes. For example, a CSP might leverage remote unattended identity proofing validation processes in advance of a remote attended session where the verification will take place.
IAL2-2	IAL2 Evidence Collection	For identity proofing at IAL2, the CSP SHALL collect: one piece of FAIR evidence and one piece of STRONG evidence; OR, two pieces of STRONG evidence; OR, one piece of SUPERIOR evidence.	Confirm that the CSP collects the specified evidence for identity proofing at IAL 2.	Examine the CSP's practices statement or other documentation to determine its evidence collection requirements for IAL 2. Test the CSP's IAL2 identity proofing workflow to determine that documented evidence collection processes are followed.	4.2.2	CSP	IAL2	

NIST SP 800-63-4 Conformance Criteria v0.1: 63A

Control Identifier	Control Name	Control Text	Objective	Assessment Method	Index	Target	Profile/XAL Level	Discussion
IAL2-3	IAL2 Attribute Collection	The CSP SHALL collect all core attributes, including at least one government identifier. Validated evidence is the preferred source of identity attributes.	Confirm that the CSP collects all core attributes, including at least one government identifier.	Examine the CSP's practices statement or other documentation to determine its policy for collecting core attributes. Test the CSP's IAL2 identity proofing workflow to determine that all documented core attribute collection processes are followed.	4.2.3	CSP	IAL2	If the presented identity evidence does not provide all of the attributes that the CSP considers to be core attributes, it MAY collect attributes that are self-asserted by the applicant.
IAL2-4	IAL2 Fair/Strong Validation	Each piece of FAIR or STRONG evidence that is presented SHALL be validated using one of the following techniques: (a) Confirming the authenticity of the digital evidence by interrogating the digital security features (e.g., signatures on assertions or data). (b) Confirming the authenticity of the physical evidence using automated scanning technology that can detect physical security features. (c) Confirming the integrity of any physical security features through a visual inspection by a proofing agent using a real-time or asynchronous process (e.g., offline manual review). (d) Confirming the integrity of any physical security features through physical and tactile inspection by a proofing agent at an on-site location.	Confirm that the CSP validates each piece of FAIR and STRONG evidence as specified.	Examine the CSP's practices statement or other documentation to determine its process for validating FAIR and STRONG evidence. Test the CSP's IAL2 identity proofing workflow to determine that all documented validation processes for FAIR and STRONG evidence are followed.	4.2.4 #1	CSP	IAL2	
IAL2-5	IAL2 Superior Validation	Each piece of SUPERIOR evidence SHALL be validated through the cryptographic verification of the evidence contents and the issuing source, including digital signature verification and the validation of any trust chain back to a trust anchor.	Confirm that the CSP validates each piece of SUPERIOR evidence as specified.	Examine the CSP's practices statement or other documentation to determine its process for validating SUPERIOR evidence. Test the CSP's IAL2 identity proofing workflow to determine that all documented validation processes for SUPERIOR evidence are followed.	4.2.4 #2	CSP	IAL2	
IAL2-6	IAL2 Attribute Validation	The CSP SHALL validate all core attributes by either: (a) Comparing the government identifier and other core attributes against an authoritative or credible source to determine accuracy. (b) Validating the accuracy of digitally signed attributes that are contained on SUPERIOR evidence through the public key of the issuing source.	Confirm that the CSP validates all collected core attributes as specified.	Examine the CSP's practices statement or other documentation to determine its core attribute validation policy and processes. Test the CSP's IAL2 identity proofing workflow to determine that all core attribute validation processes are followed.	4.2.5 #1	CSP	IAL2	CSPs SHOULD evaluate attributes obtained from different sources (e.g., presented evidence, self-asserted, authoritative or credible sources) for consistency. CSPs SHOULD validate any reference numbers on the presented identity evidence, if available.
IAL2-7	IAL2 Pathway Record	CSPs that offer multiple verification pathways SHALL record in the subscriber record which pathways were followed to achieve IAL2 and SHALL make that information available to RPs in the assertion, API, or as part of their trust agreement.	If the CSP offers more than one verification pathway at IAL2, confirm that it records the employed pathway in its subscriber accounts.	Examine the CSP's practices statement or other documentation to determine that it records which verification pathway was followed in its subscriber accounts.	4.2.6 A	CSP	IAL2	

NIST SP 800-63-4 Conformance Criteria v0.1: 63A

Control Identifier	Control Name	Control Text	Objective	Assessment Method	Index	Target	Profile/XAL Level	Discussion
IAL2-8	IAL2 Pathway Assertion	CSPs that offer multiple verification pathways SHALL make that information available to RPs in the assertion, API, or as part of their trust agreement.	If the CSP offers more than one verification pathway at IAL2, confirm that it makes this information available to RPs that use its service.	Examine the CSP's practices statement or other documentation to determine it makes information about what verification pathway was followed by a subscriber to RPs that use its service. Examine a sample trust agreement or service contract to determine it makes this information available to its RPs.	4.2.6 B	CSP	IAL2	
IAL2-9	IAL2 Non-Bio Pathway	When the Non-Biometric Pathway is used, the CSP SHALL additionally record whether a mailed confirmation code or a visual comparison of the applicant against evidence was used for verification.	When the Non-Biometric Pathway is used, confirm the CSP records whether verification was accomplished through a mailed confirmation code or a visual comparison of the applicant against evidence.	Examine the CSP's practices statement or other documentation to determine that it records the method used to perform verification.	4.2.6 C	CSP	IAL2	
IAL2-10	IAL2 Non-Bio Communication	If provided as an option at IAL2, CSPs SHALL communicate their use of the Non-Biometric Pathway to all RPs that use their identity service.	Confirm that the CSP communicates its use of the Non-Biometric Pathway to all RPs that use its service.	Examine the CSP's practices statement or other documentation to determine that it communicates its use of the Non-Biometric Pathway for verification to the RPs that use its service.	4.2.6.1 A	CSP	IAL2	The IAL2 Non-Biometric Pathway provides verification methods that do not use an automated comparison of biometric samples provided by the applicant. This pathway can still involve the collection and verification of biometric data (e.g., visual comparison to a facial image contained on identity evidence performed by a proofing agent), but such comparisons are done through manual rather than automated means. Additional verification methods that do not require the use of automated biometric comparison are also included in the Digital Evidence Pathway requirements specified in Sec. 4.2.6.2.

NIST SP 800-63-4 Conformance Criteria v0.1: 63A

Control Identifier	Control Name	Control Text	Objective	Assessment Method	Index	Target	Profile/XAL Level	Discussion
IAL2-11	IAL2 Non-Bio Evidence	For remote attended, remote unattended, and on-site unattended identity proofing, the CSP SHALL verify the applicant's ownership of all pieces of presented identity evidence. For on-site attended identity proofing, the CSP SHALL verify the applicant's ownership of the strongest piece of presented identity evidence.	For the Non-Biometric Pathway, confirm that the CSP meets the evidence ownership verification requirements associated with the identity proofing type.	Examine the CSP's practices statement or other documentation to determine its policies for verifying ownership of identity evidence when using the Non-Biometric Pathway based on the identity proofing type (i.e., remote attended, remote unattended, on-site unattended, on-site attended).	4.2.6.1 #1	CSP	IAL2	Approved non-biometric methods for verifying FAIR evidence at IAL2 include: (a) Confirming the applicant's ability to return a confirmation code delivered to a validated address associated with the evidence (e.g., postal address, phone number). (b) Visually comparing the applicant's facial image to a facial portrait on the presented evidence (e.g., student or employee ID card) or in records associated with the evidence during an on-site attended session (i.e., in-person with a proofing agent), a remote attended session (i.e., live video with a proofing agent), or an asynchronous process (i.e., visual comparison made by a proofing agent at a different time). Approved non-biometric methods for verifying STRONG and SUPERIOR evidence at IAL2 include: (b) Visually comparing the applicant's facial image to a facial portrait on the presented evidence or in records associated with the evidence during an on-site attended session (i.e., in-person with a proofing agent), a remote attended session (i.e., live video with a proofing agent), or an asynchronous process (i.e., visual comparison made by a proofing agent at a different time). If the comparison is performed asynchronously at a later time, the CSP SHALL implement PAD and passive or active document presence checks to increase confidence that both the live applicant and physical documents are present during the captured identity proofing event.

NIST SP 800-63-4 Conformance Criteria v0.1: 63A

Control Identifier	Control Name	Control Text	Objective	Assessment Method	Index	Target	Profile/XAL Level	Discussion
IAL2-12	IAL2 Digital Evidence	For remote attended, remote unattended, and on-site unattended identity proofing, the CSP SHALL verify the applicant's ownership of all pieces of presented identity evidence. For on-site attended identity proofing, the CSP SHALL verify the applicant's ownership of the strongest piece of presented identity evidence.	For the Digital Evidence Pathway, confirm that the CSP meets the evidence ownership verification requirements associated with the identity proofing type.	Examine the CSP's practices statement or other documentation to determine its policies for verifying ownership of identity evidence when using the Digital Evidence Pathway based on the identity proofing type (i.e., remote attended, remote unattended, on-site unattended, on-site attended).	4.2.6.2 #1	CSP	IAL2	Approved digital evidence verification methods for FAIR evidence at IAL2 include: (a) Confirming the applicant's ability to return a microtransaction value delivered to a validated account (e.g., checking account owned by the applicant that has been validated by an authoritative or credible source). (b) Confirming the applicant's ability to return a confirmation code delivered to a validated digital address associated with the digital evidence (e.g., MNO/phone account). (c) Confirming the applicant's ability to successfully complete an authentication and federation protocol equivalent to AAL2/ FAL2 to access an account related to the identity evidence. Approved digital evidence verification methods for STRONG evidence at IAL2 involve confirming the applicant's ability to successfully complete an authentication and federation protocol equivalent to AAL2/ FAL2 or higher to access an account related to the identity evidence. Approved digital evidence verification methods for SUPERIOR evidence at IAL2 include confirming the applicant's possession of the evidence through the use of a local activation factor and the presentation of a cryptographically verifiable attribute bundle.
IAL2-13	IAL2 Biometric Pathway	For remote attended, remote unattended, and on-site unattended identity proofing, the CSP SHALL verify the applicant's ownership of all pieces of presented identity evidence. For on-site attended identity proofing, the CSP SHALL verify the applicant's ownership of the strongest piece of presented identity evidence.	For the Biometric Pathway, confirm that the CSP meets the evidence ownership verification requirements associated with the identity proofing type.	Examine the CSP's practices statement or other documentation to determine its policies for verifying ownership of identity evidence when using the Biometric Pathway based on the identity proofing type (i.e., remote attended, remote unattended, on-site unattended, on-site attended).	4.2.6.3 #1	CSP	IAL2	Approved methods for verifying FAIR, STRONG, and SUPERIOR evidence for use in the IAL2 Biometric Pathway include: (a) Using automated means to compare a facial image represented on or stored in the identity evidence or in records associated with the evidence to a live sample provided by the applicant. (b) Using automated means to compare a biometric characteristic other than a facial image stored on the identity evidence or in records associated with the evidence to a live sample provided by the applicant.
IAL2-14	IAL2 Video Session	For Remote Attended identity proofing, during the video session, the applicant SHALL remain in view of the proofing agent during each step of the proofing process.	For remote attended video sessions, confirm the CSP requires that the applicant is visible to the proofing agent for each step of the identity proofing process.	Examine the CSP's practices statement or other documentation to determine its requirements for applicant visibility during remote attended identity proofing sessions. Interview appropriate personnel to determine the process for viewing applicants during each step of remote attended identity proofing sessions.	4.2.8 #1	CSP	IAL2	

NIST SP 800-63-4 Conformance Criteria v0.1: 63A

Control Identifier	Control Name	Control Text	Objective	Assessment Method	Index	Target	Profile/XAL Level	Discussion
IAL2-15	IAL2 Video Quality	For Remote Attended identity proofing, the video quality SHALL be sufficient to support the necessary steps in the validation and verification processes, such as inspecting evidence and comparing the applicant to the evidence.	For remote attended video sessions, confirm the video quality is sufficient to support the needs of the identity proofing process.	Examine the CSP's practices statement or other documentation to determine it employs video technologies of sufficient quality to support the identity proofing processes.	4.2.8 #2	CSP	IAL2	
IAL2-16	IAL2 Remote Attended Coercion Training	For Remote Attended identity proofing, proofing agents SHALL be trained to identify signs of manipulation, coercion, or social engineering occurring during the session.	Confirm the CSP trains its agents to identify signs that an applicant has been coerced or manipulated into participating in the identity proofing process.	Examine the CSP's practices statement or other documentation to determine its policy for training its agents to identify signs of coercion, manipulation, or social engineering. Interview one or more agents of the CSP to determine the training they've received to identify these signs.	4.2.8 #3	CSP	IAL2	
IAL2-17	IAL2 Remote Attended Recorded Video	For Remote Attended identity proofing, if the CSP records a video session, the following additional requirements apply: (a) The CSP SHALL notify the applicant of the recording prior to initiating a recorded session. (b) The CSP SHALL gain consent from the applicant prior to initiating a recorded session. (c) The CSP SHALL publish their retention schedule and deletion processes for all video records.	If the CSP records remote attended video identity proofing sessions, confirm that the specified requirements are met.	Examine the CSP's practices statement or other documentation to determine that it meets all the specified requirements for recording remote attended identity proofing sessions. Test the remote attended identity proofing process and determine that all the specified requirements for recording remote attended identity proofing sessions are met.	4.2.8 #4	CSP	IAL2	CSPs MAY record and maintain video sessions for fraud prevention and prosecution purposes pursuant to a privacy risk assessment, as defined in Sec. 3.3.1.
IAL2-18	IAL2 Injection Protection	For Remote Attended identity proofing, the CSP SHALL implement injection protection and modified media controls, as defined in Sec. 3.14.	Confirm that the CSP employs injection protection and controls against modified media.	Examine the CSP's practices statement or other documentation to determine it has implemented injection project and modified media controls.	4.2.8 #5	CSP	IAL2	
IAL2-19	IAL2 Remote Attended Fraud Flags	For Remote Attended identity proofing, the CSP SHALL provide proofing agents with a method or mechanism to flag events for potential fraud.	Confirm the CSP provides its proofing agents with a mechanism to flag potential fraud.	Examine the CSP's practices statement or other documentation to determine it provides its proofing agents with a mechanism to flag incidents of potential fraud. Interview one or more agents of the CSP to determine the mechanism they use to flag incidents of potential fraud.	4.2.8 #6	CSP	IAL2	
IAL2-20	IAL2 Physical Setting	For On-site Attended identity proofing, the CSP SHALL provide a physical setting in which on-site identity proofing sessions are conducted.	Confirm the CSP provides physical location in for on-site attended identity proofing.	Examine the CSP's practices statement or other documentation to determine that it provides a physical setting for on-site attended identity proofing sessions. Examine a location where the CSPs conducts on-site identity proofing.	4.2.9 #1	CSP	IAL2	
IAL2-21	IAL2 On-Site Attended Security Controls	For On-site Attended identity proofing, all devices SHALL be protected by appropriate baseline security features comparable to FISMA moderate controls, including malware protection, administrator-specific access controls, and software update processes.	Confirm that the CSP employs security controls comparable to FISMA moderate or higher for all equipment used for on-site attended identity proofing.	Examine the CSP's practices statement or other documentation to confirm it protects the equipment used in on-site attended identity proofing by security controls comparable to FISMA moderate or higher.	4.2.9 #2	CSP	IAL2	

NIST SP 800-63-4 Conformance Criteria v0.1: 63A

Control Identifier	Control Name	Control Text	Objective	Assessment Method	Index	Target	Profile/XAL Level	Discussion
IAL2-22	IAL2 On-Site Attended Coercion Training	For On-site Attended identity proofing, CSP proofing agents SHALL be trained to identify signs of manipulation, coercion, or social engineering occurring during the on-site session.	Confirm the CSP trains its agents to identify signs that an applicant has been coerced or manipulated into participating in the identity proofing process.	Examine the CSP's practices statement or other documentation to determine its policy for training its agents to identify signs of coercion, manipulation, or social engineering. Interview one or more agents of the CSP to determine the training they've received to identify these signs.	4.2.9 #3	CSP	IAL2	
IAL2-23	IAL2 On-Site Attended Recorded Video	For On-site Attended identity proofing, if the CSP records a video session, the following additional requirements apply: (a) The CSP SHALL notify the applicant of the recording prior to initiating a recorded session. (b) The CSP SHALL gain consent from the applicant prior to initiating a recorded session. (c) The CSP SHALL publish their retention schedule and deletion processes for all video records.	If the CSP records on-site attended video identity proofing sessions, confirm that the specified requirements are met.	Examine the CSP's practices statement or other documentation to determine that it meets all the specified requirements for recording on-site attended identity proofing sessions. Test the on-site attended identity proofing process to determine that all the requirements for recording video sessions are met.	4.2.9 #4	CSP	IAL2	CSPs MAY record and maintain video sessions for fraud prevention and prosecution purposes pursuant to a privacy risk assessment, as defined in Sec. 3.3.1.
IAL2-24	IAL2 On-Site Attended Fraud Flags	For On-site Attended identity proofing, the CSP SHALL provide proofing agents with a method or mechanism to covertly flag events for potential fraud.	Confirm the CSP provides its proofing agents with a mechanism to flag potential fraud.	Examine the CSP's practices statement or other documentation to determine it provides its proofing agents with a mechanism to flag incidents of potential fraud. Interview one or more agents of the CSP to determine the mechanism they use to flag incidents of potential fraud.	4.2.9 #5	CSP	IAL2	
IAL2-25	IAL2 Tamper Prevention	For On-site Unattended identity proofing, all devices SHALL be safeguarded from tampering through observation by CSP representatives and/or physical and digital tamper prevention features.	Confirm that the CSP safeguards all devices and equipment used for on-site unattended identity proofing at IAL2 are safeguarded from tampering.	Examine the CSP's practices statement or other documentation to determine that it safeguards the devices it uses for on-site attended identity proofing from tampering.	4.2.10 #1	CSP	IAL2	
IAL2-26	IAL2 On-Site Unattended Security Controls	For On-site Unattended identity proofing, all devices SHALL be protected by appropriate baseline security features comparable to FISMA moderate controls, including malware protection, administrator-specific access controls, and software update processes.	Confirm that the CSP employs security controls comparable to FISMA moderate or higher for all equipment used for on-site attended identity proofing.	Examine the CSP's practices statement or other documentation to confirm it protects the equipment used in on-site attended identity proofing by security controls comparable to FISMA moderate or higher.	4.2.10 #2	CSP	IAL2	
IAL2-27	IAL2 Device Inspection	For On-site Unattended identity proofing, all devices SHALL be inspected periodically by trained technicians to deter tampering, modification, or damage.	Confirm that the CSP has a policy for ensuring that all equipment used for on-site attended identity proofing is periodically inspected by technicians who are trained to detect tampering, modification, and damage.	Examine the CSP's practices statement or other documentation to determine its policy for inspecting equipment used for on-site attended identity proofing.	4.2.10 #3	CSP	IAL2	

NIST SP 800-63-4 Conformance Criteria v0.1: 63A

Control Identifier	Control Name	Control Text	Objective	Assessment Method	Index	Target	Profile/XAL Level	Discussion
IAL2-28	IAL2 On-Site Unattended Recorded Video	For On-site Unattended identity proofing, if the CSP records a video session, the following additional requirements apply: (a) The CSP SHALL notify the applicant of the recording prior to initiating a recorded session. (b) The CSP SHALL gain consent from the applicant prior to initiating a recorded session. (c) The CSP SHALL publish their retention schedule and deletion processes for all video records.	If the CSP records remote attended video identity proofing sessions, confirm that the specified requirements are met.	Examine the CSP's practices statement or other documentation to determine that it meets all the specified requirements for recording on-site unattended identity proofing sessions. Test the on-site unattended identity proofing process to determine that all the requirements for recording video sessions are met.	4.2.10 #4	CSP	IAL2	
IAL2-29	IAL2 Proofing Notification	Upon the successful completion of identity proofing at IAL2, the CSP SHALL send a notification of proofing to a validated address for the applicant, as specified in Sec. 3.10.	Confirm that the CSP sends notifications of proofing to validated addresses for applicants after they have successfully complete identity proofing.	Examine the CSP's practices statement or other documentation to determine that it sends notifications of proofing to applicant's validated addresses, upon successful completion of identity proofing. Test the identity proofing workflow to confirm that appropriate notifications are delivered to a validated address.	4.2.11	CSP	IAL2	CSPs SHOULD send the notification of proofing to the applicant's postal address. Note to assessors: Notifications can be delivered to test accounts and addresses as appropriate based on the capabilities of the assessor or the testing environment available to them and any privacy restrictions on the use of legitimate addresses.
IAL2-30	IAL2 Authenticator Binding	The CSP SHALL provide the ability for the applicant to bind an authenticator using one of the following methods: (a) Remote enrollment of a subscriber-provided authenticator consistent with the requirements for the authenticator type, as defined in Sec. 4.1.3 of [SP800-63B]. (b) Distribution of a physical authenticator to a validated address. (c) Distribution or on-site enrollment of an authenticator.	Confirm that the CSP provides the ability for an applicant to bind an authenticator using one of the specified methods.	Examine the CSP's practices statement or other documentation to determine its policy and process for allowing an applicant to bind one or more authenticators to their subscriber account. Test the identity proofing workflow to confirm that the applicants are able to bind authenticators using one or more of the specified methods.	4.2.12 #1	CSP	IAL2	
IAL2-31	IAL2 Subscriber Verification	If authenticators are bound outside of a single protected session with the user, the CSP SHALL confirm the presence of the intended subscriber through one of the following methods: (a) Return of a continuation code. (b) Comparison against a biometric collected at the time of proofing.	For authenticators that are bound outside of a single, protection session, confirm that the CSP validates the presence of the intended subscriber through using one of the specified methods.	Examine the CSP's practices statement or other documentation to determine its process for verifying subscribers prior to binding authenticators outside of a single protected session. Test the authenticator binding workflow to confirm that the CSP employs its documented processes for using continuation codes or biometrics to confirm the presence of the intended subscriber prior to binding authenticators that were issued outside of the original identity proofing session.	4.2.12 #2	CSP	IAL2	
IAL3-1	IAL3 On-Site Attended	IAL3 identity proofing SHALL only be delivered as on-site attended.	Confirm that the CSP only offers on-site attended (Collocated Agent or Kiosk-based) identity proofing for IAL3.	Examine the CSP's practices statement or other documentation to determine that all IAL3 identity proofing is conducted via on-site attended processes.	4.3.1 A	CSP	IAL3	The proofing agent MAY be co-located with the applicant or attend the identity proofing session via a CSP-controlled kiosk or device.

NIST SP 800-63-4 Conformance Criteria v0.1: 63A

Control Identifier	Control Name	Control Text	Objective	Assessment Method	Index	Target	Profile/XAL Level	Discussion
IAL3-2	IAL3 Evidence Collection	For identity proofing at IAL3, the CSP SHALL collect: one piece of FAIR evidence and one piece of STRONG evidence; OR, two pieces of STRONG evidence; OR one piece of SUPERIOR evidence.	Confirm that the CSP collects the specified evidence for identity proofing at IAL .	Examine the CSP's practices statement or other documentation to determine its evidence collection requirements for IAL 3. Test the CSP's IAL3 identity proofing workflow to determine that documented evidence collection processes are followed.	4.3.2 A	CSP	IAL3	
IAL3-3	IAL3 Attribute Collection	The CSP SHALL collect all core attributes, including at least one government identifier.	Confirm that the CSP collects all core attributes, including at least one government identifier.	Examine the CSP's practices statement or other documentation to determine its policy for collecting core attributes. Test the CSP's IAL3 identity proofing workflow to determine that all documented core attribute collection processes are followed.	4.3.3 #1	CSP	IAL3	Validated evidence is the preferred source of identity attributes. If the presented identity evidence does not provide all of the attributes that a CSP considers to be core attributes, the CSP MAY collect attributes that are self asserted by the applicant.
IAL3-4	IAL3 Fair Strong	Each piece of FAIR or STRONG evidence that is presented SHALL be validated using one of the following techniques: (a) Confirming the authenticity of the digital evidence by interrogating the digital security features (e.g., signatures on assertions or data). (b) Confirming the authenticity of the physical evidence using automated scanning technology that can detect physical security features. (c) Confirming the integrity of any physical security features through a visual inspection by a proofing agent using a real-time or asynchronous process (e.g., offline manual review).	Confirm that the CSP validates each piece of FAIR or STRONG evidence using the one of the techniques provided in item #1 of Sec. 4.3.4.	Examine the CSP's practices statement or other documentation to determine its policy and process for validating FAIR and STRONG evidence at IAL3. Test the CSP's IAL3 identity proofing workflow to determine that all documented validation processes for FAIR and STRONG evidence are followed.	4.3.4 #1	CSP	IAL3	
IAL3-5	IAL3 Superior Evidence	Each piece of SUPERIOR evidence SHALL be validated through the cryptographic verification of the evidence contents and the issuing source, including digital signature verification and the validation of any trust chain back to a trust anchor.	Confirm that the CSP validates each piece of presented SUPERIOR evidence through the cryptographic verification of the evidence contents and the issuing source.	Examine the CSP's practices statement or other documentation to determine its policy and process for validating SUPERIOR evidence at IAL3. Test the CSP's IAL3 identity proofing workflow to determine that all documented validation processes for SUPERIOR evidence are followed.	4.3.4 #2	CSP	IAL3	

NIST SP 800-63-4 Conformance Criteria v0.1: 63A

Control Identifier	Control Name	Control Text	Objective	Assessment Method	Index	Target	Profile/XAL Level	Discussion
IAL3-6	IAL3 ID Verification	The CSP SHALL verify the applicant's ownership of the strongest piece of evidence (STRONG or SUPERIOR) by one of the following methods: (a) Confirming the applicant's ability to successfully authenticate to a physical device or application (e.g., a mobile driver's license) and comparing a digitally protected and transmitted facial portrait to the applicant. (b) Comparing the applicant's facial image to the facial portrait on the presented evidence via an automated comparison. (c) Visually comparing the applicant's facial image to the facial portrait on the presented evidence during an on-site attended session or a remote attended session. (d) Performing an automated comparison of a stored biometric on the identity evidence or in the authoritative records associated with the evidence to a sample provided by the applicant.	Confirm that the CSP verifies the applicant's ownership of the strongest piece of evidence by one of the methods provided in Sec 4.3.6.	Examine the CSP's practices statement or other documentation to determine how it verifies an applicant's ownership of the strongest piece of presented evidence. Test the CSP's IAL3 identity proofing workflow to determine that all documented verification processes for evidence are followed.	4.3.6 #1	CSP	IAL3	
IAL3-7	IAL3 Secure Setting	For on-site attended identity proofing with collocated agents, the CSP SHALL provide a secure, physical setting in which on-site identity proofing sessions are conducted.	Confirm that the CSP provides a secure, physical setting for on-site attended identity proofing sessions with collocated agents.	Examine the CSP's practices statement or other documentation to determine it provides a secure, physical setting for on-site attended identity proofing sessions with collocated agents to determine the setting is secure. Examine one or more locations where the CSP conducts on-site attended identity proofing with collocated agents.	4.3.7 #1	CSP	IAL3	
IAL3-8	IAL3 Biometric Capture	For on-site attended identity proofing with collocated agents, the CSP SHALL provide sensors and capture devices for the collection of biometrics from the applicant.	Confirm that the workstations the CSP employs for on-site identity proofing at IAL3 include devices for the secure collection of biometric samples.	Examine the CSP's practices statement or other documentation to determine the workstations it employs for on-site identity proofing include sensors and capture devices for the secure collection of biometric samples. Examine one or more identity proofing sites to determine the CSP provides sensors and capture devices for the collection of biometrics.	4.3.7 #2	CSP	IAL3	
IAL3-9	View Biometric Source	For on-site attended identity proofing with collocated agents, the CSP SHALL have the proofing agent view the source of the collected biometric for the presence of any non-natural materials (e.g., putty, glue).	Confirm that the CSP requires its IAL3 proofing agents to view the source of the biometric (applicant's face, fingers, etc.) for the presence of any non-natural materials.	Examine the CSP's practices statement or other documentation to determine that it requires its collocated proofing agents to view the source of biometric samples. Interview one or more proofing agents to determine that they are required and understand how to view the source(s) of biometric samples for the presences of non-natural materials.	4.3.7 #3	CSP	IAL3	
IAL3-10	Biometric Collection Source	For on-site attended identity proofing with collocated agents, the CSP SHALL have the proofing agent collect the biometric samples in such a way that ensures the sample was collected from the applicant and no other source.	Confirm that the CSP employs practices and mechanisms that ensure that all biometric samples are collected from the intended applicant.	Examine the CSP's practices statement or other documentation to determine that it employs practices and mechanisms to ensure that all biometric samples are collected from the intended applicants.	4.3.7 #4	CSP	IAL3	

NIST SP 800-63-4 Conformance Criteria v0.1: 63A

Control Identifier	Control Name	Control Text	Objective	Assessment Method	Index	Target	Profile/XAL Level	Discussion
IAL3-11	IAL3 Colocated Agent Security Controls	For on-site attended identity proofing with colocated agents, the CSP SHALL ensure that all information systems and technology leveraged by proofing agents and trusted referees are protected consistent with at least FISMA moderate or comparable levels of controls, including physical controls for the proofing facility.	Confirm that the CSP employs security controls comparable to FISMA moderate or higher for all information systems and equipment used for on-site attended identity proofing with colocated agents.	Examine the CSP's practices statement or other documentation to confirm it protects all information systems and equipment used in on-site attended identity proofing with colocated agents by security controls comparable to FISMA moderate or higher.	4.3.7 #5	CSP	IAL3	
IAL3-12	IAL3 Coercion Training	For on-site attended identity proofing with colocated agents, CSP proofing agents SHALL be trained to identify signs of manipulation, coercion, or social engineering occurring during the on-site session.	Confirm the CSP trains its agents to identify signs that an applicant has been coerced or manipulated into participating in the identity proofing process.	Examine the CSP's practices statement or other documentation to determine its policy for training its agents to identify signs of coercion, manipulation, or social engineering. Interview one or more agents of the CSP to determine the training they've received to identify these signs.	4.3.7 #6	CSP	IAL3	
IAL3-13	IAL3 Recorded Video	For on-site attended identity proofing with colocated agents, if the CSP records a session, the following additional requirements apply: (a) The CSP SHALL notify the applicant of the recording prior to initiating a recorded session. (b) The CSP SHALL gain consent from the applicant prior to initiating a recorded session. (c) The CSP SHALL publish their retention schedule and deletion processes for all video records.	If the CSP records video sessions of on-site attended identity proofing with colocated agents at IAL3, confirm that the requirements specified in Sec. 4.3.7 #7 are met.	Examine the CSP's practices statement or other documentation to determine that it meets all the specified requirements for recording on-site attended with colocated agent identity proofing sessions. Test the on-site attended with colocated agent identity proofing process and determine that all the specified requirements for recording remote attended identity proofing sessions are met.	4.3.7 #7	CSP	IAL3	CSPs MAY record and maintain video sessions for fraud prevention and prosecution purposes pursuant to a privacy risk assessment, as defined in Sec. 3.3.1.
IAL3-14	IAL3 Fraud Flags	For on-site attended identity proofing with colocated agents, the CSP SHALL provide proofing agents with a method or mechanism to discretely flag events or actions as potential fraud.	Confirm the CSP provides its colocated proofing agents with a mechanism to flag potential fraud.	Examine the CSP's practices statement or other documentation to determine it provides its proofing agents with a mechanism to flag incidents of potential fraud. Interview one or more agents of the CSP to determine the mechanism they use to flag incidents of potential fraud.	4.3.7 #8	CSP	IAL3	
IAL3-15	Kiosk Video Transmission	For kiosk-based on-site attended identity proofing, the CSP SHALL monitor the entire identity proofing session through a high-resolution video transmission with the applicant.	Confirm that all workstations and kiosks employed by the CSP for kiosk-based on-site attended identity proofing at IAL3 include video cameras that support high-resolution video transmission.	Examine the CSP's practices statement or other documentation to determine it employs high-resolution video cameras in the kiosk used for kiosk-based on-site attended identity proofing at IAL3.	4.3.8 #1	CSP	IAL3	

NIST SP 800-63-4 Conformance Criteria v0.1: 63A

Control Identifier	Control Name	Control Text	Objective	Assessment Method	Index	Target	Profile/XAL Level	Discussion
IAL3-16	Live Agent Participation	For kiosk-based on-site attended identity proofing, the CSP SHALL have a live proofing agent participate remotely with the applicant for the evidence collection, evidence validation, and verification steps of the identity proofing process.	Confirm that the CSP's proofing agents participate remotely in the evidence collection, evidence validation, and identity verification steps of kiosk-based on-site attended identity proofing at IAL3.	Examine the CSP's practices statement or other documentation to determine its agents participate remotely in the evidence collection, evidence validation, and identity verification steps for kiosk-based on-site attended identity proofing at IAL3. Interview one or more proofing agents of the CSP to determine that, for kiosk-based on-site attended identity proofing, they are required to participate remotely, at a minimum, in the evidence collection, evidence validation, and identity verification steps of the identity proofing process for IAL3.	4.3.8 #2	CSP	IAL3	
IAL3-17	Clearly Visible Actions	For kiosk-based on-site attended identity proofing, the CSP SHALL require all actions taken by the applicant during the evidence collection, evidence validation, and verification steps to be clearly visible to the remote proofing agent.	Confirm that the CSP designs the workstations used for kiosk-based on-site attended identity proofing at IAL3 so that all specified actions taken by the applicants are clearly visible to proofing agents who are participating remotely.	Examine the CSP's practices statement or other documentation to determine that all specified actions taken by the applicant in kiosk-based on-site attended identity proofing at IAL3 are visible to the remote proofing agent. Interview one or more proofing agents of the CSP to determine that, for kiosk-based on-site attended identity proofing, all specified actions taken by the applicant are visible to the remote proofing agent.	4.3.8 #3	CSP	IAL3	
IAL3-18	IAL3 Integrated Sensors	For kiosk-based on-site attended identity proofing, the CSP SHALL require that all digital validation and verification of evidence be performed by integrated scanners and sensors.	Confirm that the CSP's kiosk-based identity proofing stations employ integrated scanners and sensors.	Examine the CSP's practices statement or other documentation to determine that kiosk-based identity proofing stations employ integrated scanners and sensors. Examine one or more stations used for kiosk-based on-site attended identity proofing to determine it includes integrated scanners and sensors.	4.3.8 #4	CSP	IAL3	Scanners and sensors that are built into the
IAL3-19	Kiosk Tamper Prevention	For kiosk-based on-site attended identity proofing, all devices used to support interaction between the proofing agent and the applicant SHALL be safeguarded from tampering through observation by CSP representatives or monitoring devices (e.g., cameras) and through physical and digital tamper prevention features.	Confirm that the CSP employs mechanisms to safeguard the equipment and devices used for kiosk-based on-site attended identity proofing from tampering.	Examine the CSP's practices statement or other documentation to determine the safeguards it employs to protect its kiosk-based on-site attended identity proofing stations from tampering.	4.3.8 #5	CSP	IAL3	
IAL3-20	IAL3 Kiosk-Based Security Controls	For kiosk-based on-site attended identity proofing, all devices used to support interaction between the proofing agent and the applicant SHALL be protected by appropriate baseline security features that are comparable to at least FISMA moderate controls, including malware protection, administrator-specific access controls, and software update processes.	Confirm that the CSP employs security controls comparable to FISMA moderate or higher for all information systems and equipment used for kiosk-based on-site attended identity proofing.	Examine the CSP's practices statement or other documentation to confirm it protects all information systems and equipment used in kiosk-based on-site attended identity proofing by security controls comparable to FISMA moderate or higher.	4.3.8 #6	CSP	IAL3	

NIST SP 800-63-4 Conformance Criteria v0.1: 63A

Control Identifier	Control Name	Control Text	Objective	Assessment Method	Index	Target	Profile/XAL Level	Discussion
IAL3-21	IAL3 Device Inspection	For kiosk-based on-site attended identity proofing, all devices used to support interaction between the proofing agent and the applicant SHALL be inspected periodically by trained technicians to deter tampering, modification, or damage.	Confirm that the CSP ensures that the devices and stations used for kiosk-based on-site attended identity proofing are inspected periodically by trained technicians.	Examine the CSP's practices statement or other documentation to determine it employs trained technicians to periodically inspect the equipment and area used for kiosk-based on-site attended identity proofing for evidence of tampering, modification, or damage.	4.3.8 #7	CSP	IAL3	
IAL3-22	IAL3 Proofing Notification	Upon the successful completion of identity proofing at IAL3, the CSP SHALL send a notification of proofing to a validated address for the applicant, as specified in Sec. 3.10.	Confirm that the CSP sends notifications of proofing to validated addresses for applicants after they have successfully complete identity proofing.	Examine the CSP's practices statement or other documentation to determine that it sends notifications of proofing to applicant's validated addresses, upon successful completion of identity proofing. Test the identity proofing workflow to confirm that appropriate notifications are delivered to a validated address.	4.3.9 A	CSP	IAL3	CSPs SHOULD send the notification of proofing to the applicant's postal address. Note to assessors: Notifications can be delivered to test accounts and addresses as appropriate based on the capabilities of the assessor or the testing environment available.
IAL3-23	IAL3 Authenticator Binding	The CSP SHALL distribute or enroll the subscriber's initial authenticator during an on-site attended interaction with a proofing agent.	Confirm that the CSP distributes and/or enrolls the subscriber's initial authenticator during an on-site attended session with a proofing agent.	Examine the CSP's practices statement or other documentation to determine its policy and process for distributing and/or enrolling the subscriber's initial authenticator. Interview one or more proofing agents to determine that the CSP distributes and enrolls initial authenticators during on-site attended identity proofing sessions.	4.3.10 #1	CSP	IAL3	
IAL3-24	IAL3 Subscriber Verification	If the CSP distributes or enrolls the initial authenticator outside of a single authenticated protected session with the subscriber, the CSP SHALL compare a biometric sample collected from the subscriber to the one collected at the time of proofing prior to registration of the authenticator.	For initial authenticators that are distributed or enrolled outside a single authenticated protected session with the subscriber, confirm that the CSP compares a biometric sample collected from the subscriber to the one collected at the time of proofing prior to registration of the authenticator.	Examine the CSP's practices statement or other documentation to determine its process for verifying subscribers prior to binding authenticators outside of a single protected session. Test the authenticator binding workflow to confirm that the CSP employs biometric comparison to confirm the presence of the intended subscriber prior to binding authenticators that were issued outside of the original identity proofing session.	4.3.10 #2	CSP	IAL3	The CSP MAY request that the subscriber bring the identity evidence used during the proofing process to further strengthen the process of binding the authenticator to the subscriber.
SUB-1	Unique Subscriber Account	The CSP SHALL establish and maintain a unique subscriber account for each active subscriber in its identity system from the time of enrollment to the time of account closure.	Confirm that the CSP establishes and maintains subscriber accounts for all its active subscribers.	Examine the CSP's practices statement or other documentation to determine that it establishes and maintains unique accounts for its active subscribers.	5.1 A	CSP	ALL	The CSP establishes a subscriber account to record each subscriber as a unique identity within its identity service and to maintain a record of all authenticators associated with that account.
SUB-2	Subscriber Identifier	The CSP SHALL assign a unique identifier to each subscriber account.	Confirm that the CSP assigns a unique identifier to each subscriber account.	Examine the CSP's practices statement or other documentation to determine that it assigns a unique identifier to each subscriber account.	5.1 B	CSP	ALL	The identifier SHOULD be randomly generated by the CSP's system and of sufficient length and entropy to ensure uniqueness within its user population and to support federation with RPs, where applicable. The identifier MAY be used as a subject identifier in the generation of assertions, consistent with [SP800-63C].

NIST SP 800-63-4 Conformance Criteria v0.1: 63A

Control Identifier	Control Name	Control Text	Objective	Assessment Method	Index	Target	Profile/XAL Level	Discussion
SUB-3	Subscriber Account Information	At a minimum, the CSP SHALL include the following information in each subscriber account: the unique identifier associated with the subscriber account; any subject identifiers established for the subscriber, including any RP-specific subject identifiers; a record of the identity proofing steps completed for the subscriber;* maximum IAL successfully achieved for the identity proofing of the subscriber; records of any applicant consent agreements related to the collection and processing of information about the applicant throughout the subscriber account life cycle, including biometrics; all authenticators currently bound to the subscriber account, whether registered at enrollment or subsequent to enrollment; and attributes that were validated during the identity proofing process or in subsequent transactions to support RP access.	Confirm that CSP's subscriber accounts include all the specified information.	Examine the CSP's practices statement or other documentation to determine what information it stores in its subscriber accounts. Examine one or more example subscriber accounts to determine it includes, at a minimum, the specified information.	5.1 C	CSP	ALL	* Required details about the identity proofing steps completed for the subscriber include: - The type and issuer of identity evidence. - The type of proofing (i.e., remote unattended, remote attended, on-site attended, on-site unattended). - The validation and verification methods used. - The use of a trusted referee or other exception handling process. - The use of an applicant reference, including a unique identifier for the applicant reference.
SUB-4	Subscriber Account Access	The CSP SHALL provide the capability for subscribers to authenticate and access information in their subscriber account.	Confirm that the CSP provides subscribers with the ability to access their subscriber accounts.	Examine the CSP's practices statement or other documentation to determine it provides subscribers with the ability to access their accounts. Test to determine that appropriately authenticated subscribers can access their subscriber account information.	5.2 A	CSP	ALL	
SUB-5	Subscriber Account AAL	For subscriber accounts that contain personal information, this capability SHALL be accomplished through AAL2 or AAL3 authentication processes using authenticators that are registered to the subscriber account.	Confirm that the CSP requires subscribers to authenticate to their accounts using registered authenticators and AAL2 or AAL3 processes.	Examine the CSP's practices statement or other documentation to determine the authentication processes associated with accessing subscriber accounts that contain personal information. Test to determine that a subscriber account with PII requires at least AAL2 authentication.	5.2 B	CSP	ALL	
SUB-6	SA Update Requests	The CSP SHALL provide the capability for a subscriber to request that information be updated in their subscriber account.	Confirm that the CSP provides the ability for subscribers to request updates to the information contained in their accounts.	Examine the CSP's practices statement or other documentation to determine its policy and process for subscribers to request information be updated in their subscriber accounts. Test to determine that subscribers can request changes to their subscriber information.	5.3 A	CSP	ALL	
SUB-7	Core Attribute Updates	With the exception of physical addresses, the CSP SHALL validate any changes to core attribute information maintained in the subscriber account.	Confirm that the CSP validates any updated core attribute information maintained in a subscriber's account, with the exception of physical address.	Examine the CSP's practices statement or other documentation to determine its policy for validating updated core attribute information stored in a subscriber's account.	5.3 B	CSP	ALL	

NIST SP 800-63-4 Conformance Criteria v0.1: 63A

Control Identifier	Control Name	Control Text	Objective	Assessment Method	Index	Target	Profile/XAL Level	Discussion
SUB-8	SA Update Notifications	The CSP SHALL notify the subscriber of any updates made to information in the subscriber account.	Confirm that the CSP notifies its subscribers anytime information in their subscriber accounts changes.	Examine the CSP's practices statement or other documentation to determine its policy or process for notifying subscribers when information in their accounts is updated. Test to determine that subscribers can request changes to their subscriber information.	5.3 C	CSP	ALL	
SUB-9	Subscriber Account Compromise	The CSP SHALL provide the capability for the subscriber to report any unauthorized access or potential compromise to information in their subscriber account.	Confirm that the CSP provides a mechanism for subscribers to report suspected or confirmed incidents of fraud associated with their accounts.	Examine the CSP's practices statement or other documentation to determine it provides the capability for subscribers to report any unauthorized access or suspect incidence of fraud in association with their subscriber accounts. Test this capability.	5.3 D	CSP	ALL	
SUB-10	Subscriber Account Termination	The CSP SHALL promptly suspend or terminate the subscriber account when [any of events listed in Sec. 5.4 occurs].	Confirm that the CSP suspends or terminates subscriber accounts when any of the specified conditions occurs.	Examine the CSP's practices statement or other documentation to determine its policy and process for suspending or terminating subscriber accounts based on the specified conditions.	5.4 A	CSP	ALL	
SUB-11	Account Status Notification	The CSP SHALL notify the subscriber if their account has been suspended or terminated.	Confirm that the CSP notifies subscribers if their subscriber account has been suspended or terminated.	Examine the CSP's practices statement or other documentation to determine its policy for notifying a subscriber if their account has been suspended or terminated. Examine an example of such a notice.	5.4 B	CSP	ALL	
SUB-12	SA Notification Details	Such notices SHALL include information about why the account was suspended or terminated, reactivation or renewal options, and any options for redress if the subscriber thinks the account was suspended or terminated in error.	Confirm that the CSP's account suspension or termination notices include sufficient details about the action and options for redress in the case of error.	Examine the CSP's practices statement or other documentation to determine what information is included in its account suspension or termination notices. Examine an example of such a notice.	5.4 C	CSP	ALL	
SUB-13	SA Information Deletion	The CSP SHALL delete all personal information from the subscriber account records following account termination in accordance with the record retention and disposal requirements, as documented in its practices statement (see Sec. 3.1).	Confirm that the CSP has a documented records retention and disposal policy, and that it deletes all personal information upon subscriber account determination in accordance with this policy.	Examine the CSP's practices statement or other documentation to determine its policy for deleting all personal information from subscriber accounts following account termination.	5.4 D	CSP	ALL	
SUB-14	Data Breach Notification	In the event of a data breach of CSP records, the CSP SHALL provide notification to subscribers whose personal information may have been exposed to unauthorized access.	Confirm that the CSP has a documented policy and process for data breach notifications.	Examine the CSP's practices statement or other documentation to determine its data breach notification policy.	5.5 A	CSP	ALL	
SUB-15	Breach Notification Details	Such notification SHALL include information about the breach and actions for subscribers to take to recover or maintain access to their accounts and to protect against any unauthorized disclosure of their personal information.	Confirm that the CSP's data breach notifications include, at a minimum, information about the breach and any actions the subscriber needs to take with regard to their subscriber account.	Examine the CSP's practices statement or other documentation to determine the information it includes in its data breach notifications. Examine an example data breach notification.	5.5 B	CSP	ALL	

NIST SP 800-63-4 Conformance Criteria v0.1: 63A

Control Identifier	Control Name	Control Text	Objective	Assessment Method	Index	Target	Profile/XAL Level	Discussion
SUB-16	Expeditious Breach Notification	The CSP SHALL send such notifications as expeditiously as possible to the subscribers' validated address.	Confirm that the CSP sends its data breach notifications as soon as reasonably possible, and that such notifications are sent to validated addresses for its subscribers.	Examine the CSP's practices statement or other documentation to determine that its policy for sending data breach notifications.	5.5 C	CSP	ALL	
SUB-17	Multiple Account Reviews	The CSP SHALL develop and document their process for reviewing and assessing subscribers with multiple accounts to identify possible fraud.	Confirm that the CSP has a policy and process for assessing fraud associated with multiple accounts for a single subscriber.	Examine the CSP's practices statement or other documentation to determine its policy for dealing with multiple accounts associated with a single subscriber.	5.6 #1	CSP	ALL	Some CSPs need to support a single user's ability to interact with the CSP while fulfilling different roles or personas. To limit fraud and avoid redundant costs and processes, CSPs SHOULD provide users with a means to manage multiple user personas without having to create multiple subscriber accounts. If this is not possible, and multiple subscriber accounts are supported for a single subscriber, the CSP SHOULD implement its subscriber accounts in a manner that avoids unnecessary re-proofing of the same subscriber (e.g., linking accounts via a common identifier or through biometric or attribute resolution).
SUB-18	Multiple Accounts Tracking	The CSP SHALL maintain a mapping of all accounts associated with a unique government identifier or common core attributes.	Confirm the CSP has a mechanism for tracking all subscriber accounts associated with an individual.	Examine the CSP's practices statement or other documentation to determine its approach for mapping all subscriber accounts associated with a subscriber.	5.6 #2	CSP	ALL	
SUB-19	Multiple Accounts Visibility	The CSP SHALL provide individuals with visibility into the full list of subscriber accounts associated with their identity.	Confirm that the CSP provides a mechanism for subscribers to view a list of all subscriber accounts associated with their identity.	Examine the CSP's practices statement or other documentation to determine that it allows subscribers to view and track all subscriber accounts associated with their identity.	5.6 #3	CSP	ALL	

NIST SP 800-63-4 Conformance Criteria v0.1: 63B

Control Identifier	Control Name	Control Text	Objective	Assessment Method	Index	Target	Profile/XAL Level	Discussion
AAL-1	AAL Minimum Requirements	To satisfy the requirements of a given AAL and be recognized as a subscriber, a claimant SHALL authenticate to an RP (or IdP, as described in [SP800-63C]) with a process whose strength is equal to or greater than the requirements at that level.	Authentication requirements meet the requirements of assessed AALs.	Examine CSP documentation to determine that authentication requirements for supported assurance levels address requirements. Test online processes to ensure that authentication is required whenever identification as a subscriber is required.	2.0 A	CSP/Verifier	ALL	
AAL-2	Personal Information AAL	Federal agencies SHALL select a minimum of AAL2 when personal information is made available online.	Comply with Section 3 of Executive Order 13681 requiring multifactor authentication	For federal agency relying parties, where personal information is made available online, Examine policies defining accepted authentication methods to determine that all meet a minimum of AAL2. Test online authentication processes for identified applications that handle personal information to confirm AAL2 authentication policies are enforced.	2.0 B	RP	ALL	Applies to federal agencies only.
AAL-3	Fraud Indications	CSPs or verifiers SHALL assess their use of indicators of potential fraud for efficacy and to identify and mitigate potential negative impacts on their user populations.	Minimize fraud and potential negative impacts on authentication where possible.	Interview CSPs and verifier operators to determine that they have evaluated potential fraud indicators. Examine CSP UX testing procedures and results to confirm that processes are in place to identify and address UX challenges for user populations.	2.0 C	CSP	ALL	
AAL-4	Privacy Fraud Indications	CSPs or verifiers SHALL include fraud indicators in the authentication privacy risk assessment.	Minimize potential privacy impacts stemming from use of fraud indicators.	Examine privacy risk assessment to confirm that it includes any identified uses of fraud indicators.	2.0 D	CSP/RP	ALL	

NIST SP 800-63-4 Conformance Criteria v0.1: 63B

Control Identifier	Control Name	Control Text	Objective	Assessment Method	Index	Target	Profile/XAL Level	Discussion
AAL1PAT-1	AAL1 Authenticator Types	AAL1 authentication SHALL use any of the following authentication types, which are further defined in Sec. 3: (a) Password (Sec. 3.1.1): A memorizable secret typically chosen by the subscriber. (b) Look-up secret (Sec. 3.1.2): A secret determined by the claimant by looking up a prompted value in a list held by the subscriber. (c) Out-of-band device (Sec. 3.1.3): A secret sent or received through a separate communication channel with the subscriber. (d) Single-factor one-time password (OTP) (Sec. 3.1.4): A one-time secret obtained from a device or application held by the subscriber. (e) Multi-factor OTP (Sec. 3.1.5): A one-time secret obtained from a device or application held by the subscriber that requires activation by a second authentication factor. (f) Single-factor cryptographic authentication (Sec. 3.1.6): Proof of possession and control via an authentication protocol of a cryptographic key held by the subscriber. (g) Multi-factor cryptographic authentication (Sec. 3.1.7): Proof of possession and control via an authentication protocol of a cryptographic key held by the subscriber that requires activation by a second authentication factor.	Identify acceptable authenticator types at AAL1.	Examine documentation defining authentication interactions to determine that all authentication methods meet the requirements of one of the defined authenticator types. Test authentication events at AAL1 to confirm that implemented processes meet the requirement one of the defined authenticator types.	2.1.1 A	Verifier	AAL1	
AAL1AVR-1	AAL1 Approved Cryptography	Authenticators used at AAL1 SHALL use approved cryptography.	Use secure cryptographic algorithms.	Examine documented policies or practices to determine that only cryptographic algorithms specified in NIST cryptographic guidelines are used. Test the system's functionality to observe the cryptographic algorithm(s) being accepted and determine whether the algorithms are specified in NIST cryptographic guidelines.	2.1.2 A	Verifier	AAL1	
AAL1AVR-2	AAL1 Authenticated Protected Channels	Communication between the claimant and verifier SHALL occur via one or more authenticated protected channels.	Protect the exchange of authenticator information between the verifier and the claimant.	Examine the verifier's documentation to ensure that TLS or a similarly secure protocol is used in conjunction with an approved encryption protocol. Test the verifier's interactions and observe that TLS or similarly secure protocol is used in conjunction with an approved encryption protocol.	2.1.2 B	Verifier	AAL1	
AAL1AVR-3	AAL1 FIPS140 Validation	Cryptography used by verifiers operated by or on behalf of federal agencies at AAL1 SHALL be validated to meet the requirements of [FIPS140] Level 1.	Use validated cryptographic modules and components.	Examine system documentation or software information to identify the cryptographic modules used by the verifiers and verify associated CMVP validation certificates.	2.1.2 C	Verifier	AAL1	Applies to federal agencies and those acting on their behalf (e.g., contractors) only.
AAL1REA-1	AAL1 Reauthentication	Periodic reauthentication of subscriber sessions SHALL be performed, as described in Sec. 5.2.	Mitigate theft of session secrets, session hijacking, and unauthorized use of open session.	See REAUTH 1 - 5	2.1.3 A	RP	AAL1	

NIST SP 800-63-4 Conformance Criteria v0.1: 63B

Control Identifier	Control Name	Control Text	Objective	Assessment Method	Index	Target	Profile/XAL Level	Discussion
AAL1REA-2	AAL1 Overall Timeout	A definite reauthentication overall timeout SHALL be established, which SHOULD be no more than 30 days at AAL1.	Mitigate theft of session secrets, session hijacking, and unauthorized use of open session.	Examine documentation for defined reauthentication intervals. Test implemented controls to confirm reauthentication behavior is consistent with documented AAL1 reauthentication intervals.	2.1.3 B	RP	AAL1	
AAL2PAT-1	AAL2 Multiple Factors	At AAL2, authentication SHALL use either a multi-factor authenticator (MFA) or a combination of two separate authentication factors.	Enforce MFA at AAL2.	Examine documentation defining authentication interactions to determine that all authentication methods meet the requirements of AAL2 authenticator types and combinations. Test authentication events at AAL2 to confirm that implemented processes meet the requirements of the defined authenticator types and combinations.	2.2.1 A	Verifier	AAL2	
AAL2PAT-2	AAL2 Authenticator Combinations	When a combination of two single-factor authenticators is used, the combination SHALL include one physical authenticator (i.e., "something you have") from the following list in conjunction with either a password (Sec. 3.1.1) or a biometric comparison: (a) Look-up secret (Sec. 3.1.2) (b) Out-of-band device (Sec. 3.1.3) (c) Single-factor OTP (Sec. 3.1.4) (d) Single-factor cryptographic authentication (Sec. 3.1.6)	Enforce MFA at AAL2.	See AAL2PAT-1	2.2.1 B	Verifier	AAL2	Applies when multiple authenticators are used to achieve AAL2.
AAL2AVR-1	AAL2 Approved Cryptography	Authenticators used at AAL2 SHALL use approved cryptography.	Use secure cryptographic algorithms.	Examine documented policies or practices to determine that only cryptographic algorithms specified in NIST cryptographic guidelines are used. Test the system's functionality to observe the cryptographic algorithm(s) being accepted and determine whether the algorithms are specified in NIST cryptographic guidelines.	2.2.2 A	Verifier	AAL2	
AAL2AVR-2	AAL2 FIPS140 Authenticators	Cryptographic authenticators procured by federal agencies SHALL be validated to meet the requirements of [FIPS140] Level 1.	Authenticators procured by or on behalf of government agencies use validated cryptographic modules and components.	Examine system documentation or vendor documentation to identify the cryptographic modules used by authenticators and verify associated CMVP validation certificates.	2.2.2 B	CSP	AAL2	Applies to authenticators procured by federal agencies only.

NIST SP 800-63-4 Conformance Criteria v0.1: 63B

Control Identifier	Control Name	Control Text	Objective	Assessment Method	Index	Target	Profile/XAL Level	Discussion
AAL2AVR-3	AAL2 Replay Resistance	At least one authenticator used at AAL2 SHALL be replay-resistant, as described in Sec. 3.2.7.	Prevent attackers from reusing stolen or observed authentication data to hijack accounts.	Examine the combinations of authenticators that can be used at AAL2 and verify that for each combination, at least one authenticator is replay-resistant. OTP authenticators, cryptographic authenticators, and look-up secrets are considered replay resistant. Test if verifying a physical authenticator that does not implement a cryptographic challenge/response protocol, attempt to authenticate more than once using the same authenticator output (during its validity period, if time-based). If a subsequent authentication succeeds, the test of replay resistance has failed.	2.2.2 C	Verifier	AAL2	
AAL2AVR-4	AAL2 Authenticated Protected Channels	Communication between the claimant and verifier SHALL occur via one or more authenticated protected channels.	Determine that the communication channel meets the requirements of an authenticated protected channel as defined in SP 800-63B-4 Appendix D.	Examine the verifier's documentation to ensure that TLS or a similarly secure protocol is used in conjunction with an approved encryption protocol. Test the verifier's interactions and observe that TLS or similarly secure protocol is used in conjunction with an approved encryption protocol.	2.2.2 D	Verifier	AAL2	
AAL2AVR-5	AAL2 FIPS140 Verifiers	Cryptography used by verifiers operated by or on behalf of federal agencies at AAL2 SHALL be validated to meet the requirements of [FIPS140] Level 1 unless otherwise specified.	Verifiers operated by or on behalf of government agencies are required to be validated to meet FIPS 140 requirements. The FIPS 140 requirements generally apply to cryptographic modules (both hardware and software).	Examine system documentation or software information to identify the cryptographic modules used by the verifiers and verify associated CMVP validation certificates.	2.2.2 E	Verifier	AAL2	Applies to federal agencies and those acting on their behalf (e.g., contractors) only.
AAL2AVR-6	AAL2 Phishing Resistance Offer	Verifiers SHALL offer at least one phishing-resistant authentication option at AAL2, as described in Sec. 3.2.5.	Ensure that phishing-resistant authentication methods are available to subscribers who wish to use them.	Examine documentation to determine that authentication at AAL2 always includes a phishing-resistant option. Test authentication selection screens at AAL2 to confirm that a phishing resistant authentication options is presented to users.	2.2.2 F	Verifier	AAL2	
AAL2AVR-7	AAL2 Phishing Resistance Requirement	Federal agencies SHALL require their staff, contractors, and partners to use phishing-resistant authentication to access federal information systems.	Ensure phishing resistance for applications used by federal staff, contractors, and partners.	Examine documentation to determine that authentication of internal applications at AAL2 requires use of a phishing-resistant authenticator. Test authentication to determine that authentication at AAL2 requires use of a phishing-resistant authenticator.	2.2.2 G	Verifier	AAL2	Applies to federal agencies only.

NIST SP 800-63-4 Conformance Criteria v0.1: 63B

Control Identifier	Control Name	Control Text	Objective	Assessment Method	Index	Target	Profile/XAL Level	Discussion
AAL2REA-1	AAL2 Reauthentication	Periodic reauthentication of subscriber sessions SHALL be performed, as described in Sec. 5.2.	Determine that appropriate expiration of sessions occurs to mitigate theft of session secrets or use of a forgotten session.	Examine documentation to determine that required reauthentication requirements are enforced. Test by authenticating, then idle for documented inactivity timeout and determine that reauthentication is required. Maintain a session for at least the overall timeout period and observe that reauthentication is required.	2.2.3 A	RP	AAL2	
AAL3PAT-1	AAL3 Authenticator Combinations	AAL3 authentication SHALL require an authenticator combination consisting of either multi-factor cryptographic authentication (Sec. 3.1.7); or single-factor cryptographic authentication (Sec. 3.1.6) used in conjunction with either a password (Sec. 3.1.1) or a biometric comparison.	Require use of highest security authenticators at AAL3.	Examine documented policies or practices to determine authenticator types that can be used. Test the system's functionality to observe the authenticator types being made available to users and accepted.	2.3.1 A	Verifier	AAL3	
AAL3AVR-1	AAL3 Approved Cryptography	Authenticators used at AAL3 SHALL use approved cryptography.	Determine that only secure, well-vetted cryptographic algorithms are being used.	Examine documented policies or practices to determine that only approved cryptographic algorithms can be used. Examine the system's functionality to observe the cryptographic algorithm(s) being accepted and determine whether the algorithms are approved.	2.3.2 A	Verifier	AAL3	
AAL3AVR-2	AAL3 Authenticated Protected Channels	Communication between the claimant and verifier SHALL occur via one or more authenticated protected channels.	Determine that the communication channel meets the requirements of an authenticated protected channel as defined in SP 800-63B-4 Appendix D.	Examine the verifier's documentation to ensure that TLS or a similarly secure protocol is used in conjunction with an approved encryption protocol.	2.3.2 B	Verifier	AAL3	
AAL3AVR-3	AAL3 Non-Exportable Key	The cryptographic authenticator used at AAL3 SHALL have a non-exportable private key.	Require use of high-security authenticators at AAL3.	Examine the authenticators and their associated architecture/documentation offered by the CSP to determine how keys are protected and that they meet non-exportability requirements. Examine signed authenticator attestations (if available) to determine key protection characteristics and that they meet non-exportability requirements.	2.3.2 C	CSP	AAL3	
AAL3AVR-3.5	AAL3 Phishing Resistance	The cryptographic authenticator used at AAL3 SHALL provide phishing resistance, as described in Sec. 3.2.5.	Require use of phishing resistant authenticators at AAL3.	Examine documentation to determine that authentication at AAL3 requires use of a phishing-resistant authenticator. Test authentication to determine that authentication at AAL3 requires use of a phishing-resistant authenticator.	2.3.2 C	Verifier	AAL3	
AAL3AVR-3.7	AAL3 Replay Resistance	The cryptographic authentication protocol SHALL be replay-resistant.	Ensure that the authentication transaction cannot be replayed by an attacker.	Requirement is met by satisfying requirement to use a cryptographic authenticator (AAL3PAT-1).	2.3.2 D	Verifier	AAL3	
AAL3AVR-4	AAL3 Intent	All authentication and reauthentication processes at AAL3 SHALL demonstrate authentication intent from at least one authenticator, as described in Sec. 3.2.8.	Ensure that authentication is actively requested, and not accidental.	Examine CSP documentation to determine the acceptable combinations of authenticators that are available to subscribers authenticating at AAL3.	2.3.2 E	Verifier	AAL3	

NIST SP 800-63-4 Conformance Criteria v0.1: 63B

Control Identifier	Control Name	Control Text	Objective	Assessment Method	Index	Target	Profile/XAL Level	Discussion
AAL3AVR-5	AAL3 Public-Key Cryptography	Cryptographic authenticators used at AAL3 SHALL use public-key cryptography to protect the authentication secrets from compromise of the verifier.	Avoid the use of shared authentication secrets that could be compromised by an attacker.	Examine documentation of verifiers to determine that they only store public keys for cryptographic authenticators used at AAL3.	2.3.2 F	CSP	AAL3	
AAL3AVR-6	AAL3 FIPS140 Authenticators	Single-factor and multi-factor authenticators used at AAL3 SHALL be validated to meet the requirements of [FIPS140] Level 1 or higher overall.	Cryptographic authenticators at AAL3 are required to be validated to meet FIPS 140 requirements. The FIPS 140 requirements generally apply to cryptographic modules (both hardware and software).	Examine system documentation or software information to identify the cryptographic modules used by the authenticators and verify associated CMVP validation certificates.	2.3.2 G	CSP	AAL3	
AAL3AVR-7	AAL3 Unsyncability	Syncable authenticators SHALL NOT be used at AAL3.	Ensure that syncable authenticators, which have exportable authentication keys, are not used.	Requirement is met by authenticators meeting AAL3AVR-3.	2.3.2 H	CSP	AAL3	
AAL3AVR-8	AAL3 FIPS140 Verifiers	Cryptography used by verifiers at AAL3 SHALL be validated at [FIPS140] Level 1 or higher.	Verifiers operated by or on behalf of government agencies are required to be validated to meet FIPS 140 requirements. The FIPS 140 requirements generally apply to cryptographic modules (both hardware and software).	Examine system documentation or software information to identify the cryptographic modules used by the verifiers and verify associated CMVP validation certificates.	2.3.2 I	Verifier	AAL3	
AAL3REA-1	AAL3 Reauthentication	Periodic reauthentication of subscriber sessions SHALL be performed, as described in Sec. 5.2.	Determine that appropriate expiration of sessions occurs to mitigate theft of session secrets or use of a forgotten session.	Test to authenticate, then idle for documented inactivity timeout and determine that reauthentication is required. Maintain a session for at least the overall timeout period and observe that reauthentication is required. Examine verifier or CSP documentation to determine that required reauthentication requirements are enforced.	2.3.3 A	RP	AAL3	
AAL3REA-2	AAL3 Reauthentication Limit	At AAL3, the overall timeout for reauthentication SHALL be no more than 12 hours.	Establish upper bound on session lifetime.	Examine CSP documentation to see that maximum overall session timeout is less than or equal to 12 hours.	2.3.3 B	RP	AAL3	
SC-1	Security Controls	The verifier SHALL employ appropriately tailored security controls from the moderate baseline security controls defined in [SP800-53] or an equivalent federal (e.g., [FEDRAMP]) or industry standard that the organization has chosen for the information systems, applications, and online services that these guidelines are used to protect.	Determine compliance with relevant overall security controls.	Examine the CSP's documentation to determine it employs appropriately tailored security controls to include control enhancements, from the medium baseline of security controls defined in SP 800-53 or equivalent federal (e.g., FEDRAMP) or industry standard.	2.4.1 A	Verifier	ALL	
RRP-1	Records Retention	The verifier SHALL comply with its respective records retention policies in accordance with applicable laws, regulations, and policies, including any National Archives and Records Administration (NARA) records retention schedules that may apply.	Determine compliance with records retention policy requirements.	Examine the CSP's records retention policy and evaluate its applicability with laws and regulations. Where applicable, audit a sample of retained records to ensure that their retention is consistent with policy.	2.4.2 A	Verifier	ALL	

NIST SP 800-63-4 Conformance Criteria v0.1: 63B

Control Identifier	Control Name	Control Text	Objective	Assessment Method	Index	Target	Profile/XAL Level	Discussion
RRP-2	Records Retention Risk	If the verifier opts to retain records in the absence of mandatory requirements, the verifier or the CSP or IdP of which it is a part SHALL conduct a risk management process [NISTRMF], including assessments of privacy and security risks, to determine how long records should be retained and SHALL inform the subscriber of that retention policy.	Verify justification for records retention not covered by mandatory requirements.	Examine evidence to determine risk-based decision for records retention was used, and that notice to subscribers is provided.	2.4.2 B	Verifier	ALL	Non-mandatory records retention.
PR-1	Privacy Controls	The verifier SHALL employ appropriately tailored privacy controls defined in [SP800-53] or an equivalent industry standard.	Determine compliance with relevant overall privacy requirements.	Examine the CSP's operating procedure documentation and, as applicable, authority-to-operate (ATO) for consistency with SP 800-53 or equivalent standard.	2.4.3 A	Verifier	ALL	
PR-2	Attribute Privacy Management	If CSPs or IdPs process attributes for purposes other than identity services (i.e., identity proofing, authentication, or attribute assertions), related fraud mitigation, or compliance with laws or legal processes, they SHALL implement measures to maintain predictability and manageability commensurate with the privacy risks that arise from the additional processing.	Determine compliance with relevant privacy requirements for supplemental services.	Examine the CSP's documented policies or practices to determine which predictability and manageability measures it employs, (e.g., notice, consent, selective disclosure).	2.4.3 B	CSP	ALL	Applies when there is non-identity use of identity attributes.
PR-3	Consent Non-Mandatory	When CSPs or IdPs use consent measures, they SHALL NOT make consent for the additional processing a condition of the identity service.	Ensure that consent measures are voluntary.	Examine terms of use to ensure that additional consent is not a requirement.	2.4.3 C	CSP	ALL	Applies when consent is requested from subscriber.
PR-4	Privacy Act Consultation	The agency SHALL consult with their Senior Agency Official for Privacy (SAOP) and conduct an analysis to determine whether the collection of personal information to issue or maintain authenticators triggers the requirements of the Privacy Act of 1974 [Privacy Act] (see Sec. 7.4).	Determine when Privacy Act requirements are triggered.	Examine documentation to determine that consultation with the SAOP occurred and that all determinations of whether the service is subject to the privacy act of 1974 have been recorded. Interview to confirm that the agency has consulted with its SAOP to determine if the service is subject to the Privacy Act of 1974.	2.4.3 #1	CSP/IdP/RP	ALL	Applies to federal agencies and others acting on their behalf.
PR-5	SORN Publication	The agency SHALL publish a System of Records Notice (SORN) to cover such collections, as applicable.	Determine that a SORN is published when required.	Examine the agency's System of Records Notice, as applicable.	2.4.3 #2	CSP/IdP/RP	ALL	Applies to federal agencies only.
PR-6	E-Government Consultation	The agency SHALL consult with its SAOP and conduct an analysis to determine whether the collection of personal information to issue or maintain authenticators triggers the requirements of the E-Government Act of 2002 [E-Gov].	Determine when E-Government Act requirements are triggered.	Interview to confirm that the agency offering or using the identity proofing service has consulted with its SAOP to determine if the service is subject to the E-Government Act of 2002. Examine documentation of the SAOP assessment.	2.4.3 #3	CSP/IdP/RP	ALL	Applies to federal agencies only.
PR-7	Privacy Impact Assessment Publication	The agency SHALL publish a Privacy Impact Assessment (PIA) to cover such collection, as applicable.	Determine that a PIA is published when required.	Examine the agency's Privacy Impact Assessment, as applicable.	2.4.3 #4	CSP/IdP/RP	ALL	Applies to federal agencies and others providing services to federal agencies.
REDAUTH-1	Redress Provision	The verifier and associated CSP or IdP SHALL provide mechanisms for the redress of subscriber complaints and problems that arise from subscriber authentication processes, as described in Sec. 5.6 of [SP800-63].	Determine that useful redress for authentication problems is provided.	Test redress mechanisms from the viewpoint of the claimant. Examine redress mechanisms from the viewpoint of the claimant.	2.4.4 A	Verifier/CSP	ALL	

NIST SP 800-63-4 Conformance Criteria v0.1: 63B

Control Identifier	Control Name	Control Text	Objective	Assessment Method	Index	Target	Profile/XAL Level	Discussion
REDAUTH-2	Redress Usability	These mechanisms SHALL be easy for subscribers to find and use.	Ensure that redress mechanisms are usable by the population of subscribers.	Test redress mechanisms to determine their ease of use.	2.4.4 B	Verifier/CSP	ALL	
REDAUTH-3	Redress Efficacy	The CSP or IdP SHALL assess the mechanisms for efficacy in resolving complaints or problems.	Ensure that redress mechanisms are sufficient to resolve expected authentication problems.	Interview CSP or IdP operator to determine the results of their assessment.	2.4.4 C	CSP	ALL	
PASSAUTH-1	Password Choice	Passwords SHALL either be chosen by the subscriber or assigned randomly by the CSP.	Establish acceptable methods of password creation (e.g., no default passwords).	Test by creating a new account or changing a password to determine how password is chosen. If the password is not chosen by the subscriber. Interview CSP to establish that the password is assigned randomly.	3.1.1.1 A	CSP	ALL	
PASSAUTH-2	Password Blocklist	If the CSP disallows a chosen password because it is on a blocklist of commonly used, expected, or compromised values (see Sec. 3.1.1.2), the subscriber SHALL be required to choose a different password.	Prohibit use of passwords expected to be commonly chosen.	Test by attempting to set an account to use a memorized secret that is on the blocklist. The attempt should fail.	3.1.1.1 B	CSP	ALL	
PASSAUTH-3	Password Composition	Other composition requirements for passwords SHALL NOT be imposed.	Prohibit composition rules (e.g., requirement for specific character types).	Test by attempting to create an unusual password that does not meet usual composition requirements (e.g., all lower case letters) and determine that it is accepted.	3.1.1.1 C	CSP	ALL	
PV-1	Password Length	Verifiers and CSPs SHALL require passwords that are used as a single-factor authentication mechanism to be a minimum of 15 characters in length. Verifiers and CSPs MAY allow passwords that are only used as part of multi-factor authentication processes to be shorter but SHALL require them to be a minimum of eight characters in length.	Require passwords to be long enough to provide baseline security.	Test by trying to create a password that does not meet the minimum length requirements and verify that it is not accepted.	3.1.1.2 #1	CSP	ALL	
PV-2	Unicode Passwords	Verifiers and CSPs SHOULD accept Unicode [ISO/IEC 10646] characters in passwords. Each Unicode code point SHALL be counted as a single character when evaluating password length.	Allow use of characters memorable to the subscriber, even if they use a language not represented by ASCII.	Test by creating a password containing a Unicode character such as an accented vowel and determine that it is accepted, and that the unaccented version of the same character does not allow successful authentication.	3.1.1.2 #4	Verifier/CSP	ALL	
PV-3	Password Verifier Composition	Verifiers and CSPs SHALL NOT impose other composition rules (e.g., requiring mixtures of different character types) for passwords.	Prohibit composition rules (e.g., requirement for specific character types)	See PASSAUTH-3	3.1.1.2 #5	Verifier/CSP	ALL	
PV-4	Password Non-Expiration	Verifiers and CSPs SHALL NOT require subscribers to change passwords periodically. However, verifiers SHALL force a change if there is evidence that the authenticator has been compromised.	Prohibit password rotation, which has been shown to cause selection of weaker passwords.	Interview to determine from CSP that periodic password changes are not required, but that a mechanism is in place to force password changes for affected subscribers after a breach.	3.1.1.2 #6	Verifier/CSP	ALL	
PV-5	Password Hints	Verifiers and CSPs SHALL NOT permit the subscriber to store a hint (e.g., a reminder of how the password was created) that is accessible to an unauthenticated claimant.	Prohibit use of password hints, which greatly weaken security.	Test to ensure that there is no provision for a password hint to be displayed to unauthenticated claimants and that there is no provision for storing a hint in subscribers' account management.	3.1.1.2 #7	Verifier/CSP	ALL	

NIST SP 800-63-4 Conformance Criteria v0.1: 63B

Control Identifier	Control Name	Control Text	Objective	Assessment Method	Index	Target	Profile/XAL Level	Discussion
PV-6	Passwords Not KBA	Verifiers and CSPs SHALL NOT prompt subscribers to use knowledge-based authentication (KBA) (e.g., "What was the name of your first pet?") or security questions when choosing passwords.	Prohibit use of KBA, which greatly weakens security.	Test to ensure that there is no authentication flow that involves the use of KBA and that there is no provision for storing authentication questions and answers in subscribers' account management.	3.1.1.2 #8	Verifier/CSP	ALL	
PV-7	Password Full Verification	Verifiers SHALL request the password to be provided in full (not a subset of it) and SHALL verify the entire submitted password (e.g., not truncate it).	Require use of the entire password for authentication to maximize the security benefit of the whole password.	Examine verification code to ensure that entire password is verified. Test by creating long passwords and attempting to authenticate with truncated passwords.	3.1.1.2 #9	Verifier	ALL	
PV-8	Password Verifier Blocklist	When processing a request to establish or change a password, verifiers SHALL compare the prospective secret against a blocklist that contains known commonly used, expected, or compromised passwords.	Require use of a blocklist to prevent selection of excessively weak passwords.	Interview CSP to determine contents of the blocklist. Test to ensure that it is not possible to change a password to a blocklist entry.	3.1.1.2 A	CSP	ALL	
PV-9	Verifier Blocklist Substrings	The entire password SHALL be subject to comparison, not substrings or words that might be contained therein.	Ensure that the entire password is verified so that the full security benefit of long passwords is realized.	Test to ensure that a long password containing a blocklist entry is accepted.	3.1.1.2 B	Verifier	ALL	
PV-10	Verifier Blocklist Response	If the chosen password is found on the blocklist, the CSP SHALL require the subscriber to select a different secret and SHALL provide the reason for rejection.	Require selection of a different password if a weak one is chosen.	Test to ensure that a substitute for a blocklisted password is requested.	3.1.1.2 C	CSP	ALL	
PV-11	Strong Password Guidance	Verifiers SHALL offer guidance to the subscriber to help the subscriber choose a strong password. This is particularly important following the rejection of a password on the blocklist as it discourages trivial modifications of listed weak passwords [Blocklists].	Require coaching of the subscriber on selection of better passwords if a weak one is initially chosen.	Test to determine that helpful advice on choosing strong passwords is offered.	3.1.1.2 D	Verifier	ALL	
PV-12	Password Rate-Limiting	Verifiers SHALL implement a rate-limiting mechanism that effectively limits the number of failed authentication attempts that can be made on the subscriber account, as described in Sec. 3.2.2.	Strengthen verifier against online password guessing attacks.	Test by making a large number of incorrect authentication attempts and ensure that number and/or rate of attempts is limited.	3.1.1.2 E	Verifier	ALL	
PV-13	Password Manager Use	Verifiers SHALL allow the use of password managers and autofill functionality.	Allow subscriber to use a password manager, which aids in the use of strong and unguessable passwords.	Test by attempting to authenticate using one or more popular password managers and verify that a password stored in the manager can be filled in.	3.1.1.2 F	Verifier	ALL	
PV-14	Password Authenticated Protected Channels	Verifiers and CSPs SHALL use approved encryption and an authenticated protected channel when requesting passwords.	Ensure that the communication channel to the verifier is secure against eavesdropping.	Test password transmission to verify that an authenticated protected channel such as TLS is used. Examine encryption algorithms used to verify that they are approved.	3.1.1.2 G	Verifier/CSP	ALL	
PV-15	Password Offline Attack Resistance	Verifiers SHALL store passwords in a form that is resistant to offline attacks.	Require strong storage to protect against offline attacks.	Requirement is satisfied by PV-16 through PV-18.	3.1.1.2 H	Verifier/CSP	ALL	

NIST SP 800-63-4 Conformance Criteria v0.1: 63B

Control Identifier	Control Name	Control Text	Objective	Assessment Method	Index	Target	Profile/XAL Level	Discussion
PV-16	Password Salted Hashing	Passwords SHALL be salted and hashed using a suitable password hashing scheme.	At a minimum, require salting and hashing of passwords as protection against offline attacks should the verifier be breached.	Examine password verification storage to determine evidence of password hashing and salt storage.	3.1.1.2 I	Verifier/CSP	ALL	
PV-17	Salt Requirements	The salt SHALL be at least 32 bits in length and chosen to minimize salt value collisions among stored hashes (i.e., to prevent multiple subscriber accounts from having the same hashed password).	Require use of a salt sufficient to ensure that two subscribers with the same password do not hash to the same value in the verifier.	Examine stored salt values to ensure that they are at least 32 bits in length. Interview CSP personnel to determine that salt is chosen to avoid collisions.	3.1.1.2 J	Verifier/CSP	ALL	
PV-18	Salt Storage	Both the salt value and the resulting hash SHALL be stored for each password.	Describes the use of a salt.	Requirement is satisfied by verification method of PV-16.	3.1.1.2 K	Verifier/CSP	ALL	
PV-19	Hashing Key Generation	If used, this key value SHALL be generated by an approved random bit generator, as described in Sec. 3.2.1.2.	For keyed hashing, require appropriate selection of the key.	Interview CSP personnel to determine how the key value is generated.	3.1.1.2 L	Verifier/CSP	ALL	Applies when keyed hashing is used.
PV-20	Hashing Key Storage	The secret key value SHALL be stored separately from the hashed passwords.	Require separate storage for a keyed hash key so it is not also breached if the hashed passwords are.	Interview CSP personnel to determine how the key value is stored.	3.1.1.2 M	Verifier/CSP	ALL	Applies when keyed hashing is used.
LSA-1	Look-Up Secret Generation	CSPs that create look-up secret authenticators SHALL use an approved random bit generator, as described in Sec. 3.2.12, to generate the list of secrets.	Require selection of sufficiently random look-up secrets	Examine code used to generate look-up secrets.	3.1.2.1 A	CSP	ALL	
LSA-1.5	Look-Up Secret Delivery	CSPs that create look-up secret authenticators SHALL deliver the authenticator list securely to the subscriber (e.g., in an in-person session, via an online session, through the postal mail to a contact address).	Ensure that eavesdroppers and other intermediaries do not have access to look-up secrets being delivered to the subscriber.	Interview CSP to determine the possible methods for delivering look-up secrets to subscribers.	3.1.2.1 A	CSP	ALL	
LSA-2	Online Look-Up Secret Delivery	If delivered via an online session, the session SHALL be authenticated by the subscriber at AAL2 or higher and SHALL deliver the secrets through an authenticated protected channel and in accordance with the post-enrollment binding requirements in Sec. 4.1.2.	Ensure that online delivery of look-up secrets is sufficiently secure.	Test by requesting delivery of look-up secrets online, and ensure that a minimum of AAL2 authentication is required and that an authenticated protected channel such as TLS is used.	3.1.2.1 B	Verifier	ALL	Applies when look-up secrets are delivered online.
LSA-3	Look-Up Secret Length	Look-up secrets SHALL be at least six decimal digits (or equivalent) in length. Additional requirements described in Sec. 3.1.2.2 may also apply, depending on their length.	Verify that look-up secrets are sufficiently long to provide adequate security.	Examine look-up secrets received in response to a request and verify that they are at least six decimal digits or equivalent in length.	3.1.2.1 C	CSP	ALL	
LSV-1	Look-Up Secret Prompt	Verifiers of look-up secrets SHALL prompt the claimant for a secret from their authenticator.	Verify appropriate authentication flow.	Test by authenticating with a look-up secret authenticator and verify the prompt.	3.1.2.2 A	Verifier	ALL	
LSV-2	Look-Up Secret Reuse	A secret from a look-up secret authenticator SHALL be used successfully only once.	Ensure that look-up secrets are replay resistant.	Test by attempting to authenticate using the same look-up secret more than once and verify that subsequent attempts are unsuccessful.	3.1.2.2 B	Verifier	ALL	
LSV-3	Look-Up Secret Offline Attack Resistance	Verifiers SHALL store look-up secrets in a form that is resistant to offline attacks.	Require strong storage to protect against offline attacks.	Requirement is satisfied by LSV-4 and LSV-6 through LSV-8.	3.1.2.2 C	Verifier/CSP	ALL	
LSV-4	Look-Up Secret Storage	All lookup secrets SHALL be stored in a hashed form using an approved hashing function.	Require use of a hashing function known to be sufficiently secure.	Examine code to determine hashing function used.	3.1.2.2 D	Verifier/CSP	ALL	

NIST SP 800-63-4 Conformance Criteria v0.1: 63B

Control Identifier	Control Name	Control Text	Objective	Assessment Method	Index	Target	Profile/XAL Level	Discussion
LSV-5	Look-Up Secret Verifier Length	Look-up secrets SHALL be at least six decimal digits (or equivalent) in length, as specified in Sec. 3.1.2.1.	Verify that look-up secrets are sufficiently long to provide adequate security.	See LSA-3.	3.1.2.2 E	CSP	ALL	
LSV-6	Look-Up Secret Salted Hashing	Look-up secrets that are shorter than the minimum security strength specified in the latest revision of [SP800-131A] (i.e., 112 bits as of the date of this publication) SHALL be stored in a salted and hashed form using a suitable password hashing scheme, as described in Sec. 3.1.1.2.	Require salting for look-up secrets that are at risk of collision with other secrets.	Examine look-up secret verification storage to determine evidence of password hashing and salt storage.	3.1.2.2 F	Verifier/CSP	ALL	Applies to look-up secrets shorter than 112 bits.
LSV-7	Look-Up Secret Salt Length	The salt value SHALL be at least 32 bits in length and arbitrarily chosen to minimize salt value collisions among stored hashes.	Require use of a salt sufficient to ensure that two subscribers with the same look-up secrets do not hash to the same value in the verifier.	Examine stored salt values to ensure that they are at least 32 bits in length. Interview CSP personnel to determine that salt is chosen to avoid collisions.	3.1.2.2 G	Verifier/CSP	ALL	Applies to look-up secrets shorter than 112 bits.
LSV-8	Look-Up Secret Salt Storage	Both the salt value and the resulting hash SHALL be stored for each lookup secret.	Describes the use of a salt.	Requirement is satisfied by verification method of LSV-6.	3.1.2.2 H	Verifier/CSP	ALL	Applies to look-up secrets shorter than 112 bits.
LSV-9	Look-Up Secret Rate Limiting	The verifier SHALL implement a rate-limiting mechanism that effectively limits the number of failed authentication attempts that can be made on the subscriber account, as described in Sec. 3.2.2.	Strengthen verifier against online look-up secret guessing attacks.	Test by making a large number of incorrect authentication attempts and ensure that number and/or rate of attempts is limited.	3.1.2.2 I	Verifier	ALL	
LSV-10	Look-Up Secret Authenticated Protected Channel	The verifier SHALL use approved encryption and an authenticated protected channel when requesting look-up secrets.	Ensure that online delivery of look-up secrets is sufficiently secure.	Requirement is satisfied by LSA-2.	3.1.2.2 J	Verifier	ALL	
OBA-1	Out-Of-Band Channel Independence	The out-of-band authenticator SHALL establish a separate channel with the verifier to retrieve the out-of-band secret or authentication request.	Verify that a separate channel is used to communicate with the verifier.	Test to verify that the secondary channel is established with a separate device or that it is established with an independent application on the authenticating device.	3.1.3.1 A	Verifier	ALL	
OBA-2	Out-Of-Band Approved Encryption	Communication over the secondary channel SHALL use approved encryption unless sent via the public switched telephone network (PSTN).	Establish that delivery of the out-of-band secret is delivered securely.	Test by requesting an out-of-band secret and verify that an authenticated protected channel such as TLS is used or that it is delivered via the PSTN.	3.1.3.1 B	Verifier	ALL	
OBA-3	Out-Of-Band Email Prohibition	Email SHALL NOT be used for out-of-band authentication because it may be vulnerable to: (a) Access using only a password. (b) Interception in transit or at intermediate mail servers. (c) Rerouting attacks, such as those caused by Domain Name System (DNS) spoofing.	Prohibit the use of email for delivery of out-of-band secrets because of multiple security vulnerabilities.	Test by attempting to authenticate and verify that there is no option to use email for out-of-band authentication.	3.1.3.1 C	CSP/Verifier	ALL	

NIST SP 800-63-4 Conformance Criteria v0.1: 63B

Control Identifier	Control Name	Control Text	Objective	Assessment Method	Index	Target	Profile/XAL Level	Discussion
OBA-4	Out-Of-Band Communication Methods	The out-of-band authenticator SHALL uniquely authenticate itself in one of the following ways when communicating with the verifier: (a) Using approved cryptography, establish a mutually authenticated protected channel (e.g., client-authenticated transport layer security (TLS) [RFC8446]) with the verifier. Communication between the out-of-band authenticator and the verifier MAY use a trusted intermediary service to which each authenticates. The key used to establish the channel SHALL be provisioned in a mutually authenticated session during authenticator binding, as described in Sec. 4.1. (b) Authenticate to a public mobile telephone network using a SIM card or equivalent secret that uniquely identifies the subscriber. This method SHALL only be used if a secret is sent from the verifier to the out-of-band device via the PSTN (i.e., SMS or voice) or an encrypted instant messaging service; use a wired connection to the PSTN that the verifier can call and dictate the out-of-band secret. For the purposes of this definition, "wired connection" includes services such as cable providers that offer PSTN services through other wired media and fiber via analog telephone adapters.	Confirm that out-of-band secrets are delivered only to authenticated devices.	Examine code to verify that one of the specified methods is used to authenticate the device receiving an out-of-band secret.	3.1.3.1 D	Verifier	ALL	
OBA-5	Out-Of-Band Secondary Approval	If the out-of-band authenticator requests approval over the secondary communication channel rather than by presenting a secret that the claimant transfers to the primary communication channel, it SHALL accept a transfer of the secret from the primary channel and send it to the verifier over the secondary channel to associate the approval with the authentication transaction.	Ensure that authentication approval over the secondary channel requires transfer of a secret from the primary channel to avoid approval fatigue attacks.	Test , if present, secondary channel approval to verify that it requires entry of a secret obtained from the primary channel.	3.1.3.1 E	Verifier	ALL	
OBV-1	Out-Of-Band Key Verification	The verifier SHALL NOT store the identifying key itself but SHALL use a verification method (e.g., an approved hash function or proof of possession of the identifying key) to uniquely identify the authenticator.	Ensure that, should the verifier be compromised, any active out-of-band secrets are protected from disclosure.	Examine verifier storage of out-of-band secrets to verify that they are protected from compromise.	3.1.3.2 A	Verifier	ALL	

NIST SP 800-63-4 Conformance Criteria v0.1: 63B

Control Identifier	Control Name	Control Text	Objective	Assessment Method	Index	Target	Profile/XAL Level	Discussion
OBV-2	Out-Of-Band Transfer Methods	Depending on the type of out-of-band authenticator, one of the following SHALL take place: (a) Transfer of the secret from the secondary to the primary channel. As shown in Fig. 1, the verifier MAY signal the device that contains the subscriber's authenticator to indicate a readiness to authenticate. It SHALL then transmit a random secret to the out-of-band authenticator and wait for the secret to be returned via the primary communication channel. (b) Transfer of the secret from the primary to the secondary channel. As shown in Fig. 2, the verifier SHALL transmit a random authentication secret to the claimant via the primary channel. It SHALL then wait for the secret to be returned via the secondary channel from the claimant's out-of-band authenticator. The verifier MAY additionally display an address, such as a phone number or VoIP address, for the claimant to use in addressing its response to the verifier.	Ensure that one of the approved authentication flows involving the transfer of a secret from one device or application to another is used.	Test out-of-band authentication to verify that one of the given authentication flows is used.	3.1.3.2 B	Verifier	ALL	
OBV-3	Out-Of-Band Time Limit	In all cases, the authentication SHALL be considered invalid unless completed within 10 minutes.	Make sure that out-of-band secrets are only valid for the short term.	Test out-of-band authentication by delaying slightly more than 10 minutes before transferring the secret and verify that authentication is unsuccessful.	3.1.3.2 C	Verifier	ALL	
OBV-4	Out-Of-Band Replay Resistance	Verifiers SHALL accept a given authentication secret as valid only once during the validity period to provide replay resistance, as described in Sec. 3.2.7.	Verify that out-of-band secrets are replay resistant.	Test by attempting to authenticate and ensure that a given out-of-band secret can be used only once.	3.1.3.2 D	Verifier	ALL	
OBV-5	Out-Of-Band Secret Length	The verifier SHALL generate random authentication secrets that are at least six decimal digits (or equivalent) in length.	Verify that out-of-band secrets are sufficiently long to provide adequate security.	Examine look-up secrets received in response to a request and verify that they are at least six decimal digits or equivalent in length.	3.1.3.2 E	Verifier	ALL	
OBV-5.5	Out-Of-Band Secret Generation	The verifier SHALL generate random authentication secrets using an approved random bit generator as described in Sec. 3.2.12.	Require selection of sufficiently random look-up secrets.	Examine code used to generate look-up secrets.	3.1.3.2 E	Verifier	ALL	
OBV-6	Out-Of-Band Rate Limiting	If the authentication secret is less than 64 bits long, the verifier SHALL implement a rate-limiting mechanism that effectively limits the total number of consecutive failed authentication attempts that can be made on the subscriber account as described in Sec. 3.2.2.	Ensure that out-of-band authentication is sufficiently protected against online guessing attacks.	Test by making a large number of incorrect authentication attempts and ensure that number and/or rate of attempts is limited.	3.1.3.2 F	Verifier	ALL	
OBV-7	Out-Of-Band Failure Count	Generating a new authentication secret SHALL NOT reset the failed authentication count.	Ensure that obtaining a new out-of-band secret does not bypass the rate limiting mechanism.	Test by making a large number of incorrect authentication attempts and ensure that number and/or rate of attempts is limited even if a new authentication secret is obtained.	3.1.3.2 G	Verifier	ALL	
AUPSTN-1	Pstn Restricted	Use of the PSTN for out-of-band verification is restricted as described in this section and SHALL satisfy the requirements of Sec. 3.2.9.	Invoke restricted authenticator provisions.	Satisfied by RESTA-1 and RESTA-2.	3.1.3.3 A	CSP	ALL	

NIST SP 800-63-4 Conformance Criteria v0.1: 63B

Control Identifier	Control Name	Control Text	Objective	Assessment Method	Index	Target	Profile/XAL Level	Discussion
AUPSTN-2	Pstn Modification Binding	Setting or changing the pre-registered telephone number is considered to be the binding of a new authenticator and SHALL only occur as described in Sec. 4.1.2.	Defend against attackers who attempt to change the pre-registered telephone number.	Test by changing pre-registered telephone number and verify that requirements BAA-2 and BAA-3 are satisfied.	3.1.3.3 B	CSP	ALL	
AUPSTN-3	Pstn Alternatives	Verifiers SHALL ensure that alternative authenticator types are available to all subscribers and SHOULD remind subscribers of this limitation of PSTN out-of-band authenticators before binding one or more devices controlled by the subscriber.	Ensure that subscribers understand the risks associated with PSTN out-of-band authentication.	Satisfied by RESTA-2.	3.1.3.3 C	Verifier	ALL	
MFOBA-1	MF-OOB Activation	Each use of the authenticator SHALL require the presentation of the activation factor.	Ensure that a previously activated authenticator cannot be coopted by an attacker.	Test by authenticating more than once with the same authenticator and verify that the activation factor is required each time. Also satisfied by MFOBA-4.	3.1.3.4 A	Verifier	ALL	
MFOBA-2	MF-OOB Activation Secrets	Authenticator activation secrets SHALL meet the requirements of Sec. 3.2.10.	Invoke requirements for activation secrets.	Satisfied by AS-1 through AS-8.	3.1.3.4 B	CSP	ALL	
MFOBA-3	MF-OOB Biometric Requirements	A biometric activation factor SHALL meet the requirements of Sec. 3.2.3, including limits on the number of consecutive authentication failures.	Invoke requirements for biometric authentication factors.	Satisfied by UB-1 through UB-4.	3.1.3.4 C	CSP	ALL	
MFOBA-4	MF-OOB Activation Erasure	The password or biometric sample used for activation and any biometric data derived from the biometric sample (e.g., a fingerprint image and feature locations produced by a fingerprint feature extractor) SHALL be erased immediately after an authentication operation.	Ensure that the activation factor cannot be used or extracted following an authentication operation.	Examine code to establish that activation factor is erased as required.	3.1.3.4 D	CSP	ALL	
SFOA-1	OTP Generation Key Strength	The secret key and its algorithm SHALL provide at least the minimum security strength specified in the latest revision of [SP800-131A] (i.e., 112 bits as of the date of this publication).	Ensure that the key used to generate the OTP is of sufficient size to be secure.	Examine code to determine the security strength of the key used to generate the OTP.	3.1.4.1 A	CSP	ALL	
SFOA-2	OTP Nonce Length	The nonce SHALL be of sufficient length to ensure that it is unique for each operation of the authenticator over its lifetime.	Ensure that the nonce is large enough that the OTP sequence doesn't repeat.	Examine code to determine if the nonce is sufficiently long to not repeat during the expected lifetime of the authenticator.	3.1.4.1 B	CSP	ALL	
SFOA-3	TOTP Change Frequency	If the nonce used to generate the authenticator output is based on a real-time clock, the nonce SHALL be changed at least once every two minutes.	Ensure that the nonce of a time-based OTP changes frequently enough.	Test to determine that the OTP changes at least once every two minutes.	3.1.4.1 C	CSP	ALL	Applies to time-based OTP authenticators.
SFOV-1	OTP Verifier Key Protection	The symmetric keys used by authenticators are also present in the verifier and SHALL be strongly protected against unauthorized disclosure by access controls that limit access to the keys to only those software components that require access.	Protect against attacks on verifier.	Examine storage of OTP generation keys to determine whether they are strongly protected.	3.1.3.2 A	CSP	ALL	
SFOV-2	OTP Key Establishment	When binding a single-factor OTP authenticator to a subscriber account, the verifier or associated CSP SHALL use approved cryptography for key establishment to generate and exchange keys or to obtain the secrets required to duplicate the authenticator output.	Determine that only secure, well-vetted cryptographic algorithms are being used.	Examine code or documentation showing the algorithms being used and verify that they are NIST approved.	3.1.4.2 B	CSP	ALL	

NIST SP 800-63-4 Conformance Criteria v0.1: 63B

Control Identifier	Control Name	Control Text	Objective	Assessment Method	Index	Target	Profile/XAL Level	Discussion
SFOV-3	OTP Authenticated Protected Channels	The verifier SHALL use approved encryption and an authenticated protected channel when collecting the OTP.	Determine that only secure, well-vetted cryptographic algorithms and protocols are being used.	Examine documented policies or code to determine that only approved cryptographic algorithms can be used. Examine secure use of a protocol such as TLS for communication with the claimant.	3.1.4.2 C	Verifier	ALL	
SFOV-4	OTP Replay Protection	Verifiers SHALL accept a given OTP only once while it is valid to provide replay resistance, as described in Sec. 3.2.7.	Ensure that OTP use is replay resistant.	Test to ensure that it is not possible to successfully use the same OTP value for two different authentication transactions while it is valid.	3.1.4.2 D	Verifier	ALL	
SFOV-5	TOTP Key Lifetime	Time-based OTPs [TOTP] SHALL have a defined lifetime that is determined by the expected clock drift in either direction of the authenticator over its lifetime plus an allowance for network delay and claimant entry of the OTP.	Ensure that OTP will not fail prematurely due to clock drift.	Examine specifications for authenticator clock drift and planned lifetime and ensure that time tolerance of OTP entry is sufficiently long.	3.1.4.2 E	CSP	ALL	Applies to time-based OTP authenticators.
SFOV-6	OTP Rate Limiting	The verifier SHOULD implement or, if the authenticator output is less than 64 bits in length, SHALL implement a rate-limiting mechanism that effectively limits the number of failed authentication attempts that can be made on the subscriber account, as described in Sec. 3.2.2.	Protect against OTP guessing attacks	Test by making a large number of incorrect authentication attempts and ensure that number and/or rate of attempts is limited.	3.1.4.2 F	Verifier	ALL	Applies when authenticator output is less than 64 bits in length.
MFOA-1	MF-OTP Activation	Each use of the authenticator SHALL require the input of the activation factor.	Ensure that all use of the authenticator is protected by the activation factor.	Test by attempting to authenticate and verify that the activation factor is needed for each authentication.	3.1.5.1 A	Verifier	AAL2	
MFOA-2	MF-OTP Generation Key Strength	The secret key and its algorithm SHALL provide at least the minimum security strength specified in the latest revision of [SP800-131A] (i.e., 112 bits as of the date of this publication).	Ensure that the key used to generate the OTP is of sufficient size to be secure.	Examine code to determine the security strength of the key used to generate the OTP.	3.1.5.1 B	CSP	AAL2	
MFOA-3	MF-OTP Nonce Length	The nonce SHALL be of sufficient length to ensure that it is unique for each operation of the authenticator over its lifetime.	Ensure that the nonce is large enough that the OTP sequence doesn't repeat.	Examine code to determine if the nonce is sufficiently long to not repeat during the expected lifetime of the authenticator.	3.1.5.1 C	CSP	AAL2	
MFOA-4	MF-TOTP Change Frequency	If the nonce used to generate the authenticator output is based on a real-time clock, the nonce SHALL be changed at least once every two minutes.	Ensure that the nonce of a time-based OTP changes frequently enough.	Test to determine that the OTP changes at least once every two minutes.	3.1.5.1 D	CSP	AAL2	Applies to time-based OTP authenticators.
MFOA-5	MF-OTP Activation Secrets	Authenticator activation secrets SHALL meet the requirements of Sec. 3.2.10.	Invoke requirements for activation secrets.	Satisfied by AS-1 through AS-8.	3.1.5.1 E	CSP	AAL2	Authenticator uses activation secrets.
MFOA-6	MF-OTP Biometric Requirements	A biometric activation factor SHALL meet the requirements of Sec. 3.2.3, including limits on the number of consecutive authentication failures.	Invoke requirements for biometric authentication factors.	Satisfied by UB-1 through UB-4.	3.1.5.1 F	CSP	AAL2	Authenticator uses biometric activation.
MFOA-7	MF-OTP Activation Erasure	The unencrypted key and activation secret or biometric sample and any biometric data derived from the biometric sample (e.g., a fingerprint image and feature locations produced by a fingerprint feature extractor) SHALL be erased immediately after an OTP has been generated.	Ensure that the activation factor cannot be used or extracted following an authentication operation.	Examine code to establish that activation factor is erased as required.	3.1.5.1 G	CSP	AAL2	

NIST SP 800-63-4 Conformance Criteria v0.1: 63B

Control Identifier	Control Name	Control Text	Objective	Assessment Method	Index	Target	Profile/XAL Level	Discussion
MFOV-1	MF-OTP Verifier Key Protection	The symmetric keys used by authenticators SHALL be strongly protected against unauthorized disclosure by access controls that limit access to the keys to only those software components that require access.	Protect against attacks on verifier.	Examine storage of OTP generation keys to determine whether they are strongly protected.	3.1.5.2 A	CSP	AAL2	
MFOV-2	MF-OTP Key Establishment	When binding a multi-factor OTP authenticator to a subscriber account, the verifier or associated CSP SHALL use approved cryptography for key establishment to generate and exchange keys or to obtain the secrets required to duplicate the authenticator output.	Determine that only secure, well-vetted cryptographic algorithms are being used.	Examine code or documentation showing the algorithms being used and verify that they are NIST approved.	3.1.5.2 B	CSP	AAL2	
MFOV-3	MF-OTP Authenticated Protected Channels	The verifier SHALL use approved encryption and an authenticated protected channel when collecting the OTP.	Determine that only secure, well-vetted cryptographic algorithms and protocols are being used.	Examine documented policies or code to determine that only approved cryptographic algorithms can be used. Examine secure use of a protocol such as TLS for communication with the claimant.	3.1.5.2 C	Verifier	AAL2	
MFOV-4	MF-OTP Replay Protection	Verifiers SHALL accept a given OTP only once while it is valid to provide replay resistance, as described in Sec. 3.2.7.	Ensure that OTP use is replay resistant.	Test to ensure that it is not possible to successfully use the same OTP value for two different authentication transactions while it is valid.	3.1.5.2 D	Verifier	AAL2	
MFOV-5	MF-TOTP Key Lifetime	Time-based OTPs [TOTP] SHALL have a defined lifetime that is determined by the expected clock drift in either direction of the authenticator over its lifetime plus an allowance for network delay and claimant entry of the OTP.	Ensure that OTP will not fail prematurely due to clock drift.	Examine specifications for authenticator clock drift and planned lifetime and ensure that time tolerance of OTP entry is sufficiently long.	3.1.5.2 E	CSP	AAL2	
MFOV-6	MF-OTP Rate Limiting	The verifier SHALL implement a rate-limiting mechanism that effectively limits the number of consecutive failed authentication attempts that can be made on the subscriber account, as required by Sec. 3.2.10.	Protect against OTP guessing attacks	Test by making a large number of incorrect authentication attempts and ensure that number and/or rate of attempts is limited.	3.1.5.2 F	Verifier	AAL2	
SFCATION-1	SF Crypto Public Key	Single-factor cryptographic authenticators used at AAL3 SHALL use public-key cryptography to protect the authentication secrets from compromise of the verifier.	Avoid the use of shared authentication secrets that could be compromised by an attacker.	Examine documentation of verifiers to determine that they only store public keys for cryptographic authenticators	3.1.6 A	CSP	AAL3	
SFCATORS-1	SF Exportable Authentication Key Protection	If they are accessible to the endpoint being authenticated, exportable authentication keys SHALL be strongly protected against unauthorized disclosure with access controls that limit access to the key to only those software components that require access.	Protect against attacks on authenticator.	Examine storage of authentication keys to determine whether they are strongly protected.	3.1.6.1 A	CSP	AAL2	Applies to exportable authentication keys.
SFCATORS-2	SF Non-Exportable Authentication Key Storage	Nonexportable authentication keys (usable at AAL3 or below) SHALL be stored in an isolated execution environment that is protected by hardware or in a separate processor with a controlled interface to the central processing unit of the user endpoint.	Protect against attacks on authenticator.	Examine storage of authentication keys to determine whether they are stored in an isolated execution environment.	3.1.6.1 B	CSP	ALL	Applies to non-exportable authentication keys.
SFCATORS-3	SF External Authentication Key Requirements	External (i.e., non-embedded) cryptographic authenticators SHALL meet the requirements for connected authenticators in Sec. 3.2.11.	Ensure integrity of endpoint-authenticator connection.	Satisfied by CONNAUTH-1 through CONNAUTH-3, and if wireless, WC-1 through WC-7.	3.1.6.1 C	CSP	ALL	Applies to non-embedded cryptographic authenticators.

NIST SP 800-63-4 Conformance Criteria v0.1: 63B

Control Identifier	Control Name	Control Text	Objective	Assessment Method	Index	Target	Profile/XAL Level	Discussion
SFCVER-1	Cryptographic Verifier Symmetric Key Protection	While both types of keys SHALL be protected against modification, symmetric keys SHALL additionally be protected against unauthorized disclosure by access controls that limit access to the key to only those software components that require access.	Protect against attacks on verifier.	Examine storage of authentication keys to determine whether they are strongly protected.	3.1.6.2 A	CSP/Verifier	ALL	Applies when symmetric authentication keys are used.
SFCVER-2	Cryptographic Authentication Key Strength	The authentication key and its algorithm SHALL provide at least the minimum security strength specified in the latest revision of [SP800-131A] (i.e., 112 bits as of the date of this publication).	Ensure that the authentication key is of sufficient size to be secure.	Examine code to determine the security strength of the authentication key.	3.1.6.2 B	CSP	ALL	
SFCVER-3	Cryptographic Nonce Length	The challenge nonce SHALL be at least 64 bits in length and SHALL either be unique over the authenticator's lifetime or statistically unique (i.e., generated using an approved random bit generator, as described in Sec. 3.2.12).	Provide strong protection against replay attacks.	Examine code used to generate the authentication nonce.	3.1.6.2 C	CSP/Verifier	ALL	
SFCVER-4	Cryptographic Verifier Approved Cryptography	The verification operation SHALL use approved cryptography.	Determine that only secure, well-vetted cryptographic algorithms and protocols are being used.	Examine documented policies or code to determine that only approved cryptographic algorithms can be used.	3.1.6.2 D	Verifier	ALL	
MFCTION-1	MF Crypto Public Key	Multi-factor cryptographic authenticators used at AAL3 SHALL use public-key cryptography to protect the authentication secrets from compromise of the verifier.	Avoid the use of shared authentication secrets that could be compromised by an attacker.	Examine documentation of verifiers to determine that they only store public keys for cryptographic authenticators.	3.1.7 A	CSP	AAL3	
MFCTORS-1	MF Crypto Authenticator Activation Required	Multi-factor cryptographic authenticators encapsulate one or more authentication keys that SHALL only be accessible through the presentation and verification of an activation factor (i.e., a password or a biometric characteristic).	Ensure that authenticator enforces use of an activation factor.	Examine storage of authentication secret to determine that the secret is only accessible upon presentation of a valid activation factor.	3.1.7.1 A	CSP	AAL2/AAL3	
MFCTORS-2	MF Non-Exportable Authentication Key Storage	Non-exportable authentication keys, suitable for use at AAL3, SHALL be stored in an isolated execution environment that is protected by hardware or in a separate processor with a controlled interface to the central processing unit of the user endpoint.	Protect against attacks on authenticator.	Examine storage of authentication keys to determine whether they are stored in an isolated execution environment.	3.1.7.1 B	CSP	AAL3	Applies to non-exportable authentication keys.
MFCTORS-3	MF Exportable Authentication Key Protection	If accessible to the endpoint being authenticated, authentication keys SHALL be strongly protected against unauthorized disclosure by using access controls that limit access to the authentication keys to only those software components that require access.	Protect against attacks on authenticator.	Examine storage of authentication keys to determine whether they are strongly protected.	3.1.7.1 C	CSP	AAL2	Applies to exportable authentication keys.
MFCTORS-4	MF External Authentication Key Requirements	External (non-embedded) cryptographic authenticators SHALL meet the requirements for connected authenticators in Sec. 3.2.11.	Ensure integrity of endpoint-authenticator connection.	Satisfied by CONNAUTH-1 through CONNAUTH-3, and if wireless, WC-1 through WC-7.	3.1.7.1 D	CSP	AAL2/AAL3	Applies to non-embedded cryptographic authenticators.
MFCTORS-5	MF Crypto Activation	Each authentication event SHALL require input and verification of the local activation factor.	Ensure that a previously activated authenticator cannot be coopted by an attacker.	Test by authenticating more than once with the same authenticator and verify that the activation factor is required each time.	3.1.7.1 E	CSP	AAL2/AAL3	
MFCTORS-6	MF Crypto Activation Secrets	Authenticator activation secrets SHALL meet the requirements of Sec. 3.2.10.	Invoke requirements for activation secrets.	Satisfied by AS-1 through AS-8.	3.1.7.1 F	CSP	AAL2/AAL3	Authenticator uses activation secrets.

NIST SP 800-63-4 Conformance Criteria v0.1: 63B

Control Identifier	Control Name	Control Text	Objective	Assessment Method	Index	Target	Profile/XAL Level	Discussion
MFCTORS-7	MF Crypto Biometric Requirements	A biometric activation factor SHALL meet the requirements of Sec. 3.2.3, including limits on the number of consecutive authentication failures.	Invoke requirements for biometric authentication factors.	Satisfied by UB-1 through UB-4.	3.1.7.1 G	CSP	AAL2/AAL3	Authenticator uses biometric activation.
MFCTORS-8	MF Crypto Activation Erasure	The activation secret or biometric sample and any biometric data derived from the biometric sample (e.g., a fingerprint image and feature locations produced by a fingerprint feature extractor) SHALL be erased after an authentication transaction.	Ensure that the activation factor cannot be used or extracted following an authentication operation.	Examine code to establish that activation factor is erased as required.	3.1.7.1 H	CSP	AAL2/AAL3	
MFCFIERS-0.5	MF Crypto Verifier Requirements	Requirements for a multi-factor cryptographic verifier are identical to those for a single-factor cryptographic verifier.	Ensure baseline requirements for cryptographic verifiers are met.	Satisfied by SFCVER-1 through SFCVER-4	3.1.7.2	CSP/Verifier	AAL2/AAL3	
MFCFIERS-1	MF Crypto Activation Flag	If a flag indicating use of an activation factor is present and indicates that an activation factor was not used, the authentication SHALL be treated as single-factor.	Ensure that an activation factor was used if indication was provided.	Examine code to determine if the activation factor flag is checked and heeded, if provided.	3.1.7.2 A	Verifier	AAL2/AAL3	
UWSCW-1	Wallet Activation Required	Access to the private key SHALL require an activation factor.	Ensure that authenticator enforces use of an activation factor.	Examine storage of authentication secret to determine that the secret is only accessible upon presentation of a valid activation factor.	3.1.7.3 A	CSP	AAL2/AAL3	
UWSCW-2	Wallet Activation Secrets	Authenticator activation secrets SHALL meet the requirements of Sec. 3.2.10.	Invoke requirements for activation secrets.	Satisfied by AS-1 through AS-8.	3.1.7.3 B	CSP	AAL2/AAL3	Authenticator uses activation secrets.
UWSCW-3	Wallet Biometric Requirements	Biometric activation factors SHALL meet the requirements of Sec. 3.2.3, including limits on the number of consecutive authentication failures.	Invoke requirements for biometric authentication factors.	Satisfied by UB-1 through UB-4.	3.1.7.3 C	CSP	AAL2/AAL3	Authenticator uses biometric activation.
UWSCW-4	Wallet Activation Erasure	The password or biometric sample used for activation and any biometric data derived from the biometric sample SHALL be erased immediately after an authentication transaction.	Ensure that the activation factor cannot be used or extracted following an authentication operation.	Examine code to establish that activation factor is erased as required.	3.1.7.3 D	CSP	AAL2/AAL3	
UWSCW-5	Wallet Federation	Authentication processes using subscriber-controlled wallets SHALL be used with a federation process as detailed in Sec. 5 of [SP800-63C].	Ensure that subscriber-controlled wallets are used in connection with federation requirements.	Examine federation process and verify compliance with requirements in Section 5 of SP 800-63C	3.1.7.3 E	Verifier	AAL2/AAL3	
UWSCW-6	Wallet Phishing-Resistance Conditions	Assertions that lack a valid signature from the wallet or an audience restriction SHALL NOT be considered phishing-resistant.	Ensure that wallets satisfy applications requiring phishing resistance.	Examine assertions or code generating them to determine if valid signatures or audience restrictions are present.	3.1.7.3 F	RP	AAL2/AAL3	
UWSCW-7	Wallet Activation Information	Assertions SHALL also include sufficient information to determine the nature of the activation method used to activate the wallet.	Ensure that activation information is provided to relying parties.	Examine assertions or code generating them to determine if the activation method is included.	3.1.7.3 G	IdP	AAL2/AAL3	
PHYSA-1	Physical Authenticator Instructions	CSPs SHALL provide subscriber instructions for appropriately protecting the authenticator against theft or loss.	Ensure that subscribers understand their responsibilities for protecting authenticators.	Test by establishing a new subscriber account and observe whether sufficient instructions are provided.	3.2.1 A	CSP	AAL2/AAL3	
PHYSA-2	Physical Authenticator Invalidation	The CSP SHALL provide a mechanism to invalidate the authenticator immediately upon notification from a subscriber that the authenticator's loss, theft, or compromise is suspected.	Ensure that subscribers have a meaningful way to report authenticator issues and that appropriate action is taken.	Test by simulating the loss of an authenticator and determine whether instructions are provided to the subscriber to handle this situation and that appropriate action is taken when reported.	3.2.1 B	CSP	AAL2/AAL3	

NIST SP 800-63-4 Conformance Criteria v0.1: 63B

Control Identifier	Control Name	Control Text	Objective	Assessment Method	Index	Target	Profile/XAL Level	Discussion
RL-1	Rate Limiting Requirement	When required by the authenticator type descriptions in Sec. 3.1, the verifier SHALL implement controls to protect against online guessing attacks.	Control online guessing attacks.	Satisfied by RL-2 through RL-6	3.2.2 A	Verifier	AAL2/AAL3	
RL-2	Rate Limiting Upper Bound	Unless otherwise specified in the description of a given authenticator, the verifier SHALL limit consecutive failed authentication attempts using a specific authenticator on a single subscriber account to no more than 100 by disabling that authenticator.	Set overall upper limit on consecutive failed authentication attempts.	Test by making 101 authentication failures with an authenticator. Examine subscriber account to verify that the authenticator has been disabled.	3.2.2 B	Verifier	AAL2/AAL3	
RL-3	Rate Limiting Authenticator Association	If more than one authenticator is involved with an excessive number of authentication attempts (e.g., single-factor cryptographic authenticator and centrally verified password), both authenticators SHALL be disabled.	Address excessive authentication failures involving more than one authenticator.	Test by making excessive authentication failures with two authenticators. Examine subscriber account to verify that both authenticators have been disabled.	3.2.2 C	CSP/Verifier	AAL2/AAL3	
RL-4	Rate Limiting Rebinding	Authenticators that have been disabled SHALL be required to rebind to the subscriber account, as described in Sec. 4.1, to be usable in the future.	Ensure that disabled authenticators are treated as unbound to the subscriber account.	Test by causing an authenticator to be disabled due to excessive authentication failures and verify that there is no way to successfully use the authenticator other than to go through the authenticator binding procedure.	3.2.2 D	CSP	AAL2/AAL3	
RL-5	Rate Limiting AAL Limitation	If the retry count of an authenticator is reset following a successful authentication, the maximum AAL of the authenticator being reset SHALL not exceed the AAL of the session from which it is being reset.	Prevent AAL escalation due to authenticator retry count reset.	Test by authenticating unsuccessfully and then successfully with a given authenticator and examine the maximum AAL at which it can be used to verify that it does not increase.	3.2.2 E	CSP	AAL2/AAL3	Applies to verifiers that reset the unsuccessful authentication count after successful authentication.
RL-6	Rate Limiting Recovery Requirement	If the subscriber cannot authenticate at the required AAL, the account recovery procedures in Sec. 4.2 SHALL be used.	Require account recovery in the event that authenticator rebinding is unavailable.	Satisfied by section 4.2 compliance	3.2.2 F	CSP	AAL2/AAL3	
UB-1	Biometrics Applicability	Biometrics SHALL only be used as part of multi-factor authentication with a physical authenticator (i.e., "something you have").	Block use of biometric comparison as a single factor or with only a password.	Test available authentication methods to ensure that all require a physical authenticator.	3.2.3 A	Verifier	AAL2/AAL3	
UB-2	Biometrics Not Cached	The biometric characteristic SHALL be presented and compared for each authentication operation.	Do not allow biometric characteristics to be cached.	Test by making multiple authentications using biometric comparison and verify that the biometric characteristic is required to be presented each time.	3.2.3 B	Verifier	AAL2/AAL3	
UB-3	Biometrics Alternatives	An alternative nonbiometric authentication option SHALL always be provided to the subscriber.	Require alternatives in the event that a biometric characteristic cannot be presented for some reason.	Test available authentication methods to ensure that an alternative to biometric comparison is always available.	3.2.3 C	CSP	AAL2/AAL3	
UB-4	Biometrics Sensitivity	Biometric data SHALL be treated and secured as sensitive personal information.	Ensure that biometric data is sufficiently protected.	Examine storage of biometric data and evaluate access controls for that data.	3.2.3 D	Verifier/CSP	AAL2/AAL3	
BA-1	Biometric FMR	The biometric system SHALL operate with an FMR [ISO/IEC2382-37] of one in 10000 or better for all demographic groups.	Ensure biometric comparison is sufficiently secure against false matches.	Examine test results or certifications for biometric system	3.2.3.1 A	CSP	AAL2/AAL3	
BA-2	Biometric Demographic Categories	Demographic categories to be considered SHALL include sex and skin tone when these factors affect biometric performance.	Ensure biometric comparison works for a wide demographic range.	Examine test procedure for biometric system to verify that a wide demographic range was included.	3.2.3.1 B	CSP	AAL2/AAL3	

NIST SP 800-63-4 Conformance Criteria v0.1: 63B

Control Identifier	Control Name	Control Text	Objective	Assessment Method	Index	Target	Profile/XAL Level	Discussion
BA-3	Biometric Test Conditions	This FMR SHALL be achieved under the conditions of a conformant attack (i.e., zero-effort impostor attempt), as defined in [ISO/IEC30107-1].	Define test conditions for false match rate test.	Examine test procedure to determine test conditions.	3.2.3.1 C	CSP	AAL2/AAL3	
BA-4	Biometric Test Procedure	Biometric performance SHALL be tested in accordance with [ISO/IEC19795-1].	Define test conditions for false match rate test.	Examine test procedure to determine test conditions.	3.2.3.1 D	CSP	AAL2/AAL3	
BA-5	Biometric Threshold	The biometric system SHALL be configured with a fixed threshold; it is not feasible to change the threshold for each demographic.	Require consistent match criteria for all demographic groups.	Examine comparison algorithm to verify that it uses a single threshold.	3.2.3.1 E	CSP	AAL2/AAL3	
PAD-1	Biometric Pad	The biometric system SHOULD implement PAD for iris and fingerprint modalities and SHALL implement PAD for facial recognition.	Require PAD for facial recognition to counter deepfakes.	Test facial recognition with a synthetic image to verify use of presentation attack detection.	3.2.3.2 A	CSP	AAL2/AAL3	Applies to facial recognition modality.
PAD-2	Biometric Voice Prohibition	Biometric comparison based on voice SHALL NOT be used.	Prohibit use of voice recognition due to ease in spoofing.	Test available authentication methods to verify that voice recognition is not available.	3.2.3.2 B	CSP	AAL2/AAL3	Applies to voice recognition modality.
IAD-1	Biometric Failure Threshold	The biometric system SHALL allow no more than five consecutive failed authentication attempts or 10 consecutive failed attempts if PAD is implemented and meets the above requirements.	Limit opportunity to spoof biometric comparison.	Test by creating unsuccessful comparisons and verify that requests are throttled after the specified limit is reached.	3.2.3.3 A	CSP	AAL2/AAL3	
IAD-2	Biometric Failure Delay	Once that limit has been reached, the biometric authenticator SHALL impose a delay of at least 30 seconds before each subsequent attempt with an overall limit of no more than 50 consecutive failed authentication attempts or 100 if PAD is implemented due to the mitigation of presentation attacks.	Limit opportunity to spoof biometric comparison.	Test by creating unsuccessful comparisons and verify that requests are throttled after the specified limit is reached.	3.2.3.3 B	CSP	AAL2/AAL3	
IAD-3	Biometric Failure Limit	Once the overall limit is reached, the biometric system SHALL disable biometric authentication and offer another factor (e.g., a different biometric modality or an activation secret if it is not a required factor) if such an alternative method is already available.	Limit opportunity to spoof biometric comparison.	Test by creating unsuccessful comparisons and verify that biometric comparison is disabled when the specified limit is reached.	3.2.3.3 C	CSP	AAL2/AAL3	
IAD-4	Biometric Unlocking Independence	The presentation of a biometric factor for authenticator activation SHALL be a separate operation from unlocking the host device (e.g., smartphone).	Minimize opportunity for an attacker to authenticate on an already unlocked device.	Test by attempting to authenticate on an already unlocked device and verify that an additional biometric comparison is required.	3.2.3.3 D	CSP	AAL2/AAL3	
IAD-5	Biometric Endpoint Authentication	If the comparison is performed centrally, the sender or endpoint SHALL be authenticated before capturing the biometric sample from the claimant.	Protect against injection attacks from rogue hardware devices.	Examine method for authenticating sensor or endpoint and evaluate its security	3.2.3.3 E	Verifier	AAL2/AAL3	Central biometric comparison.
IAD-5.1	Biometric Central Protection	If the comparison is performed centrally, appropriate controls (e.g., encryption and access controls) for sensitive personal information SHALL be implemented.	Ensure that centrally stored biometric data is sufficiently secure.	Examine storage of biometric data and evaluate access controls for that data.	3.2.3.3 F	Verifier	AAL2/AAL3	Central biometric comparison.
IAD-5.2	Biometric Authenticated Protected Channel	If the comparison is performed centrally, an authenticated protected channel between the sensor (or an endpoint containing a sensor that resists sensor replacement) and the verifier SHALL be established. All transmission of biometric information SHALL be conducted over that authenticated protected channel.	Ensure that biometric data is transmitted securely for central comparison.	Examine code or communications protocol to verify that all biometric data is transmitted over an authenticated protected channel.	3.2.3.3 G	Verifier	AAL2/AAL3	Central biometric comparison.

NIST SP 800-63-4 Conformance Criteria v0.1: 63B

Control Identifier	Control Name	Control Text	Objective	Assessment Method	Index	Target	Profile/XAL Level	Discussion
UBS-1	Biometric Sample Erasure	The biometric samples and any other biometric data derived from them SHALL be erased immediately after any adaptation or research data has been derived.	Ensure that biometric samples are securely erased as soon as they are no longer needed.	Examine code to verify erasure of biometric samples.	3.2.3.4 A	CSP/Verifier	AAL2/AAL3	
UBS-2	Biometric Sample Storage Limit	A limit on the allowable time for adaptation SHALL be established and enforced by the authenticator or the CSP.	Establish reasonable limits on adaptation time to limit persistence of biometric samples.	Examine documentation to determine adaptation time limit. Examine code to verify that biometric samples are erased at or before that time limit.	3.2.3.4 B	CSP	AAL2/AAL3	
ATT-1	Attestation Signature Requirements	Attestations SHALL be signed using a digital signature that provides at least the minimum security strength specified in the latest revision of [SP800-131A] (i.e., 112 bits as of the date of this publication).	Ensure that the key used to sign the attestation is of sufficient size to be secure.	Examine code to determine the security strength of the attestation key.	3.2.4 A	CSP	ALL	
PHIRES-1	Phishing Resistance Approved Algorithms	Approved cryptographic algorithms SHALL be used to establish phishing resistance where required.	Determine that only secure, well-vetted cryptographic algorithms and protocols are being used.	Examine documented policies or code to determine that only approved cryptographic algorithms can be used.	3.2.5 A	Verifier	AAL2/AAL3	
PHIRES-2	Phishing Resistance Key Strength	Keys used for phishing resistance SHALL provide at least the minimum security strength specified in the latest revision of [SP800-131A] (i.e., 112 bits as of the date of this publication).	Ensure that the authentication key is of sufficient size to be secure.	Examine code to determine the security strength of the authentication key.	3.2.5 B	Verifier	AAL2/AAL3	
PHIRES-3	Phishing Resistance Manual Prohibition	Authenticators that involve the manual entry of an authenticator output (e.g., out-of-band and OTP authenticators) SHALL NOT be considered phishing-resistant because the manual entry does not bind the authenticator output to the specific session being authenticated.	Ensure that manual intervention, which can be socially engineered, is not part of phishing-resistant authentication.	Test available authentication methods to ensure that phishing -resistant authentication methods do not use manual entry.	3.2.5 C	Verifier	AAL2/AAL3	
CB-1	Channel Binding Authenticated Protected Channel	An authentication protocol with channel binding SHALL establish an authenticated protected channel with the verifier.	Ensure that phishing-resistant authentication uses a secure channel that authenticates the verifier.	Test by to verify that authenticated protected channel such as TLS is used.	3.2.5.1 A	Verifier	AAL2/AAL3	
CB-2	Channel Binding Identifier	The protocol SHALL then strongly and irreversibly bind a channel identifier negotiated in establishing the authenticated protected channel to the authenticator output (e.g., by signing the two values together using a private key controlled by the claimant for which the public key is known to the verifier).	Ensure that the authentication protocol is bound to the communications channel.	Test to determine if client-authenticated TLS is being used or analyze protocol to verify channel binding.	3.2.5.1 B	Verifier	AAL2/AAL3	
CB-3	Channel Binding Validation	The verifier SHALL validate the signature or other information used to prove phishing resistance.	Ensure that authentication requires a valid signature.	Test to verify that invalid signatures are not accepted.	3.2.5.1 C	Verifier	AAL2/AAL3	
VNB-1	Name Binding Authenticated Protected Channel	An authentication protocol with verifier name binding SHALL establish an authenticated protected channel with the verifier.	Ensure that phishing-resistant authentication uses a secure channel that authenticates the verifier.	Test by to verify that authenticated protected channel such as TLS is used.	3.2.5.2 A	Verifier	AAL2/AAL3	
VNB-2	Name Binding Authenticated Verifier	The protocol SHALL generate an authenticator output that is cryptographically bound to a verifier identifier that is authenticated as part of the protocol.	Ensure that the authentication transaction can only succeed when connected to a specific host or domain.	Test by simulating connection to a different host or domain and verify that the transaction does not succeed.	3.2.5.2 B	Verifier	AAL2/AAL3	

NIST SP 800-63-4 Conformance Criteria v0.1: 63B

Control Identifier	Control Name	Control Text	Objective	Assessment Method	Index	Target	Profile/XAL Level	Discussion
VNB-3	Name Binding Hostname	In the case of DNS identifiers, the verifier identifier SHALL be either the authenticated hostname of the verifier or a parent domain that is at least one level below the public suffix [PSL] associated with that hostname.	Ensure the correct relationship between the transaction hostname and the bound verifier name.	Examine code to determine that the correct comparison is made between the bound host/domain and the hostname of the authenticated protected channel.	3.2.5.2 C	Verifier	AAL2/AAL3	
VCIC-1	Separate Verifier Mutually Authenticated Channel	If the verifier and CSP or IdP are separate entities (as shown by the dotted line in Fig. 3 of [SP800-63]), communications between the verifier and CSP or IdP SHALL occur through a mutually authenticated protected channel (e.g., a client-authenticated TLS connection) using approved cryptography.	Ensure a secure relationship between verifier and CSP/IdP.	Examine communications channel between verifier and CSP/IdP and verify that client-authenticated TLS or equivalent is used.	3.2.6 A	CSP	ALL	Applies when verifier and CSP/IdP are separate entities.
AI-1	Intent Requirement	The authenticator itself SHALL establish authentication intent.	Ensure that authentication only occurs when intended by the claimant.	Test available authentication methods to ensure that all require some action on the part of the claimant.	3.2.8 A	CSP	ALL	
AI-2	Intent Explicit	In scenarios involving biometric authentication not requiring claimant action, an explicit mechanism (e.g., tapping a software or physical button) SHALL be provided to establish authentication intent.	Ensure that "passive" biometric authentication is not sufficient to establish intent.	Test available authentication methods using biometrics to ensure that all require some action on the part of the claimant.	3.2.8 B	CSP	ALL	Applies to authentication methods using biometric comparison.
RESTA-1	Restricted Authenticator Risk Determination	If the RP determines that the risk to any party is unacceptable, the restricted authenticator SHALL NOT be used, and an alternative authenticator type SHALL be used.	Ensure that restricted authenticators are not used in high-risk situations.	Examine risk assessment for evaluation and acceptability of risks.	3.2.9 A	Verifier	ALL	
RESTA-2	Non-Restricted Authenticator Requirement	The CSP SHALL offer subscribers at least one alternative authenticator that is not restricted and can be used to authenticate at the required AAL.	Ensure that alternative authentication methods not using restricted authenticators are provided.	Examine available authentication methods to verify that one or more non-restricted authenticators can be used.	3.2.9 B #1	CSP	ALL	
RESTA-3	Restricted Authenticator Risk Notice	The CSP SHALL provide subscribers with meaningful notice regarding the restricted authenticator's security risks and the availability of unrestricted alternatives.	Ensure that subscribers are aware of the risks and alternatives.	Examine text displayed to subscriber when binding a restricted authenticator to make sure meaningful notice is displayed.	3.2.9 B #2	CSP	ALL	
RESTA-4	Restricted Authenticator Risk Documentation	The CSP SHALL address any additional risks to subscribers and RPs in its risk assessment.	Ensure that risks are documented.	Examine risk assessment for documentation of any additional risks.	3.2.9 B #3	CSP	ALL	
RESTA-5	Restricted Authenticator Migration Plan	The CSP SHALL develop a migration plan for the possibility that the restricted authenticator will not be acceptable in the future and include this migration plan in its Digital Identity Acceptance Statement (see Sec. 3.4.4 of [SP800-63]).	Plan for the likelihood that restricted authenticators will be non-compliant in the future.	Examine migration plan to verify a plan for deprecation/removal of restricted authenticator.	3.2.9 B #4	CSP	ALL	
AS-1	Activation Secret Non-Transferable	In all cases, the activation secret SHALL remain within the authenticator and its associated user endpoint.	Ensure that activation secret remains secure.	Examine protocol between authenticator or endpoint and verifier and confirm that activation secret is not transmitted.	3.2.10 A	CSP	AAL2/AAL3	
AS-2	Activation Secret Minimum Length	Authenticators that use activation secrets SHALL require the secrets to be at least four characters in length and SHOULD require the secrets to be at least six characters in length.	Ensure that activation secret is not too easy to guess.	Test by attempting to establish an activation secret that is three characters or less and verify that it is not accepted.	3.2.10 B	CSP	AAL2/AAL3	
AS-3	Activation Secret Retry Limit	The authenticator or verifier SHALL implement a retry-limiting mechanism that limits the number of consecutive failed activation attempts using the authenticator to no more than 10.	Ensure that the verification process limits excessive retries that would indicate a brute force attack.	Test by making more than 10 consecutive incorrect activation secret entries followed by a successful one and verify that authentication does not succeed.	3.2.10 C	CSP	AAL2/AAL3	

NIST SP 800-63-4 Conformance Criteria v0.1: 63B

Control Identifier	Control Name	Control Text	Objective	Assessment Method	Index	Target	Profile/XAL Level	Discussion
AS-4	Retry Limit Authenticator Implementation	Unless the authenticator generates an invalid output when an incorrect activation secret is provided, retry limiting SHALL be implemented in the authenticator.	Ensure that it is not possible to do an offline activation attack by observing the authenticator output.	Test by attempting to activate the authenticator offline and ensure that it is locally throttled.	3.2.10 D	CSP	AAL2/AAL3	Does not apply when the authenticator provides an output, but a wrong one, when an activation secret is provided.
AS-5	Retry Limit Exceeded Disables	Once the limit of attempts is reached, the authenticator SHALL be disabled, and a different authenticator SHALL be required for authentication.	Ensure that an authenticator that has reached its limit of activation attempts cannot be easily reactivated.	Examine procedures for use of an authenticator that has reached its activation attempts limit and verify that rebinding of the authenticator to the subscriber account is required.	3.2.10 E	CSP	AAL2/AAL3	
AS-6	AAL3 Hardware-Protected Authentication Secret Verification	For authenticators that are usable at AAL3, verification of activation secrets SHALL be performed in a hardware-protected environment (e.g., a secure element, TPM, or TEE).	Ensure that authenticator protects activation secrets sufficiently for use at AAL3.	Examine implementation of authenticator to verify that activation secret verification is hardware-protected.	3.2.10 F	CSP	AAL2/AAL3	
AS-7	AAL2 Activation Secret Derivation	At AAL2, if a hardware-protected environment is not used, the authenticator SHALL use the activation secret to derive a key used to decrypt the authentication key.	Ensure that the authentication key is protected by knowledge of the activation secret.	Examine storage of the authentication key and verify it is the result of a decrypting the stored key with a key derived from the activation secret.	3.2.10 G	CSP	AAL2/AAL3	Applies when authentication key is stored in a software protected environment.
AS-8	Activation Secret Independence	Submitting the activation factor SHALL be a separate operation from unlocking the host device (e.g., smartphone).	Minimize opportunity for an attacker to authenticate on an already unlocked device.	Test by attempting to authenticate on an already unlocked device and verify that a separate entry of the activation secret is required.	3.2.10 H	CSP	AAL2/AAL3	
CONNAUTH-1	Authenticator Connection Types	This connection SHALL be made using a wired connection (e.g., USB or direct connection with a smartcard), a wireless technology, or a hybrid of those technologies, including network connections.	Ensure that connection to the authenticator meets an accepted model.	Examine ways that a connected authenticator can be used and verify that it meets one of the three models for connection.	3.2.11 A	CSP	ALL	
CONNAUTH-2	Connected Authenticator Approved Cryptography	Approved cryptography SHALL be used for all cases in which cryptographic operations are required.	Determine that only secure, well-vetted cryptographic algorithms and protocols are being used.	Examine documented policies or code to determine that only approved cryptographic algorithms can be used.	3.2.11 B	CSP	ALL	
CONNAUTH-3	Connected Authenticator Authenticated Protected Channel	All communication of authentication data between authenticators and endpoints SHALL occur directly between those devices or through an authenticated protected channel between the authenticator and endpoint.	Require secure communications between authenticator and endpoint.	Examine protocol for any communications between authenticator and endpoint that may be indirect (through intermediaries).	3.2.11 C	CSP	ALL	Applies when communication between authenticator and endpoint is not point-to-point.
WC-1	Wireless Authenticator Physical Proximity Requirement	To minimize the attack surface for threats to the authenticator-endpoint connection, the authentication process SHALL require physical proximity between the authenticator and endpoint by establishing a wireless connection with a range of no more than 240 meters.	Limit opportunity for attack by remotely located attackers.	Test authentication process with a remotely located authenticator and verify that it fails.	3.2.11.2 A	CSP	ALL	
WC-2	Wireless Authenticator Key Establishment	Wireless connections SHALL establish a key for encrypted communication between the authenticator and endpoint in one of the following ways: (1) Through a temporary wired connection between the devices. (2) Through an association process that is similar to a pairing process but does not require a persistent relationship between devices to establish a key for encrypted communication between the authenticator and endpoint.	Define acceptable methods for associating authenticator and endpoint.	Test key establishment between endpoint and authenticator and verify that it is done in an acceptable way.	3.2.11.2 B	CSP	ALL	

NIST SP 800-63-4 Conformance Criteria v0.1: 63B

Control Identifier	Control Name	Control Text	Objective	Assessment Method	Index	Target	Profile/XAL Level	Discussion
WC-2.1	Wireless Authenticator Pairing Code	If an association process is used, it SHALL employ a pairing code or other shared secret between the devices.	Require use of a shared secret to identify the parties to the association.	Test association process and verify that a pairing code or shared secret is required.	3.2.11.2 B	CSP	ALL	Applies when an association process is used instead of a temporary wired connection.
WC-2.2	Wireless Authenticator Pairing Code Length	If an association process is used, either the authenticator or endpoint SHALL have a pairing code that is at least six decimal digits (or equivalent) in length that MAY be printed on the device.	Require that the pairing code be long enough to provide appropriate security.	Test association process and verify that the pairing code or shared secret is long enough.	3.2.11.2 B	CSP	ALL	Applies when an association process is used instead of a temporary wired connection.
WC-2.3	Wireless Authenticator Association Methods	If an association process is used, the pairing code SHALL be conveyed between the devices by manual entry or using a QR code or similar representation that is optically communicated.	Allow use of manual or optically-assisted entry of pairing code.	Test association process to verify that the pairing code is manually entered or optically communicated.	3.2.11.2 B	CSP	ALL	Applies when an association process is used instead of a temporary wired connection.
WC-3	Wireless Authenticator Proximate Activation Secret	When using a wireless technology with an effective range of less than 1 meter (e.g., NFC), any activation secret transmitted from the endpoint to the authenticator SHALL be encrypted using a key that is established between the devices.	Ensure secure transmission of the activation secret from the endpoint to the authenticator.	Examine implementation to verify that transmission of the activation secret is encrypted using a key established between the devices.	3.2.11.2 C	CSP	ALL	Applies when very short range (<1 m) wireless technologies are used.
WC-4	Wireless Authenticator Pairing Code Use	A pairing code SHALL be used if the authenticator is configured to require authenticated pairing.	Use pairing processes appropriate for the authenticator.	Test to verify that a pairing code is used when authenticated pairing is required.	3.2.11.2 D	CSP	ALL	Applies when authenticator uses authenticated pairing.
WC-5	Wireless Authenticator Non-Proximate Authenticated Protected Channel	Network connections and wireless technologies with an effective range of 1 meter or more (e.g., Bluetooth Low Energy [BLE]) SHALL use an authenticated protected channel between the authenticator and endpoint.	Require stronger protections for wireless connections with longer range.	Examine implementation to verify that an authenticated protected channel such as TLS is used.	3.2.11.2 F	CSP	ALL	Applies when longer range (>=1 m) wireless technologies are used.
WC-6	Wireless Authenticator Encryption	The entire authentication transaction SHALL be encrypted.	Protect authentication transaction in transit between devices.	Examine implementation to verify that the entire transaction is authenticated.	3.2.11.2 G	CSP	ALL	
WC-7	Wireless Authenticator Persistent Key Removal	A mechanism for endpoints to remove persistent keys SHALL be provided.	Require removal of associations between authenticator and endpoint when no longer needed.	Test authenticator and/or endpoint to verify that a mechanism to remove persistent keys exists.	3.2.11.2 H	CSP	ALL	
HYBC-1	Hybrid Connection Establishment	Hybrid connections (e.g., hybrid transports specified by the CTAP2.2 protocol) SHALL be established between authenticators and endpoints in one of the following ways: (1) By communicating initial keying information and the identity of the tunnel service to be used via a displayed QR code or similar visual representation coupled with the receipt by the endpoint of wireless data containing the additional information required to establish the tunnel connection. (2) Through cached keying and tunnel information retained by the authenticator and endpoint from a previous authentication transaction.	Require hybrid connections to be established securely or to be based on cached information.	Test establishment of hybrid connections between authenticators and endpoints to verify that they are established in one of the permitted methods.	3.2.11.3 A	CSP	ALL	
HYBC-1.1	Hybrid Connection Proximity	The wireless data SHALL be conveyed over a technology with a maximum effective range of no more than 240 meters.	Limit opportunity for attack by remotely located attackers.	Test authentication process with a remotely located authenticator and verify that it fails.	3.2.11.3 B	CSP	ALL	Applies when initial keying information is being established.

NIST SP 800-63-4 Conformance Criteria v0.1: 63B

Control Identifier	Control Name	Control Text	Objective	Assessment Method	Index	Target	Profile/XAL Level	Discussion
HYBC-2	Hybrid Connection Association Removal	A mechanism for endpoints to remove cached associations with authenticators SHALL be provided.	Require removal of associations between authenticator and endpoint when no longer needed.	Test authenticator and/or endpoint to verify that a mechanism to remove persistent keys exists.	3.2.11.3 C	CSP	ALL	
RANV-1	Random Value Generation Requirements	Unless otherwise specified, random values that reference this section SHALL be generated by an approved random bit generator that provides at least the minimum security strength specified in the latest revision of SP800-131A (i.e., 112 bits as of the date of this publication).	Require use of sufficiently secure random values.	Examine implementation of random bit generator to verify that it meets SP 800-131A requirements.	3.2.12 A	CSP/Verifier	ALL	
EXPO-1	Non-Exportability Hardware Requirements	To be considered non-exportable, an authenticator SHALL either be a separate piece of hardware or an embedded processor or execution environment (e.g., secure element, TEE, TPM).	Require that non-exportable keys not be directly accessible to the endpoint.	Examine implementation, including APIs, to ensure that authentication keys are not sent or accessible outside the authenticator.	3.2.13 A	CSP	AAL1/AAL2	
EXPO-2	Non-Exportable Authentication Key Protection	A non-exportable authenticator SHALL be designed to prohibit the export of the authentication secret to the host processor and SHALL NOT be capable of being reprogrammed by the host processor to allow the secret to be extracted.	Ensure that reprogramming of the secure environment is not possible as a back door to obtain access to authentication secrets.	Examine APIs between the endpoint and authenticator to verify that it is not possible for the endpoint to reprogram the authenticator.	3.2.13 B	CSP	AAL1/AAL2	
AUTHB-1	Authenticator Binding Requirements	Authenticators SHALL be bound to subscriber accounts by either: being issued by the CSP as part of enrollment; or using a subscriber-provided authenticator that is acceptable to the CSP.	Allow CSP to verify that all authenticators bound to subscriber accounts meet their requirements.	Examine procedures for binding authenticators and verify that they provide an opportunity for the CSP to verify the authenticator's security.	4.1 A	CSP	ALL	
AUTHB-2	Authenticator Record-Keeping	Throughout the lifetime of a digital identity, CSPs SHALL maintain a record of all authenticators that are bound to each subscriber account.	Maintain the ability to audit authenticators that are or have been bound to subscriber accounts.	Examine CSP records to verify that records of current and past bound authenticators are maintained.	4.1 B	CSP	ALL	
AUTHB-3	CSP Authenticator Characteristics Determination	The CSP SHALL determine the characteristics of the authenticator being bound (e.g., single-factor versus multifactor, phishing-resistant or not) so that verifiers can assess compliance with the requirements at each AAL.	Ensure that authenticators bound to subscriber accounts meet requirements for the AALs at which they will be used.	Interview CSP to determine the sufficiency of procedures for approving authenticators.	4.1 C	CSP	ALL	
AUTHB-4	CSP Authenticator State Storage	The CSP SHALL also maintain other state information that is required to meet the authenticator verification requirements.	Ensure that the CSP is equipped to maintain other state information such as that required for throttling.	Examine CSP records to verify that required state information is maintained.	4.1 D	CSP	ALL	
AUTHB-5	CSP Authenticator Lifecycle Logging	The record created by the CSP SHALL contain the date and time of significant authenticator life cycle events (e.g., binding to the subscriber account, renewal, update, expiration).	Maintain the ability to audit authenticator life cycle events.	Examine CSP records to verify that authenticator life cycle events are documented.	4.1 E	CSP	ALL	
BAA-1	Multiple Authenticator Binding	Accordingly, CSPs SHALL permit the binding of multiple authenticators to a subscriber account.	Allow subscribers to bind multiple authenticators to guard against loss or failure of a given authenticator.	Test by attempting to bind multiple authenticators and verify that it is successful.	4.1.2.1 A	CSP	ALL	

NIST SP 800-63-4 Conformance Criteria v0.1: 63B

Control Identifier	Control Name	Control Text	Objective	Assessment Method	Index	Target	Profile/XAL Level	Discussion
BAA-2	Binding Authentication Requirement	When any new authenticator is bound to a subscriber account, the CSP SHALL ensure that the process requires authentication at either the maximum AAL currently available in the subscriber account or the maximum AAL at which the new authenticator will be used, whichever is lower.	Ensure that it is not possible to increase authenticated AAL by binding a new authenticator.	Test by binding a new authenticator for use at AAL2 or AAL3 and verify that it requires authentication at the corresponding AAL.	4.1.2.1 B	CSP	ALL	
BAA-3	Binding Notification Requirement	When an authenticator is added, the CSP SHALL notify the subscriber via a mechanism independent of the transaction binding the new authenticator, as described in Sec. 4.6.	Warn subscriber in case an authenticator is bound without their knowledge.	Test by binding an additional authenticator and verify that the subscriber receives a notification as described.	4.1.2.1 C	CSP	ALL	
BINAE-1	External Authenticator Binding	The binding process SHALL proceed in one of the following ways: (1) An endpoint that has authenticated to the CSP requests a binding code from the CSP. The binding code is input into the endpoint associated with the new authenticator and sent to the CSP. (2) The endpoint associated with the new authenticator obtains a binding code from the CSP. The binding code is input to an authenticated endpoint and sent to the CSP.	Ensure that the binding of authenticators not directly connected to an authenticated session uses a secure process.	Test by binding an authenticator that is not connected to the authenticated endpoint, and ensure that it uses one of the described processes.	4.1.2.2 A	CSP	ALL	
BINAE-2	External Authenticator Authenticated Protected Channel	When binding an external authenticator, an authenticated protected channel SHALL be established by the endpoint associated with the new authenticator and the CSP.	Ensure that channel between authenticator and endpoint are protected against eavesdropping and intermediaries.	Examine implementation to verify that an authenticated protected channel such as TLS is used.	4.1.2.2 B	CSP	ALL	
BINAE-3	External Authenticator Binding Code	When binding an external authenticator, the CSP SHALL generate a binding code using an approved random bit generator as described in Sec. 3.2.12 and send it to either the new authenticator endpoint or the authenticated endpoint approving the binding.	Ensure that a sufficiently random binding code is used and transmitted to the endpoint or authenticator.	Examine implementation to see how the binding code is generated.	4.1.2.2 C	CSP	ALL	
BINAE-4	External Authenticator Identifier Binding Code Length	The binding code SHALL be at least 40 bits in length if it is used with an identifier entered by the subscriber on the new authenticator.	Ensure that the binding code is sufficiently large to provide the required level of security.	Test by binding an external authenticator and verify that the binding code is sufficiently long.	4.1.2.2 D	CSP	ALL	Applies when an identifier is entered by the subscriber on the new authenticator.
BINAE-5	External Authenticator Non-Identifier Binding Code Length	The binding code SHALL be at least 112 bits in length if it is not used with an identifier entered by the subscriber on the new authenticator.	Ensure that the binding code is sufficiently large to provide the required level of security.	Test by binding an external authenticator and verify that the binding code is sufficiently long.	4.1.2.2 E	CSP	ALL	Applies when no identifier is entered by the subscriber on the new authenticator.
BINAE-6	External Authenticator Association Methods	When binding an external authenticator, the subscriber SHALL transfer the binding code to the other endpoint manually or via a local out-of-band method such as a QR code.	Ensure that the binding code is transferred through action by the subscriber.	Test all supported methods for binding an external authenticator and verify that manual or local out-of-band action is required.	4.1.2.2 F	CSP	ALL	
BINAE-7	External Authenticator Binding Code Security	The binding code SHALL NOT be communicated over an insecure channel.	Ensure that the binding code is not available to an attacker.	Test all supported methods for binding an external authenticator and verify that no insecure channels are used.	4.1.2.2 G	CSP	ALL	
BINAE-8	External Authenticator Binding Code Replay	When binding an external authenticator, the binding code SHALL be usable only once.	Guard against replay of the binding code.	Test by attempting to use the same binding code more than once and verify that it fails.	4.1.2.2 H	CSP	ALL	

NIST SP 800-63-4 Conformance Criteria v0.1: 63B

Control Identifier	Control Name	Control Text	Objective	Assessment Method	Index	Target	Profile/XAL Level	Discussion
BINAE-9	External Authenticator Binding Code Lifetime	The binding code SHALL be valid for a maximum of 10 minutes.	Limit usability of a binding code that may have been part of an incomplete binding transaction.	Test by attempting to bind an external authenticator while delaying transfer of the binding code for more than 10 minutes, and verify that it fails.	4.1.2.2 I	CSP	ALL	
BINAE-10	External Authenticator Binding Instructions	The CSP SHALL provide clear instructions on what the subscriber should do in the event of an authenticator binding mishap.	Provide recourse for binding transactions that do not occur normally.	Test by attempting to bind an external authenticator and verify that suitable guidance to the subscriber is provided.	4.1.2.2 J	CSP	ALL	
BSPA-1	Subscriber Provided Authenticator Procedure	The binding of subscriber-provided authenticators SHALL be done as described in Sec. 4.1.2.	Ensure that subscriber-provided authenticators are bound in a secure manner.	Examine procedures for binding subscriber-controlled authenticators and verify that they meet BAA-1 through BAA-3 and BINAE-1 through BINAE-9 as applicable.	4.1.3 A	CSP	ALL	
BSPA-2	Authenticator Type Documentation	The types of authenticators accepted by the CSP SHALL be documented in the CSP practice statement.	Make sure clear guidelines for subscriber acceptability are published.	Examine CSP practice statement to verify that acceptable types of subscriber-provided authenticators are documented.	4.1.3 B	CSP	ALL	
ARM-1	Account Recovery Requirement	CSPs SHALL support one or more of the four account recovery mechanisms described.	Ensure that secure account recovery mechanisms are provided.	Examine available recovery procedures to verify that at least one of the described account recovery mechanisms is supported.	4.2.1 A	CSP	ALL	
ARM-2	Account Recovery Alternatives	The use of alternative methods SHALL be based on a risk analysis and documented by the CSP.	Require that alternative recovery mechanisms by documented and accompanied by a valid risk analysis.	Examine risk analysis for any alternative account recovery mechanisms that are supported.	4.2.1 B	CSP	ALL	
SRC-1	Saved Recovery Code Generation	The recovery code SHALL include at least 64 bits from an approved random bit generator.	Ensure that a sufficiently random recovery code is used.	Examine implementation to see how the recovery code is generated.	4.2.1.1 A	CSP	ALL	
SRC-2	Saved Recovery Code Issuance Notification	The issuance of a replacement recovery code SHALL result in an account recovery notification, as described in Sec. 4.6.	Confirm that subscriber is notified of account recovery events.	Test by performing a recovery using a saved recovery code and verify that the subscriber is notified in one of the ways described.	4.2.1.1 B	CSP	ALL	
SRC-3	Saved Recovery Code Rate Limitation	The verification of saved recovery codes SHALL be subject to the throttling requirements in Sec. 3.2.2.	Limit ability to guess recovery codes.	Test by performing a recovery using a number of invalid recovery codes followed by a correct code and confirm that throttling has occurred.	4.2.1.1 C	CSP	ALL	
SRC-4	Saved Recovery Code Storage	Saved recovery codes SHALL be stored in the subscriber account in hashed form using an approved one-way function, as described in Sec. 3.1.1.2.	At a minimum, require salting and hashing of recovery codes as protection against offline attacks should the verifier be breached.	Examine recovery code verification storage to determine evidence of hashing.	4.2.1.1 D	CSP	ALL	
SRC-5	Saved Recovery Code Replay	Following the use of a saved recovery code, the CSP SHALL invalidate that recovery code and SHALL issue a new saved recovery code to the subscriber.	Prevent replay of recovery codes.	Test by attempting a second recovery using a saved recovery code and verify that it is unsuccessful.	4.2.1.1 E	CSP	ALL	
IRC-1	Issued Recovery Code Generation	The issued recovery code SHALL include at least six decimal digits (or equivalent) from an approved random bit generator, as described in Sec. 3.2.12.	Ensure that a sufficiently random recovery code is used.	Examine implementation to see how the recovery code is generated.	4.2.1.2 A	CSP	ALL	

NIST SP 800-63-4 Conformance Criteria v0.1: 63B

Control Identifier	Control Name	Control Text	Objective	Assessment Method	Index	Target	Profile/XAL Level	Discussion
IRC-2	Issued Recovery Code Validity	Issued recovery codes SHALL be valid for at most: (a) 21 days when sent to a postal address within the contiguous United States. (b) 30 days when sent to a postal address outside of the contiguous United States. (c) 10 minutes when sent via text message or voice. (d) 24 hours when sent to an email address.	Limit lifetimes of issued recovery codes based on expected delivery times.	Examine methods for issued recovery code delivery and verify that implementation limits their validity to within the specified timeframes.	4.2.1.2 B	CSP	ALL	
IRC-3	Issued Recovery Code Rate Limitation	The verification of issued recovery codes SHALL be subject to the throttling requirements in Sec. 3.2.2.	Limit ability to guess recovery codes.	Test by performing a recovery using a number of invalid recovery codes followed by a correct code and confirm that throttling has occurred.	4.2.1.2 C	CSP	ALL	
IRC-4	Issued Recovery Code Address Verification	When establishing recovery addresses other than those validated or verified as part of the identity proofing process, the address SHALL be verified.	Confirm reliability of recovery addresses.	Examine metadata associated with recovery addresses and verify that a confirmation flag is present and is required in order to be used for recovery.	4.2.1.2 D	CSP	ALL	
IRC-5	Issued Recovery Code Address Verification Procedure	To verify an address, the CSP SHALL send a confirmation code with the same characteristics as a recovery code to the newly established recovery address and require that the subscriber return the same confirmation code to the CSP.	Specify procedure for address confirmation.	Test by establishing a new recovery address and verify that it is only usable for recovery after having been confirmed.	4.2.1.2 E	CSP	ALL	
IRC-6	Issued Recovery Code Multiple Address Requirement	CSPs SHALL allow the subscriber to establish at least two recovery addresses.	Provide backup in case subscriber loses control of a recovery address.	Test by verifying that it is possible to establish more than one recovery address.	4.2.1.2 H	CSP	ALL	
RECC-1	Recovery Contact Addresses	CSPs that support the use of recovery contacts SHALL allow the subscriber to specify one or more addresses of trusted associates to receive issued recovery codes.	Define recovery contacts mechanism.	Test by establishing a recovery contact and performing account recovery to verify that associate received recovery code and instructions on what to do with it.	4.2.1.3 A	CSP	ALL	
RECC-2	Recovery Contact Management	If the CSP supports the use of recovery contacts, the CSP SHALL provide methods for subscribers to view and manage recovery contacts.	Allow subscriber to manage recovery contacts (e.g., to change them).	Test by changing and deleting recovery contacts and verify that it is possible to do so.	4.2.1.3 B	CSP	ALL	
RIP-1	Repeated Proofing Account Recovery	The CSP SHALL repeat the necessary steps of identity proofing consistent with the level of initial identity proofing and SHALL confirm that the claimant's identity is consistent with the previously established account.	Define requirements for recovery via repeated identity proofing.	Examine procedures for recovery via identity proofing to verify their usability and security.	4.2.1.4 A	CSP	ALL	
RWIP-1	Non-Proofing Recovery	The recovery of such subscriber accounts SHALL require the successful use of a saved recovery code, issued recovery code, or recovery contact.	Define non-proofing recovery.	Satisfied by ARM, IRC, and RECC controls	4.2.2.1 A	CSP	AAL1	

NIST SP 800-63-4 Conformance Criteria v0.1: 63B

Control Identifier	Control Name	Control Text	Objective	Assessment Method	Index	Target	Profile/XAL Level	Discussion
RAAL2-1	AAL2 Recovery Requirements	To recover an account that can authenticate at a maximum of AAL2, the CSP SHALL require the subscriber to complete one of the following: (1) Two recovery codes obtained using different methods from the set (i.e., saved, issued, and recovery contacts). (2) One recovery code from the set (i.e., saved, issued, and recovery contacts) plus authentication with a single-factor authenticator that is bound to the subscriber account. (3) Repeated identity proofing (provided that the subscriber account has been identity-proofed).	Specify methods of account recovery at AAL2.	Test to verify that one recovery method is required to recover a single authentication factor, two methods are required to recover two authentication factors, or repeated identity proofing is required at AAL2.	4.2.2.2 A	CSP	AAL2	
RAAL3-1	AAL3/IAL3 Recovery Requirements	If an account that can authenticate at AAL3 has been identity-proofed at IAL3, the CSP SHALL successfully perform a successful biometric comparison against the biometric characteristic collected during an initial on-site attended identity proofing session, as described in [SP800-63A].	Require biometric comparison for subscriber accounts to meet AAL3/IAL3 security requirements.	Examine procedures for account recovery at AAL3/IAL3 and verify that a successful biometric comparison is required.	4.2.2.3 A	CSP	AAL3	
ACCRN-1	Account Recovery Notification	In all cases, account recovery SHALL cause a notification to be sent to the subscriber or their designee, as described in Sec. 4.6.	Confirm that subscriber is notified of account recovery events.	Test by performing a recovery and verify that the subscriber is notified in one of the ways described.	4.2.3 A	CSP	ALL	
LTDC-1	Compromise Suspension Requirement	The CSP SHALL suspend, invalidate, or destroy compromised authenticators from the subscriber's account promptly following compromise detection.	Require processes for rendering compromised authenticators inoperative.	Examine procedures for handling compromised authenticators and verify that such authenticators are disabled.	4.3 A	CSP	ALL	
LTDC-2	Compromise Reporting Authenticators	Backup authenticators used for secure reporting of compromise SHALL be a password or a physical authenticator.	Establish requirements for authenticators reporting compromise.	Examine procedures for issuing backup authenticators for reporting.	4.3 B	CSP	ALL	Applies if CSP issues an authenticator for reporting.
EXP-1	Expired Authenticators Unusable	When an authenticator expires, it SHALL NOT be usable for authentication.	Ensure that expired authenticators are not usable.	Test by trying to authenticate with an expired authenticator and verify that it is unsuccessful.	4.4 A	CSP/Verifier	ALL	Applies if authenticators that expire are used.
EXP-2	Expired Authenticator Replacement	The replacement of expired authenticators SHALL conform to the binding process for an additional authenticator, as described in Sec. 4.1.2.	Require standard issuance process for issuance of replacements for expired authenticators.	Examine CSP procedures for issuing replacements for expired authenticators and verify that the full issuance process is used.	4.4 B	CSP	ALL	Applies if authenticators that expire are used.
INVAL-1	Authenticator Invalidation	CSPs SHALL promptly invalidate authenticators when a subscriber account ceases to exist (e.g., subscriber's death, the discovery of a fraudulent subscriber), when requested by the subscriber, when the authenticator is compromised, or when the CSP determines that the subscriber no longer meets its eligibility requirements.	Require a process for invalidating authenticators when required.	Examine process for receiving and processing invalidation requests from subscriber and other appropriate sources.	4.5 A	CSP	ALL	
INVAL-2	Authenticator Invalidation Reporting Risk	The CSP SHALL make a risk-based determination of the authenticity of invalidation requests from the subscriber.	Guard against denial-of-service attacks from spurious invalidation requests.	Examine process for evaluating invalidation requests that are received.	4.5 B	CSP	ALL	

NIST SP 800-63-4 Conformance Criteria v0.1: 63B

Control Identifier	Control Name	Control Text	Objective	Assessment Method	Index	Target	Profile/XAL Level	Discussion
ANOT-1	Notification Addresses	Events that require notification SHALL cause a notification to be sent to the notification addresses stored in the subscriber account. Notification addresses may be any means by which the subscriber can be reliably contacted, such as: postal address; email address; address (e.g., telephone number) to which a text message or voice message may be sent; and reference to the subscriber in a push notification service.	Define overall requirement for notification.	Examine implementation to verify that notification infrastructure exists.	4.6 A	CSP	ALL	
ANOT-2	Notification Multiple Address Support	CSPs SHALL support at least two notification addresses per subscriber account.	Require ability to establish multiple notification addresses for redundancy.	Test establishment of multiple notification addresses and verify that it is possible to establish at least two.	4.6 B	CSP	ALL	
ANOT-3	Notification Address Validation	For subscriber accounts that have undergone identity proofing, at least one address SHALL have been validated during the identity proofing process.	Require use of an identity proofed address for reliability.	Test with an identity proofed subscriber account to verify that an identity proofed address is already used.	4.6 C	CSP	AAL2/AAL3	Applies when subscriber account has been identity proofed.
ANOT-4	Notification Multiplicity	Notifications SHALL be sent to all notification addresses except postal addresses.	Require transmission to multiple addresses except postal addresses due to cost considerations.	Test by generating a notification to a subscriber account with multiple non-postal notification addresses, and verify that the notification is sent to all of them.	4.6 D	CSP	ALL	
ANOT-5	Postal Notification	However, notifications SHALL be sent to postal addresses if no other form of notification address is stored in the subscriber account or if the notification is for account recovery at AAL3.	Require notifications to postal addresses when they are the only notification address or for high assurance account recovery.	Test by generating a notification to subscriber accounts with only a postal address and by performing AAL3 account recovery and verify that a postal notification would be sent.	4.6 E	CSP	ALL	Applies when the only notification address is a postal address or AAL3 recovery.
ANOT-6	Postal Recovery Notification	Account recovery notifications SHALL also be sent to a postal address if the only other notification address in the subscriber account is the address to which an issued recovery code was sent.	Provide postal notification when needed to provide notification independent of account recovery.	Test by using an issued recovery code and verify that a postal notification would be sent if no other notification address exists.	4.6 F	CSP	ALL	Applies when using issued recovery codes and the only other notification address is postal.
ANOT-7	Notification Repudiation Instructions	The notification SHALL provide clear instructions, including contact information, in case the recipient repudiates the event associated with the notification.	Provide recourse for account holders receiving notification of events they did not authorize.	Examine notification and verify presence of instructions and contact information.	4.6 G	CSP	ALL	
SB-1	Session Secret Requirement	A session secret SHALL be shared between the subscriber's software and the accessed service.	Require that a session establishment be based on a shared secret.	Examine implementation to verify that a session secret is shared when a session is established based on authentication.	5.1 A	RP	ALL	
SB-2	Session Secret Presentation	The secret SHALL be directly presented by the subscriber's software, or possession of the secret SHALL be proven using a cryptographic mechanism.	Allow verification of the secret to be either direct or cryptographic	Examine process for verifying the shared secret to verify how it is verified.	5.1 B	RP	ALL	
SB-3	Session Continuity Secrets	The continuity of authenticated sessions SHALL be based on the possession of a session secret that is issued by the session host at the time of authentication and optionally refreshed during the session. The nature of a session depends on the application, such as: a web browser session with a "session" cookie; and an instance of a mobile application that retains a session secret.	Provide examples of session verification methods.	Satisfied by SB-1 and SB-2.	5.1 C	RP	ALL	

NIST SP 800-63-4 Conformance Criteria v0.1: 63B

Control Identifier	Control Name	Control Text	Objective	Assessment Method	Index	Target	Profile/XAL Level	Discussion
SB-4	Session Secrets Not Replace Authentication	Cookies and similar "remember my browser" features SHALL NOT be used instead of authentication except as provided for reauthentication at AAL2 in Sec. 2.2.3 when the inactivity limit has been exceeded but the time limit has not.	Emphasize that secrets may not be used to bypass multifactor authentication requirements.	Examine implementation to verify that multifactor authentication requirements are enforced regardless of session secrets.	5.1 D	RP	ALL	
SB-5	Session Lifetime Limits	However, RPs and CSPs SHALL ensure that the session lifetime limits described in Sec. 2.2.3 are enforced even when a knowledge of the session secret is demonstrated.	Emphasize that secrets may not be used to bypass reauthentication time limits.	Examine implementation to verify that reauthentication requirements are enforced regardless of session secrets.	5.1 E	RP/CSP	ALL	
SB-6	Session Secret Generation	The secret used for session binding SHALL be generated by the session host in direct response to an authentication event.	Specify party generating session secret.	Examine protocol to verify that session secret is generated by host upon authentication.	5.1 F	RP	ALL	
SB-7	Session AAL Limitation	A session MAY be considered at a lower AAL than the authentication event but SHALL NOT be considered at a higher AAL than the authentication event.	Allow sessions to be used at lower AALs than authenticated.	Test to verify that it is possible to use a session at a lower AAL than was authenticated but not a higher AAL.	5.1 G	RP	ALL	Applies to relying parties that support applications at multiple AALs.
SB-8	Session Secrets Result From Authentication	Secrets used for session binding SHALL be established during or immediately following authentication.	Require tight relationship between authentication and session binding.	Satisfied by SB-6.	5.1 #1	RP	ALL	
SB-8.1	Session Secret Generation Requirements	Secrets used for session binding SHALL be established using input from an approved random bit generator, as described in Sec. 3.2.12, and are at least 64 bits in length.	Ensure that a sufficiently random session secret is used.	Examine implementation to see how the session secret is generated and verify that it uses an approved random bit generator and is of sufficient length.	5.1 #2	RP	ALL	
SB-8.2	Session Secret Logout Invalidation	Secrets used for session binding SHALL be erased or invalidated by the session subject when the subscriber logs out.	Ensure that sessions are no longer usable following logout.	Examine implementation to verify that session secrets are no longer valid following logout.	5.1 #3	RP	ALL	
SB-8.3	Session Secret Establishment	Secrets used for session binding SHALL be either transferred from the session host to the RP or CSP via an authenticated protected channel or derived from keys that are established as part of establishing a valid, mutually authenticated protected channel.	Define secure methods of establishing the session secret.	Examine implementation to verify that the session secret is transferred or derived as described.	5.1 #4	RP/CSP	ALL	
SB-8.4	Session Secret Time Limits	Secrets used for session binding SHALL time out and not be accepted after the times specified in Sec. 2.1.3, Sec. 2.2.3, and Sec. 2.3.3, as appropriate for the AAL.	Ensure that session secrets are invalidated when time out times are met.	Examine implementation to verify that necessary timers are in place and used to invalidate session secrets.	5.1 #5	RP	ALL	
SB-8.5	Session Secret Intermediary Protection	Secrets used for session binding SHALL be unavailable to intermediaries between the host and the subscriber's endpoint.	Prevent intermediaries and eavesdroppers from accessing session secrets	Satisfied by SB-8.3.	5.1 #6	RP/CSP	ALL	
SB-9	Session Transport Security Maintenance	Following authentication, authenticated sessions SHALL NOT fall back to an insecure transport (e.g., from https to http).	Prevent sessions from falling back to an insecure state	Test , if insecure transport is supported at all, by attempting to substitute an insecure transport and verify that it is unsuccessful.	5.1 I	RP	ALL	
SB-10	CSRF Protection Requirement	POST/PUT content SHALL contain a session identifier that the RP SHALL verify to protect against cross-site request forgery (CSRF).	Protect against cross-site request forgery.	Examine content (e.g., with browser developer tools) to verify that session identifiers are present.	5.1 J	RP	ALL	
AT-1	Access Tokens Not Presence	The RP SHALL NOT interpret the presence of an access token as an indicator of the subscriber's presence in the absence of other signals.	Ensure that session secrets rather than access/refresh tokens define validity of a session.	Test by logging out of a federated session while a valid access token exists and verify that the session has been terminated.	5.1.2 A	RP	ALL	Applies to sessions established through federation. Note: last sentence of 5.1.2, "authentication session" -> "authenticated session"

NIST SP 800-63-4 Conformance Criteria v0.1: 63B

Control Identifier	Control Name	Control Text	Objective	Assessment Method	Index	Target	Profile/XAL Level	Discussion
REAUTH-1	Periodic Reauthentication Requirement	The periodic reauthentication of sessions SHALL be performed to confirm the subscriber's continued presence at an authenticated session (e.g., that the subscriber has not walked away without logging out).	Ensure that a reauthentication process exists.	Examine implementation to verify use of a reauthentication process following session time out.	5.2 A	RP	ALL	
REAUTH-2	Reauthentication Timeout Terminates Session	When either the overall or inactivity timeout expires, the session SHALL be terminated.	Ensure that time out results in process termination.	Satisfied by SB-8.4.	5.2 B	RP	ALL	
REAUTH-3	Reauthentication Timeout Reset	Session activity SHALL reset the inactivity timeout, and successful reauthentication during a session SHALL reset both timeouts.	Define criteria for resetting timeouts.	Examine implementation of timeouts to verify that they are reset under these circumstances.	5.2 C	RP	ALL	
REAUTH-4	Reauthentication Documentation	Agencies SHALL establish and document the inactivity and overall time limits being enforced in a system security plan, such as that described in [SP800-39].	Verify documentation of timeouts.	Examine system security plan to verify that timeouts are described.	5.2 D	RP	ALL	
REAUTH-5	Reauthentication RP Authoritative	The IdP can communicate the time and details of the authentication event to the RP, but the RP SHALL be authoritative as to whether the reauthentication requirements have been met.	Establish precedence for control of session timing.	Examine implementation of timeouts at the RP to verify that it is not over-dependent on timing from the IdP.	5.2 E	RP	ALL	Applies to sessions established through federation.
SESSM-1	Session Monitoring Documentation	Collection, the storage of expected subscriber characteristics, and the processing of session characteristics SHALL be included in the privacy risk assessment described in Sec. 7.	Verify documentation of session monitoring.	Examine privacy risk assessment to verify that any use of session monitoring is included.	5.3 A	RP	ALL	
USEL-1	Consent Measures Voluntary	Therefore, as stated in Sec. 2.4.3, when CSPs use consent measures, the subscriber's acceptance of additional uses SHALL NOT be a condition of providing authentication services.	Ensure that consent measures are voluntary.	Satisfied by PR-3.	7.3 A	CSP	ALL	
CAK-1	Syncable Authentication Key Generation	All keys SHALL be generated using approved cryptography.	Determine that only secure, well-vetted cryptographic algorithms are being used.	Examine documented policies or practices to determine that only approved cryptographic algorithms can be used.	B.2 #1	CSP	Syncable	
CAK-2	Syncable Authentication Key Fabric Requirements	Authentication keys that are cloned or exported from a device to a sync fabric SHALL only be stored in an encrypted form using a key with the minimum security strength specified in the latest revision of [SP800-131A] (i.e., 112 bits as of the date of this publication).	Protection of authentication keys in the sync fabric.	Examine sync fabric implementation(s) to verify that keys are stored in encrypted form with sufficient strength.	B.2 #2	CSP	Syncable	
CAK-3	Syncable Private-Key Operations Local	All authentication transactions SHALL perform private-key operations on the local device using cryptographic keys that are generated on-device or recovered from the sync fabric.	Require cryptographic operations to be performed locally.	Examine implementation to verify that the source of private keys is local or from the sync fabric.	B.2 #3	CSP	Syncable	
CAK-4	Syncable Key Fabric Access Control	Authentication keys stored in the sync fabric SHALL be protected by access control mechanisms such that only the authenticated user can access their authentication keys in the sync fabric.	Control access to keys in the sync fabric.	Examine implementation to verify that authentication keys are only available to the subscriber.	B.2 #4	CSP	Syncable	

NIST SP 800-63-4 Conformance Criteria v0.1: 63B

Control Identifier	Control Name	Control Text	Objective	Assessment Method	Index	Target	Profile/XAL Level	Discussion
CAK-5	Syncable Key Fabric MFA	User access to authentication keys in the sync fabric SHALL be protected by AAL2-equivalent MFA to preserve the integrity of the authentication protocols using the synced keys.	Require sufficient authentication to access keys in the sync fabric.	Examine sync fabric implementation(s) to verify that at least AAL2 authentication is required to access authentication keys.	B.2 #5	CSP	Syncable	
CAK-6	Syncable Authenticator Documentation	These general requirements and any other agency-specific requirements for using syncable authenticators SHALL be documented and communicated, including on public-facing websites and digital service policies, where applicable.	Clearly document controls on use of syncable authenticators.	Examine documentation, including on websites, of syncable authenticator guidelines.	B.2 #6	CSP/Verifier	Syncable	
CAK-7	Syncable Key Management	Authenticators that enable the use of syncable authentication keys SHOULD provide a user interface (UI) that allows subscribers to view the services for which they have created a syncable authentication key, whether that key has been synced, and where that key has been synced. The UI SHALL NOT expose the authentication key itself.	Require manageability of syncable authentication keys by the subscriber.	Test to verify the ability of the subscriber to obtain information about their syncable keys, but not the key itself.	B.2 #7	CSP	Syncable	
CAK-8	Syncable Key Fabric FISMA	Federal enterprise authentication keys SHALL be stored in sync fabrics that have achieved Federal Information Security Modernization Act (FISMA) [FISMA] moderate protections or equivalent.	Require FISMA compliance for federal enterprise authentication keys.	Examine FISMA certification of sync fabric to verify that it meets provides moderate protection.	B.2 #8	CSP	Syncable	Applies to federal enterprise use cases only.
CAK-9	Syncable Key Device Management	Devices (e.g., mobile phones, laptops, tablets) that generate, store, and sync authenticators containing federal enterprise authentication keys SHALL be protected by mobile device management software or other device configuration controls that prevent the syncing or sharing of keys to unauthorized devices or sync fabrics.	Restrict choices of sync fabric to those approved by the agency.	Examine acceptance of authentication using syncable authenticators to verify that authentication requires appropriate device configuration management.	B.2 #9	CSP	Syncable	Applies to federal enterprise use cases only.
CAK-10	Syncable Key Fabric Management	Access to the sync fabric SHALL be controlled by agency-managed accounts (e.g., a central identity and access management solution, platform-based managed account) to maintain federal enterprise control over the authentication key's life cycle.	Maintain federal control over authentication keys throughout their life cycle.	Examine choices of sync fabric approved by the agency to verify that it manages access to the fabric.	B.2 #10	CSP	Syncable	Applies to federal enterprise use cases only.
IMPR-1	Syncable Key User Verification	Verifiers SHALL indicate that user verification (UV) is preferred and SHALL inspect responses to confirm the value of the UV flag.	Prefer syncable authenticators providing multi-factor authentication.	Examine implementation to verify that the value of the UV flag is observed.	B.3 A	Verifier	Syncable	
IMPR-2	Syncable Non-UV Key SF	If the user is not verified, agencies SHALL treat the authenticator as a single-factor cryptographic authenticator.	Authentication without user verification is single-factor.	Examine implementation to verify that authentication without user verification requires an additional password or biometric factor.	B.3 B	Verifier	Syncable	
IMPR-3	Syncable Key Flag Trust	Agencies SHALL evaluate the use cases for syncable authenticators and determine the appropriate access policy decisions that they intend to make based on returned information including flags and attestation.	Provide basis for trusting information such as flags received from the authenticator.	Examine procedures and their basis to determine that appropriate attention has been paid to reliability of information received from syncable authenticators.	B.3 C	CSP	Syncable	

NIST SP 800-63-4 Conformance Criteria v0.1: 63C

Control Identifier	Control Name	Control Text	Objective	Assessment Method	Index	Target	Profile/XAL Level	Discussion
FAL-1	FAL Compliance	In order to fulfill the requirements for a given FAL, the federation transaction SHALL meet or exceed all requirements listed for that FAL.	Determine that the IdP and RP each enforce all requirements associated with the applicable FAL and that every federation transaction meets or exceeds the criteria defined for that FAL.	Satisfied when all controls applicable to the asserted FAL are satisfied.	2.0 A	IdP/RP	ALL	This requirement ensures that the assurance level claimed in a federation transaction reflects the actual technical protections in use. Each FAL defines minimum requirements for audience restriction, replay protection, assertion injection protection, trust agreement establishment, identifier and key establishment, and presentation. Both the IdP and RP must enforce those requirements so that no transaction is represented as operating at a higher FAL than the implemented controls support. See also SECC-4, which is a summative control for xAL baseline compliance.
CFAL-1	Federation Requirements	At all FALs, all federation transactions SHALL comply with the requirements in Sec. 3 to deliver an assertion to the RP and create an authenticated session at the RP.	Determine whether all federation transactions comply with the requirements in Section 3 for assertion delivery and RP session establishment.	For IdPs, satisfied by AAD-1, AAD-4, AAD-6, TSI-1, IDA-1 through IDA-3, ARTP-1, ARTI-1, SIGNA-1, SIGNA-3, SIGNA-4, and AUDR-1; also by PROXY-1, PROXY-3 if proxied federation is used; PPI-1, PPI-4 through PPI-8, PPI-10 if PPIs are used; DAV-1 if derived attribute values are used; and ENCA-1 if encrypted assertions are used. If FAL3, satisfied by HKA-1, HKA-3, HKA-5 when HoK assertions are used, and BAUTH-1 when the bound-authenticators are used. For RPs, satisfied by ASRP-1, SIGNA-2, and AUDR-2; also by FEDID-1, FEDID-2 when federated identifiers are used or ACCR-1 when account resolution is used; ABUN-2 and ABUN-3 if attribute bundles are used; and IDAP-3 if identity APIs are used. If FAL3, satisfied by ASRP-2; also HKA-2, RPPHBA-1, RPPHBA-3, RPPHBA-4 when HoK assertions are used; and BAUTH-5, BAUTH-7, RPPHBA-1, RPPHBA-3, and RPPHBA-4 when the bound-authenticators are used.	2.1 A	IdP/RP	ALL	This is a summative control based on the outcomes of all controls governing assertion delivery and RP session creation. Compliance is demonstrated when all applicable Section 3 requirements are met.
CFAL-2	Assertion Validation	At all FALs, the RP SHALL validate the assertion from the IdP, since the RP needs to trust the IdP to provide valid assertions representing the subscriber's authentication event.	Determine whether the RP validates each assertion received from the IdP to ensure its authenticity, integrity, and origin before establishing a session.	Satisfied by ARTC-10 and ARTVL-3.	2.1 B	RP	ALL	This is a summative control. Assertion validation is assessed under ARTC-10 (traditional federation) and ARTVL-3 (subscriber-controlled wallets).

NIST SP 800-63-4 Conformance Criteria v0.1: 63C

Control Identifier	Control Name	Control Text	Objective	Assessment Method	Index	Target	Profile/XAL Level	Discussion
CFAL-3	Security Control Requirements	All parties in the federation SHALL employ security controls, as discussed in Sec. 3.11.	Determine whether the party undergoing assessment employs the security controls required in Section 3.11.	For IdPs/CSPs, satisfied by SECC-1, SECC-4, PSI-1 through PSI-3, and SSIN-2. For RPs, satisfied by SECC-2 through SECC-4, PSI-1 through PSI-3, and SSIN-1 through SSIN-3.	2.1 C	CSP/IdP/RP	ALL	Section 3.11 establishes a tiered security controls baseline for federation participants. CSPs and IdPs must implement appropriately tailored controls from at least the SP 800-53 moderate baseline (or equivalent federal or industry standard such as FedRAMP). RPs must implement at least the low baseline, but RPs that request or process personal information must step up to the moderate baseline. All parties must also satisfy the minimum assurance-related controls for their systems. This is a summative control that relies on the conclusions of all applicable assessments related to Section 3.11 in this catalog. Compliance is demonstrated when all Section 3.11 requirements applicable to the assessed party are met.
FAL1-1	Approved Cryptography: Assertion Signatures	At FAL1, the IdP SHALL sign the assertion using approved cryptography.	Determine whether approved cryptography is used for the assertion signature.	Examine the IdP's assertion signing configuration to confirm that all assertions are cryptographically signed using approved algorithms and key sizes. Test by generating an assertion from the IdP and verifying the presence of a cryptographic signature using approved cryptography. See SIGNA-4 for assessment of the specific signature mechanism and key type.	2.2 A	IdP	ALL	SP 800-63-4 defines approved cryptography as any algorithm, hash function, random bit generator, or similar technique that is FIPS-approved or NIST-recommended. For assertion signatures, the relevant standards are FIPS 186-5 (Digital Signature Standard, covering RSA, ECDSA, and EdDSA) and SP 800-131A (algorithm and key length transition schedules). Assessors should verify the IdP's signing algorithm and key size against these references.
FAL1-2	Signature Verification	The RP SHALL validate the signature using the verification key associated with the expected IdP.	Determine whether the RP validates the assertion signature using the verification key associated with the expected IdP.	Examine the RP's signature-validation logic, configuration, and key-establishment documentation to verify that the RP selects the verification key based on the expected IdP identifier and validates assertion signatures only with the verification key associated with that IdP. Examine the documented results of conformance testing to the IdP/RP implemented standards, protocols, and profiles if available (e.g., OIDC federation OP test) Test by setting up a test IdP and (1) Presenting a valid assertion signed by the expected IdP's key. Verify acceptance. (2) Presenting an assertion signed by a different trusted IdP's valid key. Verify rejection. (3) Presenting an assertion claiming the expected IdP as issuer but signed with a different IdP's key. Verify rejection. (4) Presenting an assertion signed with an unknown or untrusted key. Verify rejection. (5) Presenting an assertion with no signature. Verify rejection.	2.2 B	RP	ALL	This requirement ensures that the RP verifies the cryptographic signature on assertions to confirm their authenticity and integrity. The RP must use the verification key specifically associated with the expected IdP. For assessment of how the RP obtains and establishes that key through trusted mechanisms (discovery, registration, manual exchange, or federation authorities), see ICKM-1 and ICKM-2. For assessment of the specific signature mechanism type, see SIGNA-4.

NIST SP 800-63-4 Conformance Criteria v0.1: 63C

Control Identifier	Control Name	Control Text	Objective	Assessment Method	Index	Target	Profile/XAL Level	Discussion
FAL1-3	FAL1 Audience Restriction	At FAL1, the assertion SHALL be audience-restricted to a specific RP or set of RPs.	Determine whether the IdP includes audience restrictions in all FAL1 assertions targeting specific RP(s).	Satisfied by AUDR-1.	2.2 C	IdP	FAL1	At all FALs, the IdP must include audience restrictions identifying the intended recipient(s). FAL1 allows multiple RPs per assertion, but the assertion must explicitly list all intended recipients. This prevents unscoped assertions that could be accepted by any RP. To reduce the risk of assertion replay, IdPs SHOULD issue assertions designated for a single audience whenever possible. Restriction to a single audience becomes mandatory at FAL2 and higher.
FAL1-4	FAL1 RP Audience Validation	At FAL1, the RP SHALL validate that it is one of the targeted RPs for the given assertion.	Verify that the RP validates each received assertion to ensure its own identifier appears in the audience restriction and rejects any assertion not explicitly targeted to it.	Satisfied by AUDR-2.	2.2 D	RP	FAL1	The RP must check that its identifier appears in the assertion's audience field. This prevents replay attacks where assertions intended for other RPs are injected at an unintended RP. If the RP utilizes an IdP that lists multiple RPs in a single assertion at FAL1, confirm that the RP correctly handles assertions containing multiple RP identifiers.
FAL1-5	FAL1 RP Assertion Replay Protection	Each RP in the [assertion] audience SHALL enforce replay protection mechanisms in the assertion to ensure that the same assertion is not accepted by a given RP multiple times.	Verify that the RP enforces replay protection by detecting and rejecting any assertion that has already been accepted, ensuring the same assertion cannot be used more than once.	Examine RP documentation, federation configuration, code, and test results to confirm that replay detection mechanisms exist (e.g., nonce validation, assertion ID, and timestamp) and that repeated assertions are rejected. Examine documented results of conformance testing to the standards, protocols, and profiles implemented by the RP, if available. Test the RP configuration by replaying a previously accepted, valid assertion. Confirm rejection.	2.2 E	RP	ALL	Replay protection ensures that a given RP does not accept the same assertion more than once within its validity time window. At FAL1, where multi-audience assertions are permitted, each RP in the audience may accept the assertion once - but no individual RP may accept it a second time. Common replay detection mechanisms include tracking assertion identifiers, validating nonces, and enforcing timestamp-based expiration windows.

NIST SP 800-63-4 Conformance Criteria v0.1: 63C

Control Identifier	Control Name	Control Text	Objective	Assessment Method	Index	Target	Profile/XAL Level	Discussion
FAL2-1	Assertion Injection Protection	At FAL2, the assertion SHALL be strongly protected from assertion injection attacks, as discussed in Sec. 3.11.1.	Determine whether the RP implements strong protections against assertion injection attacks consistent with Sec. 3.11.1.	Satisfied by implementing all of the following: FAL1-1, FAL1-2, FAL1-5, FAL2-2, ARTRQ-1, AUDR-1, ARTC-7, ARTC-10 items 3 and 5, AUDR-2, BCP-1 through BCP-10, FCP-1 through FCP-3.	2.3 A	RP	FAL2/FAL3	An assertion injection attack in the context of a federated protocol consists of an attacker attempting to force an RP to accept or process an assertion or assertion reference in order to gain access to the RP or deny a legitimate subscriber access to the RP. The attacker does this by taking an assertion or assertion reference and injecting it into a vulnerable RP. A successful attacker can trick an RP into binding the attacker's session to the federated identifier in the assertion. The attacker's assertion could be either stolen from a legitimate subscriber or manufactured to perpetrate the attack. Protection from assertion injection attacks is recommended at all FALs and required at FAL2 and above. In all cases, the RP needs to take reasonable steps to prevent an attacker from presenting an injected assertion or assertion reference based on the nature of the RP software, the capabilities of the federation protocol in use, and the needs of the overall system.
FAL2-2	RP-Initiated Transactions	The federation transaction SHALL be initiated by the RP.	Verify that, at FAL2 and above, all federation transactions are initiated by the RP rather than the IdP.	Examine the RP's federation implementation and protocol configuration to confirm that all authentication requests originate from the RP. Verify that unsolicited IdP-initiated assertions are not accepted at FAL2 or above. Test the RP flow by delivering an assertion directly to the RP's federation endpoint without initiating the transaction at the RP. Confirm the RP rejects it.	2.3 B	RP	FAL2/FAL3	IdP-initiated federation processes are prohibited at FAL2 and FAL3 to prevent the RP from accepting unsolicited assertions and assertion references from the IdP. Inclusion and validation of RP-provided nonces in assertions is an indication of an RP-initiated transaction. However, this prohibition does not include processes in which an external party (e.g., the IdP or a federation authority) signals the RP to start a federation process with the IdP, allowing the RP to begin the federation transaction and securely await a response within that transaction.
FAL2-3	FAL2+ Audience Restriction	At FAL2, the assertion SHALL be audience restricted to a single RP.	Verify that, at FAL2 and above, the IdP includes an audience restriction in each assertion that designates exactly one RP as the intended recipient.	Satisfied by AUDR-1.	2.3 C	IdP	FAL2/FAL3	At FAL2, assertions must be explicitly scoped to a single RP to prevent cross-RP assertion replay. Unlike FAL1, where multiple audiences are permitted, FAL2 and above require one-to-one binding between the assertion and the RP, ensuring that a captured assertion cannot be reused at another RP within the federation.
FAL2-4	RP Assertion Replay Protection Enforcement	The RP SHALL enforce replay protection mechanisms in the assertion.	Determine whether the RP enforces replay protection mechanisms.	Satisfied by FAL1-5.	2.3 D	RP	FAL2/FAL3	This is the FAL2/FAL3 restatement of the replay protection requirement from Sec. 2.2 (see FAL1-5). At FAL2+, multi-audience assertions are not permitted, so replay protection applies to single-audience assertions only. The assessment methodology and test procedures are the same as FAL1-5.

NIST SP 800-63-4 Conformance Criteria v0.1: 63C

Control Identifier	Control Name	Control Text	Objective	Assessment Method	Index	Target	Profile/XAL Level	Discussion
FAL2-5	Federated Identifier Privacy Protection	At FAL2, federated identifiers SHALL NOT contain plaintext personal information, such as usernames, email addresses, employee numbers, etc.	Verify that, at FAL2 and above, the IdP issues federated identifiers that do not include any plaintext personal information such as usernames, email addresses, employee numbers, or other directly identifying data.	Examine the IdP's federated identifier construction rules, documentation, and representative issued identifiers to determine whether any federated identifier contains plaintext personal information, such as usernames, email addresses, employee numbers, names, phone numbers, or similar directly identifying values. Test by generating representative identifiers for sample subscriber accounts and verifying that no identifier reveals plaintext personal information.	2.3 E	IdP	FAL2/FAL3	At FAL2 and higher, identifiers must be privacy-preserving and non-identifying. This protects subscriber privacy if assertions are intercepted.
FAL2-6	Pre-Established trust agreements	At FAL2 [or higher], a trust agreement SHALL be established prior to the federation transaction taking place (i.e., a "pre-established" trust agreement), as discussed in Sec. 4.3.1.	Verify that, at FAL2 and above, a trust agreement between the IdP and RP is established and in effect before any federation transaction occurs.	Satisfied by PETA-1, PETA-2, PETA-3, PETA-4, and PETA-7; additionally satisfied by PETA-6 where shared signaling is used, and by PETA-5 where FAL3 is permitted within the trust agreement.	2.3 F	IdP/RP	FAL2/FAL3	At FAL2 and above, the IdP and RP must have a trust agreement in place before any federation transaction occurs. The agreement must cover all terms identified in Section 4.3.1, but those terms need not appear in a single document. The required content may be spread across multiple artifacts that, together, establish the technical, operational, and legal basis for trust. Acceptable artifacts can include binding documents such as contracts, memoranda of understanding, or service agreements, and non-binding but authoritative materials such as CSP practice statements, federation authority agreements, or published federation policies. For example, an IdP may publish a policy describing the assurance levels (xALs) it supports, the security controls it enforces, and the responsibilities of RPs. If the RP documents that it has received and accepted that policy, those terms satisfy the corresponding portion of the trust agreement.
FAL2-7	Key Protection	IdPs operated by or on behalf of federal agencies that present assertions at FAL2 or higher SHALL protect signing keys used to generate assertions with mechanisms validated at [FIPS140] Level 1 or higher.	Determine whether the IdP protects assertion-signing keys using cryptographic modules validated at FIPS 140 Level 1 or higher.	Examine the IdP's federation system documentation and configuration to verify that assertion-signing keys are generated, stored, and used only within a FIPS 140-validated cryptographic module. Confirm that the module appears on the CMVP validation list with a status of Active and is validated at Level 1 or higher.	2.3 G	IdP	FAL2/FAL3	Assessment is required when: The IdP provides assertions to one or more federal agencies or the IdP is a federal agency.

NIST SP 800-63-4 Conformance Criteria v0.1: 63C

Control Identifier	Control Name	Control Text	Objective	Assessment Method	Index	Target	Profile/XAL Level	Discussion
FAL3-1	RP Verification of Subscriber Authenticator Control	At FAL3, the RP SHALL verify that the subscriber is in control of an authenticator in addition to the assertion.	Determine whether the RP verifies subscriber control of an authenticator beyond the assertion at FAL3.	For holder-of-key assertions, satisfied by HKA-2. For bound authenticators, satisfied by RPPHBA-1 and RPPHBA-4.	2.4 A	RP	FAL3	This is a summative control. Compliance is demonstrated when the authenticator control mechanism(s) utilized by the RP have been assessed. At least one of these two mechanisms must be implemented to achieve compliance. At FAL3, the RP must verify both that it has received a valid assertion from the IdP and that the subscriber controls an authenticator in addition to the assertion. The subscriber-controlled authenticator is either identified in a holder-of-key assertion (see Sec. 3.15) or is an authenticator bound to the RP subscriber account (see Sec. 3.16). In both cases, the authenticator must be phishing-resistant, and the RP must verify proof of control before granting access.
FAL3-2	FAL3 Pre-Established Trust Agreements	At FAL3, a trust agreement SHALL be established prior to the federation transaction taking place (i.e., a "pre-established" trust agreement), as discussed in Sec. 4.3.1.	Determine whether trust agreement artifact(s) are pre-established prior to the federation transaction.	Satisfied by FAL2-6.	2.4 B	IdP/RP	FAL2/FAL3	
FAL3-3	Manual Identifier Establishment at FAL3	At FAL3, the identifiers for the CSP, IdP, and RP SHALL be established manually.	Determine whether identifiers for all federation parties are established through manual processes at FAL3.	Examine configuration documentation to confirm that federation identifiers (e.g., entity IDs, issuer URIs) for the CSP, IdP, and RP are manually configured by authorized personnel. Verify that dynamic registration (Sec. 4.4.2) is not enabled for FAL3 transactions.	2.4 C	CSP/IdP/RP	FAL3	FAL3 prohibits dynamic or automated identifier establishment. Party identifiers must be manually configured through direct administrative action. This requirement reduces automated attack vectors and ensures human verification of party identity before establishing FAL3 connections.
FAL3-4	Identifier-Key Association	Each [CSP, IdP, and RP] identifier SHALL be uniquely associated with the verification keys for the party represented.	Determine whether each party identifier is uniquely bound to that party's verification keys.	Examine configuration data or metadata to confirm that each federation participant's identifier (e.g., entity ID) maps to a distinct and authorized verification key or key set. Verify that no key is shared across different identifiers and that key rotation procedures preserve this one-to-one mapping.	2.4 D	CSP/IdP/RP	FAL3	This control prevents key-substitution and impersonation attacks by ensuring that when a signature verifies under a stored key, it can only be attributed to the single, specific party whose identifier is bound to that key in the local configuration.

NIST SP 800-63-4 Conformance Criteria v0.1: 63C

Control Identifier	Control Name	Control Text	Objective	Assessment Method	Index	Target	Profile/XAL Level	Discussion
FAL3-5	Verification Key Transmission	Verification keys SHALL be transmitted through a trusted mechanism, which could be manual or automated, as indicated in the trust agreement.	Determine whether verification keys are transmitted through a trusted mechanism, ensuring that key material is received from an authenticated and authorized source, and that the mechanism is documented as part of the trust agreement.	Examine documented procedures to determine how verification keys are exchanged, confirming that the mechanism matches the trusted method specified in the relevant trust agreement artifact(s). Determine whether the key exchange mechanism is manual or automated. For automated mechanisms, confirm conformance with ICKM-2. For manual mechanisms, verify that procedures are in place to confirm that the requesting party's identity has been sufficiently verified. Verify that the mechanism for transmitting the verification key is accurately documented and made available to the key recipients.	2.4 E	CSP/IdP/RP	FAL3	This requirement ensures that each participant obtains verification keys only from validated sources consistent with the established trust agreement. For example, a public-key certificate that represents the RP is uploaded to the IdP during a manual registration process. The RP is manually configured with a URL that it can use to download the IdP's public key. Alternatively, the IdP and RP could each upload their respective public keys to a federation authority and then download each other's keys from that same location. For a subscriber-controlled wallet, the RP could be manually configured with the URL that represents the CSP's public key. The RP fetches this public key and uses it to validate the signature of the attribute bundle presented by the subscriber-controlled wallet. See Sec. 3.6 for more information on the establishment, management, rotation, and revocation of keys and their association with identifiers.
RXAL-1	RP-Specified Minimum Acceptable xALs	IdPs SHALL support a mechanism for RPs to specify a set of minimum acceptable xALs as part of the trust agreement.	Determine whether the IdP provides a mechanism for RPs to specify minimum acceptable xALs in the trust agreement.	Satisfied by PETA-1, item (n).	2.5 A	IdP	ALL	PETA-1, item (n) requires the trust agreement artifact(s) to document the xALs required by the RPs the IdP supports.
RXAL-2	xAL Reporting	The IdP SHALL always indicate the resulting xAL in the assertion, even if the request has not been met.	Determine whether the IdP includes the actual xAL values achieved in every assertion.	The presence of xALs in assertions is satisfied by RXAL-3 (IAL), RXAL-4 (AAL), and RXAL-5 (FAL). Examine the IdP's federation processing logic, assertion-generation logic, configuration, and documentation to determine how the IdP handles transactions in which the RP requests xAL values that the IdP cannot satisfy. Determine whether the IdP issues an assertion containing the xAL values actually achieved, or fails the request and does not issue an assertion. Test the IdP using a transaction in which the RP requests xAL values that the IdP cannot satisfy. If the IdP is designed to issue an assertion in that case, determine that the assertion contains the xAL values actually achieved rather than the xAL values requested by the RP. If the IdP is designed to fail the request in that case, determine that the transaction fails and that no assertion is issued.	2.5 B	IdP	ALL	IdPs must report the actual IAL, AAL, and FAL in the assertion, regardless of what the RP requested. This allows RPs to make informed access decisions when requirements aren't met. For example, if the subscriber has an active session that was authenticated at AAL1, but the RP has requested AAL2, the IdP needs to prompt the subscriber for AAL2 authentication to increase the security of the session at the IdP during the subscriber's interaction at the IdP, if possible. The IdP sends the resulting AAL as part of the returned assertion, whether it is AAL1 (i.e., the step-up authentication request was not met) or AAL2 (i.e., the step-up authentication request was met successfully).

NIST SP 800-63-4 Conformance Criteria v0.1: 63C

Control Identifier	Control Name	Control Text	Objective	Assessment Method	Index	Target	Profile/XAL Level	Discussion
RXAL-3	IAL Reporting	The IdP SHALL inform the RP of the following information for each federation transaction: The IAL of the subscriber account being presented to the RP, or an indication that no IAL claim is being made.	Determine whether the IdP informs the RP of the IAL for each federation transaction.	If the IAL is static: Satisfied by RXAL-6. If the IAL is variable: Examine the IdP assertion schema, metadata, or other documentation to confirm that the IdP provides either a claim or attribute conveying the IAL of the subscriber account, or a defined mechanism by which no IAL claim is made in the assertion format used by the IdP. Test by initiating a transaction in which the IdP asserts an IAL value and determine that the assertion or associated message includes that value. Then, initiate a transaction in which the IdP omits an IAL claim and determine that the assertion output matches the IdP's documented no-claim mechanism.	2.5 C	IdP	ALL	The RP obtains this IAL information from a combination of the terms of the trust agreement (see Sec. 3.5) and information included in the assertion (see Sec. 4.9 and Sec. 5.8).
RXAL-4	AAL Reporting	The IdP SHALL inform the RP of the following information for each federation transaction: The AAL of the currently active session of the subscriber at the IdP, or an indication that no AAL claim is being made.	Determine whether the IdP informs the RP of the AAL for each federation transaction.	If the AAL is static: Satisfied by RXAL-6. If the AAL is variable: Examine the IdP assertion schema, metadata, or other documentation to confirm that the IdP provides either a claim or attribute conveying the AAL of the subscriber account, or a defined mechanism by which no AAL claim is made in the assertion format used by the IdP. Test by initiating a transaction in which the IdP asserts an AAL value and determine that the assertion or associated message includes that value. Then, initiate a transaction in which the IdP omits an AAL claim and determine that the assertion output matches the IdP's documented no-claim mechanism.	2.5 D	IdP	ALL	The RP obtains this AAL information from a combination of the terms of the trust agreement (see Sec. 3.5) and information included in the assertion (see Sec. 4.9 and Sec. 5.8).
RXAL-5	FAL Reporting	The IdP SHALL inform the RP of the following information for each federation transaction: The FAL of the federation transaction.	Determine whether the IdP informs the RP of the FAL for each federation transaction.	If the FAL is static: Satisfied by RXAL-6. If the FAL is variable: Examine the IdP assertion schema, metadata, or other documentation to confirm that the IdP provides a claim or attribute that conveys the FAL of the federation transaction. Test by initiating a transaction where the IdP asserts an FAL value - verify that the assertion or associated message includes that value.	2.5 E	IdP	ALL	The RP obtains this FAL information from a combination of the terms of the trust agreement (see Sec. 3.5) and information included in the assertion (see Sec. 4.9 and Sec. 5.8).

NIST SP 800-63-4 Conformance Criteria v0.1: 63C

Control Identifier	Control Name	Control Text	Objective	Assessment Method	Index	Target	Profile/XAL Level	Discussion
RXAL-6	Static xALs	If the xAL is unchanging for all messages between the IdP and RP (e.g., enterprise scenarios in which all subscribers are identity-proofed at the same IAL and use the same authenticator type), the xAL information SHALL be included in the terms of the trust agreement between the IdP and RP.	Determine whether the xAL information is included in the terms of the trust agreement between the IdP and RP when the xAL is unchanging for all messages.	Examine the trust agreement artifact(s) the IdP has established with its RPs to verify that values are stated for all static xALs. If PETA-1 item (m) documents fixed xAL values, confirm those values reflect the actual, unchanging xALs for all transactions between the IdP and each RP.	2.5 F	IdP	ALL	Assessment is required when: The xAL is the same for all messages between the IdP and RP (e.g., enterprise scenarios in which all subscribers are identity-proofed at the same IAL and use the same authenticator type). The IdP MAY indicate that no claim is made to the IAL or AAL for a given federation transaction. In such cases, no default value is assigned to the resulting xAL by the RP. That is, a federation transaction without an IAL declaration in either the trust agreement or the assertion is functionally considered to have "no IAL" and the RP cannot assume the account meets "IAL1," which is the lowest numbered IAL described in this suite.
RXAL-7	Variable xALs	If the xAL could be within a range of possible values specified by the trust agreement, then sufficient information SHALL be included as part of the assertion contents to allow the RP to determine the xALs.	Determine whether the IdP includes sufficient information in assertions for RPs to determine xALs when values vary within a range.	For IALs: Satisfied by the variable-xAL case in RXAL-3. For AALs: Satisfied by the variable-xAL case in RXAL-4. For FALs: Satisfied by the variable-xAL case in RXAL-5.	2.5 G	IdP	ALL	Assessment is required when: The xAL is within a range of possible values specified by the trust agreement
RXAL-8	xAL Requirements	The RP SHALL determine the minimum IAL, AAL, and FAL that it is willing to accept for access to any offered functionality and assess all IdP assertions to ensure that these xALs have been met before granting access to protected resources.	Determine whether the RP defines minimum acceptable xALs and validates that incoming assertions meet these requirements before granting access.	Examine the RP's Digital Identity Acceptance Statement (DIAS) to confirm that it specifies the minimum IAL, AAL, and FAL required for each offered function. Verify that RP configuration, authorization logic, or policy enforcement mechanisms use these DIAS-defined minimums when evaluating xAL information. Confirm that the RP's evaluation process accepts xALs conveyed through assertions, trust-agreement terms, or both, consistent with how the IdP provides them. Test by presenting transactions where the xALs meet the DIAS-defined minimums - verify that access is granted. Test by presenting transactions where any xAL falls below the DIAS-defined minimum - verify that access is denied. Test by presenting transactions where required xAL information is absent from both the assertion and trust-agreement terms - verify that access is denied.	2.5 H	RP	ALL	This requirement mandates that the RP determine the minimum IAL, AAL, and FAL it is willing to accept for access to any offered functionality through the Digital Identity Risk Management (DIRM) process outlined in NIST SP 800-63-4, Section 3, which requires RPs to conduct impact assessments, select initial xALs based on impact, tailor controls if needed, and document decisions in a Digital Identity Acceptance Statement (DIAS). The RP must then assess all IdP assertions to ensure these xALs have been met before granting access to protected resources. The RP must validate the indicated xALs in the assertion (or trust agreement for fixed xALs) against its required minimums, denying access if these requirements are not met. If no xAL claim is made, the RP must treat it as "no level" without defaults (e.g., no assumption of IAL1).

NIST SP 800-63-4 Conformance Criteria v0.1: 63C

Control Identifier	Control Name	Control Text	Objective	Assessment Method	Index	Target	Profile/XAL Level	Discussion
RXAL-9	Unmet xAL Requirements	If IdP responses do not meet the requested parameters, the RP SHALL have a mechanism for addressing these requests (e.g., declining the request or routing the user to an exception handling process).	Determine that the RP has a defined mechanism for handling cases where IdP responses do not meet the RP's requested or required xAL parameters.	Examine the RP's documentation and access-control logic to confirm the presence of a defined mechanism, such as request rejection, access denial, or an exception-handling workflow (such as a step-up mechanism) for transactions that do not satisfy the RP's minimum xAL requirements. Test by presenting transactions in which asserted xALs do not meet the RP's required minimums, or required xAL information is missing, and verify that the RP invokes the documented handling mechanism and does not grant protected access unless and until the RP's documented exception process is successfully completed.	2.5 I	RP	ALL	If an IdP response does not satisfy the RP's required xALs, the RP must have a mechanism for handling the mismatch. Acceptable mechanisms include denying the request or redirecting the user to an exception-handling process.
RXAL-10	IAL, AAL, & FAL Reporting	Consequently, the IdP SHALL provide the RP with sufficient information to determine the IAL, AAL, and the IdP's intended FAL for each federation transaction.	Determine whether the IdP provides the RP with sufficient information to determine the IAL, AAL, and FAL for each federation transaction.	Satisfied by RXAL-3 (IAL), RXAL-4 (AAL), and RXAL-5 (FAL).	2.5 J	IdP	ALL	
RXAL-11	RP FAL Compliance	The RP SHALL ensure that it meets its obligations in the federation transaction for the FAL declared in the transaction.	Verify that the RP fulfills all RP-specific requirements associated with the FAL declared in each federation transaction.	Satisfied by the RP components of the following controls: CFAL-1, CFAL-2, CFAL-3, FAL1-2, FAL1-4, and FAL1-5; additionally by FAL2-1, FAL2-2, and FAL2-6 at FAL2 and above; and at FAL3, by FAL3-3, FAL3-4, FAL3-5, and ASRP-2, and as applicable, HKA-2 plus RPPHBA-1, RPPHBA-3, and RPPHBA-4 when holder-of-key assertions are used, or BAUTH-5 plus RPPHBA-1, RPPHBA-3, and RPPHBA-4 when bound authenticators are used.	2.5 K	RP	ALL	This requirement states that the RP must adhere to all RP-directed obligations for the FAL declared for the transaction, either in the assertion or the trust agreement. Compliance is demonstrated when the RP satisfies all controls relevant to that FAL.
PROXY-1	Proxy FAL Accuracy	The FAL of the connection between the proxy and the downstream RP is considered to be the lowest FAL along the entire path, and the proxy SHALL accurately represent this to the downstream RP.	Determine whether a proxy does not mask a lower level FAL from its inbound side.	Examine the proxy's downstream federation configuration, xAL signaling logic, and applicable trust agreement terms to determine how the proxy communicates the resulting FAL to the downstream RP. Test by initiating a proxied transaction in which the inbound federation leg is at a lower FAL than the downstream leg supports, and determine that the proxy represents the resulting overall FAL to the downstream RP as the lower FAL through the mechanism used in that deployment.	3.3.3 C	IdP	ALL	<i>Assessment is required when: Proxied federation is used.</i> When using a proxy, different federation processes could be used on either side of the proxy. To avoid accidental upgrading of the transaction giving a false perception of security, the overall FAL for the transaction is limited to the lowest FAL used on either side of the proxy. For example, if FAL1 is used inbound to the proxy, but FAL2 (assertion encryption) is used outbound from the proxy, the proxy has to report the entire transaction at FAL1 to the downstream RP.
PROXY-2	Proxy Compliance	As a consequence, all normative requirements that apply to IdPs and RPs SHALL apply to proxies in their respective roles on each side.	Determine whether a proxy functions as both a compliant IdP and a compliant RP.	This is a summative control. The proxy is assessed against all applicable IdP controls for its IdP-facing role and all applicable RP controls for its RP-facing role.	3.3.3 A	IdP/RP	ALL	<i>Assessment is required when: Proxied federation is used.</i> A proxy needs to fulfill all of the normative requirements for both RPs and IdPs in order to be considered compliant, in addition to any proxy-specific requirements.

NIST SP 800-63-4 Conformance Criteria v0.1: 63C

Control Identifier	Control Name	Control Text	Objective	Assessment Method	Index	Target	Profile/XAL Level	Discussion
PROXY-3	Proxy Identifier	The federated identifier (see Sec. 3.4) of an assertion from a proxy SHALL indicate the proxy as the issuer of the assertion.	Determine whether the federated identifier of an assertion from a proxy indicates the proxy as the issuer of the assertion.	Examine the proxy's assertion templates, identifier-generation logic, or documentation to confirm that assertions issued by the proxy use an identifier that unambiguously represents the proxy itself as the issuer. Verify that no upstream IdP identifiers appear as the federated identifier in proxy-issued assertions. Test by first receiving an assertion from the upstream IdP at the proxy and verifying the upstream IdP is the issuer in the assertion, then by generating an assertion from the proxy to the downstream RP and verifying that the proxy is the issuer in the assertion.	3.3.3 B	IdP	ALL	<i>Assessment is required when: Proxied federation is used.</i> When a proxy acts as an intermediary between an upstream IdP and downstream RP, it creates new assertions based on upstream assertions. The federated identifier in the proxy's assertion must show the proxy as the issuer, not the original upstream IdP. This ensures proper attribution and prevents confusion about the assertion's source.
FEDID-1	Unique Federated Identifiers	When federated identifiers are used, the federated identifier SHALL be unique to that subscriber.	Determine whether the IdP/ CSP assigns identifiers that are unique to each subscriber.	This is a definitional statement, not an independently assessable requirement. Subject identifier uniqueness is an inherent property of any functioning IdP or CSP identity system. Enforcement of federated identifier uniqueness is satisfied by FEDID-2.	3.4 A	RP	ALL	Assessment is required when: Federated identifiers are used.
FEDID-2	Federated Identifier Single-Subscriber Association	Federated identifiers SHALL be associated with a single subscriber at the RP.	Determine whether the RP associates each federated identifier with a single subscriber.	For IdP transactions: Satisfied by ARTC-11. For subscriber-controlled wallet transactions: Satisfied by ARTCN-11.	3.4 B	RP	ALL	<i>Assessment is required when: Federated identifiers are used.</i> Different IdPs manage their subject identifiers independently and may assign identical values to different subscribers. The RP must never process a subject identifier without accounting for the issuer. Failure to do so creates a collision risk where subscribers from different IdPs are incorrectly mapped to the same RP subscriber account.
PPI-1	PPI Uniqueness	When using pairwise pseudonymous identifiers within the assertions generated by the IdP for the RP, the IdP SHALL generate a different federated identifier for each RP (see Sec. 3.4.1.2) or set of RPs (see Sec. 3.4.1.3).	Determine whether the IdP generates unique pairwise pseudonymous identifiers for each RP or authorized set of RPs.	Examine the PPI generation algorithm to confirm that it produces different outputs for each RP or authorized RP set. Test by logging the same subscriber into two unrelated RPs - verify different identifiers are asserted.	3.4.1.1 A	IdP	ALL	<i>Assessment is required when: Pairwise Pseudonymous Identifiers (PPIs) are used.</i> In some circumstances, it is desirable to prevent the subscriber account from being easily linked at multiple RPs through the use of a common subject identifier. A pairwise pseudonymous identifier (PPI) allows an IdP to provide multiple distinct federated identifiers to different RPs for a single subscriber account. The use of a PPI prevents different RPs from colluding to track the subscriber using the federated identifier.

NIST SP 800-63-4 Conformance Criteria v0.1: 63C

Control Identifier	Control Name	Control Text	Objective	Assessment Method	Index	Target	Profile/XAL Level	Discussion
PPI-2	PPI Correlation Prevention	If PPIs are used alongside identifying attributes, RPs SHALL establish privacy policies, processes, and procedures to prevent the correlation of subscriber data consistent with applicable legal and regulatory requirements.	Determine whether RPs prevent correlation of subscriber data when using PPIs alongside identifying attributes.	Examine the privacy policies, data-handling procedures, and data-sharing agreements to confirm they explicitly address the use of PPIs together with identifying attributes and prohibit correlating subscriber records or activity across organizations except where required or explicitly permitted by applicable law or regulation.	3.4.1.1 B	RP	ALL	<i>Assessment is required when: Pairwise Pseudonymous Identifiers (PPIs) are used.</i> Some identity attributes such as names, physical addresses, phone numbers, email addresses, and others can be used to identify a subscriber outside of a federation transaction. When PPIs are used alongside these kinds of identifying attributes, it may still be possible for multiple colluding RPs to re-identify a subscriber by correlation across systems. For example, if two independent RPs each see the same subscriber identified with a different PPI, the RPs could still determine that the subscriber is the same person by comparing the name, email address, physical address, or other identifying attributes carried alongside the PPI in the respective assertions.
PPI-3	PPI Mapping as Subscriber Information	If a proxy is used: The mapping of a PPI to other identifiers is considered subscriber information and SHALL be treated in accordance with the requirements in Sec. 3.10.1.	Determine whether the proxy treats PPI-to-identifier mappings as subscriber information subject to Section 3.10.1 requirements.	Satisfied by applying TSI-1, TSI-2, and TSI-3 to the PPI mapping data.	3.4.1.1 C	IdP	ALL	<i>Assessment is required when: Pairwise Pseudonymous Identifiers (PPIs) are used.</i> In a proxied federation model (see Sec. 3.3.3), the upstream IdP may not be able to generate a PPI for the downstream RP, since the proxy could blind the IdP from knowing which RP is being accessed by the subscriber. In such situations, the PPI is generally established between the IdP and the federation proxy. Acting as an IdP, the proxy can provide a PPI to the downstream RP. Depending on the protocol, the federation proxy may need to map the PPI back to the associated identifiers from upstream IdPs in order to allow the identity protocol to function. In such cases, the proxy will be able to track and determine which PPIs represent the same subscriber at different RPs.
PPI-4	Anonymous PPIs	The PPI SHALL contain no identifying information about the subscriber (e.g., username, email address, employee number).	Determine whether pairwise identifiers contain any identifying information about the subscriber.	Examine the documentation and generation algorithm used by the IdP to assign a pairwise identifier to a subscriber at an RP. Test by generating an assertion containing a PPI, then inspecting the resulting identifier to confirm it contains no readable personal information, such as usernames, email addresses, or employee numbers.	3.4.1.2 A	IdP	ALL	<i>Assessment is required when: Pairwise Pseudonymous Identifiers (PPIs) are used.</i> Pairwise identifiers are intended to protect the privacy of the subscriber and prevent collation of subscriber information. If the identifier itself has any identifying information in it, such as a username or employee number, this protection is lost. To prevent this, pairwise identifiers should be random and unguessable values or generated using information known only to the IdP, such as a secret key. If pairwise identifiers are not used, this requirement does not apply.

NIST SP 800-63-4 Conformance Criteria v0.1: 63C

Control Identifier	Control Name	Control Text	Objective	Assessment Method	Index	Target	Profile/XAL Level	Discussion
PPI-5	Unguessable PPIs	The PPI SHALL be difficult to guess by a party with access to information about the subscriber.	Determine whether pairwise identifiers can be guessed or easily generated by a party with access to subscriber information.	Examine the PPI generation algorithm to confirm that outputs cannot be predicted by a party with knowledge of the subscriber's attributes. Verify that generation relies on inputs known only to the IdP (e.g., a secret key) or uses an approved random bit generator.	3.4.1.2 B	IdP	ALL	Assessment is required when: Pairwise Pseudonymous Identifiers (PPIs) are used.
PPI-6	PPI Brute Force Protection	The PPI...SHALL provide sufficient entropy as to be unguessable by an attacker.	Determine whether PPIs provide sufficient entropy to be unguessable by an attacker.	Examine the mechanism used to generate the Pairwise Pseudonymous Identifier (PPI). If the PPI is generated as a random value, verify it is produced by an approved random bit generator with a security strength of at least 112 bits. If the PPI is derived from other subscriber information (e.g., using a key derivation function), verify the derivation uses an approved key derivation function with a secret key of at least 112 bits of security strength, as discussed in SP 800-131A.	3.4.1.2 C	IdP	ALL	<i>Assessment is required when: Pairwise Pseudonymous Identifiers (PPIs) are used.</i> Per NIST SP 800-131A Rev 2, Section 1.2.1, "a security strength of at least 112 bits is required at this time for applying cryptographic protection." This establishes the technical floor for what constitutes "sufficient entropy" to be "unguessable."
PPI-7	PPIs Unique to Each RP	Unless the PPI is designated as shared by the trust agreement, the PPI SHALL be disclosed to only a single RP.	Determine whether PPIs are disclosed to only a single RP unless designated as shared by the trust agreement artifact(s).	Satisfied by PPI-1.	3.4.1.2 D	IdP	ALL	Assessment is required when: Pairwise Pseudonymous Identifiers (PPIs) are used.
PPI-8	Justification and Consent for Shared PPIs	The same shared PPI SHALL be used for a specific set of RPs if all of the following criteria are met: (a) The trust agreement stipulates a shared PPI for a specific set of RPs. (b) The authorized party consents to and is notified of the use of a shared PPI. (c) Those RPs have a demonstrable relationship that justifies an operational need for the correlation, such as a shared security domain or shared legal ownership. (d) All RPs in the set of a shared PPI consent to being correlated in such a manner (i.e., one RP cannot request to have another RP's PPI without that other RP's knowledge and consent).	Determine whether shared PPIs are issued only when all four criteria are satisfied.	Examine trust agreement artifact(s) to confirm they stipulate a shared PPI for a specific, named set of RPs. Identify the authorized party and confirm documentation of their notification and consent to the shared PPI. Review documentation of the relationship between the RPs in the set to confirm a demonstrable operational need for correlation (e.g., shared security domain, shared legal ownership). Confirm that each RP in the set has documented consent to being correlated with the other RPs in the set.	3.4.1.3 A	IdP	ALL	Assessment is required when: Pairwise Pseudonymous Identifiers (PPIs) are used and common pairwise identifiers are requested by RPs.
PPI-9	Privacy Risks with Shared PPIs	The RPs SHALL conduct a privacy risk assessment to consider the privacy risks associated with requesting a shared PPI. See Sec. 7.2 for further privacy considerations.	Determine whether the RPs have conducted a privacy risk assessment before requesting a common identifier.	Examine the RP privacy risk assessment specific to its use of a shared PPI, verifying that it addresses the risks of subscriber correlation across the RPs in the shared set.	3.4.1.3 B	RP	ALL	<i>Assessment is required when: Pairwise Pseudonymous Identifiers (PPIs) are used and common pairwise identifiers are requested by RPs.</i> If an RP requests a common pairwise identifier, a privacy risk assessment can help the RP consider the likelihood that requesting the same identifier for a subscriber at multiple RPs could create a problem for the applicant and the impact if a problem did occur. The RP should be able to justify any response it takes to identified privacy risks, including accepting the risk, mitigating the risk, and sharing the risk. If common pairwise identifiers are not used, this requirement does not apply.

NIST SP 800-63-4 Conformance Criteria v0.1: 63C

Control Identifier	Control Name	Control Text	Objective	Assessment Method	Index	Target	Profile/XAL Level	Discussion
PPI-10	Shared PPIs only between Authorized RPs	The IdP SHALL ensure that only intended RPs are included in the set.	Determine whether only RPs that have been explicitly configured to use a common identifier are given the common identifier.	Examine by comparing the IdP's configured shared PPI sets against the authorized RP sets documented in the trust agreement artifact(s). Confirm that no RP appears in a shared PPI set without corresponding authorization.	3.4.1.3 C	IdP	ALL	Assessment is required when: Pairwise Pseudonymous Identifiers (PPIs) are used and common pairwise identifiers are requested by RPs.
TRUST-1	Trust Agreement Establishment	A trust agreement SHALL address one or more of the following relationships: IdP to CSP: The IdP trusts the CSP to provide access to attributes in subscriber accounts, through either an IdP onboarding process or the issuance of attribute bundles. The IdP trusts the CSP's identity proofing processes used in the establishment of the subscriber account. CSP to IdP: The CSP trusts the IdP to accurately represent subscriber identity attributes to RPs and to not disclose identity attributes outside of agreed-upon functionality. The CSP trusts the IdP to protect the release of attributes, such as requiring authentication of the subscriber or the presentation of an activation factor before attributes are released. RP to IdP: The RP trusts the IdP to accurately represent subscriber identity attributes as provided by the CSP. The RP trusts the IdP to authenticate or identify the subscriber when representing an authentication event. IdP to RP: The IdP trusts the RP to only use the requested attributes for its stated purposes RP to CSP: The RP trusts the CSP to provide access to subscriber identity attributes through IdPs. The RP trusts that the CSP has identity-proofed the subscriber and is managing the subscriber account.	Determine whether the trust agreement artifact(s) address the trust relationships applicable to the federation deployment.	Examine the set of federation relationships and verify that the trust agreement artifact(s) address each one. For each relationship addressed, verify that the artifact(s) document the parties' specific trust expectations.	3.5 A	CSP/IdP/RP	ALL	
TRUST-2	TAs for All Federation Transactions	All federation transactions SHALL be governed by the terms of one or more trust agreements between the applicable parties.	Determine whether all trust agreement requirements are met by all federation parties for all federation transactions.	Satisfied by PETA-1 through PETA-7 for pre-established trust agreements, or SDTAE-1 through SDTAE-4 for subscriber-driven trust agreements; by MTA-1 through MTA-9 when a multilateral trust agreement is used; and by TAGREE-1 through TAGREE-3, CR-1, CR-2, CSCW-1, CSCW-2, and RSCW-1 when subscriber-controlled wallets are used.	3.5 B	CSP/IdP/RP	ALL	Trust agreements can take different forms, including formal contractual agreements, informal dynamic user agreements, and other documented bilateral or multilateral trust decisions by the parties in the federation. In many cases, trust agreements can be implemented using a trust framework, which formalizes a set of rules for parties to connect with each other. Trust frameworks are often used by federation authorities to formalize the rules for the federation being managed by the federation authority.

NIST SP 800-63-4 Conformance Criteria v0.1: 63C

Control Identifier	Control Name	Control Text	Objective	Assessment Method	Index	Target	Profile/XAL Level	Discussion
TRUST-3	TA Customer Experience	The trust agreement SHALL establish customer experience requirements for the federation transaction, as discussed in Sec. 8.	Determine whether trust agreements establish customer experience requirements for federation transactions that involve the user.	Examine the trust agreement artifact(s) to verify that they include customer experience requirements for the federation transaction.	3.5 C	CSP/IdP/RP	ALL	Trust agreements must define customer experience parameters for federation transactions. Section 8 provides informative guidance that parties should consider when establishing these requirements. The specific customer experience requirements will vary based on the federation implementation and use case.
TRUST-4	TA CSP Proofing Process	The trust agreement SHALL include details of the proofing process used at the CSP for subscribers covered by the trust agreement, including any compensating controls and exception handling processes.	Determine whether the RP has access to the details of the proofing process used at the CSP for subscribers covered by the trust agreement, including any compensating controls and exception handling processes.	Examine the trust agreement artifacts for details on the CSP proofing process, compensating controls, and exception-handling procedures.	3.5 D	CSP/IdP	ALL	The required information may be conveyed directly by the CSP or relayed through the IdP, but it must be available to the relying party because the relying party is responsible for making risk based decisions.
TRUST-5	TA Subscriber Population	All trust agreements SHALL define a specific population of subscriber accounts to which the agreement is applicable.	Determine whether each participating party identifies the set of subscriber accounts covered by the relationship and documents how that population is scoped.	Examine the trust agreement artifacts to verify that the population of subscriber accounts covered by the federated relationship is explicitly defined.	3.5 E	CSP/IdP/RP	ALL	The exact means of defining this population are out of scope for this document. In many cases, the population is defined as the full set of subscriber accounts that the CSP manages and makes available through an IdP. In other cases, the population is a demarcated subset of accounts that are available through an IdP. It is also possible for an RP to have a distinct trust agreement established with an IdP for a single subscriber account, such as in a subscriber-driven trust agreement. For pre-established trust agreement artifact(s), this requirement is also addressed by PETA-1 item (e).
TRUST-6	Combined Trust Agreement Artifact(s)	If more than one trust agreement is applicable to a federation transaction, the combined set of terms of all applicable trust agreements SHALL constitute the effective trust agreement of that transaction.	Determine whether federation transactions are governed by an unambiguous set of trust agreement artifact(s) and whether each transaction meets the requirements of all applicable trust agreement artifact(s).	Examine the set of trust agreement artifacts applicable to the federation relationship (e.g., bilateral contracts, Memoranda of Understanding (MOUs), Interconnection Security Agreements (ISAs), federation authority operating rules, or subscriber terms of service). Then, review a representative sample of federation transactions, verifying that each transaction adheres to the combined requirements of all applicable trust agreement artifacts.	3.5 F	CSP/IdP/RP	ALL	If the combination of multiple agreements creates the potential for conflicting requirements, the parties should have a documented process or order of precedence to resolve those conflicts.
TRUST-7	Expected and Acceptable xALs	Trust agreements SHALL establish terms regarding expected and acceptable IALs, AALs, and FALs in connection with the federated relationship.	Determine whether the trust agreement artifact(s) establish terms regarding expected and acceptable IALs, AALs, and FALs for the federation relationship.	For pre-established trust agreement artifact(s): Satisfied by PETA-1 items (m) and (n). For subscriber-driven trust agreement artifact(s): Satisfied by SDTAE-1.	3.5 G	IdP/RP	ALL	

NIST SP 800-63-4 Conformance Criteria v0.1: 63C

Control Identifier	Control Name	Control Text	Objective	Assessment Method	Index	Target	Profile/XAL Level	Discussion
TRUST-8	Redress Coordination	Trust agreements SHALL define necessary mechanisms and materials to coordinate redress and issues between the different participants in the federation, as discussed in Sec. 3.5.3.	Determine whether the trust agreement artifact(s) explicitly define the mechanisms (e.g., processes, protocols, escalation paths) and materials (e.g., templates, contact information, shared documentation) required for coordinating the resolution of issues and providing redress among all participants in the federation.	Examine the trust agreement artifacts (e.g., federation agreements, operating rules, policies, metadata, onboarding documentation) for provisions addressing inter-party coordination of redress and issues, including: contact information or escalation paths for each party, procedures for routing subscriber complaints across party boundaries, defined responsibilities when issues span multiple parties, and timelines or service-level expectations for inter-party communications on subscriber issues. Interview representatives from each federation party to verify awareness of and adherence to documented coordination mechanisms, including understanding of how to escalate issues to partner organizations and what information is exchanged during coordination. Test by simulating a cross-party redress scenario (e.g., a subscriber complaint involving inaccurate attributes from the CSP affecting an RP session) and observing whether the agreement's mechanisms enable effective coordination and resolution.	3.5 H	CSP/IdP/RP	ALL	Federation transactions occur between multiple parties that are often controlled by multiple entities, and different stages of the federation transaction can lead to situations in which a subscriber would need to seek redress from the other parties. Federation, therefore, creates distributed responsibility for subscriber redress. A subscriber issue may originate at the RP but require resolution by the IdP or CSP, or may involve multiple parties simultaneously. Section 3.5.3 establishes specific redress obligations for each party type, but those individual requirements (covered in controls RR-1 through RR-6) address subscriber-facing mechanisms. This control addresses the coordination layer: how parties coordinate to resolve cross-organizational issues. The "mechanisms and materials" may include escalation procedures, contact directories, agreed-upon response timeframes, information-sharing protocols for issue investigation, and processes for jointly resolving disputes. In federations operating under a federation authority, these coordination mechanisms may be defined in the trust framework's operating rules. In bilateral relationships, they may be documented in contracts or service agreements. This control is a prerequisite for RR-2, which requires the RP to provide the subscriber with a means of initiating the redress process with the IdP or CSP. That subscriber-facing capability depends on the inter-party coordination mechanisms assessed here. This control does not assess whether subscribers have access to redress (see RR-1 through RR-6); it assesses whether the parties have established the infrastructure to work together when redress requires coordination.

NIST SP 800-63-4 Conformance Criteria v0.1: 63C

Control Identifier	Control Name	Control Text	Objective	Assessment Method	Index	Target	Profile/XAL Level	Discussion
TRUST-9	Data Retention Policies	Trust agreements SHALL declare the data retention policies expected of all parties.	Determine whether trust agreement artifact(s) declare the data retention policies expected of each federation party.	Examine the trust agreement artifacts (e.g., federation agreements, operating rules, data processing agreements, privacy policies referenced in agreements) for declarations of data retention policies applicable to each party, including: types of data subject to retention requirements, retention periods or criteria for determining retention periods, conditions under which retention requirements may differ (e.g., regulatory constraints, risk-based justifications), and expectations for data deletion upon account termination. Interview representatives from each federation party to confirm awareness of declared retention policies and how those policies are operationalized within their organization.	3.5 I	CSP/IdP/RP	ALL	Data retention policies govern how long each party retains subscriber information, under what conditions, and what happens to that data when accounts are terminated. Declaring these policies in the trust agreement ensures that all parties share expectations and enables subscribers to understand how their data will be handled across the federation. Section 2.4.2 of SP 800-63B-4 requires verifiers to comply with applicable records retention policies and conduct risk management processes to determine retention periods when no mandatory requirements apply. The trust agreement should reflect these determinations for federation contexts. Different parties may have different retention requirements based on their regulatory environment (e.g., NARA schedules for federal agencies, industry-specific requirements). The trust agreement need not mandate uniform retention periods but must declare what each party's policies are so that expectations are clear.

NIST SP 800-63-4 Conformance Criteria v0.1: 63C

Control Identifier	Control Name	Control Text	Objective	Assessment Method	Index	Target	Profile/XAL Level	Discussion
TRUST-10	Subscriber Disclosure	As such, the relevant terms of the trust agreement SHALL be made available to subscribers in clear and understandable language.	Determine whether the relevant terms of the trust agreement are made available to subscribers in clear and understandable language.	Examine the subscriber-facing disclosures of trust agreement terms (e.g., web pages, notices, runtime decision summaries) for clarity, readability (e.g. a Flesch-Kincaid score of 70 or higher), and avoidance of technical jargon. Verify that the disclosure mechanism is accessible to subscribers and that the content addresses the terms relevant to the subscriber's participation in the federation. Test by attempting to access trust agreement terms through subscriber-facing channels, then evaluating whether the terms are presented in plain language appropriate to the expected subscriber population.	3.5 J	CSP/IdP/RP	ALL	Although subscribers are not generally directly involved in the trust agreement's terms, they are affected by those terms and the resulting federation transactions. This requirement ensures that subscribers can understand how their identity information will be handled, what attributes may be shared, and what rights and recourse they have. As stated in section 7.2, "a link to a complex, legalistic privacy policy or general terms and conditions that a substantial number of subscribers do not read or understand is never an effective notice." The disclosure must be genuinely comprehensible, not merely technically available. Common disclosure methods identified in Section 3.5 include: providing a subscriber-accessible web page with relevant terms, sending a notice to the subscriber, or displaying a summary of the terms during a runtime decision, with an option to review the full terms. The party responsible for disclosure varies based on the trust agreement. Section 3.5 does not specify which party must provide notice; parties may use contracts or trust framework policies to determine responsibility. This control assesses whether disclosure occurs and meets clarity requirements, regardless of which party provides it. SP 800-63A-4 Section 8.1.1 provides guidance applicable here: write in plain language, avoid technical jargon, tailor language to the literacy level of the intended population, use active voice and conversational style, and follow good information design practices. Related controls PETA-3 (4.3.1 C) and SDTAE-1 (4.3.2 A) address specific disclosure requirements for pre-established and subscriber-driven trust agreements, respectively.

NIST SP 800-63-4 Conformance Criteria v0.1: 63C

Control Identifier	Control Name	Control Text	Objective	Assessment Method	Index	Target	Profile/XAL Level	Discussion
TRUST-11	Disclosure Security Review	The terms of the trust agreement SHALL be reviewed by all parties (e.g., the CSP, IdP, RP, or a federation authority) that are responsible for informing the subscriber of the terms of the trust agreement before the disclosure to the subscriber occurs in order to avoid revealing sensitive security information.	Determine whether all parties responsible for informing subscribers of trust agreement terms have reviewed those terms before disclosure to avoid revealing sensitive security information.	Examine documentation of the review process, including records of which parties participated in the review, what was reviewed, and any redactions or modifications made to protect sensitive security information. Examine the subscriber-facing disclosure to verify that sensitive security details (e.g., security monitoring capabilities, fraud detection thresholds) are not exposed. Interview representatives from each party responsible for subscriber disclosure to confirm that a review occurred prior to disclosure and to understand the criteria used to identify and protect sensitive security information.	3.5 K	CSP/IdP/RP	ALL	This control is a prerequisite for TRUST-10, which requires that trust agreement terms be disclosed to subscribers in clear, understandable language. While subscribers need sufficient information to understand how their data is handled, the disclosure must not inadvertently reveal security details that could be exploited by attackers. Sensitive security information that should be protected from disclosure may include specific fraud-detection mechanisms, security-monitoring thresholds, incident-response procedures, cryptographic implementation details beyond what is necessary for subscriber understanding, and internal system architecture that could aid targeted attacks. The review must include all parties responsible for informing subscribers. Which parties bear this responsibility depends on the trust agreement structure: in bilateral agreements, the IdP and RP coordinate directly; in multilateral agreements, the federation authority may also be involved.
MTA-1	MTA Vetting Practices	The trust agreement SHALL enumerate the required practices for vetting all parties.	Determine whether the multilateral trust agreement (MTA) artifact(s) enumerate(s) the required practices for vetting all parties.	Examine trust framework documentation (e.g., operating rules, membership agreements, onboarding policies) for enumeration of vetting practices applicable to CSPs, IdPs, and RPs.	3.5.2 A	Federation Authority	ALL	<i>Assessment is required when: A federation authority facilitates the inclusion of CSPs, IDPs, and RPs under a trust agreement.</i> This control applies to multilateral trust agreements in which a federation authority facilitates onboarding of CSPs, IdPs, and RPs. The subsequent requirements in Section 3.5.2 (MTA-2 and following) establish minimum criteria that vetting must address. This control assesses whether the trust agreement documents vetting practices; the substantive vetting criteria are assessed separately. NISTIR 8149 (Developing Trust Frameworks to Support Identity Federations) provides additional context on conformance assessment approaches, including self-assessment, third-party assessment, and audit, which federations may use to implement vetting.

NIST SP 800-63-4 Conformance Criteria v0.1: 63C

Control Identifier	Control Name	Control Text	Objective	Assessment Method	Index	Target	Profile/XAL Level	Discussion
MTA-2	MTA Vetting Responsibility	The trust agreement ... SHALL indicate the party or parties that are responsible for performing the vetting process.	Determine whether the multilateral trust agreement artifact(s) indicate(s) the party or parties responsible for performing the vetting process.	Examine trust framework documentation (e.g., operating rules, membership agreements, onboarding policies) for an explicit designation of the party or parties responsible for vetting CSPs, IdPs, and RPs.	3.5.2 B	Federation Authority	ALL	<i>Assessment is required when: A federation authority facilitates the inclusion of CSPs, IDPs, and RPs under a trust agreement.</i> This control complements MTA-1, which requires enumeration of vetting practices. This control ensures accountability by requiring a clear assignment of vetting responsibility. Section 3.5.2 notes that "the federation authority can outsource the vetting process to another party, but the federation authority is ultimately responsible for the results of the vetting process." The trust agreement must make clear who performs vetting, whether that is the federation authority itself, a delegated third-party assessor, or another arrangement. Outsourcing vetting does not transfer ultimate accountability from the federation authority.
MTA-3	MTA Vetting: CSP Subscriber Proofing	At a minimum, the vetting of CSPs, IdPs, and RPs SHALL establish that: (1) CSPs identity proof subscriber accounts in accordance with [SP800-63A].	Determine whether the federation authority's vetting process establishes that CSPs identity proof subscriber accounts in accordance with SP 800-63A.	Examine federation authority vetting procedures, checklists, and assessment criteria to verify that CSP identity proofing practices are evaluated against SP 800-63A requirements for each IAL offered by the CSP.	3.5.2 C	Federation Authority	ALL	<i>Assessment is required when: A federation authority facilitates the inclusion of CSPs, IDPs, and RPs under a trust agreement.</i> This is the first of six minimum vetting criteria specified in Section 3.5.2. The federation authority's vetting process must verify that CSPs perform identity proofing consistent with SP 800-63A requirements for the applicable IAL(s) supported by the federation. SP 800-63A-4 establishes requirements for identity proofing at IAL1, IAL2, and IAL3, including evidence collection, validation, and verification processes. The depth of vetting should be commensurate with the IALs the federation supports.

NIST SP 800-63-4 Conformance Criteria v0.1: 63C

Control Identifier	Control Name	Control Text	Objective	Assessment Method	Index	Target	Profile/XAL Level	Discussion
MTA-4	MTA Vetting: CSP Subscriber Onboarding	The vetting of CSPs, IdPs, and RPs SHALL establish that: (2) CSPs onboard subscriber accounts (including attributes, derived attribute values, and attribute bundles) to IdPs in a secure fashion in adherence to the requirements in Sec. 4.1 or Sec. 5.1, as applicable.	Determine whether the federation authority's vetting process establishes that CSPs onboard subscriber accounts to IdPs securely in accordance with Section 4.1 (general-purpose IdPs) or Section 5.1 (subscriber-controlled wallets), as applicable to the federation model.	Examine federation authority vetting procedures, checklists, and assessment criteria to verify that CSP onboarding practices are evaluated against the requirements in Section 4.1 for IdP account provisioning or Section 5.1 for attribute bundle issuance to subscriber-controlled wallets, as applicable to the federation's supported models.	3.5.2 D	Federation Authority	ALL	<i>Assessment is required when: A federation authority facilitates the inclusion of CSPs, IDPs, and RPs under a trust agreement.</i> Section 4.1 governs how CSPs provision subscriber accounts to general-purpose IdPs, including the disclosure of provisioning methods in the trust agreement, and the relationship between subscriber accounts and federation-specific attributes. Section 5.1 governs how CSPs issue attribute bundles to subscriber-controlled wallets, including the steps for subscriber identity verification, wallet activation, key generation, and attribute bundle creation. The applicable section depends on the federation model: Section 4.1 applies when the federation uses general-purpose IdPs hosted on remote services; Section 5.1 applies when the federation supports subscriber-controlled wallets. A federation may support both models, in which case vetting must address both sections.
MTA-5	MTA Vetting: Subscriber Authenticators	The vetting of CSPs, IdPs, and RPs SHALL establish that: (3) The authenticators used to authenticate the subscriber at the IdP (during a federation transaction) or CSP (while issuing attribute bundles to a subscriber controlled wallet) are used in accordance with [SP800-63B].	Determine whether the federation authority's vetting process establishes that the authenticators used to authenticate subscribers at the IdP and/or CSP comply with SP 800-63B requirements.	Examine federation authority vetting procedures, checklists, and assessment criteria to verify that authenticator usage is evaluated against SP 800-63B requirements for each AAL supported by the IdP or CSP.	3.5.2 E	Federation Authority	ALL	<i>Assessment is required when: A federation authority facilitates the inclusion of CSPs, IDPs, and RPs under a trust agreement.</i> This requirement addresses two authentication contexts: (1) authentication of the subscriber at the IdP during a federation transaction with a general-purpose IdP, and (2) authentication of the subscriber at the CSP when issuing attribute bundles to a subscriber-controlled wallet. SP 800-63B-4 establishes requirements for authenticator types, authenticator lifecycle management, and authentication processes at AAL1, AAL2, and AAL3. The depth of vetting should be commensurate with the AALs the federation supports.
MTA-6	MTA Vetting: IdP Assertions	The vetting of CSPs, IdPs, and RPs SHALL establish that: (4) The assertions generated by IdPs adhere to the requirements in Sec. 4.9 or Sec. 5.8, as applicable.	Determine whether the federation authority's vetting process establishes that assertions generated by IdPs comply with the requirements in Section 4.9 (general-purpose IdPs) or Section 5.8 (subscriber-controlled wallets), as applicable.	Examine the federation authority's vetting procedures, checklists, assessment criteria, and records to determine whether the vetting process for IdPs addresses the applicable assertion-content requirements in Sec. 4.9 for general-purpose IdPs or Sec. 5.8 for subscriber-controlled wallets, as applicable to the supported federation models. Test by selecting a representative vetted IdP or subscriber-controlled wallet implementation and determining that the vetting record shows assessment of the applicable assertion-content requirements.	3.5.2 F	Federation Authority	ALL	<i>Assessment is required when: A federation authority facilitates the inclusion of CSPs, IDPs, and RPs under a trust agreement.</i>

NIST SP 800-63-4 Conformance Criteria v0.1: 63C

Control Identifier	Control Name	Control Text	Objective	Assessment Method	Index	Target	Profile/XAL Level	Discussion
MTA-7	MTA Vetting: RP Data Handling	The vetting of CSPs, IdPs, and RPs SHALL establish that: (5) RPs adhere to requirements for handling subscriber attribute data, such as retention, aggregation, deletion, and disclosure to third parties.	Determine whether the federation authority's vetting process establishes that RPs adhere to requirements for handling subscriber attribute data, including retention, aggregation, deletion, and disclosure to third parties.	Examine federation authority vetting procedures, checklists, and assessment criteria to verify that RP data-handling practices are included in the vetting scope. The federation authority's vetting process must address the following controls: (1) Retention/Storage: SSIN-1 (3.11.3), SSIN-3 (3.11.3), CAARP-1 (4.6.6); (2) Deletion: SSIN-2 (3.11.3), SSIN-3 (3.11.3), CAARP-5 (4.6.6); (3) Disclosure: CAARP-2 (4.6.6), CAARP-6 (4.6.6, Federal only); (4) Transmission: TSI-4 (3.10.1), TSI-5 (3.10.1), CAARP-4 (4.6.6); and (5) Usage Limitation: CAARP-3 (4.6.6).	3.5.2 G	Federation Authority	ALL	<i>Assessment is required when: A federation authority facilitates the inclusion of CSPs, IDPs, and RPs under a trust agreement.</i> Before adding an RP to the federation, the federation authority must ensure that the party in question handles all subscriber information appropriately. This is a summative control that verifies that the federation authority's vetting process complies with RP data-handling requirements. The detailed requirements are assessed against the controls in Section 3.10.1 (limitations on transmission of subscriber information), Section 3.11.3 (storage requirements and deletion upon account termination), and Section 4.6.6 (handling of attributes collected outside the federation transaction).
MTA-8	MTA Vetting: Protocol Profiles	The vetting of CSPs, IdPs, and RPs SHALL establish that: (6) RP and IdP systems use agreed-upon profiles of federation protocols, as specified by the federation authority.	Determine whether the federation authority documents acceptable profiles and that IdPs and RPs follow these profiles.	Examine the federation authority's documentation of acceptable profiles and its enforcement of adherence to those profiles (e.g., SAML 2.0 Web Browser SSO Profile, OpenID Connect Core, specific FAPI profiles).	3.5.2 H	Federation Authority	ALL	<i>Assessment is required when: A federation authority facilitates the inclusion of CSPs, IDPs, and RPs under a trust agreement.</i> The federation authority determines which federation protocol profiles are approved for use within the federation and must ensure that all federation participants use only these profiles. The federation authority must verify that IdPs and RPs adhere to these profiles before they are added to the federation. NISTIR 8149 Section 5.7 (Technical Specifications) notes that trust frameworks promote interoperability by identifying common protocols and standards. The federation authority's specifications should rely on existing profiles whenever possible, but may create their own profiles if necessary. Whether requiring existing profiles or designing a new profile, vendor support should be carefully considered.

NIST SP 800-63-4 Conformance Criteria v0.1: 63C

Control Identifier	Control Name	Control Text	Objective	Assessment Method	Index	Target	Profile/XAL Level	Discussion
MTA-9	MTA Periodic Reevaluation	Federation authorities SHALL periodically reevaluate members for compliance, in terms disclosed in the trust agreement.	Determine whether the federation authority periodically reevaluates members for compliance and whether the reevaluation schedule is disclosed in the trust agreement artifact(s).	Examine trust agreement artifact(s) for disclosed reevaluation terms (e.g., frequency, scope, criteria). Examine the federation authority records of completed reevaluations to verify that the schedule is followed.	3.5.2 I	Federation Authority	ALL	<i>Assessment is required when: A federation authority facilitates the inclusion of CSPs, IDPs, and RPs under a trust agreement.</i> Initial vetting (MTA-1 through MTA-8) establishes baseline compliance at onboarding. This control ensures ongoing compliance throughout membership. The trust agreement must disclose the reevaluation terms so members understand their continuing obligations. Reevaluation frequency may vary based on risk, federation model, or member role. The trust agreement should specify whether reevaluation applies uniformly or varies by party type (CSP, IdP, RP). Reevaluation may include reassessment of the criteria established in MTA-3 through MTA-8.
RR-1	RP Subscriber Redress	For matters that involve the RP subscriber account (including any attributes stored in the account), RP functionality, bound authenticators, RP allowlists, and other items under the RP's control, the RP SHALL provide a clear and accessible means of redress to the subscriber.	Determine whether the RP provides a clear and accessible means for subscribers to seek redress for matters under the RP's control.	Examine RP documentation, subscriber-facing interfaces, and help resources for redress mechanisms. Verify that redress mechanisms are clearly presented and accessible to subscribers, and that they address RP subscriber accounts, attributes stored by the RP, RP functionality, bound authenticators, and RP allowlists. Review RP documentation to determine whether there are any other items under the RP's control, and if so, verify that redress mechanisms are sufficient. Test the redress process by locating and initiating it as a test subscriber to verify accessibility.	3.5.3 A	RP	ALL	Section 3.5.3 establishes that the RP is the subscriber's primary point of access to the federated system, and in some cases, subscribers may be unaware that an IdP is involved. This control addresses redress for matters solely within the RP's control. "Clear and accessible" means the redress mechanism must be easy to find and use. Complex processes, hidden contact information, or technical jargon that prevents subscribers from understanding how to seek redress would fail this requirement.
RR-2	RP Redress Routing	For matters that involve the IdP or CSP, the RP SHALL provide the subscriber with a means of initiating the redress process with the IdP or CSP, as appropriate.	Determine whether the RP provides subscribers with a means of initiating the redress process with the IdP or CSP for matters outside the RP's control.	Examine RP documentation, subscriber-facing interfaces, and help resources for mechanisms that direct subscribers to IdP or CSP redress processes when appropriate. Verify that the RP distinguishes between matters it handles directly (RR-1) and matters requiring IdP or CSP involvement. Test the RP's interfaces by attempting to locate information for initiating redress with the IdP or CSP, acting as a test subscriber.	3.5.3 B	RP	ALL	Since the RP is typically the subscriber's primary point of access to the federated system, subscribers may not know how to reach the IdP or CSP, or when an issue is more appropriately addressed by the IdP or CSP. This control ensures the RP acts as a bridge, directing subscribers to the appropriate party for matters outside the RP's control. TRUST-8 (Redress Coordination) establishes the inter-party infrastructure that enables this routing. This control assesses whether the RP makes that routing accessible to subscribers.

NIST SP 800-63-4 Conformance Criteria v0.1: 63C

Control Identifier	Control Name	Control Text	Objective	Assessment Method	Index	Target	Profile/XAL Level	Discussion
RR-3	IdP Subscriber Redress	For matters that involve the use of the subscriber account in federation transactions, including attribute values and derived attribute values made available over federation transactions, IdP functionality, holder-of-key authenticators, IdP allowlists, and other items in the IdP's control, the IdP SHALL provide a clear and accessible means of redress to the subscriber.	Determine whether the IdP provides clear and accessible means for subscribers to seek redress for matters under the IdP's control.	Examine IdP documentation, subscriber-facing interfaces, and help resources for redress mechanisms. Verify that redress mechanisms are clearly presented and accessible to subscribers, and that they address subscriber account usage in federation transactions, attribute values, and, if applicable, derived attribute values, IdP functionality, holder-of-key authenticators, and IdP allowlists. Review IdP documentation to determine whether there are any other items under the IdP's control, and if so, verify that redress mechanisms are sufficient. Test by locating and initiating the redress process to verify clarity and accessibility.	3.5.3 C	IdP	ALL	This is the IdP counterpart to RR-1 (RP Subscriber Redress). This control addresses redress for matters solely within the IdP's control. "Clear and accessible" means the redress mechanism must be easy to find and use. Complex processes, hidden contact information, or technical jargon that prevents subscribers from understanding how to seek redress would fail this requirement.
RR-4	IdP Redress Routing: RP	For matters that also involve a particular RP, the IdP SHALL provide the subscriber with a means of initiating the redress process with the RP.	Determine whether the IdP provides subscribers with a means of initiating the redress process with the RP for matters that involve a particular RP.	Examine IdP documentation, subscriber-facing interfaces, and help resources for mechanisms that direct subscribers to RP redress processes when appropriate. Verify that the IdP distinguishes between matters it handles directly (RR-3) and matters requiring RP involvement. Test the IdP's interfaces by attempting to locate information to initiate redress with the RP, acting as a test subscriber.	3.5.3 D	IdP	ALL	This is the IdP counterpart to RR-2 (RP Redress Routing). Subscribers may contact the IdP for issues that are more appropriately resolved by a specific RP (e.g., RP mishandling attributes received from the IdP, RP subscriber account issues). This control ensures the IdP directs subscribers to the appropriate RP. TRUST-8 (Redress Coordination) establishes the inter-party infrastructure that enables this routing. This control assesses whether the IdP makes that routing accessible to subscribers.
RR-5	IdP Redress Routing: CSP	For matters that involve a subscriber account that has been made available to the IdP, the IdP SHALL provide the subscriber with a means of initiating the redress process with the CSP.	Determine whether the IdP provides subscribers with a means of initiating the redress process with the CSP for matters involving the CSP subscriber account.	Examine IdP documentation, subscriber-facing interfaces, and help resources for mechanisms that direct subscribers to CSP redress processes when appropriate. Verify that the IdP distinguishes between matters it handles directly (RR-3) and matters requiring CSP involvement. Test the IdP's interfaces by attempting to locate information for initiating redress with the CSP, acting as a test subscriber.	3.5.3 E	IdP	ALL	When the IdP is separate from the CSP, the subscriber may contact the IdP for issues that are more appropriately resolved by CSP (e.g., identity proofing errors, incorrect attributes in the CSP subscriber account, authenticator binding issues). This control ensures the IdP correctly redirects subscribers to the CSP. TRUST-8 (Redress Coordination) establishes the inter-party infrastructure that enables this routing. This control assesses whether the IdP makes that routing accessible to subscribers.

NIST SP 800-63-4 Conformance Criteria v0.1: 63C

Control Identifier	Control Name	Control Text	Objective	Assessment Method	Index	Target	Profile/XAL Level	Discussion
RR-6	CSP Redress	For matters that involve the subscriber account, including identity attributes and authenticators in the subscriber account, the CSP SHALL provide the subscriber with a clear and accessible means of redress.	Determine whether the CSP provides a clear and accessible means for subscribers to seek redress for matters involving the CSP subscriber account.	Examine CSP documentation, subscriber-facing interfaces, and help resources for redress mechanisms. Verify that redress mechanisms are clearly presented and accessible to subscribers, and that all potential areas of redress are addressed, including the CSP subscriber account, identity attributes (if collected), and authenticators. Review CSP documentation to determine whether there are any other items under the CSP's control, and if so, verify that redress mechanisms are sufficient. Test the redress process by attempting to locate and initiate it as a test subscriber to verify accessibility.	3.5.3 F	CSP	ALL	This is the CSP counterpart to RR-1 (RP Subscriber Redress) and RR-3 (IdP Subscriber Redress). This control addresses redress for matters solely within the CSP's control. "Clear and accessible" means the redress mechanism must be easy to find and use. Complex processes, hidden contact information, or technical jargon that prevents subscribers from understanding how to seek redress would fail this requirement.
ICKM-1	Secure Discovery and Registration	The discovery and registration processes SHALL be established in a secure fashion as defined by the trust agreement that governs the federation transaction.	Determine whether discovery and registration processes are established securely in accordance with the trust agreement artifact(s).	Examine trust agreement artifact(s) to verify that they define security requirements for discovery and registration processes. The specific implementation requirements are satisfied by ICKM-2 (authenticated protected channel for key exchange); ICKM-3 (symmetric key uniqueness); ICKM-4 (wildcard identifier prohibition); DR-1, DR-2, and DR-3 (IdP discovery and RP registration, Sec. 4.4); MR-1 (manual registration, Sec. 4.4.1); DYR-1 (dynamic registration channel protection, Sec. 4.4.2); and DISCR-1 (CSP verification key determination for wallets, Sec. 5.5). If the trust agreement artifact(s) do not define security requirements for discovery and registration, this control fails regardless of downstream control results.	3.6 A	CSP/IdP/RP	ALL	This control requires that the trust agreement artifact(s) define the security for discovery and registration. The downstream controls assess whether the implementation conforms to specific technical requirements. A federation could pass all downstream controls individually but fail this control if the trust agreement artifact(s) are silent on discovery and registration security, leaving parties without a documented basis for their security expectations.

NIST SP 800-63-4 Conformance Criteria v0.1: 63C

Control Identifier	Control Name	Control Text	Objective	Assessment Method	Index	Target	Profile/XAL Level	Discussion
ICKM-2	Secure Key Exchange	Protocols that require the transfer of cryptographic key information SHALL use an authenticated protected channel to exchange the cryptographic key information needed to operate the federated relationship, including any shared secrets or public keys.	Determine whether all cryptographic key information is exchanged over an authenticated protected channel.	Examine documentation describing the key exchange processes for all federation relationships. For each relationship, verify that the documented process specifies the use of an authenticated protected channel for all transfers of cryptographic key information, including shared secrets and public keys. Test by selecting a sample of key exchange operations across the federation deployment. For each, verify that the authenticated protected channel is properly implemented (e.g., TLS with server-side certificate validation). Specific key exchange scenarios are satisfied by their respective controls: DR-2 for RP retrieval of IdP keys over a network, DR-3: RP for registration with an IdP, DYR-1 for dynamic registration, and DISCR-1 for RP discovery of CSP wallet keys. If any key exchange in the deployment is not covered by a downstream control (e.g., key exchange between a separated CSP and IdP), document and assess it here.	3.6 B	CSP/IdP/RP	ALL	The IdP, CSP, and RP need access to cryptographic keying materials to validate signatures and encrypt content. The association of these keys with specific parties is vital to the security of the protocol. In order to prevent an attacker impersonating an IdP/CSP or RP, all keys have to be transferred using secure methods. Methods include the publication of asymmetric public keys over HTTPS (and therefore TLS) at a well-known and trusted URL associated with the IdP/CSP or RP, or the use of TLS to transfer keying material in the registration process. Alternatively, keys could be transferred and configured manually by administrators to ensure a strong mapping between the intended party and the value of the key itself.
ICKM-3	Symmetric Key Uniqueness	Any symmetric keys used in this relationship SHALL be unique to a pair of federation participants.	Determine whether symmetric keys are unique to each pair of federation participants.	Examine documentation describing symmetric key generation and assignment processes. Verify that the documented process produces a unique symmetric key for each pair of federation participants. Determine whether the process ensures that any symmetric key used for one pair of federation participants is not reused for any other pair. Examine key management system records or configuration entries for a sample of federation relationships. Verify that distinct key identifiers or key entries exist for each pair of participants.	3.6 C	CSP/IdP/RP	ALL	Assessment is required when: Symmetric keys, rather than asymmetric key pairs, are used for the federation relationship. Since symmetric keys allow for both the creation and verification of both signed and encrypted content by all parties who possess the key, it's important that any symmetric keys be limited to use between only a single pair of connected parties. If symmetric keys are made available to any other parties, those parties can impersonate each other. Reusing symmetric keys across multiple federation relationships also increases the risk of key compromise: a compromise of one relationship would compromise all relationships that use the same key. This control ensures that a key shared between an IdP and RP-A is different from the key shared between the same IdP and RP-B.

NIST SP 800-63-4 Conformance Criteria v0.1: 63C

Control Identifier	Control Name	Control Text	Objective	Assessment Method	Index	Target	Profile/XAL Level	Discussion
ICKM-4	Wildcard Identifier Prohibition	When domain names, URIs, or other structured identifiers are used to identify parties, wildcards SHALL NOT be used.	Determine whether party identifiers avoid the use of wildcards.	Examine system configurations, discovery/registration records, and trust agreement artifact(s) for party identifiers. Verify that no identifiers contain wildcards (e.g., "*.csp.com"). Test by attempting to register or configure a party identifier containing a wildcard and verify that the system rejects it, if identifier establishment is performed through an automated interface.	3.6 D	CSP/IdP/RP	ALL	Wildcards in identifiers create ambiguity about which party is being identified, potentially allowing unintended parties to match the identifier. For example, if an RP is deployed at "www.example.com", "service.example.com", and "gateway.example.com", each identifier must be registered separately. A wildcard of "*.example.com" cannot be used, as it would unintentionally match "user.example.com" and "unknown.example.com" under the same RP identifier.
CKR-1	Key Rotation Documentation	The allowable update process for any identifiers and cryptographic keys SHALL be defined by the trust agreement.	Determine whether the trust agreement artifact(s) define the allowable update process for identifiers and cryptographic keys.	Examine trust agreement artifact(s) for documentation of the allowable key and identifier update process, including permitted methods, timing, and any restrictions.	3.6.1 A	CSP/IdP/RP	ALL	Over time, it may be desirable or necessary to update cryptographic keys associated with a CSP, IdP, or RP due to key expiration, suspected compromise, algorithm deprecation, or organizational changes. The trust agreement must define how these updates are performed so all parties understand the process. Related Controls: - CKR-2 requires that the update process be executed over an authenticated, protected channel. - ICKM-2 establishes the same requirement for initial key exchange.
CKR-2	Key Rotation Security	The allowable update process for any identifiers and cryptographic keys... SHALL be executed using an authenticated protected channel, as in the initial cryptographic key establishment.	Determine whether updates to identifiers and cryptographic keys are executed using an authenticated protected channel.	Examine system configurations for key rotation mechanisms. Verify that the update process matches the process defined in the trust agreement artifact(s) (see CKR-1). Test by performing or observing a key rotation process. For authenticated protected channel verification, see ICKM-2.	3.6.1 B	CSP/IdP/RP	ALL	Key rotation requires the same security protection as initial key establishment. Using an authenticated protected channel ensures that updated key material is not intercepted or modified during exchange.
CKS-1	Secure Key Storage	CSPs, IdPs (including subscriber-controlled wallets), and RPs SHALL store all signing keys, decryption keys, and all symmetric keys in a secure fashion. Cryptographic key storage is subject to applicable [FIPS140] requirements, including applicable tamper resistance requirements.	Determine whether the assessed party stores signing keys, decryption keys, and symmetric keys securely and in accordance with applicable FIPS 140 requirements.	Examine (1) Documentation describing key storage mechanisms for signing keys, decryption keys, and symmetric keys. Verify that the documented storage approach addresses protection from unauthorized access. (2) FIPS 140 validation certificates for cryptographic modules used to store keys, if applicable. Verify that the validated level meets the organization's requirements and applicable policies. (3) System configurations and access controls for key storage to verify that keys are protected consistent with the documented approach and FIPS 140 requirements.	3.6.2 A	CSP/IdP/RP	ALL	FIPS 140 establishes security requirements for cryptographic modules, including tamper resistance at higher levels. Federal agencies and their service providers are typically required to use FIPS 140-validated modules. The applicable FIPS 140 level depends on the organization's security requirements and applicable policies. Related Controls: - FAL2-7 requires Federal IdPs at FAL2 or higher to protect assertion signing keys with FIPS 140 Level 1 or higher validated mechanisms. - CKS-2, CKS-3, and CKS-4 establish requirements for non-exportable key storage. - KS-1 and KS-2 establish key storage requirements specific to subscriber-controlled wallets.

NIST SP 800-63-4 Conformance Criteria v0.1: 63C

Control Identifier	Control Name	Control Text	Objective	Assessment Method	Index	Target	Profile/XAL Level	Discussion
CKS-2	Non-Exportable Key Storage Definition	To be considered non-exportable, key storage SHALL either be a separate piece of hardware or an embedded processor or execution environment, such as a secure element, trusted execution environment (TEE), or trusted platform module (TPM).	Determine whether key storage claimed as non-exportable meets the hardware or embedded processor/execution environment requirements.	Examine documentation describing key storage mechanisms. Verify that any key storage claimed as non-exportable is either a separate piece of hardware or an embedded processor or execution environment that is separate from the host processor (e.g., secure element, TEE, TPM).	3.6.2 B	CSP/IdP/RP	ALL	Assessment is required when: Non-exportable key storage is required or claimed. Some circumstances require the cryptographic keys to be stored in a non-exportable manner, such as reaching FAL3 with a subscriber-controlled wallet on a subscriber's device (see Sec. 5.4.1). This control establishes the criteria for key storage to be considered non-exportable. Software-only key stores do not meet the definition of non-exportable, regardless of access controls or encryption applied to the stored keys.
CKS-3	Non-Exportable Key Isolation	Non-exportable key storage SHALL be designed to prohibit the export of the secret keys to the host processor...	Determine whether non-exportable key storage is designed to prohibit export of secret keys to the host processor.	Examine documentation and technical specifications for the key storage mechanism. Verify that the design does not include any interface or function that would allow secret keys to be exported to the host processor.	3.6.2 C	CSP/IdP/RP	ALL	Assessment is required when: Non-exportable key storage is required or claimed. This control ensures that the key storage interface does not permit secret key extraction. Cryptographic operations using the keys must occur within the secure storage environment itself, with only the results (e.g., signatures, decrypted data) returned to the host processor. Related Controls: - CKS-2 defines what qualifies as non-exportable key storage. - CKS-4 requires that non-exportable key storage cannot be reprogrammed to allow key extraction.
CKS-4	Non-Exportable Storage Immutability	Non-exportable key storage... SHALL NOT be capable of being reprogrammed by the host processor to allow the secret keys to be extracted.	Determine whether non-exportable key storage is protected against reprogramming by the host processor to allow secret key extraction.	Examine documentation and technical specifications for the key storage mechanism. Verify that the host processor cannot modify firmware, configuration, or behavior of the key storage in a way that would enable secret key extraction.	3.6.2 D	CSP/IdP/RP	ALL	Assessment is required when: Non-exportable key storage is required or claimed. This control addresses a different attack vector than CKS-3. Even if the key storage interface does not permit key export during normal operation (CKS-3), an attacker with host processor access could potentially modify the storage's firmware to add an export capability. This control requires that the key storage be designed such that the host processor cannot modify its firmware, configuration, or behavior in ways that would enable key extraction. Related Controls: - CKS-2 defines what qualifies as non-exportable key storage. - CKS-3 requires that non-exportable key storage prohibit key export to the host processor.

NIST SP 800-63-4 Conformance Criteria v0.1: 63C

Control Identifier	Control Name	Control Text	Objective	Assessment Method	Index	Target	Profile/XAL Level	Discussion
SATT-1	Software Attestation Validation	When attestations are required by the trust agreement or requested as part of the federation protocol, received attestations SHALL be validated by the receiver.	Determine whether the receiver validates software or device attestations received as part of the federation protocol.	Examine trust agreement artifact(s) to identify whether software or device attestations are required and, if so, the validation criteria. Examine system documentation and configurations to verify that attestation validation is implemented. Test by (1) presenting a valid attestation and verifying that it is accepted; (2) presenting an invalid attestation and verifying that it is rejected; and (3) presenting an assertion that is missing a required attestation and verifying that it is rejected.	3.6.3 A	CSP/IdP/RP	ALL	<i>Assessment is required when: Software or device attestations are required or received.</i> Software and device attestations can augment the establishment of identifiers and cryptographic keys, especially in dynamic and distributed systems. Attestations in this usage are cryptographically bound statements that a particular piece of software, device, or runtime system meets a set of agreed-upon parameters. The attestation is presented by the software in the context of establishing the identity of the software, device, or system with which the receiver is interacting. The attestation allows the receiver to verify the request with a higher degree of certainty than they would be able to otherwise.
AAD-1	Permissible Attribute Transmission	A subscriber's identity attributes SHALL only be transmitted between the IdP and the RP for federation transactions or support functions, such as identification of compromised subscriber accounts (see Sec. 3.10.1), even when parties are allowlisted for federation purposes.	Determine whether the IdP and RP limit transmission of subscriber identity attributes to permitted purposes.	Examine IdP and RP policies, trust agreement artifact(s), data flow documentation, federation configuration, and any identity API, provisioning API, or attribute synchronization mechanisms used to transmit subscriber identity attributes between the IdP and RP. Verify that the policies do not authorize transmission for purposes outside of federation transactions and support functions (as defined in Sec. 3.10.1). Examine the trust agreement artifact(s) to verify that the permitted purposes for attribute transmission fall within these boundaries. The operational enforcement of transmission limits is satisfied by TSI-1 (IdP transmission limits) and TSI-4 (RP transmission limits to the IdP). This control verifies that the governing policies themselves do not permit out-of-scope transmission.	3.7 A	IdP/RP	ALL	This restriction applies even when parties are allowlisted for federation purposes; allowlisting permits federation transactions, not unlimited data sharing.
AAD-2	RP Attribute Use Limitation	A subscriber's identity attributes SHALL NOT be used by the RP for purposes other than those stipulated in the trust agreement unless the subscriber specifically consents to such purposes.	Determine whether the RP limits use of subscriber identity attributes to purposes stipulated in the trust agreement or consented to by the subscriber.	Satisfied by TSI-5.	3.7 B	RP	ALL	TSI-5 establishes the RP's obligation to inform subscribers and obtain consent when using identity information for purposes beyond those described in the trust agreement artifact(s).
AAD-3	Subscriber Attribute Storage	A subscriber's attributes SHALL be stored and managed in accordance with Sec. 3.11.3.	Determine whether subscriber attributes are stored and managed in accordance with Section 3.11.3.	Satisfied by SSIN-1 through SSIN-3.	3.7 C	IdP/RP	ALL	

NIST SP 800-63-4 Conformance Criteria v0.1: 63C

Control Identifier	Control Name	Control Text	Objective	Assessment Method	Index	Target	Profile/XAL Level	Discussion
AAD-4	Subscriber Attribute Transmission Notification	The subscriber SHALL be informed of the transmission of attributes to an RP.	Determine whether the subscriber is informed of the transmission of their attributes to an RP.	If the organization is the authorized party: Satisfied by AAD-5. If the subscriber is the authorized party: Satisfied by AAD-6. For non-allowlisted RPs, the notification mechanism assessment is satisfied by IDPRD-2 and IDPRD-3.	3.7 D	IdP	ALL	This is a summative control.
AAD-5	Disclosure of Attributes by an Organization	If the authorized party is the organization, the organization SHALL make the list of approved RPs and the associated sets of attributes sent to those RPs available to the subscriber.	Determine whether the organization makes the list of approved RPs and associated attributes available to subscribers.	Satisfied by IALRP-3 and IALRP-5.	3.7 E	IdP	ALL	<i>Assessment is required when: The authorized party is the organization.</i> This is a summative control. Compliance is demonstrated by meeting the requirements of the following controls: IALRP-3 (RP Allowlist availability to subscribers) and IALRP-5 (attribute indication in allowlist entries). When the organization acts as the authorized party, the subscriber does not directly approve each federation transaction. To maintain transparency, the organization must disclose which RPs receive subscriber attributes and what attributes are sent.
AAD-6	Subscriber Attribute Release Approval	If the authorized party is the subscriber, the subscriber SHALL be prompted prior to the release of attributes using a runtime decision at the IdP as described in Sec. 4.6.1.3.	Determine whether the IdP prompts subscribers prior to attribute release using a runtime decision when the subscriber is the authorized party.	Satisfied by IDPRD-1 through IDPRD-6.	3.7 F	IdP	ALL	Assessment is required when: The authorized party is the subscriber. This is a summative control. Compliance is demonstrated when the requirements of the following controls have been met: - IDPRD-1: Runtime authorization - IDPRD-2: Attribute release consent - IDPRD-3: Attribute disclosure before release - IDPRD-4: Selective attribute disclosure - IDPRD-5: Attribute value viewing mechanism - IDPRD-6: Sensitive information masking
RPSA-1	RP Subscriber Account Termination Data Removal	Termination SHALL include the removal of all federated identifiers, bound authenticators, attributes, and identity information associated with the account, in accordance with Sec. 3.11.3.	Determine whether termination of an RP subscriber account includes removal of all federated identifiers, bound authenticators, attributes, and identity information associated with the account, except when otherwise restricted from doing so by regulations, laws, or policies, or when the risk of an application deems it essential (Sec. 3.11.3).	Examine RP policies and procedures for account termination. Examine system implementation to verify that termination processes address the removal of federated identifiers, bound authenticators, attributes, and identity information. If any attributes are not removed, confirm that the reasons for retention are documented and are appropriately attributed to regulations, laws, policies, or risk assessments. Test by terminating a test RP subscriber account and verify that all subscriber information is removed from storage as expected.	3.8 A	RP	ALL	An RP subscriber account is terminated when the RP removes all access to the account at the RP. The reference to Sec. 3.11.3 recognizes that RPs may be required to retain certain subscriber information after account termination due to regulatory or legal obligations, organizational policies, or application risk assessments.

NIST SP 800-63-4 Conformance Criteria v0.1: 63C

Control Identifier	Control Name	Control Text	Objective	Assessment Method	Index	Target	Profile/XAL Level	Discussion
RPSA-2	Inaccessible Account Policy Documentation	The RP SHALL document the practices and policies that it enacts when an RP subscriber account reaches a state of having zero associated federated identifiers; no means of access, including alternative authenticators (see Sec. 3.8.3); and no means of recovery, including account linking (see Sec. 3.8.1) and account resolution (see Sec. 3.8.2).	Determine whether the RP documents the practices and policies enacted when an RP subscriber account becomes inaccessible.	Examine the RP documentation for policies addressing RP subscriber accounts that have no associated federated identifiers, no alternative authenticators, and no means of recovery. Verify that the documentation specifies the actions taken (e.g., disable, terminate, retain for investigation).	3.8 B	RP	ALL	An RP subscriber account may reach a state where the subscriber can no longer access it - for example, when the sole federated identifier is removed, no alternative authenticators exist, and no account linking or account resolution process is available. The RP must have documented policies for handling such accounts. Common approaches include: - Disabling the account - Terminating the account - Retaining the account for investigation if suspicious activity is suspected The specific policy depends on the RP's business requirements, regulatory obligations, and risk posture.
RPSA-3	Federated Identifier Change Notifications	The RP SHALL provide a notice to the subscriber when: (a) A new federated identifier is added to an existing RP subscriber account, or (b) A federated identifier is removed from an RP subscriber account, but the account is not terminated.	Determine whether the RP provides notice to the subscriber when a federated identifier is added to or removed from an RP subscriber account.	Examine RP notification mechanisms and configurations to verify that notices are sent when federated identifiers are added or removed. Test by adding a new federated identifier to a test RP subscriber account and verifying that the subscriber receives a notification. Next, remove a federated identifier from a test RP subscriber account without terminating the account, and verify that the subscriber is notified.	3.8 C	RP	ALL	Changes to federated identifiers associated with an RP subscriber account are security-relevant events. Adding a federated identifier grants a new means of access; removing one revokes access from that identity. Notifying the subscriber allows them to detect unauthorized account linking or removal.
RPSA-4	Termination Notice Consideration	The RP SHALL consider the reason for termination when determining whether to send a notice to the subscriber, as discussed in Sec. 5.4 of [SP800-63A].	Determine whether the RP considers the reason for termination when deciding whether to send a notice to the subscriber.	Examine RP policies and procedures for account termination to verify that the reason for termination is considered when determining whether to notify the subscriber. Interview personnel responsible for account termination or notification decisions to determine how the reason for termination is considered in practice. Test by reviewing a sample of terminated or disabled RP subscriber accounts with different termination reasons and determine that the notice decision in each case reflects consideration of the reason for termination.	3.8 D	RP	ALL	Not all termination scenarios warrant subscriber notification. SP 800-63A Section 5.4 identifies various reasons for account termination, including scenarios that may warrant withholding notice, such as an account termination due to suspected fraud, since the notification could alert a malicious actor.

NIST SP 800-63-4 Conformance Criteria v0.1: 63C

Control Identifier	Control Name	Control Text	Objective	Assessment Method	Index	Target	Profile/XAL Level	Discussion
ACCL-1	Account Linking Authentication Requirement	If the RP allows a subscriber to link multiple subscriber accounts..., the RP SHALL require an authenticated session with the subscriber account for all linking functions.	Determine whether the RP requires an authenticated session for account linking functions.	Examine RP policies and system configurations to verify that account linking functions require an authenticated session. Test by attempting to link a new federated identifier to an RP subscriber account and verify that an authenticated session is required before the linking function is permitted.	3.8.1 A	RP	ALL	Assessment is required when: The RP allows a subscriber to link multiple subscriber accounts. Account linking allows a subscriber to associate multiple federated identifiers with a single RP subscriber account. This is a security-sensitive operation - without an authenticated session, an attacker could link their own federated identifier to a victim's account and gain unauthorized access. Requiring an authenticated session ensures that only the legitimate account holder can add new federated identifiers.
ACCL-2	Removed Federated Identifier Access Prohibition	When a federated identifier is removed from an RP subscriber account, the RP SHALL disallow access to the RP subscriber account from the removed federated identifier.	Determine whether the RP disallows access to the RP subscriber account from a removed federated identifier.	Examine the RP implementation logic to verify that removing a federated identifier immediately revokes access to the account previously associated with that identifier. Test by removing a federated identifier from a test RP subscriber account and attempting to authenticate using the removed federated identifier. Verify that access is denied.	3.8.1 B	RP	ALL	When a federated identifier is unlinked from an RP subscriber account, it must no longer grant access to that account. While this may seem self-evident, the requirement addresses potential implementation patterns that could inadvertently preserve access, such as soft-deleting or marking the identifier as "inactive" without enforcing access prohibition and caching mechanisms that do not immediately reflect the removal. The assessment verifies that removal is immediately and completely effective.
ACCR-1	Account Resolution Attribute Sufficiency	An RP that performs account resolution SHALL ensure that the attributes requested from the IdP are sufficient to uniquely resolve the subscriber within the RP's system before linking the federated identifier with the RP subscriber account and granting access.	Determine whether the RP ensures that the attributes requested from the IdP for account resolution are sufficient to uniquely identify the subscriber before linking the federated identifier with the RP subscriber account and granting access.	Examine RP's account resolution process, including the specific attributes used for matching. Then, examine the RP's analysis or justification demonstrating that the selected attribute combination is sufficient to uniquely resolve subscribers within its population. Test by attempting account resolution as a test subscriber and verify that the federated identifier is linked only after a unique match is confirmed.	3.8.2 A	RP	ALL	Assessment is required when: The RP performs account resolution. Account resolution occurs when the RP has existing subscriber information (e.g., from a pre-existing database) that is not yet associated with a federated identifier. When a subscriber authenticates via federation, the RP must match the incoming assertion to the correct existing account. Using insufficient attributes risks incorrect matching - for example, matching on common name and DOB alone could link a federated identifier to the wrong subscriber's account. The RP must request and use attributes that, in combination, uniquely identify the subscriber within the RP's population.

NIST SP 800-63-4 Conformance Criteria v0.1: 63C

Control Identifier	Control Name	Control Text	Objective	Assessment Method	Index	Target	Profile/XAL Level	Discussion
ACCR-2	Account Resolution Accuracy	An RP that performs account resolution SHALL design the process such that it does not associate an RP subscriber account's information with a federated identifier that does not belong to the subscriber.	Determine whether the RP's account resolution process is designed to prevent associating an RP subscriber account with a federated identifier that does not belong to the subscriber.	Satisfied by ACCR-1.	3.8.2 B	RP	ALL	Assessment is required when: The RP performs account resolution. This control requires the RP to design the account resolution process to ensure accurate association between RP subscriber accounts and federated identifiers. Account resolution may occur in scenarios where a federated identifier is not directly provided - for example, a subscriber-controlled wallet providing an attribute bundle without a federated identifier, or a pre-provisioned account being matched to an incoming assertion based on agreed-upon attributes. The RP must design the process so that the resolution correctly identifies the subscriber and does not mistakenly associate account information with an identifier belonging to a different person.
ACCR-3	Holder-of-Key Account Resolution	A similar account resolution process is also used when the RP verifies an authenticator used in a holder-of-key assertion for the first time. In this case, the RP SHALL ensure that the attributes carried with the authenticator uniquely resolve to the RP subscriber account before accepting the authenticator.	Determine whether the RP ensures that attributes carried with a holder-of-key authenticator uniquely resolve to an RP subscriber account before accepting the authenticator.	Satisfied by ACCR-1.	3.8.2 C	RP	FAL3	<i>Assessment is required when: The RP performs account resolution when verifying an authenticator used in a holder-of-key assertion for the first time.</i> When an RP encounters a holder-of-key authenticator for the first time, it must associate that authenticator with an RP subscriber account. Since the RP did not issue the authenticator, it does not know which account it belongs to. The RP uses attributes carried with the authenticator to resolve to the correct account before accepting the authenticator for FAL3 sessions.
ALTAP-1	Alternative Authenticator Management	The RP SHALL follow the requirements in [SP800-63B] to manage all alternative authenticators.	Determine whether the RP follows SP 800-63B requirements for managing alternative authenticators.	This is a summative control. The requirements for this control are met when the RP's management of alternative authenticators meets the applicable requirements in SP 800-63B.	3.8.3 A	RP	ALL	<i>Assessment is required when: The RP allows subscribers to access their RP subscriber account using direct authentication processes by allowing the subscriber to add and remove authenticators in the RP subscriber account.</i> Since the RP is using the direct authentication model discussed in [SP800-63], there is no federation transaction and therefore no FAL assigned.

NIST SP 800-63-4 Conformance Criteria v0.1: 63C

Control Identifier	Control Name	Control Text	Objective	Assessment Method	Index	Target	Profile/XAL Level	Discussion
ALTAP-2	Bound vs. Alternative Authenticators	While it is possible for bound authenticators (see Sec. 3.16) to be used as an alternative authenticator for direct access to the RP, these uses are distinct from each other and an RP SHALL determine whether a given authenticator can be used in one or both scenarios.	Determine whether the RP has determined whether bound authenticators can be utilized as alternative authenticators, and vice versa.	Examine RP documentation and policies to verify that the RP has explicitly determined whether bound authenticators can also be used for direct access, and vice versa.	3.8.3 B	RP	FAL3	<i>Assessment is required when: An RP supports both bound and alternative authenticators.</i> A single authenticator may potentially serve two purposes at the RP: 1. As a bound authenticator for FAL3 federation transactions 2. As an alternative authenticator for direct access without federation These are distinct use cases with different security implications. The RP must explicitly determine which authenticators are permitted for each scenario.
ASRP-1	RP Authenticated Session Requirements	An authenticated session SHALL be created by the RP only when the following conditions are true: (a) The RP has processed and verified a valid assertion. (b) The assertion is from the expected IdP for a transaction. (c) The IdP that issued the assertion is the IdP identified in the federated identifier of the assertion. (d) The assertion is associated with an RP subscriber account, which may be ephemeral. (e) The RP subscriber account has been provisioned at the RP through the method specified in the trust agreement.	Determine whether the RP creates authenticated sessions only once all required conditions are met.	Examine RP assertion processing logic and session management documentation to verify that: (a) The assertion's signature and validity are verified before session creation; (b) The assertion's issuing IdP is checked against the expected IdP for the transaction, and the assertion is from the expected IdP; (c) The federated identifier's IdP matches the assertion's issuer; (d) The assertion is linked to an RP subscriber account; and (e) The provisioning method matches what is specified in the trust agreement artifact(s). Test by presenting a valid assertion meeting all conditions and verify that an authenticated session is created. Then present assertions that fail one or more conditions and verify that no authenticated session is created.	3.9 A	RP	ALL	The RP must verify all five conditions before creating an authenticated session. This prevents session creation based on invalid or incomplete assertions.
ASRP-2	RP Authenticated Session Requirements: HoK Verification	If the assertion is a holder-of-key assertion at FAL3, the authenticator indicated in the assertion SHALL be verified before the RP subscriber account is associated with an authenticated session, as discussed in Sec. 3.15.	Determine whether the RP verifies the authenticator indicated in a holder-of-key assertion before associating the RP subscriber account with an authenticated session.	Examine RP documentation to verify that holder-of-key authenticator verification occurs before session creation. Test by presenting a holder-of-key assertion and verifying that the RP requires proof of the indicated authenticator before creating an authenticated session.	3.9 B	RP	FAL3	Assessment is required when: The assertion is a holder-of-key assertion at FAL3. A holder-of-key assertion contains a reference to an authenticator. Before creating an authenticated session, the RP must verify that the subscriber controls this authenticator - the assertion signature alone is insufficient.

NIST SP 800-63-4 Conformance Criteria v0.1: 63C

Control Identifier	Control Name	Control Text	Objective	Assessment Method	Index	Target	Profile/XAL Level	Discussion
ASRP-3	RP Authenticated Session Requirements: Bound Authenticator Verification	If the assertion also requires authentication with a bound authenticator at FAL3, a bound authenticator SHALL be verified before the RP subscriber account is associated with an authenticated session, as discussed in Sec. 3.16.	If the assertion requires authentication with a bound authenticator, determine whether the RP verifies a bound authenticator before associating the RP subscriber account with an authenticated session.	Satisfied by RPPHBA-1 and RPPHBA-4.	3.9 C	RP	FAL3	Assessment is required when: The assertion requires authentication with a bound authenticator at FAL3. When an assertion indicates that a bound authenticator is required for FAL3, the RP must verify the bound authenticator before creating an authenticated session - the assertion signature alone is not sufficient. The bound authenticator is registered to the RP subscriber account and managed by the RP. Note: If bound authenticator verification occurs as part of a binding ceremony (see SUBPB-7), this requirement is not satisfied. A new FAL3 federation transaction must be initiated after the binding ceremony completes.
PRIVR-1	Privacy Act Analysis	The agency SHALL consult with their Senior Agency Official for Privacy (SAOP) to conduct an analysis that determines whether the requirements of the Privacy Act are triggered by the agency that is acting as an IdP, by the agency that is acting as an RP, or both (see Sec. 7.4).	Determine whether the agency has consulted with its SAOP to analyze Privacy Act applicability for its RP and/or IdP roles.	Examine the documentation of the SAOP consultation and the resulting Privacy Act analysis, covering the agency's role(s) as an RP, an IdP, or both.	3.10 #1	IdP/RP	ALL	Assessment is required when: The assessment target (IdP or RP) is a federal agency. It is critical to involve an agency's SAOP in the earliest stages of federation implementation development to assess and mitigate privacy risks and advise the agency on compliance obligations, such as whether the federation triggers the Privacy Act of 1974 or the E-Government Act of 2002 requirement to conduct a PIA. For example, if the Agency is serving as an IdP in a federation, it is likely that the Privacy Act requirements will be triggered and that coverage is required under either a new or existing Privacy Act system of records, since credentials would be maintained at the IdP on behalf of any RP it federates with. If, however, the agency is an RP and using a third-party IdP, federated authentication may not trigger the requirements of the Privacy Act, depending on what data passed from the RP is maintained by the agency as the RP (in such instances, the agency may have a broader programmatic SORN that covers such data). Due to the many components involved in federation, it is important for the SAOP to have awareness and understanding of each component. For example, other privacy artifacts may be applicable to an agency offering or using federated IdP or RP services, such as Data Use Agreements, Computer Matching Agreements, etc. The SAOP can assist the agency in determining what additional requirements apply. Moreover, a thorough understanding of the individual components of digital authentication will enable the SAOP to assess and mitigate privacy risks through compliance processes or other means.

NIST SP 800-63-4 Conformance Criteria v0.1: 63C

Control Identifier	Control Name	Control Text	Objective	Assessment Method	Index	Target	Profile/XAL Level	Discussion
PRIVR-2	SORN	The agency SHALL publish or identify coverage by a System of Records Notice (SORN), as applicable.	Determine whether the agency has published or identified coverage by a SORN, as applicable.	Examine the agency's SORN documentation to verify that federation activities are covered by either a dedicated SORN or an existing programmatic SORN.	3.10 #2	IdP/RP	ALL	<i>Assessment is required when: The assessment target (IdP or RP) is a federal agency.</i> This control applies when PRIVR-1 analysis determines that the Privacy Act is triggered. If the SAOP has determined that the Privacy Act is triggered, the agency is required to either publish or identify existing coverage by a SORN.
PRIVR-3	E-Government Act	The agency SHALL consult with their SAOP to conduct an analysis that determines whether the requirements of the E-Government Act are triggered by the agency that is acting as an IdP, the agency that is acting as an RP, or both.	Determine whether the agency has consulted with its SAOP to analyze E-Government Act applicability for its RP and/or IdP roles.	Examine the documentation of the SAOP consultation and the resulting E-Government Act analysis, covering the agency's role(s) as RP, IdP, or both.	3.10 #3	IdP/RP	ALL	Assessment is required when: The assessment target (IdP or RP) is a federal agency. The E-Government Act of 2002 may require the agency to conduct a Privacy Impact Assessment (PIA) for its federation activities. The SAOP can assist the agency in determining whether a PIA is required. As with PRIVR-1, these considerations should not be read as a requirement to develop a PIA for federation alone - in many cases, it will make the most sense to draft a PIA that encompasses the entire digital identity process or includes federation as part of a larger programmatic PIA.
PRIVR-4	Privacy Impact Assessment	The agency SHALL publish or identify coverage by a Privacy Impact Assessment (PIA), as applicable.	Determine whether the agency has published or identified coverage by a PIA, as applicable.	Examine agency's PIA documentation to verify that federation activities are covered, either by a dedicated PIA or by an existing programmatic PIA.	3.10 #4	IdP/RP	ALL	Assessment is required when: The assessment target (IdP or RP) is a federal agency. This control applies when PRIVR-3 analysis determines that the E-Government Act is triggered. The agency must either publish a new PIA or identify an existing PIA that covers the federation activities. A dedicated PIA for federation is not required - coverage may be provided by a broader programmatic PIA that encompasses the digital identity process or the program establishing online access.
PRIVR-5	Privacy Risk Assessment	The agency SHALL conduct a privacy risk assessment regarding the sharing of subscriber identity information between the IdP and RP.	Determine whether the agency has conducted a privacy risk assessment regarding the sharing of subscriber identity information between the IdP and RP.	Examine the agency's privacy risk assessment documentation addressing the sharing of subscriber identity information in federation transactions.	3.10 #5	IdP/RP	ALL	<i>Assessment is required when: The assessment target (IdP or RP) is a federal agency.</i> This assessment focuses specifically on the risks associated with sharing subscriber identity information between federation parties. Unlike the Privacy Act and E-Government Act analyses (PRIVR-1, PRIVR-3), this assessment is required regardless of whether those statutes are triggered.

NIST SP 800-63-4 Conformance Criteria v0.1: 63C

Control Identifier	Control Name	Control Text	Objective	Assessment Method	Index	Target	Profile/XAL Level	Discussion
PRIVR-6	Provisioning API Privacy Measures	If the RP subscriber account life cycle process gives the RP access to attributes through a provisioning API (see Sec. 4.6.3), additional privacy measures SHALL be implemented to account for the difference in the RP subscriber account life cycle (e.g., separation of non-active subscriber accounts, proactive removal of disabled and terminated accounts).	Determine whether the RP implements additional privacy measures to account for RP subscriber account life cycle differences when using a provisioning API.	Examine the RP's policies and system documentation for provisioning API integration to verify that additional privacy measures address any differences arising from the RP subscriber account lifecycle, such as the separation of non-active accounts and the proactive removal of disabled and terminated accounts.	3.10 A	RP	ALL	<i>Assessment is required when: The RP subscriber account life cycle process gives the RP access to attributes through a provisioning API.</i> When an RP receives subscriber attributes through a provisioning API, the RP subscriber account life cycle may differ from the subscriber account life cycle at the IdP. For example, the RP may have accounts that are no longer active at the IdP. Additional privacy measures address these differences by ensuring that subscriber data is appropriately managed throughout the RP subscriber account lifecycle.
PRIVR-7	Provisioning API Attribute Minimization	The IdP SHALL minimize the attributes that are made available to the RP through the provisioning API.	Determine whether the IdP minimizes the attributes made available to the RP through the provisioning API.	Satisfied by TSI-1.	3.10 B	IdP	ALL	<i>Assessment is required when: The IdP provides attributes through a provisioning API.</i> Provisioning APIs can expose a broader set of subscriber attributes than would typically be transmitted in individual federation transactions. The IdP must ensure that only the minimum necessary attributes are made available through this channel, consistent with data minimization principles.
PRIVR-8	Provisioning API Population Limitation	The IdP SHALL limit the population of subscriber accounts that are available via the provisioning API to the population of subscribers authorized to use the RP by the trust agreement.	Determine whether the IdP limits the subscriber accounts available via the provisioning API to the population of subscribers authorized to use the RP as specified in the trust agreement artifact(s).	Examine the IdP provisioning API configuration and access control documentation to verify that only subscribers authorized to use the RP per the trust agreement artifact(s) are included in the provisioned population.	3.10 C	IdP	ALL	<i>Assessment is required when: The IdP provides attributes through a provisioning API.</i> Provisioning APIs can pre-populate RP subscriber accounts before subscribers authenticate. The IdP must ensure that only subscribers authorized to use the RP under the trust agreement artifact(s) are included. This prevents the RP from receiving data about subscribers who have no relationship with the RP.

NIST SP 800-63-4 Conformance Criteria v0.1: 63C

Control Identifier	Control Name	Control Text	Objective	Assessment Method	Index	Target	Profile/XAL Level	Discussion
PRIVR-9	Subscriber Account Deprovisioning via API	To prevent RP retention of identity attributes for accounts that have been terminated at the IdP, the IdP SHALL use the provisioning API to deprovision RP subscriber accounts for terminated subscriber accounts except where restricted by RP data retention requirements, policies, or regulation.	Determine whether the IdP actively uses the provisioning API to deprovision RP subscriber accounts when corresponding subscriber accounts are terminated at the IdP, when the IdP is not restricted from doing so by RP retention requirements, policies, or regulations.	Examine the trust agreement artifact(s) documenting any RP retention exceptions that restrict automatic deprovisioning. Examine audit logs that correlate subscriber account terminations at the IdP with corresponding deprovisioning actions sent to RPs, and ensure that deprovisioning occurs unless there is an RP exception, and that deprovisioning does not occur if any RP exception conditions have been met. Test by terminating a test subscriber account at the IdP that should result in deprovisioning and verify that a deprovisioning action is sent to the RP via the provisioning API. Then, terminate a test subscriber account at the IdP that should not result in deprovisioning and verify that no deprovisioning action is sent to the RP.	3.10 D	IdP	ALL	<i>Assessment is required when: The IdP provides attributes through a provisioning API.</i> This requirement enforces data minimization principles by ensuring the IdP proactively removes subscriber data from RPs when accounts are terminated, rather than allowing indefinite retention of stale identity attributes. The exception clause acknowledges that RPs may have legitimate data retention requirements (legal, regulatory, or policy-based) that prevent immediate deletion. Trust agreement artifact(s) should document any such exceptions. Note that when an RP subscriber account is linked to multiple federated identifiers (see Sec. 3.8.1), deprovisioning one federated identifier may result in a persistent RP subscriber account linked to a different federated identifier.
PRIVR-10	Data Exchange Minimization	The IdP and RP SHALL exchange only the minimum data necessary to achieve the function of the system.	Determine whether the IdP and RP limit data exchanged between them to only what is necessary for system functionality.	For IdPs: Satisfied by TSI-1. For RPs: Examine the trust agreement artifact(s) documenting the attributes to be exchanged and their stated purposes. Review data transmitted from RP to IdP and verify that each data element has a corresponding functional justification and that no extraneous data is transmitted.	3.10 E	IdP/RP	ALL	Assessors should verify that each attribute exchanged has a documented purpose tied to system functionality-attributes exchanged "just in case" or for undefined future use would indicate non-compliance. Transmission of subscriber activities to the IdP is further restricted by TSI-4, which limits such transmission to fraud mitigation and security incident response purposes only.
TSI-1	IdP Data Exchange Minimization	The IdP SHALL limit the transmission of subscriber information to only that which is necessary for the system to function and is stipulated and disclosed by the trust agreement.	Determine whether the IdP limits transmission of subscriber information to only what is (1) necessary for permissible system functions and (2) stipulated and disclosed in the trust agreement artifact(s).	Examine the trust agreement artifact(s) documenting transmissible attributes and their purposes. For each attribute authorized for transmission, verify that it maps to a necessary system function (such as identity service, specific subscriber request, fraud mitigation, or security incident response) and has a documented functional justification. Review IdP attribute release configuration and compare against trust agreement artifact(s) to verify no unauthorized attributes are transmitted. Test by generating an assertion for a test RP. Verify that no attributes appear in the assertion beyond those authorized by the trust agreement artifact(s). If the federation protocol permits runtime attribute requests, configure the test RP to request attributes outside the trust agreement artifact(s) and verify the IdP rejects or ignores the unauthorized request.	3.10.1 A	IdP	ALL	Typical system functions include the following: - Identity proofing, authentication, or attribute assertions (collectively "identity service"); - A specific subscriber request to transmit the information; - Fraud mitigation related to the identity service; - or - Responding to a security incident related to the identity service. RP compliance with data exchange minimization is assessed under PRIVR-10.

NIST SP 800-63-4 Conformance Criteria v0.1: 63C

Control Identifier	Control Name	Control Text	Objective	Assessment Method	Index	Target	Profile/XAL Level	Discussion
TSI-2	IdP Privacy Risk Management for Additional Processing	If an IdP discloses information on subscriber activities at an RP to any party, or processes the subscriber's attributes for any purpose other than these cases [Identity proofing, authentication, or attribute assertions (collectively "identity service"); A specific subscriber request to transmit the information; Fraud mitigation related to the identity service; or Responding to a security incident related to the identity service], the IdP SHALL implement measures to maintain predictability and manageability commensurate with the privacy risks that arise from the additional processing.	Determine whether the IdP implements measures to maintain predictability and manageability commensurate with privacy risks, when the IdP discloses information on subscriber activities at an RP to any party or processes subscriber attributes for any purpose other than for an identity service, a specific subscriber request, fraud mitigation, or a security incident response.	Examine the IdP's policies and practices regarding the processing of subscriber information. First, identify whether the IdP processes subscriber information for any purpose beyond these functions: identity proofing, authentication, or attribute assertions (collectively "identity service"); a specific subscriber request to transmit the information; fraud mitigation related to the identity service; or responding to a security incident related to the identity service. If additional processing occurs, review the IdP's privacy risk assessment for that processing and verify that implemented measures (such as notice, consent, or selective disclosure controls) are commensurate with the identified risks.	3.10.1 B	IdP	ALL	Assessment is required when: An IdP discloses information on subscriber activities at an RP to any party, or processes the subscriber's attributes for any purpose other than these case: Identity proofing, authentication, or attribute assertions (collectively "identity service"); A specific subscriber request to transmit the information; Fraud mitigation related to the identity service; or Responding to a security incident related to the identity service. By the nature of a federated protocol, the IdP will know which RPs a subscriber logs in to and will know which attributes have been released to which RPs. This information is used as part of the federated login process, identified here as "identity service", to facilitate login to an RP. IdPs need to use measures to maintain the objectives of predictability (enabling reliable assumptions by individuals, owners, and operators about PII and its processing by an information system) and manageability (providing the capability for granular administration of PII, including alteration, deletion, and selective disclosure) commensurate with privacy risks that can arise from the processing of information for purposes other than identity proofing, authentication, authorization, or attribute assertion, related fraud mitigation, or to comply with law or legal process as in [NISTIR8062]. However, processing information for purposes other than the identity service can create privacy risks when individuals are not expecting or are not comfortable with the additional processing. These exception cases, which are not part of the federated identity protocol process, need to be managed in accordance with the risks associated with such additional processing of the subscriber's information. IdPs can use privacy risk assessments to determine the extent of privacy risks arising from such processing and implement measures commensurate with the privacy risk arising from the additional processing. Such measures may include providing clear notice, obtaining subscriber consent, or enabling selective use or disclosure of attributes, but other measures may be more effective in mitigating the privacy risks depending on the type of processing.

NIST SP 800-63-4 Conformance Criteria v0.1: 63C

Control Identifier	Control Name	Control Text	Objective	Assessment Method	Index	Target	Profile/XAL Level	Discussion
TSI-3	Prohibition on Coerced Consent	When an IdP gathers the subscriber's consent to use information outside the identity transaction, the IdP SHALL NOT make consent for the additional processing a condition of the identity service.	Determine whether the IdP refrains from making consent for additional processing a condition of the identity service, when the IdP gathers subscriber consent to use information outside the identity transaction.	Examine the IdP's consent mechanisms and user interface flows for gathering subscriber consent to additional processing. Verify that subscribers can decline consent for additional processing and still complete identity service functions. Test by attempting to use the identity service while declining consent for any additional processing. Verify that the identity service remains available.	3.10.1 C	IdP	ALL	Assessment is required when: An IdP gathers the subscriber's consent to use information outside the identity transaction. Subscriber consent must be meaningful. When IdPs use consent measures for processing beyond identity service functions, they cannot make subscriber acceptance of additional processing a condition of providing the identity service. For example, an IdP cannot require a subscriber to consent to marketing use of their data as a condition of federated login.
TSI-4	RP Subscriber Activity Transmission Limits	An RP SHALL limit the transmission of subscriber activities to the associated IdP to the following cases, and only if stipulated and disclosed by the trust agreement: (a) Fraud mitigation related to the identity service (b) Responding to a security incident related to the identity service	Determine whether the RP limits transmission of subscriber activities to the IdP to only fraud mitigation or security incident response, and only when stipulated and disclosed by the trust agreement.	Examine the RP's system configuration and data flow documentation to determine whether the RP transmits subscriber activity to the IdP. If transmission occurs, verify that (1) the transmission is stipulated and disclosed in the trust agreement artifact(s), and (2) the purpose is limited to fraud mitigation related to the identity service or to responding to a security incident related to the identity service.	3.10.1 D	RP	ALL	"Subscriber activities" refers to actions the subscriber takes at the RP, such as login events, transactions, or usage patterns.
TSI-5	Subscriber Notice & Consent for Additional Uses	If an RP uses the subscriber's identity information for any purpose other than those stipulated in the trust agreement, the RP SHALL inform the subscriber and obtain their consent for such additional uses.	Determine whether the RP informs the subscriber and obtains consent when using the subscriber's identity information for any purpose other than those stipulated in the trust agreement.	Examine by reviewing all RP policies that document the purposes for which subscriber identity information is used, and compare that documentation to the purposes stipulated in the trust agreement artifact(s). If uses beyond the trust agreement exist, verify that (1) the RP provides notice to subscribers describing the additional use(s), and (2) the RP obtains subscriber consent prior to the additional use(s). Test by initiating a representative subscriber flow for each category of additional use, and determine that the RP informs the subscriber of the additional use and obtains the subscriber's consent before that additional use occurs.	3.10.1 E	RP	ALL	Assessment is required when: An RP uses the subscriber's identity information for any purpose other than those stipulated in the trust agreement. "Identity information" can include identity attributes received from the IdP as well as subscriber activities at the RP. "Specifically consents" indicates that general terms of service acceptance are insufficient-the subscriber must affirmatively agree to the specific additional use.

NIST SP 800-63-4 Conformance Criteria v0.1: 63C

Control Identifier	Control Name	Control Text	Objective	Assessment Method	Index	Target	Profile/XAL Level	Discussion
SIBC-1	CSP/IdP Information Transmission Limitations	All information transmissions between CSPs and/or IdPs SHALL be subject to the limitations for IdPs enumerated in Sec. 3.10.1.	Determine whether information transmissions between CSPs and/or IdPs comply with the limitations enumerated for IdPs in Sec. 3.10.1.	Examine documentation that identifies all information transmitted between CSPs and/or IdPs. For each category of information/attributes transmitted, apply the assessment methods from TSI-1, TSI-2, and TSI-3 to verify that the transmission complies with the stated information-sharing limitations.	3.10.2 A	CSP/IdP	ALL	In some larger federation systems, particularly multilateral federations managed by federation authorities, multiple CSPs may be involved in the same trust agreement. In such cases, it may be desirable for CSPs to share information with one another to support activities such as fraud mitigation (e.g., to prevent an attacker from jumping between CSPs with different accounts to avoid detection). While sharing information in this way can help mitigate fraud, there are also substantial privacy concerns, as CSPs could learn subscriber attributes and actions from each other that were not initially disclosed to all CSPs the subscriber uses. Similar information sharing could be desirable between IdPs that operate independently of the CSP, such as between subscriber-controlled wallets hosted on remote systems, and such sharing entails similar privacy considerations. (See NISTIR 8062 for guidance on privacy engineering objectives, including predictability and manageability.)
SIBC-2	CSP/IdP Information Sharing Privacy Risk Assessment	Any such information sharing between CSPs and/or IdPs SHALL be included in their privacy risk assessments.	Determine whether information sharing between CSPs and/or IdPs is included in each party's privacy risk assessment.	Examine the documentation that identifies all information transmitted between CSPs and/or IdPs. Review each participating CSP's and IdP's privacy risk assessment and verify that the identified information sharing is addressed.	3.10.2 B	CSP/IdP	ALL	<i>Assessment is required when: Information is shared between CSPs and/or IdPs.</i> This control ensures that CSPs and IdPs explicitly consider the privacy implications of inter-party information sharing. While such sharing can support fraud mitigation, it also creates risks that CSPs could learn subscriber attributes and actions from each other that were not originally disclosed to all CSPs the subscriber uses.
SIBC-3	CSP Information Transfer Policy	The terms of the trust agreement that connects CSPs SHALL define the policies that apply for the transfer of information shared between CSPs.	Determine whether the trust agreement artifact(s) that connect CSPs define policies for the transfer of information shared between CSPs.	Examine the trust agreement artifact(s) that establish the CSP connections. Verify that policies are defined for the transfer of information shared between CSPs, including what information may be transferred, under what circumstances, and any restrictions on use. Then, examine sample records of information shared between CSPs to verify that all sharing complies with the policies defined in the trust agreement artifact(s).	3.10.2 C	CSP	ALL	<i>Assessment is required when: Two or more CSPs are connected under a (set) of trust agreement artifact(s).</i> In a trust agreement managed by a federation authority, the federation authority defines these terms.

NIST SP 800-63-4 Conformance Criteria v0.1: 63C

Control Identifier	Control Name	Control Text	Objective	Assessment Method	Index	Target	Profile/XAL Level	Discussion
SECC-1	IdP/CSP Security Controls	IdPs and CSPs SHALL employ appropriately tailored security controls from at least the moderate baseline security controls defined in [SP800-53] or an equivalent federal (e.g., [FEDRAMP]) or industry standard that the organization has determined for the information systems, applications, and online services that these guidelines are used to protect.	Determine whether the IdP/CSP employs appropriately tailored security controls from at least the moderate baseline defined in SP 800-53 or an equivalent standard.	Examine evidence that the IdP/CSP has been assessed against at least the moderate baseline security controls defined in SP 800-53 or an equivalent standard. Verify that the resulting authorization or certification is current and covers all systems supporting federation services.	3.11 A	CSP/IdP	ALL	A compromise of the IdP/CSP or its cryptographic material would be detrimental to the federation network. As a consequence, the IdP/CSP has to employ stringent security controls, and these controls help protect the network as a whole. NIST SP 800-53 rev.5 and SP 800-53B provide a comprehensive catalog of controls, three security control baselines (low, moderate, and high impact), and guidance for tailoring the appropriate baseline to specific needs and risk environments for federal information systems. These controls are the operational, technical, and management safeguards to maintain the integrity, confidentiality, and security of federal information systems and are intended to be used in conjunction with the NIST risk management framework outlined in SP 800-37 and SP 800-63-3 section 5, Digital Identity Risk Management. NIST SP 800-53B presents security control baselines determined by the security categorization of the information system (low, moderate or high) from NIST FIPS 199 Standards for Security Categorization of Federal Information and Information Systems. The moderate and high baseline controls may be considered the starting point for the selection, enhancement, and tailoring of the security controls presented. Guidance on tailoring the control baselines to best meet the organization's risk environment, systems and operations is presented in SP 800-53B section 2.4 Tailoring Baseline Security Controls. While SP 800-53B and other NIST Special Publications in the SP-800-XXX series apply to federal agencies for the implementation of the Federal Information Security Modernization (Management) Act (FISMA), non-federal entities providing services for federal information systems may also need to demonstrate appropriate controls and should similarly use SP 800-53 and associated publications as resources. Non-federal entities may be subject to and conformant with other applicable controls systems and processes for information system security (e.g., FEDRAMP, ISO/IEC 27001).

NIST SP 800-63-4 Conformance Criteria v0.1: 63C

Control Identifier	Control Name	Control Text	Objective	Assessment Method	Index	Target	Profile/XAL Level	Discussion
SECC-2	RP Security Controls	RPs SHALL employ appropriately tailored security controls from at least the low baseline security controls defined in [SP800-53] or an equivalent federal (e.g., [FEDRAMP]) or industry standard that the organization has determined for the information systems, applications, and online services that these guidelines are used to protect.	Determine whether the RP employs appropriately tailored security controls from at least the low baseline defined in SP 800-53 or an equivalent standard.	Examine evidence that the RP has been assessed against at least the low baseline security controls defined in SP 800-53 or an equivalent standard. Verify that the resulting authorization or certification is current and covers all systems supporting federation services.	3.11 B	RP	ALL	<i>Assessment is required when: The RP does not request or process personal information.</i> RPs that request or process personal information must implement security controls at the moderate baseline or higher (see SECC-3).
SECC-3	RP Security Controls for Personal Information	RPs that request or process personal information SHALL employ appropriately tailored security controls from at least the moderate baseline security controls defined in [SP800-53] or an equivalent federal (e.g., [FEDRAMP]) or industry standard.	Determine whether RPs that request or process personal information employ appropriately tailored security controls from at least the moderate baseline defined in [SP800-53] or an equivalent standard.	Examine evidence that the RP has been assessed against at least the moderate baseline security controls defined in SP 800-53 or an equivalent standard. Verify that the resulting authorization or certification is current and covers the systems supporting federation services.	3.11 C	RP	ALL	<i>Assessment is required when: The RP processes personal information.</i> This control supersedes SECC-2 for RPs handling personal information, raising the minimum baseline from low to moderate.
SECC-4	Assurance Level Baseline Controls	CSPs, IdPs, and RPs SHALL ensure that the minimum assurance-related controls for the appropriate systems or equivalent are satisfied or exceeded.	Determine whether CSPs, IdPs, and RPs satisfy or exceed the minimum assurance-related controls for their selected IAL(s), AAL(s), and FAL(s).	Examine the documentation that identifies the IAL(s), AAL(s), and/or FAL(s) that the organization accepts/ provides. Then, identify the applicable baseline controls from [SP800-63A] for the selected IAL(s), [SP800-63B] for the selected AAL(s), and [SP800-63C] for the selected FAL(s). Assess or verify the assessment of each applicable set of baseline controls. Record the compliance status based on the results of the baseline control assessment. Determine whether the minimum assurance-related controls have been satisfied or exceeded.	3.11 D	CSP/IdP/RP	ALL	Compliance with this control is demonstrated through the results of the applicable baseline control assessments from SP 800-63A, SP 800-63B, and SP 800-63C.
PSI-1	IdP-RP Communication Protection	Communications between the IdP and the RP SHALL be protected in transit using an authenticated protected channel.	Determine whether all communications between the IdP and RP are protected in transit using an authenticated protected channel.	Examine documentation that reveals the functions for which the IdP and RP communicate (e.g., assertion exchange, provisioning API, key retrieval, dynamic registration), and list those functions. For communications covered by specific controls (BCP-8, DR-2, DYR-1, ICKM-2, CKR-2, PAPI-3), assess or verify assessment of each applicable control. For any IdP-RP communications not covered by a specific control, verify that the communication is configured to use an authenticated protected channel.	3.11.2 A	IdP/RP	ALL	This control is the umbrella requirement for protecting IdP-RP communication. Most IdP-RP communication scenarios have dedicated controls with specific assessment procedures. This control catches any communication pathways that fall outside those dedicated controls. If all IdP-RP communications are covered by the specific controls listed in the assessment method, step (3) will have no additional items to assess, and the assessor should document that.

NIST SP 800-63-4 Conformance Criteria v0.1: 63C

Control Identifier	Control Name	Control Text	Objective	Assessment Method	Index	Target	Profile/XAL Level	Discussion
PSI-2	Subscriber Communication Protection	Communications between the subscriber and either the IdP or the RP (usually through a user agent) SHALL be made using an authenticated protected channel.	Determine whether communications between the subscriber and the IdP or RP occur over an authenticated protected channel.	Examine documentation that reveals the functions for which the subscriber communicates with the IdP or RP (e.g., authentication, assertion conveyance, consent), and list those functions. For communications covered by specific controls (BCP-7, FCP-3), assess or verify the assessment of each applicable control. For any subscriber-IdP or subscriber-RP communications not covered by a specific control, verify that the communication is configured to use an authenticated protected channel. Record compliance status based on the results.	3.11.2 B	IdP/RP	ALL	Compliance is determined by assessing the applicable specific controls (BCP-7, FCP-3) and verifying that any communications not covered by those controls also use an authenticated protected channel. "User agent" refers to the subscriber's browser or application.
PSI-3	Identity API Enumeration in Trust Agreement	The use of identity APIs SHALL be enumerated in the terms of the trust agreement.	Determine whether the use of identity APIs is enumerated in the trust agreement artifact(s).	Satisfied by IDAP-1.	3.11.2 C	IdP/RP	ALL	<i>Assessment is required when: An identity API is used.</i> Identity attributes MAY be included outside of the assertion itself by authorizing access to an identity API, as discussed in Sec. 3.12.3. Splitting identity information in this manner can help protect subscriber privacy and can allow for the limited disclosure of personal information in addition to the essential information in the authentication assertion itself. IDAP-1 establishes the requirement to record and disclose all possible use of identity APIs in the trust agreement artifact(s), including which provisioning models are available through the API.
SSIN-1	Personal Information Storage Security	Whether the account is active or not, the IdP and RP SHALL store personal information in a subscriber account or RP subscriber account using tailored security controls defined in [SP800-53] or an equivalent federal (e.g., [FEDRAMP]) or industry standard.	Determine whether the IdP and RP store personal information in subscriber accounts using tailored security controls from [SP800-53] or an equivalent standard.	For IdPs, satisfied by SECC-1. For satisfied by SECC-3.	3.11.3 A	IdP/RP	ALL	Storage of personal information is a form of processing. SECC-1 requires IdPs and CSPs to implement at least moderate baseline security controls. SECC-3 requires RPs that request or process personal information to implement at least moderate baseline security controls.
SSIN-2	Justification for Non-Deletion	IdPs and RPs that do not support deletion SHALL provide a statutory or risk-based justification and document it in the trust agreement.	Determine whether IdPs and RPs that do not support deletion provide a statutory or risk-based justification documented in the trust agreement artifact(s).	Examine evidence to determine whether the IdP or RP supports the deletion of personal information. If deletion is not supported, verify that a statutory or risk-based justification is documented in the trust agreement artifact(s), as required by TRUST-9.	3.11.3 B	IdP/RP	ALL	Assessment is required when: The IdP/RP does not support the deletion of personal information. TRUST-9 requires trust agreement artifact(s) to declare data retention policies for all parties. This control adds the requirement that when deletion is not supported, a statutory or risk-based justification must be provided-general policy statements are insufficient.

NIST SP 800-63-4 Conformance Criteria v0.1: 63C

Control Identifier	Control Name	Control Text	Objective	Assessment Method	Index	Target	Profile/XAL Level	Discussion
SSIN-3	Attribute Removal Upon Account Termination	When the RP subscriber account is terminated, the RP SHALL remove all subscriber attributes from storage, except when otherwise restricted by regulations, laws, or policies or when the risk of an application deems it essential.	Determine whether the RP removes all subscriber attributes from storage when the RP subscriber account is terminated, except when restricted by regulations, laws, policies, or application risk requirements.	Satisfied by RPSA-1.	3.11.3 C	RP	ALL	Assessment of attribute removal upon RP subscriber account termination is performed under RPSA-1, which covers the full scope of data removal, including federated identifiers, bound authenticators, attributes, and identity information. Exceptions must be documented with a specific regulatory, legal, policy, or risk-based justification; general data retention policies are insufficient.
IDA-1	Attribute Presentation Documentation	Attributes SHALL be either unbundled (i.e., presented directly in an assertion by the IdP) or bundled into a package that is cryptographically signed by the CSP, as described in Sec. 3.12.1.	Determine whether the IdP documents which attribute presentation technique(s) it uses - unbundled, bundled, or both.	Examine the IdP's technical documentation to confirm that the IdP specifies whether attributes are presented unbundled in assertions, bundled with CSP signatures per Section 3.12.1, or both. Verify that this documentation is available to RPs.	3.12 A	IdP	ALL	This documentation enables RPs to implement the appropriate validation logic. For unbundled attributes, the RP validates via the assertion signature. For bundled attributes, the RP must additionally validate the CSP's bundle signature per ABUN-2.
IDA-2	Attribute Type Documentation	Attributes SHALL be either attribute values (e.g., a date of birth) or derived attribute values (e.g., an indication of age of majority).	Determine whether the IdP documents which attribute types it provides - attribute values, derived attribute values, or both.	Examine the IdP's technical documentation to confirm that the IdP specifies, for each attribute, whether it is an attribute value or a derived attribute value. Verify that this information is available to RPs.	3.12 B	IdP	ALL	RPs need to know whether they will receive actual attribute values (e.g., "2/20/2000") or derived values (e.g., "over 21"). This affects RP business logic and data handling. Derived attribute values support privacy by disclosing only what is necessary; see DAV-1.
IDA-3	Attribute Delivery Method Documentation	Attributes SHALL be either presented in the assertion and covered by the assertion's signature or be made available as part of a protected identity API.	Determine whether the IdP documents how attributes are delivered - in the assertion, via identity API, or both.	Examine the IdP's technical documentation to confirm that the IdP specifies, for each attribute, whether it is delivered in the assertion or via an identity API. Verify that this information is available to RPs.	3.12 C	IdP	ALL	
IDA-4	CSP Practice Statement Reference	Trust agreements SHALL point to the CSP's practice statements that describe the processes and sources used for attribute validation.	Determine whether the trust agreement artifact(s) point to the CSP's practice statements describing the processes and sources used for attribute validation.	Examine the trust agreement artifact(s) to verify that they include a reference to the CSP's practice statements. Review the referenced practice statements to verify that they describe the processes and sources used for attribute validation.	3.12 D	IdP/RP	ALL	The CSP practice statement enables RPs to evaluate the trustworthiness of attributes by understanding how the CSP validates them. Practice statements typically describe evidence requirements, authoritative sources consulted, and validation procedures used during identity proofing or attribute collection.
ABUN-1	Attribute Bundle Presentation Protection	The presentation of an attribute bundle SHALL be protected by the IdP in the same manner as non-bundled attributes.	Determine whether the IdP protects the presentation of attribute bundles in the same manner as non-bundled attributes.	Satisfied by SIGNA-1 and SIGNA-3.	3.12.1 A	IdP	ALL	Attribute bundles are protected by the IdP's assertion signature per SIGNA-1 and SIGNA-3. The attribute bundle also retains its own CSP signature, which the RP must validate per ABUN-2. Note: Other protocols and specifications often refer to attribute bundles as credentials. However, this term would be in conflict with its use within these guidelines for a different concept. Consequently, these guidelines use the term "attribute bundle" instead.

NIST SP 800-63-4 Conformance Criteria v0.1: 63C

Control Identifier	Control Name	Control Text	Objective	Assessment Method	Index	Target	Profile/XAL Level	Discussion
ABUN-2	Attribute Bundle Signature Validation	The RP SHALL validate the signature specific to the attribute bundle as well as any container signatures, such as the signature of the assertion as a whole.	Determine whether the RP validates both the signature specific to the attribute bundle and any container signatures such as the assertion signature.	IdP assertion signature validation is satisfied by FAL1-2. For CSP-issued attribute bundles: Examine the RP's assertion processing documentation to verify that it validates the CSP's signature on the attribute bundle. Test by presenting an assertion containing an attribute bundle with an invalid bundle signature but a valid assertion signature. Verify that the RP rejects it.	3.12.1 B	RP	ALL	Attribute bundles carry the CSP's signature attesting to the authenticity of the attributes. The assertion signature (validated per FAL1-2) protects the bundle from substitution or tampering during the federation transaction. See ARTVL-1 for the equivalent requirement in subscriber-controlled wallet scenarios.
ABUN-3	Bundle-Embedded IdP Verification Key Validation	The RP SHALL confirm that the assertion is presented by the identity claimed in the attribute bundle by verifying the signature over the assertion using the IdP's verification key in the signed attribute bundle.	Determine whether the RP uses the IdP verification key embedded in the CSP-signed attribute bundle to verify the assertion signature, thereby confirming the assertion was issued by the IdP authorized by the CSP to present the bundle.	Examine the RP's assertion-processing documentation to confirm that the RP extracts the IdP's verification key from the CSP-signed attribute bundle and uses it to verify the assertion's signature. Test by presenting an assertion containing an attribute bundle with a valid embedded IdP verification key. Verify that the RP successfully validates the assertion signature using that key. Then, present an assertion signed by a different IdP than the one whose key is embedded in the attribute bundle. Verify the RP rejects the assertion.	3.12.1 C	RP	ALL	<i>Assessment is required when: The attribute bundle includes a verification key for the IdP.</i> This control establishes a CSP-to-IdP binding. When the CSP signs an attribute bundle containing a specific IdP's verification key, the CSP restricts which IdP may present that bundle. The RP enforces this restriction by verifying the assertion signature against the embedded key, rather than a key obtained from metadata or trust agreement artifact(s). Note: The phrase "identity claimed in the attribute bundle" in the source text refers to the IdP whose verification key is embedded in the CSP-signed bundle.
DAV-1	Derived Attribute Value Non-Disclosure	To preserve privacy, derived attribute values SHALL NOT disclose the underlying attribute value to a requester.	Determine whether derived attribute values are provided without disclosing the underlying attribute value.	Examine a sample or documentation describing IdP assertions and identity API responses containing derived attribute values. For each derived attribute (e.g., "over 21"), verify that the underlying attribute value (e.g., date of birth) is not also included in the same response. Test by request a derived attribute value from the IdP. Verify the response contains only the derived value and does not include the underlying attribute value.	3.12.2 A	IdP	ALL	<i>Assessment is required when: Derived attribute values are used.</i> Derived attribute values exist to preserve privacy by disclosing only what is necessary. If the underlying value is also disclosed, the privacy benefit is negated. For example, if an RP only needs to know a subscriber is over 21, disclosing the full date of birth defeats the purpose.
IDAP-1	Identity API Disclosure in Trust Agreement	All possible use of identity APIs, including which provisioning models are available through the API, SHALL be recorded and disclosed as part of the trust agreement.	Determine whether the trust agreement artifact(s) document the permitted uses of identity APIs and the provisioning models available through those APIs.	Examine the relevant trust agreement artifact(s) for each identity API offered to verify that they document all supported uses of the identity API and the provisioning model(s) available through the API.	3.12.3 A	IdP	ALL	<i>Assessment is required when: An Identity API is offered by the IdP.</i> Identity APIs allow RPs to retrieve subscriber attributes outside of the assertion itself. Provisioning models include pre-provisioning, just-in-time provisioning, and ephemeral provisioning (see Sec. 4.6.3).

NIST SP 800-63-4 Conformance Criteria v0.1: 63C

Control Identifier	Control Name	Control Text	Objective	Assessment Method	Index	Target	Profile/XAL Level	Discussion
IDAP-2	Identity API Access Time Limitation	Access to the identity API SHALL be time-limited by the trust agreement.	Determine whether access to the identity API is time-limited as specified in the trust agreement artifact(s).	Examine the relevant trust agreement artifact(s) to verify that they specify time limits for identity API access. Review the IdP's identity API configuration to verify that access is time-limited in accordance with the trust agreement artifact(s).	3.12.3 B	IdP	ALL	<i>Assessment is required when: An Identity API is offered by the IdP.</i> Access to the identity API should be limited to the duration of the federation transaction plus the time necessary to synchronize attributes (see Sec. 4.6.4). Time limits prevent indefinite access to subscriber attributes after a federation transaction.
IDAP-3	Identity API Access Insufficient for Session Establishment	Since the time limitation is separate from the validity time window of the assertion and the lifetime of the authenticated session at the RP, access to an identity API by the RP without an associated valid assertion SHALL NOT be sufficient for the establishment of an authenticated session at the RP.	Determine whether the RP requires a valid assertion to establish an authenticated session for the subscriber, and does not establish sessions based solely on identity API access.	Examine the RP's session establishment documentation to verify that a valid assertion is required to establish an authenticated session, and that identity API access alone is insufficient. Test by attempting to establish an RP session using only identity API access (without a valid assertion). Verify that the RP rejects session establishment.	3.12.3 C	RP	ALL	<i>Assessment is required when: An Identity API is offered by the IdP.</i> Identity API access is separate from assertion validity and from the lifetime of any authenticated session. Therefore, the ability to call an identity API must not be treated as evidence of a successful federation transaction or used to create an authenticated session. See also RASR-2, which prohibits using identity API access to extend an existing session.
IDAP-4	Identity API Transaction Scope	When access to the identity API is granted within the context of a federation transaction, the attributes provided by an identity API SHALL be associated with only the single subscriber identified in the associated assertion.	Determine whether attributes provided by an identity API, when accessed within the context of a federation transaction, are associated only with the single subscriber identified in the associated assertion.	Examine the IdP's identity API documentation to verify that when access is granted within a federation transaction, returned attributes are scoped to the subscriber identified in the associated assertion. Test by attempting to use the identity API to retrieve attributes for a subscriber other than the one identified in the assertion, during a federation transaction. Verify that the IdP rejects or ignores the request.	3.12.3 D	IdP	ALL	<i>Assessment is required when: An Identity API is offered by the IdP.</i> An identity API deployment may be capable of providing attributes for all subscribers for whom the IdP can create assertions. This control ensures that when API access is granted during a federation transaction, the RP cannot use that access to query attributes for other subscribers.
IDAP-5	Identity API Subject Identifier Inclusion	If the identity API is hosted by the IdP, the returned attributes SHALL include the subject identifier for the subscriber.	Determine whether the identity API returns the subject identifier for the subscriber when the API is hosted by the IdP.	Examine the Identity API response structure to verify that the subject identifier is included in the returned attributes. Test by querying the identity API and verifying that the response includes the subject identifier for the subscriber.	3.12.3 E	IdP	ALL	<i>Assessment is required when: An Identity API is offered by the IdP.</i> The subject identifier allows the RP to correlate the identity API response with the assertion's subject, ensuring attributes are associated with the correct subscriber.
IDAP-6	Pre-Provisioning Privacy Evaluation	For pre-provisioning use cases, the privacy considerations SHALL be evaluated and recorded as part of the trust agreement.	Determine whether privacy considerations for pre-provisioning use cases are evaluated and recorded in the trust agreement artifact(s).	Examine the relevant trust agreement artifact(s) to verify that the privacy considerations for pre-provisioning are documented.	3.12.3 F	IdP/RP	ALL	<i>Assessment is required when: An Identity API is offered by the IdP and pre-provisioning is utilized.</i> Pre-provisioning grants the RP access to subscriber attributes before any federation transaction, creating privacy risks that must be explicitly addressed.

NIST SP 800-63-4 Conformance Criteria v0.1: 63C

Control Identifier	Control Name	Control Text	Objective	Assessment Method	Index	Target	Profile/XAL Level	Discussion
EAI-1	External Identity API Documentation	Any use of external identity APIs for providing attributes SHALL be enumerated by the trust agreement as part of listing attribute sources.	Determine whether any use of external identity APIs for providing attributes is enumerated in the trust agreement artifact(s) as part of listing attribute sources.	Examine the relevant trust agreement artifact(s) to verify that the external identity APIs are listed as attribute sources, including which attributes are provided by each external API.	3.12.3.1 A	IdP	ALL	<i>Assessment is required when: External APIs are used for providing attributes.</i> External identity APIs are hosted by a party other than the IdP and typically provide attributes from sources other than the CSP (e.g., a medical licensure agency providing license status). The IdP is responsible for associating the external identity API's content with the subscriber account.
ARTP-1	Assertion Protection Requirements	Assertions SHALL include a set of protections to prevent attackers from manufacturing valid assertions or reusing captured assertions at different RPs.	Determine whether assertions include the required protection mechanisms.	Satisfied by ARTI-1, SIGNA-1, SIGNA-3, SIGNA-4, and AUDR-1; and by ENCA-1 when assertions are encrypted.	3.13 A	IdP	ALL	Assertions are the fundamental building block of a federated identity transaction, and protecting assertions is essential to the security of the overall system. If an attacker were able to create or modify an assertion and have that assertion accepted by an RP, the attacker would be able to impersonate a valid subscriber and log in to the target system. If an attacker were able to capture an assertion in transit and replay that assertion to a different RP, the attacker would be able to steal a valid session from the legitimate subscriber and log in to the target system. As a consequence, there are a suite of protections that are required for all assertions in a federated system, regardless of how the trust between the parties is established or how the assertion itself is.
ARTI-1	Assertion Uniqueness	Assertions SHALL be sufficiently unique to permit unique identification by the target RP.	Determine whether assertions are sufficiently unique to permit unique identification by the target RP.	Examine IdP's assertion structure(s) and documentation to verify inclusion of elements that enable unique identification (e.g., assertion identifier, embedded nonce, issuance timestamp). Test by generating multiple assertions and verifying that each can be uniquely identified by an RP.	3.13.1 A	IdP	ALL	Unique identification supports replay protection, logging, auditing, and correlation of federation events. Common techniques include the use of an embedded nonce, an issuance timestamp, an assertion identifier, or a combination of these techniques.
SIGNA-1	Signed Assertions	Assertions SHALL be cryptographically signed by the issuer (IdP).	Determine whether assertions are signed by the IdP using appropriate cryptography.	Examine the IdP's assertion configuration and documentation to determine that assertions are cryptographically signed by the IdP. Test by having the IdP issue an assertion. Examine the assertion to determine whether it includes a digital signature or MAC that uses NIST-approved cryptography.	3.13.2 A	IdP	ALL	The IdP uses a signature to protect the contents of the assertion from modification by an attacker, and to prevent an attacker from creating a fraudulent assertion. Every assertion issued by the IdP needs to be signed and the signature attached to the assertion for transit and processing by the RP.
SIGNA-2	RP Signed Assertion Validation	The RP SHALL validate the digital signature or MAC of each such assertion based on the issuer's verification key.	Determine whether the RP validates the signature or MAC of an assertion.	Satisfied by FAL1-2.	3.13.2 B	RP	ALL	It is not sufficient for the assertion to have a signature, the signature itself needs to have been made by the correct party (the IdP) and be valid for the signed content of the assertion. The RP is required to validate the signature as part of its processing.

NIST SP 800-63-4 Conformance Criteria v0.1: 63C

Control Identifier	Control Name	Control Text	Objective	Assessment Method	Index	Target	Profile/XAL Level	Discussion
SIGNA-3	Signature Coverage	This signature SHALL cover the entire assertion, including its identifier, issuer, audience, subject, and time validity window.	Determine whether the signature method used to protect the assertion covers all required components.	Examine the IdP's assertion configuration and documentation to determine that all necessary elements of the assertions are covered by the IdP signature. Test by having the IdP generate an assertion. Examine the assertion to determine whether all required assertion components are covered by the signature.	3.13.2 C	IdP	ALL	Some signature mechanisms allow for selective coverage of the signature, placing some items outside of the cryptographic protection. This requirement specifies that all the required fields and vital information of the assertion need to be covered by the signature mechanism in use.
SIGNA-4	Signature Mechanisms	The assertion signature SHALL either be a digital signature using asymmetric keys or a MAC using a symmetric key that is shared between the RP and issuer with approved cryptography.	Determine whether the signature method used to protect the assertion and the keys used to create and verify it falls under one of these defined categories.	Examine the IdP's assertion signing configuration and documentation to verify that (1) the assertion signature uses either a digital signature with asymmetric keys or a MAC with a symmetric key shared between the RP and IdP, and (2) that the algorithm and key size conform to NIST-approved cryptography requirements as defined in SP 800-63C-4. Test by generating an assertion and verifying that the signature method is one of the two permitted mechanisms and uses approved cryptography.	3.13.2 D	IdP	ALL	Assertions must be signed using one of two mechanisms: a digital signature using asymmetric keys, or a MAC using a symmetric key shared between the IdP and RP. Both mechanisms must use approved cryptography as defined in SP 800-63C-4. For digital signatures, the relevant standard is FIPS 186-5 (Digital Signature Standard). For MACs, relevant standards include FIPS 198-1 (HMAC) and SP 800-38B (CMAC). Assessors should verify the algorithm and key size against SP 800-131A.
ENCA-1	Encryption	When encrypting assertions, the IdP SHALL encrypt the contents of the assertion using the RP's encryption key with approved cryptography.	Determine whether the IdP uses approved cryptography and the RP's encryption key when encrypting assertions.	Examine the IdP's assertion encryption configuration and documentation to verify that assertions are encrypted using the RP's encryption key, and that the encryption algorithm and key size conform to NIST-approved cryptography requirements as defined in SP 800-63C-4. Test by generating an encrypted assertion and determining that it is encrypted for the intended RP using the configured encryption mechanism.	3.13.3 A	IdP	ALL	SP 800-63C-4 defines approved cryptography as an encryption algorithm, hash function, random bit generator, or similar technique that is FIPS-approved or NIST-recommended. Approved algorithms and techniques are either specified or adopted in a FIPS or NIST recommendation. Assessors must verify that the IdP's assertion encryption algorithm and key size conform to these requirements.
AUDR-1	Assertion Audience Restriction	Assertions SHALL use audience restriction techniques to allow an RP to recognize whether it is the intended target of an issued assertion.	Determine whether all assertions include audience restrictions identifying the target RP.	Examine IdP documentation to verify that an audience restriction technique is implemented for all assertions. For FAL2+ transactions, examine sample assertions to confirm that the audience restriction field contains exactly one RP identifier. Test by initiating a federation transaction and verifying that the resulting assertion contains audience restriction information identifying the target RP. For FAL2+ transactions, examine sample assertions to confirm that the audience restriction field contains exactly one RP identifier.	3.13.4 A	IdP	ALL	Assertions are targeted messages from an IdP to an RP that are created in direct response to a specific federated login process. Each assertion must be targeted to specific RPs so that an assertion intended for one RP cannot be used at an unintended RP, either by the subscriber or an attacker. At FAL1, an assertion may include multiple target RPs. At FAL2 and above, assertions must be restricted to a single RP.

NIST SP 800-63-4 Conformance Criteria v0.1: 63C

Control Identifier	Control Name	Control Text	Objective	Assessment Method	Index	Target	Profile/XAL Level	Discussion
AUDR-2	RP Audience Validation	All RPs SHALL check that the audience of an assertion contains an identifier for their RP to prevent the assertion injection and replay of an assertion generated for one RP at another RP.	Determine whether RPs enforce audience restrictions in presented assertions.	Examine the RP documentation and configuration to confirm that audience validation occurs and that only assertions listing the RP's identifier are accepted. Examine the documented results of conformance testing to the federation standards, protocols, and/or profiles implemented by the RP, if available. Test by presenting an assertion whose audience contains the RP's identifier and determining that the RP accepts it, and an assertion whose audience does not contain the RP's identifier and determining that the RP rejects it. If the RP accepts assertions with multiple audience identifiers at FAL1, test an assertion that contains the RP's identifier along with other RP identifiers and determine that the RP processes it correctly.	3.13.4 B	RP	ALL	If the RP utilizes an IdP that lists multiple RPs in a single assertion at FAL1, confirm that the RP correctly handles assertions containing multiple RP identifiers.
HKA-1	HoK Authenticator Identifier	A holder-of-key assertion (Fig. 3) SHALL include a unique identifier for an authenticator that can be verified independently by the RP, such as the public key of a certificate controlled by the subscriber.	Determine whether HoK assertions include the public key (or key identifier) of the authenticator controlled by the subscriber.	Examine the IdP HoK documentation to confirm that HoK assertions contain the necessary authenticator identifier. Test by generating a HoK assertion and verifying it contains a unique identifier for the subscriber's authenticator (e.g., a public key or key identifier).	3.15 A	IdP	FAL3	The public key allows the RP to verify that the subscriber controls the corresponding private key, binding the assertion to the subscriber.
HKA-2	HoK Validation	The RP SHALL verify that the subscriber possesses the authenticator identified by the assertion. Holder-of-key assertions are most often used when the authenticator technology is tied to a public-key infrastructure (PKI) trusted by both the IdP and RP.	Determine whether the RP validates the subscriber's key for holder-of-key assertions.	Examine the RP's assertion processing documentation to verify that holder-of-key authenticator verification is implemented before granting FAL3 access. Test by presenting a holder-of-key assertion and authenticating with the correct subscriber key. Verify that the RP grants FAL3 access. Next, present a holder-of-key assertion and authenticate with an incorrect key. Verify rejection. Finally, present a holder-of-key assertion without presenting any key. Verify rejection.	3.15 B	RP	FAL3	Holder-of-key assertions are built around proving that a subscriber is not only known to the IdP, and therefore able to get an assertion issued, but also able to present proof of a cryptographic key in the assertion. This key represents the subscriber, not the IdP or the RP, and the proof of possession of the key is presented by the subscriber directly to the RP. This requirement does not assume that the RP has registered the key for the subscriber, and the subscriber key might be unknown to the RP ahead of processing the assertion. Additionally, the technology in place might use different keys for a subscriber over time. Because of these aspects, the RP needs to validate the subscriber's key separately upon login.
HKA-3	HoK Authenticator Phishing Resistance	The authenticator identified in a holder-of-key assertion SHALL be phishing-resistant, as defined by Sec. 3.2.5 of [SP800-63B].	Determine whether the authenticator identified in the HoK assertion is phishing-resistant as defined by Sec. 3.2.5 of [SP800-63B].	Examine the documentation indicating the authenticator type(s) used in HoK assertions to verify that they meet phishing-resistance requirements per [SP800-63B] Sec. 3.2.5.	3.15 C	IdP	FAL3	

NIST SP 800-63-4 Conformance Criteria v0.1: 63C

Control Identifier	Control Name	Control Text	Objective	Assessment Method	Index	Target	Profile/XAL Level	Discussion
HKA-4	HoK Authenticator Account Resolution	When the RP encounters an authenticator in a holder-of-key assertion for the first time, the RP SHALL ensure that the authenticator can be uniquely resolved to the RP subscriber account, as discussed in Sec. 3.8.2.	Determine whether the RP ensures that a new HoK authenticator can be uniquely resolved to the RP subscriber account upon first encounter.	Satisfied by ACCR-1.	3.15 D	RP	FAL3	
HKA-5	HoK Prohibitions	A holder-of-key assertion SHALL NOT include an unencrypted private key or symmetric key to be used as an authenticator.	Determine whether the subscriber keys present in a holder-of-key assertion are of an appropriate type.	Examine IdP assertion generation documentation to confirm that assertions do not result in exposure of private keys or symmetric keys. Examine test assertions and logs of assertion tests to validate the operational configuration. Test by generating a holder-of-key assertion and ensure that the assertion does not include an unencrypted private key or symmetric key as the subscriber key.	3.15 E	IdP	FAL3	The security of holder-of-key assertions stems from the separation of the key representing the subscriber and the assertion itself. The RP will need access to some set of keying material to verify the key presented by the subscriber in a holder-of-key assertion. There are different methods of identifying this keying material to the RP, such as including the public key of an asymmetric key pair in the assertion or including an identifier for a key that the RP can securely dereference. However, if the assertion were to include private key material or a symmetric key, then any reader of the assertion would be able to create a proof to present alongside the assertion. Therefore, these types of keys are not allowed to be included in the assertion in holder-of-key presentations.
BAUTH-1	Bound Authenticator Indicator	The IdP SHALL include an indicator in the assertion when the assertion is to be used with a bound authenticator at FAL3.	Determine whether the IdP includes an indicator in the assertion when the assertion is to be used with a bound authenticator at FAL3.	Examine the assertion structure to verify inclusion of a bound authenticator indicator when bound authenticators are used at FAL3. Test by requesting an FAL3 assertion for use with a bound authenticator. Verify the assertion contains the expected bound authenticator indicator.	3.16 A	IdP	FAL3	The indicator signals to the RP that it must verify a bound authenticator before accepting the assertion. (Per ARTC-8, an FAL3 assertion must include either a HoK key identifier or a bound authenticator indicator.)
BAUTH-2	Bound Authenticator Identifier Storage	The unique identifier for the authenticator (such as its public key) SHALL be stored in the RP subscriber account.	Determine whether the RP stores the unique identifier for the bound authenticator (such as its public key) in the RP subscriber account.	Examine the RP subscriber account schema to identify where bound authenticator identifiers are stored. Then, examine sample RP subscriber accounts that have a bound authenticator and verify that the unique identifier (e.g., public key) is present.	3.16 B	RP	FAL3	
BAUTH-3	Bound Authenticator Uniqueness	A bound authenticator SHALL be unique per subscriber at the RP such that two subscribers cannot present the same authenticator for their separate RP subscriber accounts.	Determine whether bound authenticators are unique per subscriber at the RP, such that two subscribers cannot present the same authenticator for their separate RP subscriber accounts.	Examine RP-bound authenticator binding logic to verify that a uniqueness constraint prevents the same authenticator identifier from being associated with multiple RP subscriber accounts. Test by attempting to bind the same authenticator to two different RP subscriber accounts. Verify that the RP rejects the second binding.	3.16 C	RP	FAL3	
BAUTH-4	Bound Authenticator Phishing Resistance	All bound authenticators SHALL use phishing-resistant authentication mechanisms, as defined by Sec. 3.2.5 of [SP800-63B].	Determine whether bound authenticators use phishing-resistant authentication mechanisms as defined by Sec. 3.2.5 of [SP800-63B].	Examine the documentation of the authenticator types permitted as bound authenticators to verify that they meet phishing-resistance requirements per [SP800-63B] Sec. 3.2.5.	3.16 D	RP	FAL3	

NIST SP 800-63-4 Conformance Criteria v0.1: 63C

Control Identifier	Control Name	Control Text	Objective	Assessment Method	Index	Target	Profile/XAL Level	Discussion
BAUTH-5	Bound Authenticator Verification Timing	Bound authenticators SHALL be accepted for authentication in the context of processing an FAL3 assertion for a federated transaction.	Determine whether the RP verifies the bound authenticator during FAL3 assertion processing, rather than in a separate transaction.	Examine the RP's transaction flow documentation to verify that bound authenticator verification is integrated into the FAL3 assertion processing flow rather than performed as a separate authentication transaction. Test by initiating an FAL3 federated transaction requiring a bound authenticator, and successfully complete the bound authenticator verification. Verify that the RP accepts the bound authenticator and establishes the FAL3 session. Review the RP transaction logs to confirm the bound authenticator verification is recorded as part of the assertion processing event, not as a separate authentication event.	3.16 E	RP	FAL3	
BAUTH-6	Bound vs. Direct Authentication Documentation	While it is possible for the same authenticator to also be used for direct authentication to the RP (see Sec. 3.8.3), such use is not considered a bound authenticator, and the RP SHALL document these as distinct use cases.	Determine whether the RP documents for subscribers that bound authentication and direct authentication are distinct use cases, and whether the same authenticator may be used for both.	Examine the RP's subscriber-facing documentation (e.g., help pages, account settings, authenticator registration guidance) to verify that the RP explains that bound authentication and direct authentication are distinct use cases, and states whether the RP permits the same authenticator to be used for both.	3.16 F	RP	FAL3	<i>Assessment is required when: An RP supports both bound and alternative authenticators.</i> See ALTAP-2 for RP determination of permitted authenticator uses.
BAUTH-7	Pre-existing Bound Authenticator Reference in RP Subscriber Account	Before an RP can successfully accept an FAL3 assertion, the RP subscriber account SHALL include a reference to a bound authenticator that is to be verified during the FAL3 transaction.	Determine whether the RP subscriber account includes a reference to a bound authenticator before the RP accepts an FAL3 bound authenticator assertion.	Examine the RP's FAL3 assertion processing logic to verify that it checks for a bound authenticator reference in the RP subscriber account before accepting the assertion. Test by attempting to process an FAL3 assertion with a bound authenticator indicator for an RP subscriber account that has no bound authenticator reference. Verify the RP rejects the assertion.	3.16 G	RP	FAL3	The bound authenticator must be registered to the RP subscriber account before it can be verified during an FAL3 transaction.
BAUTH-8	Bound Authenticator Change Notification	The RP SHALL send a notification to the subscriber via an out-of-band mechanism (e.g., an email to an address previously associated with the subscriber)...if any of the following events occur: (a) A new bound authenticator is added to the RP subscriber account. (b) An existing bound authenticator is removed from the RP subscriber account.	Determine whether the RP sends an out-of-band notification to the subscriber when a bound authenticator is added to or removed from the RP subscriber account.	Examine the RP's bound authenticator management system to verify that out-of-band notifications are configured to be sent when authenticators are added or removed. Test as follows: (1) Add a bound authenticator to an RP subscriber account. Verify that the subscriber receives an out-of-band notification. (2) Remove a bound authenticator from an RP subscriber account. Verify that the subscriber receives an out-of-band notification.	3.16 H	RP	FAL3	Out-of-band notifications alert the subscriber to potentially unauthorized changes to their account. See [SP800-63B] Sec. 4.6 for notification requirements and considerations.

NIST SP 800-63-4 Conformance Criteria v0.1: 63C

Control Identifier	Control Name	Control Text	Objective	Assessment Method	Index	Target	Profile/XAL Level	Discussion
RPPBAI-1	RP-Provided Bound Authenticator Issuance	For RP-provided authenticators, the system administrator of the RP SHALL issue the authenticator directly to the subscriber for use with an FAL3 federation transaction.	Determine whether RP-provided bound authenticators are issued directly to the subscriber for use with FAL3 federation transactions.	Examine the RP's authenticator issuance procedures and a sample of issuance records, tracking records, or other issuance evidence to determine that RP-provided bound authenticators are issued directly to the subscriber for use with an FAL3 federation transaction. Interview the system administrator to determine that RP-provided bound authenticators are issued directly to the subscriber for use with an FAL3 federation transaction, if no recent issuance records are available.	3.16.1 A	RP	FAL3	
RPPBAI-2	RP-Provided Bound Authenticator Subscriber Verification	The system administrator of the RP SHALL use an independent means to determine whether the identified subject of the RP subscriber account is the party to which the authenticator is issued. The system administrator of the RP SHALL follow the initial authenticator binding requirements in Sec. 4 of [SP800-63A] or the post-enrollment binding requirements in Sec. 4.1.2 of [SP800-63B], as appropriate.	Determine whether the RP system administrator verifies that the subscriber receiving the bound authenticator is the subject of the RP subscriber account by following the initial authenticator binding requirements in Sec. 4 of [SP800-63A] or the post-enrollment binding requirements in Sec. 4.1.2 of [SP800-63B].	Examine the RP's bound authenticator issuance procedures to identify which binding path is used in each applicable case: Sec. 4 of SP 800-63A for initial binding or Sec. 4.1.2 of SP 800-63B for post-enrollment binding. Examine a sample of issuance records or other issuance evidence to determine that, for each sampled issuance, the system administrator used an independent means to determine that the identified subject of the RP subscriber account was the party receiving the authenticator and followed the applicable binding path. Interview the system administrator if the records are insufficient to establish how the determination was made.	3.16.1 B	RP	FAL3	The choice between 63A and 63B requirements depends on context: if the RP subscriber account was just established and this is the initial authenticator binding, use 63A requirements. If the subscriber already has an established account with authenticators and is adding an RP-provided bound authenticator, use 63B post-enrollment requirements.
RPPBAI-3	RP-Provided Bound Authenticator Identifier Storage	The system administrator of the RP SHALL store a unique identifier for the bound authenticator in the RP subscriber account, such as the public key of the authenticator.	Determine whether the RP stores a unique identifier for each RP-provided bound authenticator in the associated RP subscriber account.	Satisfied by BAUTH-2.	3.16.1 C	RP	FAL3	
SUBPB-1	Binding Ceremony for Subscriber-Provided Bound Authenticators	If no bound authenticators are associated with the RP subscriber account, the RP SHALL perform a binding ceremony to establish the connection between the authenticator, the subscriber, and the RP subscriber account, as shown in Fig. 5.	Determine whether the RP performs a binding ceremony to establish the connection between the authenticator, the subscriber, and the RP subscriber account, as shown in Fig. 5, when no bound authenticators are associated with the RP subscriber account.	Satisfied by SUBPB-2 through SUBPB-12.	3.16.2 A	RP	FAL3	This is a summative control. Compliance is determined by the results of all binding ceremony controls: SUBPB-2 through SUBPB-12. The RP MAY provide a process for associating subscriber-provided authenticators to the RP subscriber account on a trust-on-first-use basis. This process is known as a binding ceremony and has additional requirements beyond a typical FAL3 federation process.

NIST SP 800-63-4 Conformance Criteria v0.1: 63C

Control Identifier	Control Name	Control Text	Objective	Assessment Method	Index	Target	Profile/XAL Level	Discussion
SUBPB-2	Binding Ceremony Session Establishment	The RP SHALL first establish an authenticated session using federation with an assertion that meets all the other requirements of FAL3, including an indication that the assertion is intended for use at FAL3 with a bound authenticator (e.g., the assertion contains an authentication class reference or a Vectors of Trust [RFC8485] value indicating this).	Determine whether the RP requires a valid FAL3 assertion with a bound authenticator indicator before initiating a binding ceremony.	Examine the RP binding ceremony implementation to verify that it requires an FAL3 assertion containing a bound authenticator indicator before the ceremony proceeds. Test by initiating an FAL3 bound authenticator request for an account that lacks a bound authenticator. Verify that the RP performs validation per CFAL-2 and initiates a binding ceremony session only if validation succeeds.	3.16.2 B	RP	FAL3	Note: SUBPB-2 through SUBPB-12 should be evaluated together. This applies to the initial binding ceremony when no bound authenticator is yet associated with the RP subscriber account. The subscriber cannot prove possession of a bound authenticator at this stage because none has been bound yet.
SUBPB-3	Binding Ceremony Authenticator Prompt	The subscriber SHALL immediately be prompted to present and authenticate with the proposed authenticator.	Determine whether the RP immediately prompts the subscriber to present and authenticate with the proposed authenticator after establishing the binding ceremony session.	Continue from SUBPB-2 (binding ceremony session established). Test by verifying that the RP immediately prompts the subscriber to present and authenticate with the proposed authenticator.	3.16.2 C	RP	FAL3	
SUBPB-4	Binding Ceremony Authenticator Identifier Storage	Upon successful presentation of the authenticator, the RP SHALL store a unique identifier for the authenticator (such as its public key) and associate this with the RP subscriber account that is associated with the federated identifier.	Determine whether, during the binding ceremony, the RP stores a unique identifier for the authenticator and associates it with the RP subscriber account upon successful authenticator presentation.	Continue from SUBPB-3 (successful authenticator presentation). Test by authenticating with an appropriate authenticator, then inspecting the RP subscriber account record to confirm that an authenticator identifier was stored that uniquely identifies the authenticator.	3.16.2 D	RP	FAL3	This is functionally equivalent to RPPBAI-3 but is evaluated as a discrete step during a binding ceremony.
SUBPB-5	Binding Ceremony Session Timeout	The binding ceremony session SHALL have a timeout of five minutes or less.	Determine whether the binding ceremony session has a timeout of five minutes or less.	Test by initiating a binding ceremony session and continuing through the RP prompt to the subscriber to present and authenticate with the proposed authenticator (SUBPB-3). Then, wait five minutes without authenticating. Verify that the session expires and the binding ceremony fails.	3.16.2 E	RP	FAL3	If the subscriber fails to successfully authenticate to the RP using an appropriate authenticator within five minutes of being prompted to do so, the binding ceremony fails.
SUBPB-6	Binding Ceremony Session Restriction	The binding ceremony session... SHALL NOT be used as an authenticated session for any other purpose, as described in Sec. 3.9.	Determine whether the RP restricts the binding ceremony session to binding purposes only and does not use it as an authenticated session for any other purpose.	Test by attempting to access RP functions or resources that require an authenticated session during a binding ceremony session. Verify that the RP denies access.	3.16.2 F	RP	FAL3	Per Sec. 3.9, an authenticated session allows subscriber access to RP functions, identification, or attribute processing. The binding ceremony session exists solely to complete the binding process and must not grant these capabilities.
SUBPB-7	Post-Binding Ceremony Transaction Initiation	Upon successful completion of the binding ceremony, the RP SHALL immediately request a new assertion from the IdP at FAL3.	Determine whether the RP initiates a new FAL3 federation transaction immediately upon successful completion of the binding ceremony.	Test by verifying that the RP immediately initiates a new federation transaction requesting a new assertion at FAL3, following the completion of the binding ceremony.	3.16.2 G	RP	FAL3	
SUBPB-8	Post-Binding Ceremony Authenticator Prompt	Upon receiving the new assertion, the RP SHALL prompt the subscriber for the newly bound authenticator and SHALL validate the authenticator output.	Determine whether the RP prompts the subscriber to authenticate with the newly bound authenticator upon receiving the new FAL3 assertion.	Satisfied by RPPHBA-1.	3.16.2 H	RP	FAL3	This is standard FAL3 bound authenticator processing applied to the post-binding ceremony context.

NIST SP 800-63-4 Conformance Criteria v0.1: 63C

Control Identifier	Control Name	Control Text	Objective	Assessment Method	Index	Target	Profile/XAL Level	Discussion
SUBPB-9	Adding an Additional Bound Authenticator (1)	During the initial authentication step of the binding ceremony, the RP SHALL request authentication with an existing bound authenticator to reach FAL3.	Determine whether the RP requires authentication with an existing bound authenticator during the initial step of the binding ceremony when adding additional bound authenticators to an account that already has one or more.	Examine the RP's binding ceremony implementation to confirm that when a subscriber account has one or more existing bound authenticators, the workflow for adding additional authenticators requires initial authentication with an existing bound authenticator at FAL3. Test by identifying a test subscriber account with at least one existing bound authenticator. Using that account, initiate a binding ceremony for an additional authenticator. Verify the RP requests authentication with an existing bound authenticator as the initial step. Next, attempt to proceed with the binding ceremony without authenticating with an existing bound authenticator; verify the RP rejects the attempt.	3.16.2 I	RP	FAL3	This requirement applies to the alternative binding ceremony workflow for adding authenticators to accounts that already have bound authenticators. Unlike the initial binding ceremony (SUBPB-1 through SUBPB-8), which uses federation at FAL3 with a trust-on-first-use approach, this workflow requires proof of possession of an existing bound authenticator before new authenticators can be bound. See SUBPB-10 for the subsequent step of authenticating with and associating the new authenticator.
SUBPB-10	Adding an Additional Bound Authenticator (2)	Once this authentication is complete and the binding ceremony session is established, the RP SHALL request authentication with the new authenticator and associate it with the RP subscriber account as a bound authenticator.	Determine whether the RP, after the subscriber authenticates with an existing bound authenticator (SUBPB-9), requests authentication with the new bound authenticator and stores its identifier in the RP subscriber account.	Test by identifying a test subscriber account with at least one existing bound authenticator. Using that account, complete a binding ceremony to add an additional authenticator. Verify that the RP then prompts the subscriber to authenticate with that new authenticator. Authenticate with the new authenticator. Then, inspect the RP subscriber account record to confirm that a unique identifier for the new authenticator (such as its public key) was stored and associated with the account as a bound authenticator. Confirm that the account now contains at least two unique bound authenticator identifiers. Verify that the new authenticator can be used for subsequent FAL3 transactions.	3.16.2 J	RP	FAL3	
SUBPB-11	Bound Authenticator Removal - Session Termination	When a bound authenticator is removed, the RP SHALL terminate all current FAL3 sessions for the subscriber and SHALL require reauthentication of the subscriber from the IdP at FAL3.	Determine whether the RP terminates all active FAL3 sessions for the subscriber and requires IdP reauthentication at FAL3 when a bound authenticator is removed from the RP subscriber account.	Test using a test subscriber account with at least one bound authenticator and an active FAL3 session by doing the following: (1) Establish one or more additional active FAL3 sessions for the test subscriber (e.g., multiple browser sessions or devices). (2) Remove a bound authenticator from the RP subscriber account. (3) Verify that all active FAL3 sessions for the subscriber are immediately terminated. (4) Attempt to access the RP at FAL3. Verify that the RP requires a new assertion from the IdP at FAL3 before granting access.	3.16.2 K	RP	FAL3	This control addresses the security response when a bound authenticator is removed, whether initiated by the subscriber (e.g., lost or compromised authenticator) or by the RP (e.g., authenticator no longer meets requirements). Terminating all FAL3 sessions and requiring reauthentication ensures that any sessions potentially established using the removed authenticator are invalidated. See SUBPB-12 for the related requirement that the RP not prompt for the removed authenticator during this process.

NIST SP 800-63-4 Conformance Criteria v0.1: 63C

Control Identifier	Control Name	Control Text	Objective	Assessment Method	Index	Target	Profile/XAL Level	Discussion
SUBPB-12	Bound Authenticator Removal - No Prompt for Removed Authenticator	The RP SHALL NOT prompt the subscriber to authenticate with the authenticator being removed, since the subscriber will often not have access to the authenticator in question during the unbinding process, particularly if the authenticator is lost or compromised.	Determine whether the RP avoids prompting the subscriber to authenticate with the specific authenticator being removed during the unbinding process.	Test using a test subscriber account with at least one bound authenticator by initiating the removal of a bound authenticator from the RP subscriber account. Verify that the RP does not prompt the subscriber to authenticate with the authenticator while the authenticator is being removed. (Note: If the account has multiple bound authenticators, the RP may prompt for a different bound authenticator, but never the one being removed.)	3.16.2 L	RP	FAL3	
RPPHBA-1	Bound Authenticator Verification	The subscriber SHALL prove possession of the bound authenticator to the RP, in addition to presenting the assertion itself.	Determine whether the RP prompts the subscriber to prove possession of the expected authenticator and validates the authenticator output.	Test by doing the following: (1) Initiate an FAL3 federation transaction. Verify the RP prompts the subscriber to prove possession of the authenticator in addition to presenting the assertion. (2) Authenticate with the correct authenticator. Verify FAL3 access is granted. (3) Authenticate with an incorrect authenticator. Verify rejection. (4) Present the assertion without any authenticator. Verify rejection.	3.17 #1	RP	FAL3	<i>Assessment is required when: Authentication is required at both the IdP and the RP.</i> Note: This control was intended to apply to both HoK and bound authenticator assertions. When the errata corrections are issued, this control will be updated to read: "The subscriber SHALL prove possession of the authenticator to the RP, in addition to presenting the assertion itself."
RPPHBA-2	HoK Authenticator Reference Trust Level	For a holder-of-key assertion, a reference to a given authenticator that is found within an assertion SHALL be trusted at the same level as all other information within the assertion, as stipulated in the trust agreement.	Determine whether the RP validates the complete HoK assertion and does not rely solely on verification of the referenced authenticator.	Satisfied by CFAL-2 (assertion validation), FAL1-2 (signature verification), SIGNA-2 (signed assertion validation), and SIGNA-3 (signature coverage).	3.17 #2	RP	FAL3	<i>Assessment is required when: The assertion is a HoK assertion.</i> Note: This control was intended to apply to HoK assertions only. When the errata corrections are issued, this control will be moved to section 3.15.
RPPHBA-3	Assertion Validation with Bound Authenticator	The RP SHALL process and validate the assertion in addition to the bound authenticator.	Determine whether the RP validates the assertion from the IdP when processing transactions that require RP authenticator validation.	Satisfied by CFAL-2.	3.17 #3	RP	FAL3	<i>Assessment is required when: Authentication is required at both the IdP and the RP.</i> Note: This control was intended to apply to both HoK and bound authenticator assertions. When the errata corrections are issued, this control will be updated to read: "The RP SHALL process and validate the assertion in addition to verifying the authenticator."
RPPHBA-4	Bound Authenticator Failure Handling	Failure to authenticate with the bound authenticator SHALL result in an error at the RP and SHALL NOT create an authenticated session at the RP.	Determine whether the RP rejects the transaction and prevents session creation when the subscriber fails to successfully authenticate at the RP.	Test , using a test subscriber account with a bound authenticator, by initiating an FAL3 federation transaction with a valid bound authenticator assertion. When prompted for the bound authenticator, fail authentication (e.g., cancel the prompt, provide an incorrect activation factor, or allow the request to timeout). Verify that the RP returns an error and does not create an authenticated session.	3.17 #4	RP	FAL3	<i>Assessment is required when: Authentication is required at both the IdP and the RP.</i> Note: This control was intended to apply to both HoK and bound authenticator assertions. When the errata corrections are issued, this control will be updated to read: "Failure to verify the authenticator SHALL result in an error at the RP and SHALL NOT create an authenticated session at the RP."

NIST SP 800-63-4 Conformance Criteria v0.1: 63C

Control Identifier	Control Name	Control Text	Objective	Assessment Method	Index	Target	Profile/XAL Level	Discussion
IDPAP-1	Account Provisioning Disclosure	In order to make subscriber accounts available through an IdP, the subscriber accounts need to be provisioned at the IdP. The means by which the subscriber account is provisioned to the IdP SHALL be disclosed in the trust agreement.	Determine whether the trust agreement artifact(s) disclose the means by which subscriber accounts are provisioned to the IdP.	Examine the relevant trust agreement artifact(s) to confirm that they include a description of the account provisioning method(s) used to make subscriber accounts available through the IdP.	4.1 A	IdP	ALL	RPs rely on this disclosure to understand the provenance and trustworthiness of identity assertions. Different provisioning methods carry different risk profiles and may affect RP decisions about accepting assertions from a given IdP.
IDPAP-2	Attribute Bundle Signing	If the CSP issues attribute bundles to the RP: The CSP SHALL sign attribute bundles issued to the IdP.	Determine whether the CSP signs attribute bundles before issuing them to the IdP.	Test by obtaining an attribute bundle issued by the CSP to the IdP. Verify that the attribute bundle contains a valid cryptographic signature from the CSP.	4.1 B	CSP	ALL	The CSP can provide attributes from the subscriber account to the IdP as attribute values, derived attribute values, or attribute bundles.
TRUSTA-1	Trust Agreement Establishment Method	Trust agreements for general-purpose IdPs SHALL be established either: (a) As the result of an agreement by the federated parties, prior to the federation transaction; or (b) As the result of decision or action by the subscriber, during the federation transaction.	Determine whether the IdP uses one of the two trust agreement establishment methods.	Examine the relevant trust agreement artifact(s) to verify that the establishment method is either pre-established by the federated parties prior to the federation transaction, or subscriber-driven during the federation transaction.	4.3 A	IdP	ALL	For pre-established trust agreement requirements, see PETA series (Sec. 4.3.1). For subscriber-driven trust agreement requirements, see SDTAE series (Sec. 4.3.2).
PETA-1	Pre-Established Trust Agreement Terms	When the trust agreement is established by the federated parties prior to the federation transaction, the trust agreement SHALL establish the following terms: (a) The set of subscriber attributes, derived attributes, and attribute bundles that the IdP can make available to the RP. (b) The attribute storage policy of the IdP for the subscriber account, including any available means for the subscriber to request deletion. (c) Any attribute sources from which the IdP receives applicable subscriber attributes, derived attributes, and attribute bundles, including the CSP. (d) Any identity APIs that are made available by the IdP, either directly or through an external provider, and which subscriber attributes are available at these APIs. (e) The population of subscriber accounts for which the IdP can create assertions. (f) Any additional uses of subscriber information beyond providing the identity service. (g) The set of subscriber attributes, derived attributes, and attribute bundles that the RP is allowed to request (i.e., a subset of the attributes made available). (h) The purpose for each attribute requested by the RP. (i) The provisioning models used by the RP for RP subscriber accounts. (j) The authorized party responsible for decisions regarding the release of subscriber attributes to the RP (e.g., the IdP organization, the subscriber). (k) The process and techniques used to inform subscribers about attribute sharing. (l) The process and techniques for collecting consent from the authorized party when necessary. (m) The xALs available from the IdP. (n) The xALs required by the RP.	Determine whether pre-established trust agreement artifact(s) document all required terms.	Examine the trust agreement artifact(s) and verify that each of the terms (a-n) is documented.	4.3.1 A	IdP/RP	ALL	

NIST SP 800-63-4 Conformance Criteria v0.1: 63C

Control Identifier	Control Name	Control Text	Objective	Assessment Method	Index	Target	Profile/XAL Level	Discussion
PETA-2	Trust Agreement Availability to Operators	The terms of the trust agreement SHALL be available to the operators of the RP and the IdP upon its establishment.	Determine whether trust agreement terms are made available to RP and IdP operators when the agreement is established.	Examine the trust agreement artifact(s) accessible to both the IdP and RP operators to ensure that all terms required by PETA-1 are available to them. Confirm that the terms became available to them prior to the initiation of operational federated transactions between the RP and IdP.	4.3.1 B	IdP/RP	ALL	
PETA-3	Trust Agreement Availability to Subscribers	The terms of the trust agreement SHALL be made available to subscribers upon request to the IdP or RP.	Determine whether subscribers can obtain trust agreement terms upon request to the IdP or RP.	Test by requesting the trust agreement terms documented in PETA-1, as a subscriber. Verify that the terms are provided.	4.3.1 C	IdP/RP	ALL	
PETA-4	Redress Mechanism Assessment & Disclosure	The IdP and RP SHALL each assess their respective redress mechanisms for efficacy in resolving complaints or problems and disclose the results of this assessment as part of the trust agreement.	Determine whether the assessed party has evaluated its redress mechanisms and disclosed the assessment results in trust agreement artifact(s).	Examine the relevant trust agreement artifact(s) to verify that they include the results of the party's assessment of the efficacy of its redress mechanism, and that the information has been made available to the other party.	4.3.1 D	IdP/RP	ALL	See Sec. 3.5.3 (RR-1 to RR-6) for additional requirements and considerations for redress mechanisms.
PETA-5	FAL3 Trust Agreement Terms	If FAL3 is allowed within the trust agreement, the trust agreement SHALL stipulate the following terms regarding holder-of-key assertions (see Sec. 3.15) and bound authenticators (see Sec. 3.16): (a) The means by which holder-of-key assertions can be verified by the RP (such as a common trusted PKI system). (b) The means by which the RP can associate holder-of-key assertions with specific. RP subscriber accounts (such as attribute-based account resolution or pre-provisioning) (c) Whether bound authenticators are supplied by the RP or the subscriber. (d) Documentation of the binding ceremony used for any subscriber-provided bound authenticators.	Determine whether trust agreement artifact(s) document all required holder-of-key and bound authenticator terms when FAL 3 is permitted.	Examine the relevant trust agreement artifact(s) and verify the following: (1) If holder-of-key assertions are used, terms (a) and (b) are documented. (2) If bound authenticators are used, term (c) is documented. (3) If subscriber-provided bound authenticators are used, term (d) is documented.	4.3.1 E	IdP/RP	FAL3	
PETA-6	Shared Signaling Trust Agreement Terms	If shared signaling is used by the IdP or RP (see Sec. 4.8), the terms of the trust agreement SHALL establish: the events that trigger a signal to be sent; which signals are sent for each trigger; the information included in each signal; and the expected behavior of the party receiving the signal.	Determine whether the trust agreement artifact(s) establish all four required elements for shared signaling.	Examine the relevant trust agreement artifact(s) to verify documentation of each required element: (1) Triggering events: Identify and list each event that initiates a signal (e.g., account compromise detection, account termination, credential revocation). (2) Signal types per trigger: For each triggering event, verify that the specific signal(s) to be sent are identified. (3) Signal content: For each signal type, verify that the information included is specified (including whether personal information is included per SSIG-5). (4) Receiver processing: For each signal type, verify that the expected behavior of the receiving party is defined.	4.3.1 F	IdP/RP	ALL	Assessment is required when: Shared signaling is used. This control ensures operational clarity for shared signaling by requiring explicit documentation of the complete signal lifecycle: trigger -> signal selection -> content -> response. SSIG-2 requires that this documentation be made available to authorized parties.

NIST SP 800-63-4 Conformance Criteria v0.1: 63C

Control Identifier	Control Name	Control Text	Objective	Assessment Method	Index	Target	Profile/XAL Level	Discussion
PETA-7	Trust Agreement Periodic Review	The trust agreement SHALL be reviewed periodically to ensure that it is still fit for purpose and to avoid unnecessary data exchange and the over-collection of subscriber data.	Determine whether the trust agreement is periodically reviewed, and that, as part of that review, subscriber data collection and data exchanges are assessed to determine whether they are still necessary.	Examine relevant documentation to verify that the cadence of trust agreement reviews is documented and that clear ownership for the review is assigned. Determine whether the periodic reviews address whether the trust agreement remains fit for purpose and whether subscriber data exchange and collection remain necessary. For trust agreements that have been in effect long enough for a review cycle to have occurred, verify that reviews have been conducted as scheduled.	4.3.1 G	IdP/RP	ALL	
SDTAE-1	Subscriber-Driven Trust Agreement Disclosure Terms	In a subscriber-driven trust agreement, the trust agreement takes the form of a set of terms of use as opposed to a formal contract between parties. Consequently, the following terms SHALL be disclosed to the subscriber upon request: (a) Any attribute sources from which the IdP receives applicable subscriber attributes, including the CSP. (b) Any identity APIs that are made available by the IdP, either directly or through an external provider, and which subscriber attributes are available at these APIs. (c) The set of subscriber attributes, derived attributes, and attribute bundles that the IdP can make available to the RP. (d) The attribute storage policy of the IdP for the subscriber account, including any available means for the subscriber to request deletion; the use of any shared signaling between the IdP and RP. (e) The population of subscriber accounts for which the IdP can create assertions; any additional uses of subscriber information, beyond providing the identity service; the xALs available from the IdP. (f) The xALs required by the RP.	Determine whether the IdP discloses the required terms to subscribers upon request.	Test by requesting the trust agreement terms from the IdP, as a subscriber. Verify that all nine terms are provided.	4.3.2 A	IdP	ALL	Assessment is required when: The subscriber is the authorized party.
SDTAE-2	Subscriber-Driven Redress Assessment Disclosure	The IdP SHALL assess its redress mechanisms for efficacy in resolving complaints or problems and disclose the results of this assessment to the subscriber.	Determine whether the IdP has assessed the efficacy of its redress mechanisms and discloses the results to subscribers.	The redress mechanism efficacy assessment is satisfied by PETA-4. Test for disclosure to the subscriber by requesting the results of the redress mechanism efficacy assessment, as a test subscriber. Verify that the results are provided.	4.3.2 B	IdP	ALL	<i>Assessment is required when: The subscriber is the authorized party.</i> See Sec. 3.5.3 for additional requirements and considerations for redress mechanisms. (RR-1, RR-3, RR-4, RR-6)
SDTAE-3	Subscriber-Driven Attribute Release	The release of subscriber attributes SHALL be managed using a runtime decision at the IdP, as described in Sec. 4.6.1.3. The authorized party SHALL be the subscriber.	Determine whether the IdP manages attribute release using runtime decisions with the subscriber as the authorized party.	Satisfied by AAD-6.	4.3.2 C	IdP	ALL	Assessment is required when: The subscriber is the authorized party.

NIST SP 800-63-4 Conformance Criteria v0.1: 63C

Control Identifier	Control Name	Control Text	Objective	Assessment Method	Index	Target	Profile/XAL Level	Discussion
SDTAE-4	Runtime Decision Disclosure Terms	The following terms of the trust agreement SHALL be disclosed to the subscriber during the runtime decision: (a) The set of subscriber attributes, derived attributes, and attribute bundles that the RP will request (i.e., a subset of the attributes made available by the IdP). (b) The purpose for each attribute requested by the RP. (c) The attribute storage policy of the RP for the RP subscriber account, including any available means for the subscriber to request deletion.	Determine whether the subscriber is informed of the requested attributes, their purpose, and the RP's storage policy prior to making the runtime attribute-release decision.	Test by initiating a federation transaction that triggers a runtime decision, as a test subscriber. Before making the attribute-release decision as the subscriber, verify that the following disclosures are presented to the subscriber across the IdP's and RP's combined interfaces: (1) the attributes the RP is requesting (see also IDPRD-3); (2) the purpose of the requested attributes; and (3) the RP's attribute storage policy, including deletion options. For each disclosure, record whether it was presented by the IdP, the RP, or both. If any disclosure is absent from both, the control is not satisfied. For RPs, repeat this test for each IdP (or wallet) supported by the RP. For IdPs, repeat this test for a representative sample of RPs that use the IdP.	4.3.2 D	IdP/RP	ALL	<i>Assessment is required when: The subscriber is the authorized party.</i> All information disclosed to the subscriber needs to be conveyed in a manner that is understandable and actionable, as discussed in Sec. 8.
DR-1	IdP Identifier-Key Association	The RP SHALL associate the assertion validation keys and other relevant configuration information with the IdP's identifier, as stipulated by the trust agreement.	Determine whether the RP associates the IdP's public signing key(s) and configuration information with the IdP's identifier per the trust agreement artifact(s).	Examine the RP's federation configuration and discovery/registration to determine that the RP associates the IdP's assertion validation key(s), and other relevant IdP-specific configuration information with the IdP's identifier, as stipulated by the trust agreement artifacts.	4.4 A	RP	ALL	See FAL3-4 for the related requirement that each party's identifier be uniquely associated with its verification keys.
DR-2	Network Key Retrieval Protection	If the validation keys and configuration information are retrieved over a network connection, request and retrieval SHALL be made over an authenticated protected channel from a location that is associated with the IdP's identifier by the trust agreement.	Determine whether the RP retrieves IdP keys and configuration information over an authenticated protected channel from a location specified in the trust agreement artifact(s).	Examine the relevant trust agreement artifact(s) to determine the location(s) associated with the IdP's identifier for retrieval of validation keys and configuration information. Examine the RP's federation configuration to verify that it retrieves keys and configuration information only from the specified location(s). The requirement that an authenticated protected channel be used is satisfied by ICKM-2.	4.4 B	RP	ALL	Assessment is required when: The validation keys and configuration information are retrieved over a network connection. In many federation protocols, this is accomplished by the RP fetching the public keys and configuration data from a URL specified in the trust agreement artifact(s) as controlled by the IdP or offered on the IdP's behalf. It is also possible for the RP to be configured directly with this information in a manual fashion, whereby the RP's system administrator enters the IdP information directly into the RP software's configuration.
DR-3	RP Registration	The RP SHALL register its information with either the IdP or an authority that the IdP trusts, as stipulated by the trust agreement.	Determine whether the RP has registered its information with the IdP or an IdP-trusted authority per the trust agreement artifact(s).	Examine the relevant trust agreement artifact(s) to identify the required RP registration mechanism (direct with the IdP or via a federation authority). Verify that the RP has completed registration via the specified mechanism.	4.4 C	RP	ALL	In many federation protocols, the RP is assigned an identifier during this stage, which the RP will use in subsequent communication with the IdP. See also ICKM-1.

NIST SP 800-63-4 Conformance Criteria v0.1: 63C

Control Identifier	Control Name	Control Text	Objective	Assessment Method	Index	Target	Profile/XAL Level	Discussion
MR-1	Automated Tooling for Manual Registration	If [automated updates are utilized following manual registration], the trust agreement SHALL enumerate the allowable terms of the cryptographic key distribution and assignment, including allowable cache lifetimes.	Determine whether trust agreement artifact(s) document the allowable terms for cryptographic key distribution and assignment, including allowable cache lifetimes, when automated updates are used following manual registration.	Examine the relevant trust agreement artifact(s) to verify that they include the allowable terms of cryptographic key distribution and assignment, and the allowable cache lifetimes.	4.4.1 A	IdP/RP	ALL	<i>Assessment is required when: Automated updates are utilized following manual registration.</i> Key updates following manual registration may be facilitated by automated tooling that points systems to a trusted source of information (e.g., a metadata URL) that can be updated over time. Cache lifetimes determine how long a party may use cached keys before re-fetching.
DYR-1	Dynamic Registration Channel Protection	All transmission of configuration information SHALL be made over a secure protected channel to endpoints that are associated with the IdP's identifier by the trust agreement.	Determine whether configuration information transmitted during dynamic registration uses an authenticated protected channel to endpoints associated with the IdP per the trust agreement artifact(s).	Examine the relevant trust agreement artifact(s) to identify the endpoint(s) associated with the IdP's identifier for dynamic registration. Verify the RP is configured to use the specified endpoint(s). Test by initiating a dynamic registration from the RP and verify that configuration information is transmitted only to the endpoint(s) specified in the trust agreement artifact(s). The requirement that an authenticated protected channel be used is satisfied by ICKM-2.	4.4.2 A	RP	FAL1/FAL2	<i>Assessment is required when: Dynamic registration is used.</i> At FAL1 and FAL2, the cryptographic keys and identifiers of the RP can be exchanged in a dynamic process, whereby the RP software presents its configuration to the IdP either directly or through a trusted third party and receives the identifier to use with that IdP. This process is specific to the federation protocol in use but requires machine-readable configuration data to be made available over the network.
SAI-1	Subscriber Authentication Before IdP Actions	The IdP SHALL require the subscriber to have an authenticated session before any of the following events: (a) Approval of attribute release. (b) Creation and issuance of an assertion. (c) Establishment of a subscriber-driven trust agreement.	Determine whether the IdP requires the subscriber to have an authenticated session before approving attribute release, creating/issuing assertions, or establishing subscriber-driven trust agreements.	Test by (1) attempting to approve attribute release without an authenticated session. Verify that the IdP rejects the attempt. (2) Attempt to trigger assertion creation without an authenticated session. Verify that the IdP rejects the attempt. (3) If subscriber-driven trust agreements are supported, attempt to establish one without an authenticated session. Verify that the IdP rejects the attempt.	4.5 A	IdP	ALL	In a federation context, the IdP acts as the verifier for authenticators bound to the subscriber account, as described in [SP800-63B]. Verification of one or more authenticators creates an authentication event that begins the authenticated session at the IdP. This authentication event serves as the basis of the IdP's claim that the subscriber is present.

NIST SP 800-63-4 Conformance Criteria v0.1: 63C

Control Identifier	Control Name	Control Text	Objective	Assessment Method	Index	Target	Profile/XAL Level	Discussion
AUTHAD-1	Authorized Party Decision	The authorized party stipulated by the trust agreement SHALL decide whether a federation transaction proceeds and, therefore, whether an assertion is issued and attributes are released to the RP.	Determine whether the authorized party identified in the trust agreement artifact(s) makes the decision on whether federation transactions proceed.	Examine the trust agreement artifact(s) to identify the designated authorized party or parties for the RPs supported by the IdP. Ensure that all covered cases are assessed by the authorized party identified in the trust agreement. If the subscriber is an authorized party, satisfied by IDPRD-1 through IDPRD-8. If the organization is an authorized party satisfied by IALRP-1 through IALRP-6, and IDPBRP-1 and IDPBRP-2.	4.6 A	IdP	ALL	This decision can be calculated in a variety of ways, including: - An allowlist, which determines the circumstances under which the system can allow the federation transaction to proceed in an automated fashion; - A blocklist, which determines the circumstances under which the system will not allow the federation transaction to proceed; and - A runtime decision, which allows the authorized party (e.g., the subscriber) to decide whether the transaction can proceed and under what precise terms. A runtime decision can be stored and applied to future transactions. The applicability of an allowlist, blocklist, or runtime decision can be influenced by aspects of the federation transaction, including the identity of the IdP and RP, the subscriber attributes requested, the xAL required, and other factors. These decisions can be facilitated by risk management systems, federation authorities, and local system policies. For a non-normative example of an RP that has been allowlisted at an IdP for a set of subscribers to facilitate single sign-on for an enterprise application, see Sec. 9.5.
AUTHAD-2	IdP Redress Mechanisms	The IdP SHALL provide effective mechanisms for the redress of subscriber complaints or problems (e.g., subscriber identifies an inaccurate attribute value).	Determine whether the IdP provides effective mechanisms for redress of subscriber complaints or problems.	Satisfied by RR-3.	4.6 B	IdP	ALL	IdPs need to provide effective mechanisms for redress of subscriber complaints or problems arising from the federation (e.g., subscriber identifies an inaccurate attribute value). The Privacy Act requires federal agencies that maintain a system of records to follow procedures to enable applicants to access and, if incorrect, amend their records. Any Privacy Act Statement should include a reference to the applicable SORN(s), which provide the subscriber with instructions on how to make a request for access or correction. Non-federal entities should have comparable procedures, including contact information for any third parties if they are the source of the information.
IALRP-1	Allowlist: RP Conformance	When placing an RP on its allowlist, the IdP SHALL confirm that the RP abides by the terms of the trust agreement.	Determine whether RPs in an IdP's allowlist are compliant with the terms of their trust agreement.	Examine the IdP's policies and procedures for adding RPs to the allowlist to verify that a process exists to confirm RP compliance with the trust agreement artifact(s) before allowlisting. For a sample of allowlisted RPs, verify that evidence of compliance exists (e.g., review records, attestations, federation authority approval).	4.6.1.1 A	IdP	ALL	Assessment is required when: The IdP utilizes an allowlist for RPs.

NIST SP 800-63-4 Conformance Criteria v0.1: 63C

Control Identifier	Control Name	Control Text	Objective	Assessment Method	Index	Target	Profile/XAL Level	Discussion
IALRP-2	Allowlist: IdP Attribute Determination for RPs	The IdP SHALL determine which identity attributes are passed to the allowlisted RP upon authentication.	Determine whether the IdP controls which identity attributes are released to allowlisted RPs upon authentication.	Satisfied by IALRP-5 and IALRP-6.	4.6.1.1 B	IdP	ALL	Assessment is required when: The IdP utilizes an allowlist for RPs.
IALRP-3	Allowlist: Subscriber Availability	IdPs SHALL make allowlists available to subscribers, as described in Sec. 7.2.	Determine whether the list of allowlisted RPs is available to subscribers.	Examine the IdP's allowlist configuration to identify the full set of allowlisted RPs applicable to a test subscriber. Test by requesting the allowlist from the IdP, as the same test subscriber above. Compare the returned list against the allowlist identified in the examine step and verify it is complete.	4.6.1.1 C	IdP	ALL	Assessment is required when: The IdP utilizes an allowlist for RPs. When an RP is allowlisted by an IdP, some subset of the subscriber's information is made available to the RP during the login process without the subscriber being prompted at runtime for additional consent or confirmation. The IdP needs to make the list of allowlisted RPs available to subscribers to allow subscribers to view which sites their information will be sent to during a federation transaction without the subscriber being specifically prompted.
IALRP-4	Allowlist: RP Identification	IdP allowlists SHALL uniquely identify RPs through fully qualified domain names, cryptographic keys, or other identifiers that are applicable to the federation protocol in use. Any entities that share an identifier SHALL be considered equivalent for the purposes of the allowlist. An allowlist entry for an RP SHALL NOT use a wildcard domain identifier.	Determine whether IdP allowlist entries uniquely identify RPs using appropriate identifiers, and whether entities sharing an identifier are treated as equivalent.	Examine the IdP allowlist entries and verify each RP is identified using fully qualified domain names, cryptographic keys, or other protocol-appropriate unique identifiers. Verify that no wildcard domain identifiers are used.	4.6.1.1 D	IdP	ALL	<i>Assessment is required when: The IdP utilizes an allowlist for RPs.</i> For blocklists, see IDPBRP-2.
IALRP-5	Allowlist: Attribute Indication	IdP allowlist entries for an RP SHALL indicate which attributes are included as part of an allowlisted decision.	Determine whether IdP allowlist entries specify which attributes can be released to each allowlisted RP.	Examine the IdP allowlist entries and verify that each entry specifies the attributes that can be released to the RP.	4.6.1.1 E	IdP	ALL	<i>Assessment is required when: The IdP utilizes an allowlist for RPs.</i> Allowlist entries must not just identify the RP, but also define what attributes can be released. See IALRP-6 for handling of RP requests for additional attributes beyond the allowlist entry.
IALRP-6	Allowlist: Additional Attribute Requests	If additional attributes are requested by the RP, the request SHALL be: (a) Subject to a runtime decision of the authorized party to approve the additional attributes requested. (b) Redacted to only the attributes in the allowlist entry, or (c) Denied outright by the IdP.	Determine whether the IdP handles RP requests for attributes beyond the allowlist entry by either obtaining authorized party approval, redacting to allowlist attributes, or denying the request.	Test by configuring an allowlist entry for a test RP with a defined set of attributes, then submitting a federation request from that RP that includes a request for additional attributes beyond those listed in the allowlist entry. Verify the IdP responds with one of the following: (a) Prompts the authorized party to approve the additional attributes (see IDPRD-1 through IDPRD-6), or (b) returns only the attributes specified in the allowlist entry, or (c) denies the request entirely.	4.6.1.1 F	IdP	ALL	<i>Assessment is required when: The IdP utilizes an allowlist for RPs.</i> This control ensures that allowlist entries are not simply bypassed by an RP requesting additional attributes. The IdP must have a policy for handling such requests and enforce it.
IDPBRP-1	Blocklist Assertion Prohibition	If an RP is on an IdP's blocklist, the IdP SHALL NOT produce an assertion that targets the RP in question under any circumstances.	Determine whether the IdP refuses to issue assertions to blocklisted RPs.	Test by adding a test RP to the IdP's blocklist, then submitting a federation request as the blocklisted RP. Verify the IdP refuses to produce an assertion.	4.6.1.2 A	IdP	ALL	<i>Assessment is required when: The IdP utilizes a blocklist for RPs.</i>

NIST SP 800-63-4 Conformance Criteria v0.1: 63C

Control Identifier	Control Name	Control Text	Objective	Assessment Method	Index	Target	Profile/XAL Level	Discussion
IDPBRP-2	Blocklist: RP Identification	IdP blocklists SHALL identify RPs through the means of domain names, cryptographic keys, or other identifiers that are applicable to the federation protocol in use. Any entities that share an identifier SHALL be considered equivalent for the purposes of the blocklist.	Determine whether IdP blocklist entries identify RPs using appropriate identifiers, and whether entities sharing an identifier are treated as equivalent.	Examine the IdP blocklist entries and verify that each RP is identified using domain names, cryptographic keys, or other protocol-applicable identifiers. Test by adding a wildcard entry (e.g., "*.example.com") to the IdP's blocklist, then submitting federation requests from multiple subdomains matching the wildcard (e.g., "www.example.com", "service.example.com"). Verify all matching requests are blocked.	4.6.1.2 B	IdP	ALL	Assessment is required when: The IdP utilizes a blocklist for RPs. The Current text incorrectly states: IdP blocklists SHALL uniquely identify RPs through the means of fully qualified domain names, cryptographic keys, or other identifiers that are applicable to the federation protocol in use. The text will be updated in the errata volume.
IDPRD-1	RP Not on Allowlist: Runtime Authorization	Every RP that is in a trust agreement with an IdP but not on an allowlist with that IdP SHALL be governed by a default policy in which runtime authorization decisions will be made by an authorized party that is identified by the trust agreement.	Determine whether a request for information release by an RP that is not allowlisted triggers a runtime authorization decision by the authorized party.	Examine the IdP configuration to verify that a default policy exists requiring runtime authorization decisions for non-allowlisted RPs. Test by initiating a federation transaction from a non-allowlisted RP and verify that the IdP presents a runtime authorization decision to the authorized party, who can both approve and deny the request.	4.6.1.3 A	IdP	ALL	<i>Assessment is required when: The IdP is party to a trust agreement with an RP but does not have that RP on an allowlist.</i> If a given RP is allowed to request a connection from an IdP, and that RP has not been allowlisted by the IdP, then the IdP must present a runtime authorization decision to the authorized party identified in the trust agreement. The purpose of this requirement is to allow authorized party-driven connection decisions where possible in addition to traditional pre-negotiated connections enabled by allowlists.
IDPRD-2	RP Not on Allowlist: Attribute Release Consent	The IdP SHALL provide the authorized party with explicit notice and prompt them for positive confirmation before any attributes about the subscriber are transmitted to the RP.	Determine whether the IdP provides the authorized party with explicit notice and obtains positive confirmation before transmitting subscriber attributes to the RP.	Test by initiating a federation transaction from a non-allowlisted RP. Verify that the IdP presents explicit notice and requires positive confirmation from the authorized party before transmitting any attributes. Verify that denying confirmation prevents attribute transmission.	4.6.1.3 B	IdP	ALL	<i>Assessment is required when: The IdP is party to a trust agreement with an RP but does not have that RP on an allowlist.</i>
IDPRD-3	RP Not on Allowlist: Attribute Disclosure Before Release	The IdP SHALL disclose which attributes will be released to the RP if the transaction is approved.	Determine whether the IdP discloses to the authorized party the specific attributes that will be released to the RP before the transaction is approved.	Examine the IdP's runtime decision screens and related configurations to verify that a runtime decision prompt displays the list of attributes to be released prior to authorization. Test by initiating a federation transaction that triggers a runtime decision and verifying that the IdP presents the list of attributes to be released before the authorized party approves the transaction.	4.6.1.3 C	IdP	ALL	Assessment is required when: The IdP is party to a trust agreement with an RP but does not have that RP on an allowlist. This control ensures informed decisions are made by requiring the IdP to show which attributes will be transmitted before the authorized party approves the transaction. Related Controls: - IDPRD-2 requires explicit notice and positive confirmation before attribute transmission. - IDPRD-5 requires the IdP to provide mechanisms for viewing attribute values. - IDPRD-4 addresses selective disclosure of optional attributes.

NIST SP 800-63-4 Conformance Criteria v0.1: 63C

Control Identifier	Control Name	Control Text	Objective	Assessment Method	Index	Target	Profile/XAL Level	Discussion
IDPRD-4	RP Not on Allowlist: Selective attribute disclosure	If the federation protocol in use allows for optional or selective attribute disclosure at runtime, the authorized party SHALL be given the option to decide whether to transmit specific attributes to the RP without terminating the federation transaction entirely.	Determine whether the authorized party can selectively approve or deny the RP access to any optional attributes without terminating the transaction.	Examine the IdP's runtime decision interface to verify that optional attributes are clearly delineated from required attributes and that the authorized party is given the option to approve or deny individual optional attributes. Test by initiating a federation transaction that includes a request for optional attributes. Verify that: (1) The authorized party is presented with a clear distinction between required and optional attributes. (2) The authorized party can deny optional attributes. (3) Denied optional attributes are not released to the RP. (4) The transaction continues after the denial of optional attributes.	4.6.1.3 D	IdP	ALL	<i>Assessment is required when: The IdP is party to a trust agreement with an RP but does not have that RP on an allowlist, and the federation protocol supports optional attributes in the request</i> Some federation protocols allow for attributes to be requested for optional release. In such cases, the IdP must provide the authorized party with the opportunity to decide, during the process, whether to transmit those optional attributes to the RP. Optional attributes and the selection method need to be clearly delineated for the authorized party.
IDPRD-5	RP Not on Allowlist: Attribute Value Viewing Mechanism	If the authorized party is the subscriber, the IdP SHALL provide mechanisms for the subscriber to view the attribute values and derived attribute values to be sent to the RP.	Determine whether the IdP provides the subscriber with a mechanism to view the actual attribute values and derived attribute values that will be transmitted to the RP.	Examine the runtime decision screens to verify that mechanisms exist to display attribute and derived attribute values to the subscriber. Test by initiating a federation transaction as a subscriber that triggers a runtime decision. Verify that the subscriber can view the actual values of the attributes and derived attributes to be released.	4.6.1.3 E	IdP	ALL	Assessment is required when: The IdP is party to a trust agreement with an RP but does not have that RP on an allowlist. This control goes beyond IDPRD-3 (which requires disclosure of which attributes will be released) by requiring the IdP to show the actual values of those attributes. This enables the subscriber to verify correctness and make an informed decision. Related Controls: - IDPRD-3 requires disclosure of which attributes will be released. - IDPRD-6 requires masking of sensitive information by default.
IDPRD-6	RP Not on Allowlist: Sensitive Information Masking	To mitigate the risk of unauthorized exposure of sensitive information (e.g., shoulder surfing), the IdP SHALL, by default, mask sensitive information displayed to the subscriber.	Determine whether sensitive information is masked upon display by default.	Test by initiating a federation transaction that triggers a runtime decision. Verify that all sensitive information displayed to the subscriber is masked by default.	4.6.1.3 F	IdP	ALL	<i>Assessment is required when: The IdP is party to a trust agreement with an RP but does not have that RP on an allowlist.</i> The IdP is a trusted holder of information for the subscriber. When the subscriber interacts with the IdP, the IdP may need to display sensitive information to the subscriber to allow the subscriber to confirm and authorize its release to the RP. When doing so, the IdP must present that information so that the full value of the sensitive information is not displayed on the screen by default.

NIST SP 800-63-4 Conformance Criteria v0.1: 63C

Control Identifier	Control Name	Control Text	Objective	Assessment Method	Index	Target	Profile/XAL Level	Discussion
IDPRD-7	RP Not on Allowlist: Remembered Decision Disclosure	The IdP SHALL disclose to the authorized party that the storage mechanism is in use.	Determine whether the IdP discloses to the authorized party that a mechanism is in use to remember their authorization decision.	Examine the runtime decision screens and IdP documentation to verify that disclosure of the remembered decision mechanism is presented to the authorized party. Test by initiating a federation transaction that triggers a runtime decision and verify that the IdP either (a) gives the authorized party a choice whether or not the decision should be remembered for future transactions or (b) discloses that the authorization decision may be remembered for future transactions.	4.6.1.3 G	IdP	ALL	<i>Assessment is required when: The IdP is party to a trust agreement with an RP but does not have that RP on an allowlist, and the IdP employs a mechanism to remember the authorized party's decision.</i> Related Control: IDPRD-8 requires the IdP to allow revocation of remembered decisions.
IDPRD-8	RP Not on Allowlist: Remembered Decision Revocation	[The IdP] SHALL allow the authorized party to revoke such remembered access at a future time.	Determine whether a previous runtime decision can be revoked by the authorized party.	Examine the IdP interface to verify that the authorized party can view and revoke remembered authorization decisions. Test by approving a non-allowlisted RP at runtime and have the IdP remember the decision. Then, initiate a new transaction with the same RP. Verify no runtime prompt appears. Test by revoking the above remembered decision using the IdP's revocation mechanism. Then, initiate another transaction with the same RP. Verify the runtime prompt reappears.	4.6.1.3 H	IdP	ALL	<i>Assessment is required when: The IdP is party to a trust agreement with an RP but does not have that RP on an allowlist, and the IdP employs a mechanism to remember the authorized party's decision.</i> When the IdP remembers an authorized party's runtime decision, the IdP must provide a mechanism for the authorized party to revoke that decision so that future transactions with the same RP will trigger a new runtime authorization prompt. Related control: IDPRD-7 requires the IdP to disclose that the remembered decision mechanism is in use.
RPAIDP-1	RP Allowlist: IdP Conformance	When placing an IdP in its allowlist, the RP SHALL confirm that the IdP abides by the terms of the trust agreement. This confirmation can be facilitated by a federation authority or undertaken directly by the RP.	Determine whether all IdPs in an RP's allowlist are compliant with the requirements of their trust agreement artifact(s).	Examine RP policies and procedures for adding IdPs to the allowlist to verify that a process exists for confirming IdP compliance with trust agreement artifact(s) before allowlisting. For a sample of allowlisted IdPs, verify that evidence of compliance confirmation exists (e.g., review records, attestation, federation authority approval).	4.6.2.1 A	RP	ALL	<i>Assessment is required when: The RP maintains an IdP allowlist.</i> Before adding an IdP to its allowlist, the RP must confirm that the IdP abides by the terms of the trust agreement artifact(s). This confirmation may be facilitated by a federation authority or undertaken directly by the RP.
RPAIDP-2	RP Allowlist: IdP Identification	RP allowlists SHALL uniquely identify IdPs through fully qualified domain names, cryptographic keys, or other identifiers that are applicable to the federation protocol in use. An allowlist entry for an IdP SHALL NOT use a wildcard domain identifier.	Determine whether the RP's allowlist uniquely identifies IdPs using appropriate identifiers for the federation protocol in use.	Examine the RP's allowlist configuration to verify that each IdP entry uses a unique identifier such as a fully qualified domain name, cryptographic key, or other protocol-appropriate identifier, and that no entries use wildcard domain identifiers.	4.6.2.1 B	RP	ALL	<i>Assessment is required when: The RP maintains an IdP allowlist.</i> Wildcard identifiers (e.g., "*.example.com") are prohibited because they could match unintended IdPs, undermining the security of the allowlist.

NIST SP 800-63-4 Conformance Criteria v0.1: 63C

Control Identifier	Control Name	Control Text	Objective	Assessment Method	Index	Target	Profile/XAL Level	Discussion
RPBIDP-1	RP Blocklist: IdP Identification	RP blocklists SHALL identify IdPs through domain names, cryptographic keys, or other identifiers that are applicable to the federation protocol in use. Any entities that share an identifier SHALL be considered equivalent for the purposes of the blocklist.	Determine whether the RP's blocklist identifies IdPs using appropriate identifiers for the federation protocol in use and treats entities sharing an identifier as equivalent for blocking purposes.	Examine the RP blocklist entries and verify that each IdP is identified using domain names, cryptographic keys, or other protocol-applicable identifiers. Test with representative matching IdPs and determine that all matching entities are treated as equivalent for blocklist purposes, if the RP uses an identifier that can match multiple IdPs,	4.6.2.2 A	RP	ALL	<i>Assessment is required when: The RP maintains an IdP blocklist.</i> Unlike allowlists, blocklists may use wildcard domain identifiers to block multiple malicious or untrusted IdPs under a common domain. The Current text incorrectly states: "RP blocklists SHALL uniquely identify IdPs through fully qualified domain names, cryptographic keys, or other identifiers that are applicable to the federation protocol in use." The text will be updated in the errata volume.
RPRD-1	RP Runtime Decision: IdP Acceptance	Every IdP that is in a trust agreement with an RP but not on an allowlist with that RP SHALL be governed by a default policy in which runtime authorization decisions will be made by the authorized party indicated in the trust agreement.	Determine whether non-allowlisted IdPs are governed by a default policy in which runtime authorization decisions are made by the authorized party identified in the trust agreement artifact(s).	Examine the trust agreement artifact(s) and RP decision logic to determine which party is designated as the authorized party for non-allowlisted IdPs. Test by initiating a federation transaction using an IdP that is in a trust agreement with the RP but is not allowlisted, and determine that the runtime decision is made by the authorized party identified in the trust agreement.	4.6.2.3 A	RP	ALL	<i>Assessment is required when: The RP is in a trust agreement with an IdP, but does not include that IdP in an allowlist.</i> For IdPs that are in a trust agreement with the RP but not allowlisted, the RP must present a runtime authorization decision to the authorized party. Common implementations include allowing the authorized party to type a directed identifier to facilitate discovery, or using an account chooser to select from available IdPs.
RPRD-2	RP Runtime Decision: Remembered Decision Disclosure	The RP SHALL disclose to the authorized party that the storage mechanism is in use.	Determine whether the RP discloses to the authorized party that a mechanism is in use to remember their prior IdP authorization decision.	Examine runtime decision screens and RP documentation to verify that the remembered IdP decision is disclosed to the authorized party. Test by initiating a federation transaction that triggers a runtime IdP selection and verify that the RP either (a) gives the authorized party a choice whether the decision should be remembered for future transactions, or (b) discloses that the decision may be remembered for future transactions.	4.6.2.3 B	RP	ALL	<i>Assessment is required when: The RP is in a trust agreement with an IdP, but does not include that IdP in an allowlist, and the RP employs a mechanism to remember the authorized party's decision.</i> This is the RP-side equivalent of IDPRD-7. The RP's remembered decision concerns which IdP to contact, not which attributes to release. Since this mechanism operates prior to authentication (e.g., via a browser cookie outside the authenticated session), it is separate from the RP subscriber account. Related Controls: RPRD-3 requires the RP to allow revocation of remembered decisions.
RPRD-3	RP Runtime Decision: Remembered Decision Revocation	[The RP] SHALL allow the authorized party to revoke such remembered access at a future time.	Determine whether a previous runtime decision can be revoked by the authorized party.	Examine the RP interface to verify a mechanism exists for the authorized party to view and revoke remembered IdP selection decisions. Test by selecting a non-allowlisted IdP at runtime and having the RP remember the decision. Then, initiate a new transaction and verify that no IdP selection prompt appears. Next, revoke the remembered decision using the RP's revocation mechanism. Initiate another transaction and verify that the IdP selection prompt reappears.	4.6.2.3 C	RP	ALL	<i>Assessment is required when: The RP is in a trust agreement with an IdP, but does not include that IdP in an allowlist, and the RP employs a mechanism to remember the authorized party's decision.</i>

NIST SP 800-63-4 Conformance Criteria v0.1: 63C

Control Identifier	Control Name	Control Text	Objective	Assessment Method	Index	Target	Profile/XAL Level	Discussion
PMRPSA-1	RP Subscriber Account Provisioning Methods	The RP subscriber account SHALL be provisioned at the RP prior to the establishment of an authenticated session at the RP in one of the following ways: (a) Just-In-Time Provisioning (b) Pre-Provisioning (c) Ephemeral Provisioning (d) Other Provisioning Methods	Determine whether the RP subscriber account is provisioned prior to session establishment using a documented provisioning method.	The underlying requirement that the RP subscriber account be provisioned through the method specified in the trust agreement artifact(s) before an authenticated session is created is satisfied by ASRP-1 and PMRPSA-7. If Just-In-Time Provisioning is used, this control is further satisfied by PMRPSA-2. If Pre-Provisioning is used, this control is further satisfied by PMRPSA-3 and PMRPSA-4. If Ephemeral Provisioning is used, this control is further satisfied by PMRPSA-5. If Alternative Provisioning Methods are used, this control is further satisfied by PMRPSA-6.	4.6.3 A	RP	ALL	
PMRPSA-2	Just-In-Time Provisioning Cached Attribute Management	The RP SHALL be responsible for managing any cached attributes it might have.	Determine whether the RP manages cached subscriber attributes obtained through just-in-time provisioning.	Examine RP policies and system documentation for attribute caching and lifecycle management, including retention periods, update procedures, and deletion processes.	4.6.3 B	RP	ALL	<i>Assessment is required when: Just-In-Time Provisioning is used.</i> In just-in-time provisioning, the RP subscriber account is created or updated at the time of the federation transaction based on attributes provided in the assertion. The RP may cache these attributes locally for use between federation transactions. This control ensures the RP has defined processes for managing the lifecycle of cached attributes.
PMRPSA-3	Pre-Provisioned Account Access Method	Pre-provisioned accounts SHALL be bound to a federated identifier at the time of provisioning, unless an alternative means of access is defined by the trust agreement, such as an account linking policy (see Sec. 3.8.1), an account resolution policy (see Sec. 3.8.2), or alternative authentication mechanisms (see Sec. 3.8.3).	Determine whether pre-provisioned RP subscriber accounts have a defined means of subscriber access, either through a federated identifier bound at the time of provisioning or through an alternative means of access defined in the trust agreement artifact(s).	Examine the provisioning model documentation assessed under PMRPSA-7, and identify the means by which subscribers access pre-provisioned RP subscriber accounts. If a federated identifier is bound at provisioning time, verify that provisioning records include a federated identifier for each pre-provisioned account. If an alternative means of access is used, verify that the trust agreement artifact(s) define the alternative access method (e.g., account linking per Sec. 3.8.1, account resolution per Sec. 3.8.2, or alternative authentication per Sec. 3.8.3) and that the method is implemented.	4.6.3 C	RP	ALL	Assessment is required when: Pre-Provisioning is used. This requirement ensures that pre-provisioned RP subscriber accounts are not created without a defined path for subscribers to access them. The default mechanism is binding a federated identifier at provisioning time. If the trust agreement defines an alternative, such as account linking, account resolution, or direct authentication, that alternative must be documented and implemented.

NIST SP 800-63-4 Conformance Criteria v0.1: 63C

Control Identifier	Control Name	Control Text	Objective	Assessment Method	Index	Target	Profile/XAL Level	Discussion
PMRPSA-4	Pre-Provisioning Privacy Considerations	The privacy considerations of the RP having access to this information prior to a federation transaction SHALL be accounted for in the trust agreement.	Determine whether the trust agreement artifact(s) address the privacy considerations of the RP having access to subscriber information prior to a federation transaction.	Examine the trust agreement artifact(s) to verify that, when pre-provisioning is used, they account for the privacy considerations of the RP receiving subscriber information prior to a federation transaction. Verify that the trust agreement addresses, as applicable: (1) the categories of subscriber information the RP receives through pre-provisioning; (2) the fact that pre-provisioned data may include subscribers who may never interact with the RP; and (3) any privacy protections or limitations applicable to that pre-provisioned information, such as restrictions on collection, use, disclosure, retention, or synchronization.	4.6.3 D	IdP/RP	ALL	<i>Assessment is required when: Pre-Provisioning is used.</i> In this model, the RP also receives attributes about subscribers who have not yet interacted with the RP and who may never do so. This is in contrast to other models in which the RP only receives information about the subset of subscribers that use the RP, and then only after the subscriber uses the RP for the first time.
PMRPSA-5	Ephemeral Provisioning Identifier Unlinking	If a federation identifier is supplied in the assertion, the RP SHALL remove any linkage of the federated identifier from an RP subscriber account.	Determine whether the RP removes any linkage between the federated identifier and the RP subscriber account when using ephemeral provisioning.	Examine RP system documentation and data retention policies to verify that federated identifiers are not persistently linked to ephemerally provisioned RP subscriber accounts. Test by conducting an ephemeral provisioning transaction and verifying that the federated identifier is not retained or linked to the RP subscriber account after the session ends.	4.6.3 E	RP	ALL	<i>Assessment is required when: Ephemeral Provisioning is used, and a federation identifier is supplied in the assertion.</i> When processing an assertion, the RP establishes a link between that assertion and a new or existing RP subscriber account but removes that link when the authenticated session ends. This process is similar to just-in-time provisioning, but the RP keeps no long-term record of the subscriber when the session is complete, in accordance with Sec. 3.11.3. This form of provisioning is useful for RPs that fully externalize access rights to the IdP, allowing the RP to be more simplified with less internal state. If this form of provisioning is used, the federated identifier is not required in the assertion.
PMRPSA-6	Alternative Provisioning Privacy Assessment	The details of any alternative provisioning model SHALL be included in the privacy risk assessments of the IdP and RP.	Determine whether the privacy risk assessments of the IdP and RP include the details of any alternative provisioning model in use.	Examine the privacy risk assessment to verify that it addresses the alternative provisioning model, including a description of the alternative provisioning model and the privacy risks specific to the model (e.g., data exposure, retention, minimization).	4.6.3 F	IdP/RP	ALL	Assessment is required when: An Alternative Provisioning Method is used.
PMRPSA-7	Provisioning Model Documentation	All organizations SHALL document their provisioning models as part of their trust agreement.	Determine whether the organization documents its provisioning model in the trust agreement artifact(s).	Examine the trust agreement artifact(s) for documentation of the provisioning model(s) in use. Verify that each documented model is identifiable as one of the provisioning methods enumerated in Sec. 4.6.3: just-in-time, pre-provisioning, ephemeral, or an alternative method.	4.6.3 G	IdP/RP	ALL	

NIST SP 800-63-4 Conformance Criteria v0.1: 63C

Control Identifier	Control Name	Control Text	Objective	Assessment Method	Index	Target	Profile/XAL Level	Discussion
ATSYNC-1	RP Processing of Termination Signal	Upon receiving such a signal, the RP SHALL process the RP subscriber account as stipulated in the trust agreement and in accordance with Sec. 3.11.3.	Determine whether the RP processes the RP subscriber account in accordance with the trust agreement artifact(s) and Section 3.11.3 upon receiving a termination or revocation signal from the IdP.	Examine the trust agreement artifact(s) to identify the stipulated processing requirements for termination and revocation signals. Review RP account termination procedures to verify alignment with those requirements, and with SSIN-1, SSIN-2, and SSIN-3. Test by sending a termination signal to the RP and verifying that the RP subscriber account is processed according to the requirements for termination and revocation signals stipulated in the trust agreement artifact(s), and in accordance with SSIN-1, SSIN-2, and SSIN-3.	4.6.4 A	RP	ALL	Assessment is required when: The RP may receive a signal from an IdP indicating that a subscriber account has been terminated or the subscriber's access to the RP has been revoked.
ATSYNC-2	IdP Notification of Terminations due to Fraud or Suspicious Activity	If the reason for termination is suspicious or fraudulent activity, the IdP SHALL notify the RP of the termination and include the reason in its signal to the RP to allow the RP to review the associated RP subscriber account's activity for suspicious activity, if specified in the trust agreement with that RP.	Determine whether the IdP notifies the RP and includes the reason when terminating a subscriber account due to suspicious or fraudulent activity, as specified in the trust agreement artifact(s).	Examine the trust agreement artifact(s) to determine whether notification of termination due to suspicious or fraudulent activity is required. If required, review IdP procedures for signaling terminations to verify that the procedures include notifying the RP of the reason for termination. Test by simulating a termination due to suspicious activity and verify that the IdP's signal to the RP includes the reason for termination, if the trust agreement artifact(s) require notification of termination due to suspicious or fraudulent activity.	4.6.4 B	IdP	ALL	Assessment is required when: The RP may receive a signal from an IdP indicating that a subscriber account has been terminated or the subscriber's access to the RP has been revoked. This notification enables the RP to review the associated RP subscriber account's activity for suspicious activity.
PAPI-1	Provisioning API: Attributes Limited to RP Functions	The attributes in the provisioning API that are available to a given RP SHALL be limited to only those necessary for the RP to perform its functions, including any audit and security purposes, as discussed in Sec. 3.10.1.	Determine whether the attributes available to the RP through the provisioning API are limited to those necessary for the RP to perform its functions.	Examine the provisioning API configuration to identify which attributes are available to each RP via the API. For each attribute, verify that it maps to a documented functional need of the RP (including audit and security purposes) as established in the trust agreement artifact(s). Verify that no attributes beyond those necessary are exposed through the API.	4.6.5 A	IdP	ALL	Assessment is required when: The IdP provides a provisioning API.
PAPI-2	Provisioning API: Documentation of Access Requirements	As part of establishing the trust agreement, the IdP SHALL document when an RP is given access to a provisioning API, including at least the following: (a) The purpose for the access using the provisioning model. (b) The set of attributes made available to the RP. (c) Whether the API functions as a push to the RP, a pull from the RP, or both. (d) The population of subscribers whose attributes are made available to the RP.	Determine whether the trust agreement artifact(s) document the requirements for provisioning API access.	Examine the trust agreement artifact(s) to verify adequate documentation of the following: (1) the purpose for provisioning API access; (2) the set of attributes made available to the RP; (3) whether the API functions as push, pull, or both; and (4) the population of subscribers whose attributes are made available.	4.6.5 B	IdP	ALL	Assessment is required when: The IdP provides a provisioning API.

NIST SP 800-63-4 Conformance Criteria v0.1: 63C

Control Identifier	Control Name	Control Text	Objective	Assessment Method	Index	Target	Profile/XAL Level	Discussion
PAPI-3	Provisioning API Mutual Authentication	Access to the provisioning API SHALL occur over a mutually authenticated protected channel.	Determine whether access to the provisioning API occurs over a mutually authenticated protected channel.	Examine the provisioning API configuration and documentation to verify that mutual authentication is required for all connections. Test by attempting to access the provisioning API without presenting RP credentials and verify that access is denied.	4.6.5 C	IdP	ALL	<i>Assessment is required when: The IdP provides a provisioning API.</i> A mutually authenticated protected channel requires both parties (IdP and RP) to authenticate to each other, unlike a standard authenticated protected channel where only the server is authenticated.
PAPI-4	Provisioning API Prohibition for Subscriber-Driven Trust Agreements	A provisioning API SHALL NOT be made available under a subscriber-driven trust agreement.	Determine whether the IdP prohibits provisioning API access under subscriber-driven trust agreements.	Examine IdP policies and provisioning API access controls to verify that provisioning API access is not granted to RPs operating under subscriber-driven trust agreements.	4.6.5 D	IdP	ALL	<i>Assessment is required when: The IdP provides a provisioning API.</i> Subscriber-driven trust agreements rely on runtime decisions by the subscriber rather than pre-established organizational agreements. Provisioning APIs provide bulk or out-of-band access to subscriber attributes, which is incompatible with the subscriber-controlled nature of subscriber-driven trust agreements.
PAPI-5	Trust Agreement Required for Provisioning API	The IdP SHALL NOT make a provisioning API available to any RP outside of an established trust agreement.	Determine whether the IdP restricts provisioning API access to RPs with established trust agreements.	Examine IdP provisioning API access control configuration to verify that each RP with API access has a corresponding established trust agreement with the IdP that allows provisioning API access (see PAPI-2). Test by attempting to access the provisioning API as an RP without an established trust agreement with the IdP. Verify that access is denied.	4.6.5 E	IdP	ALL	Assessment is required when: The IdP provides a provisioning API.
PAPI-6	Provisioning API Purpose Limitation	IdP SHALL provide access to a provisioning API only as part of a federated identity relationship with an RP to facilitate federation transactions with that RP and related functions, such as signaling revocation of the subscriber account.	Determine whether the IdP limits provisioning API access to the purpose of facilitating federation transactions and related functions.	The purpose for provisioning API access is satisfied by PAPI-2(a). Examine the IdP's provisioning API capabilities to verify that API functionality is limited to facilitating federation transactions and related functions (e.g., account provisioning, attribute synchronization, account revocation signaling). Verify that no API capabilities serve purposes outside the federated identity relationship (e.g., general-purpose directory queries, marketing data access, analytics unrelated to federation).	4.6.5 F	IdP	ALL	Assessment is required when: The IdP provides a provisioning API.
PAPI-7	Provisioning API Access Revocation	The IdP SHALL revoke an RP's access to the provisioning API once access is no longer required by the RP for its functioning purposes or when the trust agreement is terminated.	Determine whether the IdP revokes RP access to the provisioning API when no longer required or when the trust agreement is terminated	Examine IdP policies and procedures for provisioning API access lifecycle management to verify that access is terminated when the trust agreement is terminated or when the RP notifies the IdP that access is no longer needed. Test by revoking a test RP's provisioning API access and verifying that the RP can no longer access the API.	4.6.5 G	IdP	ALL	Assessment is required when: The IdP provides a provisioning API.

NIST SP 800-63-4 Conformance Criteria v0.1: 63C

Control Identifier	Control Name	Control Text	Objective	Assessment Method	Index	Target	Profile/XAL Level	Discussion
PAPI-8	Provisioning API Control and Jurisdiction	Any provisioning API provided to the RP SHALL be under the control and jurisdiction of the IdP.	Determine whether the IdP is responsible for the content and accuracy of the provisioning API, including when the API infrastructure is operated by a third party.	Examine the system architecture documentation to determine whether the provisioning API is operated directly by the IdP or by a third party. If it is operated by a third party, examine the agreement between the IdP and the third party to verify that the IdP retains responsibility for the content and accuracy of the API's outputs. Verify that the agreement defines how the IdP enforces content and accuracy requirements (e.g., attribute validation, error correction, audit rights).	4.6.5 H	IdP	ALL	Assessment is required when: The IdP provides a provisioning API.
PAPI-9	Provisioning API Account State Change Signaling	When a provisioning API is in use, the IdP SHALL signal to the RP when the state of a subscriber account has been changed, such as when the account has been terminated or disabled.	Determine whether the IdP signals the RP through the provisioning API when the state of a subscriber account changes.	Examine the IdP's provisioning API documentation and procedures to verify that account state changes (termination, disabling, etc.) trigger signals to the RP. Test by changing the state of a subscriber account (e.g., disable the account) and verifying that the IdP sends a signal to the RP indicating the state change.	4.6.5 I	IdP	ALL	<i>Assessment is required when: The IdP provides a provisioning API.</i> PRIVR-9 addresses the specific requirement to deprovision terminated accounts via the provisioning API.
PAPI-10	Federated Identifier Unbinding Upon Terminated/Disabled Signal	When receiving such a signal, the RP SHALL remove the binding of the federated identifier from the account.	Determine whether the RP removes the federated identifier from the RP subscriber account upon receiving a signal that the subscriber account has been terminated or disabled.	Examine the RP's design, configuration, and signal-processing logic for handling IdP signals indicating that a subscriber account has been terminated or disabled. Verify that receipt of such a signal causes the RP to remove the corresponding federated identifier from the affected RP subscriber account. Test by sending a signal indicating that a test subscriber account has been terminated or disabled. Verify that the RP removes the federated identifier associated with that IdP from the RP subscriber account.	4.6.5 J	RP	ALL	Assessment is required when: The IdP provides a provisioning API. In the errata publication, this control will be changed to: When receiving a signal indicating that the account has been terminated or disabled, the RP SHALL remove the federated identifier from the RP subscriber account. Related Controls: - PAPI-9 requires the IdP to signal account state changes. - ACCL-2 prohibits access once a federated identifier is removed.
PAPI-11	Provisioning API: Personal Information Handling	The RP SHALL treat all personal information sourced from the provisioning API in accordance with Sec. 3.11.3.	Determine whether the RP treats personal information sourced from the provisioning API in accordance with Section 3.11.3 requirements.	Satisfied by CAARP-1.	4.6.5 K	RP	ALL	Assessment is required when: The IdP provides a provisioning API.
CAARP-1	RP Subscriber Account Attribute Storage	All attributes in the RP subscriber account - regardless of source - SHALL be stored in accordance with Sec. 3.11.3.	Determine whether the RP stores all attributes in the RP subscriber account in accordance with Section 3.11.3 requirements.	Satisfied by SSIN-1 through SSIN-3.	4.6.6 A	RP	ALL	This control applies to all attributes regardless of source (assertion, provisioning API, identity API, or other sources).
CAARP-2	Disclosure of Purpose for Additional Attributes	The RP SHALL disclose to the subscriber the purpose for collecting any additional attributes.	Determine whether the RP discloses to the subscriber the purpose for any additional attributes collected.	Examine RP subscriber-facing documentation, such as privacy notices and consent screens, to verify that the purpose for collecting additional attributes is disclosed to the subscriber.	4.6.6 B	RP	ALL	Assessment is required when: The RP collects additional attributes not provided by the IdP.

NIST SP 800-63-4 Conformance Criteria v0.1: 63C

Control Identifier	Control Name	Control Text	Objective	Assessment Method	Index	Target	Profile/XAL Level	Discussion
CAARP-3	Additional Attribute Use Limitation	These attributes SHALL be used solely for the stated purposes of the RP's functionality.	Determine whether the RP limits use of additional attributes to the stated purposes of its functionality.	Examine RP policies and procedures for handling additional attributes to verify that use is limited to the purposes disclosed per CAARP-2.	4.6.6 C	RP	ALL	<i>Assessment is required when: The RP collects additional attributes not provided by the IdP.</i> This control requires the RP to adhere to the purpose disclosed under CAARP-2.
CAARP-4	RP Attribute Transmission Limitations	The transmission of additionally collected attributes SHALL be handled in accordance with Sec. 3.10.1.	Determine whether the RP handles the transmission of additionally collected attributes in accordance with the limitations in Sec. 3.10.1.	Apply the assessment methods from TSI-1, TSI-2, and TSI-3 to the RP's transmission of additionally collected attributes, substituting the RP for the IdP in each assessment.	4.6.6 D	RP	ALL	Assessment is required when: The RP collects additional attributes not provided by the IdP. Section 3.10.1 establishes limitations on transmitting subscriber information, directed at the IdP (TSI-1 through TSI-3). This control extends those same limitations to the RP when transmitting additionally collected attributes - attributes the RP gathered independently, not through the federation transaction.
CAARP-5	Redress for Additionally Collected Attributes	The RP SHALL provide a secure and effective means of redress for the subscriber to update and remove these additionally collected attributes from the RP subscriber account.	Determine whether the RP provides a secure and effective means of redress for subscribers to request updates to or removal of additionally collected attributes.	Examine the RP's subscriber-facing interfaces and account management capabilities to verify that subscribers can request updates to, and removal of, any additionally collected attributes from their RP subscriber account. Test by requesting an update to an attribute value and requesting the removal of an attribute, as a test subscriber who has additionally collected attributes in their RP subscriber account. Verify that both requests are processed.	4.6.6 E	RP	ALL	Assessment is required when: The RP collects additional attributes not provided by the IdP.
CAARP-6	Federal RP SORN Disclosure for Additional Attributes	An RP SHALL disclose any additional attributes collected and their use as part of its System of Records Notice (SORN).	Determine whether the federal agency RP discloses additionally collected attributes and their use in its SORN.	Examine the RP's System of Records Notice (SORN) to verify that additionally collected attributes and their uses are disclosed.	4.6.6 F	RP	ALL	<i>Assessment is required when: The RP is a federal agency and collects additional attributes not provided by the IdP.</i> This control applies only to RPs that are federal agencies. SORN requirements derive from the Privacy Act of 1974 (5 U.S.C. 552a).
TBRP-1	Time-Based Termination Notice and Reactivation	When processing an inactive account, the RP SHALL provide sufficient notice to the subscriber about the pending termination of the account and provide the subscriber with an option to re-activate the account prior to its scheduled termination.	Determine whether the RP provides sufficient notice to subscribers about pending account termination and an option to reactivate the account prior to scheduled termination, when processing inactive accounts for time-based removal.	Examine the RP's policies and procedures for time-based account termination, including notice timelines and reactivation processes. Also, examine sample termination notices to verify they inform subscribers of pending termination and provide a reactivation option. Test by triggering a time-based termination process for a test account and verifying that notice is provided, and reactivation is available prior to termination.	4.6.7 A	RP	ALL	<i>Assessment is required when: The RP uses time-based removal of RP subscriber accounts.</i> "Sufficient notice" should be tailored to expected usage patterns at the RP. For example, an RP that expects weekly access might provide 30 days' notice, while an RP that expects monthly access might provide 90 days or more.

NIST SP 800-63-4 Conformance Criteria v0.1: 63C

Control Identifier	Control Name	Control Text	Objective	Assessment Method	Index	Target	Profile/XAL Level	Discussion
TBRRP-2	Personal Information Removal Upon Time-Based Termination	Upon termination, the RP SHALL remove all personal information associated with the RP subscriber account in accordance with Sec. 3.11.3.	Determine whether the RP removes all personal information associated with the RP subscriber account upon termination in accordance with Sec. 3.11.3.	Satisfied by RPSA-1.	4.6.7 B	RP	ALL	<i>Assessment is required when: The RP uses time-based removal of RP subscriber accounts.</i>
RASR-1	Communication of Authentication Recency	The IdP SHALL communicate to the RP any information that the IdP has regarding the recency of the subscriber's latest authentication event at the IdP, and the RP MAY use this information to make authorization and access decisions.	Determine whether the IdP communicates information regarding the recency of the subscriber's latest authentication event to the RP.	Examine the IdP assertion structure and documentation to verify that recency information for the subscriber's latest authentication event is included in assertions. Test by having the IdP generate a test assertion and verify the authentication timestamp is present. Next, trigger a new authentication event at the IdP to generate a second assertion. Verify the second assertion reflects the updated authentication time.	4.7 A	IdP	ALL	A federated assertion is generated in the context of an active authentication event for the subscriber at the IdP. When communicating the authentication state of the subscriber to the RP in an assertion, the IdP has to communicate the timing of that authentication event to the RP. This information can help the RP make access decisions, such as requesting the subscriber to re-authenticate at the IdP directly before being allowed to access highly sensitive information.
RASR-2	Identity API Access Insufficient for Session Extension	The RP's ability to successfully fetch additional attributes through an identity API SHALL NOT be used to establish or extend a session at the RP.	Determine whether the RP refrains from using successful identity API attribute fetches to extend an existing authenticated session.	The prohibition on session establishment via identity API access, is satisfied by IDAP-3. For the session extension prohibition: Examine the RP session-management logic, session renewal/extension code, and timeout handling to verify that successful identity API calls do not trigger session extension or reset the overall or inactivity timeout. Test by establishing an authenticated session at the RP and allowing it to approach an overall or inactivity timeout threshold. Successfully fetch attributes via the identity API. Verify that the session is not extended or refreshed solely as a result of the API call.	4.7 B	RP	ALL	<i>Assessment is required when: An identity API is available to the RP.</i> The lifetime of the access to the identity API is independent of the lifetime of the assertion.
SSIG-1	Shared Signaling Purpose Limitations	Shared signaling SHALL be limited to the allowable functions of the identity process, as discussed in Sec. 3.10.1.	Determine whether all shared signals serve one of the allowable identity process functions defined in Section 3.10.1.	Examine the shared signals documentation (see SSIG-2 and SSIG-3). For each signal type, verify that the stated purpose maps to one of the allowable functions: (1) identity service (identity proofing, authentication, or attribute assertions), (2) a specific subscriber request, (3) fraud mitigation related to the identity service, or (4) security incident response related to the identity service. Flag any signal that serves a purpose outside these four categories.	4.8 A	IdP/RP	ALL	<i>Assessment is required when: Shared signaling is used.</i> Shared signals are communications between the IdP and RP that occur outside of the federation transaction to alert federation partner(s) of important changes in state that would not otherwise be known, such as suspected fraud or an account status change. This control gates all shared signaling to the same purpose limitations that govern other subscriber information transmissions under Section 3.10.1. SSIG-2 and SSIG-3 require documentation of signal purposes; this control verifies those purposes are permissible.

NIST SP 800-63-4 Conformance Criteria v0.1: 63C

Control Identifier	Control Name	Control Text	Objective	Assessment Method	Index	Target	Profile/XAL Level	Discussion
SSIG-2	Shared Signaling Documentation and Disclosure	All uses of shared signaling SHALL be documented in the trust agreement and made available to the authorized party stipulated by the trust agreement.	Determine whether (1) all uses of shared signaling are documented in the trust agreement artifact(s), and (2) that this documentation is made available to the authorized party.	Examine the trust agreement artifact(s) to verify that all shared signaling uses are documented. Identify the authorized party designated to receive this documentation. Verify the documentation has been made available to that party (e.g., through disclosure records, acknowledgment of receipt, or accessibility via published terms).	4.8 B	IdP/RP	ALL	<i>Assessment is required when: Shared signaling is used.</i> For documentation content requirements, see SSIG-3. The "authorized party" varies by trust agreement type. In subscriber-driven agreements, this is typically the subscriber (see SDTAE-1, which includes shared signaling in required disclosures). In pre-established agreements, this may be the federation parties or a federation authority. SSIG-3 specifies the required content of this documentation; PETA-6 establishes trust agreement terms for shared signaling.
SSIG-3	Shared Signaling Documentation Content	[The Trust Agreement artifact(s)] SHALL include the events under which a signal is sent, the type of information included in such a signal (including any personal information), any additional parameters sent with the signal, and the expected processing of a received signal.	Determine whether the trust agreement artifact(s) document the required shared signaling content elements.	Satisfied by PETA-6.	4.8 C	IdP/RP	ALL	Assessment is required when: Shared signaling is used.
SSIG-4	Shared Signaling Privacy Review	The use of shared signaling SHALL be subject to privacy review under the trust agreement.	Determine whether shared signaling has been subject to privacy review under the trust agreement.	Examine each party's privacy risk assessment (or equivalent privacy review documentation) to verify that shared signaling is addressed, including the events that trigger signals, any personal information transmitted, and the expected processing by the receiving party. Refer to SSIG-2 and PETA-6 for the documented signaling terms that should be covered by the privacy review.	4.8 D	IdP/RP	ALL	Assessment is required when: Shared signaling is used.
SSIG-5	Shared Signal Personal Information Minimization	Shared signals SHALL NOT include personal information except what is necessary to identify the subscriber account in question (e.g., an account identifier or attributes that can be correlated by the receiving party).	Determine whether shared signals limit personal information to only what is necessary to identify the subscriber account.	Examine the shared signal documentation (per PETA-6) to identify any personal information included. Verify that each personal information element is necessary for subscriber account identification by the receiving party. Flag any personal information that serves purposes beyond account identification. Test by capturing sample shared signals and verifying that the actual content matches the documented content and contains no personal information beyond what is required for identification.	4.8 E	IdP/RP	ALL	Assessment is required when: Shared signaling is used. This control applies data minimization principles to shared signaling. The permitted personal information is limited to what enables the receiving party to match the signal to the correct subscriber account - typically an opaque identifier or correlation handle already known to both parties.

NIST SP 800-63-4 Conformance Criteria v0.1: 63C

Control Identifier	Control Name	Control Text	Objective	Assessment Method	Index	Target	Profile/XAL Level	Discussion
SSIG-6	IdP-to-RP Signaling: Pre-Established Trust Agreement Required	Signaling from the IdP to the RP SHALL require a pre-established trust agreement.	Determine whether IdP-to-RP shared signaling occurs only under a pre-established trust agreement.	Examine the IdP shared signaling configuration to verify that outbound signals to RPs are sent only to RPs whose pre-established trust agreement artifact(s) explicitly authorize shared signaling (see PETA-6). Verify that no IdP-to-RP signaling is configured for RPs operating under subscriber-driven trust agreements or for RPs whose trust agreement artifact(s) do not include shared signaling terms.	4.8 F	IdP	ALL	<i>Assessment is required when: Shared signaling is used.</i> In a subscriber-driven trust agreement, the IdP has no pre-existing relationship with the RP and therefore no established channel for signaling. Per Sec. 4.8, signaling from the RP to the IdP MAY be used in both pre-established and subscriber-driven trust agreements; only IdP-to-RP signaling requires a pre-established trust agreement.
SSIG-7	IdP Compromise Signal Review	If the IdP receives a signal that a subscriber account is suspected of compromise, the IdP SHALL review actions taken by that account at the IdP for suspicious activity.	Determine whether the IdP reviews subscriber account activity upon receiving a compromise signal.	Examine the IdP incident response procedures for documented processes triggered by receipt of a subscriber account compromise signal, including the scope of activity review (e.g., authentication events, attribute changes, federation transactions). Test by simulating a compromise signal for a test subscriber account and verifying that the IdP initiates a review of that account's activity.	4.8 G	IdP	ALL	<i>Assessment is required when: Shared signaling is used.</i> Related: SSIG-8 (4.8 H) requires the IdP to signal additional RPs if suspicious activity is confirmed.
SSIG-8	IdP Compromise Notification to Affected RPs	If suspicious activity is confirmed at the IdP, the IdP SHALL signal any additional RPs that the subscriber account was used for during the suspected time frame.	Determine whether the IdP signals all RPs that the compromised subscriber account was used for during the suspected time frame when suspicious activity is confirmed.	Examine the IdP's incident response procedures to identify a documented process for signaling RPs when suspicious activity is confirmed on a subscriber account. Determine whether the IdP retains federation transaction records sufficient to identify which RPs the subscriber account interacted with during the suspected time frame. If yes, verify the process signals the RPs identified from those federation transaction records for the suspected time frame. If no, verify the process signals all RPs with which the IdP has a pre-established trust agreement authorizing shared signaling that could have been impacted for the relevant subscriber population or transaction context.	4.8 H	IdP	ALL	<i>Assessment is required when: Shared signaling is used.</i> The IdP is not required to retain records of which RPs a subscriber account interacted with. However, the obligation to signal affected RPs remains. If the IdP cannot scope the notification to RPs the account actually used during the suspected time frame, the IdP must signal all RPs that could have been impacted. In practice, this means all RPs with pre-established trust agreement artifact(s) that authorize shared signaling (see SSIG-6, PETA-6). Prerequisite: SSIG-7 (IdP review upon receiving compromise signal).

NIST SP 800-63-4 Conformance Criteria v0.1: 63C

Control Identifier	Control Name	Control Text	Objective	Assessment Method	Index	Target	Profile/XAL Level	Discussion
SSIG-9	Security and Privacy Reviews of Additional Signals	Additional signals from both the IdP and RP SHALL be subject to a security review, included in the privacy risk assessment, and addressed in the trust agreement.	Determine whether signals beyond those recommended in Sec. 4.8 have undergone a security review, been included in the privacy risk assessment, and are addressed in the trust agreement artifact(s).	Examine all shared signals implemented by the assessed party. Identify any signals not in the following recommended sets: (1) IdP-to-RP recommended signals: account terminated/suspended/disabled; account suspected of being compromised; attributes changed (including non-federated identifiers such as email address or certificate common name); possible range of IAL, AAL, or FAL for the account has changed; authenticators have been updated. (2) RP-to-IdP recommended signals: account terminated/suspended/disabled; suspected of being compromised; bound authenticator added; bound authenticator removed. For each additional signal identified, verify that it has been subject to a security review, included in the privacy risk assessment, and addressed in the applicable trust agreement artifact(s), including the event that triggers the signal, the information included in the signal, any additional parameters, and the expected processing by the receiving party.	4.8 I	IdP/RP	ALL	Assessment is required when: Shared signaling is used.
SSIG-10	Linked Account Signal Handling Documentation	If the RP allows for account linking to multiple IdPs, the RP SHALL document their practices regarding signals for linked accounts.	Determine whether the RP documents its practices for handling shared signals that affect RP subscriber accounts linked to multiple IdPs.	Examine the RP policy documentation for practices governing how signals received from one IdP are applied to an RP subscriber account that is also linked to one or more other IdPs (e.g., whether a compromise signal from one IdP triggers suspension of the entire RP subscriber account or only the affected federated identifier).	4.8 J	RP	ALL	<i>Assessment is required when: Shared signaling is used and the RP allows account linking to multiple IdPs.</i> This control addresses the ambiguity that arises when a signal pertains to one IdP's subscriber account, but the RP subscriber account is also accessible via other IdPs. Without documented practices, signal handling for linked accounts is ad hoc and potentially inconsistent. Related: SSIG-11 constrains these practices by requiring that shared signals not reveal the identity of a subscriber's linked IdPs
SSIG-11	Linked IdP Identity Protection in Shared Signals	The RP SHALL ensure that the shared signals do not reveal the identity of a subscriber's linked IdPs.	Determine whether the RP's shared signals are constructed so as not to reveal the identity of any other IdPs linked to the subscriber's RP subscriber account.	Examine the RP shared signal message content and structure to verify that no signal includes or implies the identity of other IdPs linked to the subscriber's RP subscriber account (e.g., IdP identifiers, IdP-specific federated identifiers, or attributes uniquely associated with a particular IdP). Test by generating one or more shared signals for a test RP subscriber account linked to multiple IdPs and verifying that the outbound signal content does not directly or indirectly reveal the identity of any other linked IdP.	4.8 K	RP	ALL	<i>Assessment is required when: Shared signaling is used and the RP allows account linking to multiple IdPs.</i> Companion to SSIG-10, which requires the RP to document its signal-handling practices for linked accounts. This control constrains what those signals may contain. Revealing linked IdP identities could enable profiling of a subscriber's identity provider relationships, undermining federation privacy goals.

NIST SP 800-63-4 Conformance Criteria v0.1: 63C

Control Identifier	Control Name	Control Text	Objective	Assessment Method	Index	Target	Profile/XAL Level	Discussion
ARTC-1	Assertions represent Discrete Authentication Events	Assertions SHALL represent a discrete authentication event of the subscriber at the IdP.	Determine whether each assertion issued by the IdP represents a single, discrete authentication event of the subscriber.	Examine the IdP assertion issuance process to verify that each assertion is generated in response to a specific authentication event and does not represent a standing authorization, batch of events, or ongoing session state. Examine sample assertions to verify that each contains a unique authentication time corresponding to a single event.	4.9 A	IdP	ALL	SAI-1 (4.5 A) is a prerequisite: the subscriber must have an authenticated session before assertion issuance. ARTC-3 (4.9 C) reinforces this requirement by requiring an authentication time timestamp in every assertion.
ARTC-2	RP Assertion Processing as Discrete Event	Assertions...SHALL be processed as a discrete authentication event at the RP.	Determine whether the RP processes each assertion as a discrete authentication event.	Examine the RP assertion processing procedures to verify that each received assertion is treated as a discrete event rather than being merged with, appended to, or treated as a continuation of a prior assertion. Examine the RP session management practices to verify that a new assertion does not automatically extend or refresh an existing authenticated session established by a prior assertion.	4.9 B	RP	ALL	
ARTC-3	Assertion Attribute Requirements	All assertions SHALL include the following attributes: (1) Issuer identifier: An identifier for the issuer of the assertion (i.e., the IdP). (2) Audience identifier: An identifier for the party intended to consume the assertion (i.e., the RP). An assertion can contain more than one audience identifier at FAL1. (3) Issuance time: A timestamp that indicates when the IdP issued the assertion. (4) Validity time window: A period of time outside of which the assertion SHALL NOT be accepted as valid by the RP for the purposes of authenticating the subscriber and starting an authenticated session at the RP. This is usually communicated by means of an expiration timestamp for the assertion in addition to the issuance timestamp. (5) Assertion identifier: A value that uniquely identifies this assertion and is used to prevent attackers from replaying prior assertions. (6) Authentication time: A timestamp that indicates when the IdP last verified the presence of the subscriber at the IdP through a primary authentication event. (7) Signature: Digital signature or MAC, including verification key identifier, that covers the entire assertion.	Determine whether assertions generated contain at least this list of required fields with appropriate values and that the assertion's contents are covered by the signature.	Test by generating a test assertion for a test RP. Examine the assertion for all required fields and verify their contents.	4.9 C	IdP	ALL	This criterion presents all of the elements required in every assertion. Each element provides a different and vital piece of information for the secure conveyance of the identity information. Assertions can contain additional information, whether about the subscriber or about the authentication event itself, but these fields are all required at all FALs.

NIST SP 800-63-4 Conformance Criteria v0.1: 63C

Control Identifier	Control Name	Control Text	Objective	Assessment Method	Index	Target	Profile/XAL Level	Discussion
ARTC-4	Subscriber Identification in Non-Ephemeral Assertions	If the RP subscriber account does not use an ephemeral provisioning process, the subscriber SHALL be identified in the assertion using a federated identifier (see Sec. 3.4) or through an account resolution process (see Sec. 3.8.2).	Determine whether the subscriber is identified in the assertion using a federated identifier or through attributes sufficient for account resolution, when the RP subscriber account does not use ephemeral provisioning.	Examine sample assertions to determine which subscriber identification information they include for IdPs. If a federated identifier is used, satisfied by ARTC-5 (subject identifier) and FEDID-1. If account resolution is used, examine the trust agreement artifact(s) for the agreed-upon attributes used for resolution, then examine a sample of assertions to confirm that those attributes are present. For RPs, if a federated identifier is used, satisfied by FEDID-2. If account resolution is used, satisfied by ACCR-1.	4.9 D	IdP/RP	ALL	Assessment is required when: The RP subscriber account does not use an ephemeral provisioning process.
ARTC-5	Subject Identifier in Assertion	If the subscriber is identified using a federated identifier, the assertion SHALL include: Subject Identifier: An identifier for the party to which the assertion applies (i.e., the subscriber).	Determine whether the assertion includes a subject identifier when the subscriber is identified using a federated identifier.	Examine the IdP's assertion generation configuration to verify that a subject identifier is included in assertions when federated identifiers are the subscriber identification method.	4.9 E	IdP	ALL	Assessment is required when: The subscriber is identified using a federated identifier. The subject identifier is separated from the unconditional assertion requirements in ARTC-3 because subscriber-controlled wallets acting as IdPs may not include a subject identifier in their assertions. For example, mobile driver's licenses may identify the subscriber through the driver's license number and issuer rather than a subject identifier. This control ensures a subject identifier is present when federated identifiers are the identification method.
ARTC-6	xAL Information in Assertion or Trust Agreement	The following aspects of the federation transaction SHALL be provided through information contained in the assertion contents or the applicable trust agreement: (1) The IAL as well as the type of verification used during the identity proofing process (e.g., biometric, address verification), an indication of the identity proofing processes used to establish the subscriber account, or an indication that no IAL is asserted. (2) The AAL used when the subscriber authenticated to the IdP or an indication that no AAL is asserted. (3) The IdP's intended FAL of the federation process represented by the assertion.	Determine whether all required xAL information is conveyed through the assertion contents or trust agreement artifact(s).	Examine sample assertions where IAL and AAL are asserted. For IAL, verify that the verification method used during identity proofing (e.g., biometric, home address verification, cell phone verification) is provided. Also verify that the proofing process(es) used to establish the subscriber account are indicated. Where multiple proofing pathways are possible at a given IAL, the information provided must be sufficient for the RP to determine which process was used. The conveyance of the IAL is satisfied by RXAL-3. For AAL, satisfied by RXAL-4. For FAL, satisfied by RXAL-5.	4.9 F	IdP	ALL	The IAL alone tells the RP the level of identity proofing, but not how it was achieved. SP 800-63A-4 defines multiple proofing pathways at each IAL, each with a different risk profile. Without the verification type and proofing pathway, the RP cannot make fine-grained, risk-informed access decisions; it can only make a binary accept/reject decision based on the IAL number. This control ensures the IdP provides that granularity.

NIST SP 800-63-4 Conformance Criteria v0.1: 63C

Control Identifier	Control Name	Control Text	Objective	Assessment Method	Index	Target	Profile/XAL Level	Discussion
ARTC-7	Cryptographic Nonce	At FAL2 and above, the assertion SHALL include: 1. Nonce: A cryptographic nonce from the RP's federation request.	Determine whether FAL2 and FAL3 assertions include a cryptographic nonce from the RP's federation request.	Examine the sample assertions to verify that each contains a cryptographic nonce. Verify that the nonce in the assertion corresponds to the nonce provided in the RP's federation request (see ARTRQ-1).	4.9 G	IdP	FAL2/FAL3	The nonce is a mechanism by which FAL2 achieves its defining security property: assertion injection protection (see FAL2-1). It cryptographically binds the RP's specific federation request to the resulting assertion, preventing an attacker from injecting a captured or manufactured assertion into a different transaction. The requirement operates as a three-part chain: the RP sends a nonce in its request (ARTRQ-1, Sec. 4.10 A), the IdP echoes it in the assertion (this control), and the RP validates its presence (ARTC-10 item 5). In the errata publication, this control will be changed to: At FAL2 and above, the assertion SHALL include the cryptographic nonce from the RP's federation request.
ARTC-8	FAL3 Assertion Mechanism	At FAL3, the assertion SHALL include one of the following: (1) The public key, key identifier, or other identifier for a holder-of-key assertion; or (2) An indicator that the verification of a bound authenticator is required to process this assertion	Determine whether FAL3 assertions meet holder-of-key or bound authenticator requirements.	Holder-of-key assertions: Satisfied by HKA-1. Bound authenticators: Satisfied by BAUTH-1.	4.9 H	IdP	FAL3	FAL3 achieves its defining security property, subscriber authentication at the RP as well as at the IdP, through one of two mechanisms: holder-of-key assertions or bound authenticators. The assertion must signal which mechanism is in use so the RP knows which verification path to execute.
ARTC-9	Prohibition of Authentication Secrets in Assertions	Assertions SHALL NOT contain subscriber authentication secrets (e.g., passwords).	Determine whether the IdP's assertions exclude subscriber authentication secrets.	Examine sample assertions to verify that no subscriber authentication secrets are present, including but not limited to passwords, shared secrets, or other authenticator values. Verify that the IdP's assertion generation process has no mechanism or configuration that would embed authentication secrets in assertion payloads.	4.9 I	IdP	ALL	Assertions are an identity conveyance mechanism, not an authentication credential. Including authentication secrets in an assertion would expose them to the RP and any intermediary that processes the assertion, creating a direct credential compromise vector. HKA-5 (Sec. 3.15) addresses the narrower case of prohibiting unencrypted private or symmetric keys in holder-of-key assertions. This control covers the general case across all assertion types and all categories of authentication secrets.

NIST SP 800-63-4 Conformance Criteria v0.1: 63C

Control Identifier	Control Name	Control Text	Objective	Assessment Method	Index	Target	Profile/XAL Level	Discussion
ARTC-10	RP Assertion Validation Checklist	The RP SHALL validate the assertion by checking that all of the following are true: (1) Signature validation: Ensure that the signature of the assertion is valid and corresponds to a verification key that belongs to the IdP sending the assertion. (2) Issuer verification: Ensure that the assertion was issued by the expected IdP. (3) Time validation: Ensure that the validity time window is within acceptable limits of the current timestamp. (4) Audience restriction: Ensure that this RP is the intended recipient of the assertion. (5) Nonce: Ensure that the cryptographic nonce included in the RP's request (if applicable) is included in the presentation. (6) Transaction terms: Ensure that the IAL, AAL, and FAL represented by the assertion are allowable under the applicable trust agreement and are suitable for the RP's needs. (7) Assertion identifier: Ensure that the assertion has not been replayed within its validity time window at this RP.	Determine whether the RP validates all required elements of an assertion before accepting it.	Verify that the RP's assertion validation process includes all of the following checks: (1) Signature validation, satisfied by FAL1-2. (2) Issuer verification, satisfied by ASRP-1 (b). (3) Time validation: Examine the RP's assertion processing logic to confirm it compares the assertion's issuance time and expiration against the current timestamp and rejects assertions outside the validity window. (4) Audience restriction, satisfied by AUDR-2. (5) Nonce validation (required at FAL2 & FAL3): Test by doing the following: (a) Generate a test federation transaction at FAL2 or above and capture the nonce sent in the RP's federation request. (b) Verify the RP accepts an assertion containing the matching nonce. (c) Present an otherwise valid assertion containing a different nonce value - verify rejection. (d) Present an otherwise valid assertion with the nonce omitted - verify rejection. (6) Transaction terms: Examine the xAL terms established in the trust agreement artifact(s) (see TRUST-7) and ensure that the RP is configured to only accept those xALs. Suitability terms are satisfied by RXAL-8. (7) Assertion identifier: satisfied by FAL1-5.	4.9 J	RP	ALL	This control consolidates the RP's assertion validation obligations into a single checklist. Items 1, 2, 4, 6b, and 7 defer to dedicated controls; the unique assessment work here is time validation (item 3), nonce validation (item 5), and trust agreement xAL conformance (item 6a).
ARTC-11	Subject ID Uniqueness	An RP that uses the federated identifier to identify the subscriber SHALL NOT treat subject identifiers as inherently globally unique across IdPs.	Determine whether an RP treats the same subject identifier from different IdPs as different accounts.	Examine the RP's code, configuration, and documentation to verify that subject identifiers are always interpreted in the context of the IdP that asserted them. Test by configuring two test IdPs to assert the same subject identifier. Submit an assertion from each IdP to the RP. Verify that the RP creates two distinct subscriber accounts and does not associate them.	4.9 K	RP	ALL	Assessment is required when: The RP uses the federated identifier to identify the subscriber. Even if an IdP uses a collision-resistant namespace such as a UUID for its subscriber identifiers, the tying of a specific identifier to a particular subscriber is still under the control of the IdP making the assertion. An RP's internal processing of an assertion needs to take this into account by processing the combination of the subject identifier along with the IdP that issued the assertion. If the RP does not account for the source IdP when determining the identity of the subscriber, a rogue or compromised IdP could impersonate subscribers from another IdP at a susceptible RP by mimicking the valid IdP's subject identifiers.

NIST SP 800-63-4 Conformance Criteria v0.1: 63C

Control Identifier	Control Name	Control Text	Objective	Assessment Method	Index	Target	Profile/XAL Level	Discussion
ARTC-12	RP Session Time Independent of Assertion	Assertion validity time windows SHALL NOT be used to limit the session at the RP. See Sec. 4.7 for more information.	Determine whether the RP manages its session lifetime independently of the assertion validity time window.	Examine the RP's session management configuration to confirm the session timeout is set by RP policy, and is not the same as the assertion's expiration timestamp. Test by authenticating via federation and establishing an RP session. Confirm that the RP session remains valid after the assertion's validity window has expired.	4.9 L	RP	ALL	The assertion validity window exists solely for the RP to process the assertion and create a local session; it is not a session duration directive from the IdP. Section 4.7 establishes that assertion validity, IdP session lifetime, and RP session lifetime are three independent time periods. An RP that terminates sessions when the assertion expires would force unnecessary reauthentication and effectively let the IdP dictate RP session policy. RP session management requirements are governed by SP 800-63B Section 5 (Session Management).
ARTRQ-1	Assertion Request Requirements	When the federation transaction is initiated by the RP, the RP's request for an assertion SHALL contain: (1) An identifier for the RP. (2) A cryptographic nonce to be returned in the assertion.	Determine if the RP includes the required identifier and cryptographic nonce in requests for an assertion.	Examine the RP's federation configuration to confirm that it sends its identifier and a cryptographic nonce in all assertion requests. Test by initiating a request for an assertion. Examine the request and verify that the request contains a unique identifier for the RP and a cryptographic nonce.	4.10 A	RP	ALL	The cryptographic nonce binds the assertion to the specific request, preventing replay and injection attacks. The RP's request should also contain the set of requested attributes and their purpose, and the authentication event requirements.
BCP-1	Tamper & Fabrication Resistant Assertion References	The assertion reference itself contains no information about the subscriber and SHALL be resistant to tampering and fabrication by an attacker.	Determine whether the IdP generates and manages assertion references such that they are resistant to tampering and fabrication by an attacker.	Examine the IdP's assertion reference design and generation process to verify that the assertion reference contains no subscriber information. Verify the reference is generated and managed in a way that resists tampering and fabrication by an attacker (e.g., cryptographic randomness with sufficient entropy, or cryptographic integrity protection). Test by obtaining a valid assertion reference, modifying it, and presenting the modified value to the IdP. Verify rejection. Present a fabricated reference not issued by the IdP. Verify rejection.	4.11.1 A	IdP	ALL	Assessment is required when: A back-channel presentation is used. Assertion references are used to limit the information that is exposed to different parties within the federation transaction, such as the user's browser. As a consequence, it is counterproductive to put any information about the subscriber in the assertion reference itself. Additionally, since the RP will trade the assertion reference for the actual assertion, the assertion reference needs to be something that an attacker can neither guess nor manipulate in order to alter the assertion received. It is recommended that assertion references be cryptographically random values.
BCP-2	RP-Specific Assertion Reference	The assertion reference: 1. SHALL be limited to use by a single RP.	Determine whether the IdP enforces a binding between each issued assertion reference and exactly one designated Relying Party, ensuring that the reference can only be used by a single RP.	Satisfied by BCP-10.	4.11.1 #1	IdP	ALL	<i>Assessment is required when: A back-channel presentation is used.</i> Since assertion references are traded for assertions, the IdP needs to ensure that the assertion reference is presented only by the specific RP to which it was issued. Otherwise, an attacker could capture an assertion reference and inject it into a different RP to fake a log in. This requirement applies even if the RPs are logistically related, such as being configured to receive a common identifier. If assertion references are not used, this requirement does not apply.

NIST SP 800-63-4 Conformance Criteria v0.1: 63C

Control Identifier	Control Name	Control Text	Objective	Assessment Method	Index	Target	Profile/XAL Level	Discussion
BCP-3	Single-use Assertion Reference	The assertion reference: 2. SHALL be single-use.	Determine whether assertion references can be successfully used only once.	Examine the IdP's assertion reference lifecycle configuration to confirm that the IdP maintains a state record for each issued reference. Verify that references are invalidated (e.g., flagged or deleted) upon first successful redemption. Test by obtaining a valid assertion reference and redeeming it once through the IdP's assertion-resolution endpoint. Attempt a second redemption of the same reference; verify that the IdP rejects the request (e.g., returns an error such as "invalid_reference," "expired," or "already_used").	4.11.1 #2	IdP	ALL	<i>Assessment is required when: A back-channel presentation is used.</i> The IdP is responsible for ensuring that once an assertion reference has been redeemed (i.e., used by the designated Relying Party to obtain the assertion), it cannot be used again. This control prevents replay attacks and the unauthorized reuse of valid assertion references by an attacker or another RP session.
BCP-4	Assertion Reference Time Limitation	The assertion reference: 3. SHALL be time-limited.	Determine whether assertion references are time-limited.	Examine the IdP's federation protocol configuration (e.g., authorization code lifetime in OIDC, artifact validity window in SAML) to identify the configured assertion reference lifetime. Test by completing a back-channel federation transaction up to the point where the test RP receives the assertion reference, but do not immediately redeem it. Wait beyond the configured lifetime, then have the test RP present the reference to the IdP. Confirm that the IdP rejects the expired reference.	4.11.1 #3	IdP	ALL	<i>Assessment is required when: A back-channel presentation is used.</i> The assertion reference is a temporary artifact whose sole purpose is to allow the RP to retrieve the full assertion from the IdP. A short lifetime limits the window for interception, replay, or misuse. The guidelines recommend (SHOULD) a validity window of no more than five minutes.
BCP-5	RP Authentication at Assertion Reference Redemption	The assertion reference: 4. SHALL be presented along with authentication of the RP to the IdP.	Determine whether the RP authenticates itself to the IdP when presenting the assertion reference.	Examine the RP's federation configuration to confirm that the RP authenticates to the IdP when redeeming assertion references.	4.11.1 #4	RP	ALL	<i>Assessment is required when: A back-channel presentation is used.</i> RP authentication at the point of assertion reference redemption prevents an attacker who intercepts or steals an assertion reference from redeeming it at the IdP. Without RP authentication, possession of the reference alone would be sufficient to obtain the full assertion.
BCP-6	Assertion Reference Security	The assertion reference: 5. SHALL NOT be predictable or guessable by an attacker.	Determine whether assertion references are generated in a manner that prevents prediction or guessing by an attacker.	Examine the IdP documentation describing the assertion reference generation mechanism to confirm it uses an approved random bit generator or equivalent method that produces values with at least 112 bits of security strength per SP 800-131A.	4.11.1 #5	IdP	ALL	<i>Assessment is required when: A back-channel presentation is used.</i> This control complements BCP-1, which requires tamper and fabrication resistance. BCP-1 addresses integrity protection of assertion references; this control addresses the unpredictability of their values. Together they ensure an attacker can neither guess a valid reference nor modify an intercepted one.

NIST SP 800-63-4 Conformance Criteria v0.1: 63C

Control Identifier	Control Name	Control Text	Objective	Assessment Method	Index	Target	Profile/XAL Level	Discussion
BCP-7	Subscriber Back-Channel Protection	Conveyance of the assertion reference from the IdP to the subscriber and from the subscriber to the RP SHALL be made over an authenticated protected channel.	Determine whether the delivery of the assertion reference occurs over authenticated protected channels, across all connections.	Examine the endpoint configuration to confirm that assertion reference exchange occurs only over authenticated protected channels. (e.g., HTTPS/TLS). Test by attempting to convey the assertion reference from the IdP to the subscriber and from the subscriber to the RP over an unprotected channel (e.g., plain HTTP) and verify that each attempt fails, is rejected, or the connection is refused. A protocol-specific error is not required if the endpoints refuse unprotected connections entirely.	4.11.1 B	IdP/RP	ALL	Assessment is required when: A back-channel presentation is used. In this model, the assertion reference is passed through the front channel using the subscriber's browser. This process consists of two separate network connections over which information flows, from the subscriber to the IdP and the subscriber to the RP. Both legs of this connection have to be protected from attackers by using authenticated protected channels, such as HTTPS over TLS connections.
BCP-8	RP-IdP Back-Channel Protection	Conveyance of the assertion reference from the RP to the IdP and vice versa SHALL be made over an authenticated protected channel.	Determine whether the connection between the RP and IdP takes place over an authenticated protected channel.	Examine the relevant federation configuration to verify that assertion references are conveyed between the RP and IdP only over authenticated protected channels. Test by attempting to convey the assertion reference between the RP and IdP over an unprotected channel (e.g., plain HTTP) and verify that the attempt fails, is rejected, or the connection is refused.	4.11.1 C	IdP/RP	ALL	<i>Assessment is required when: A back-channel presentation is used.</i> In this model, the assertion reference is traded for the assertion by the RP making a direct call to the IdP. This call, which carries both the assertion reference and the assertion itself, needs to be protected from attackers by using an authenticated protected channel, such as HTTPS over TLS connections.
BCP-9	Assertion Reference Injection Prevention	The RP SHALL protect itself against the injection of manufactured or captured assertion references by using cross-site scripting (XSS) and cross-site request forgery (CSRF) protection, rejecting assertion references outside of the correct stage of a federation transaction, or other accepted techniques discussed in Sec. 3.11.1.	Determine whether the RP employs best practices for its platform to protect against injection of assertion references.	Examine the RP's federation implementation to verify that it protects against assertion reference injection through XSS and CSRF protections, rejection of assertion references outside the correct stage of the federation transaction, and other RP-side countermeasures such as request correlation, nonce use, and transaction state tracking. Test by initiating a federation transaction in one RP session, capturing the resulting assertion reference, and submitting that assertion reference in a different RP session that has a different session identifier and unrelated transaction state. Verify that the RP rejects the assertion reference and does not complete the federation transaction.	4.11.1 D	RP	ALL	Assessment is required when: A back-channel presentation is used. The assertion reference needs to be delivered to the RP in some fashion, and for many protocols this happens through a front-channel redirect through the subscriber's browser. The RP needs to ensure that any assertion references presented to it are legitimate by protecting itself against common injection attacks. The techniques for protection vary depending on the type of RP application and its deployment model, but there are many resources and documented best practices for different applications and platforms. For example, ensuring that the assertion reference is returned in the same browser session that was used to request the assertion reference in the front channel. Without these protections, an attacker could convince an RP to trade an injected (but otherwise valid) assertion reference and therefore get a fraudulent assertion and give the attacker access to the RP.

NIST SP 800-63-4 Conformance Criteria v0.1: 63C

Control Identifier	Control Name	Control Text	Objective	Assessment Method	Index	Target	Profile/XAL Level	Discussion
BCP-10	RP-Assertion Reference Binding	When assertion references are presented to the IdP, the IdP SHALL verify that the RP presenting the assertion reference is the same RP that made the assertion request that resulted in the assertion reference.	Determine whether an assertion reference is bound to a single RP identified by the IdP.	Examine IdP documentation to ensure the IdP verifies the RP presenting the assertion reference using client credentials, PKCE, or alternative mechanism providing equivalent protections.	4.11.1 E	IdP	ALL	Assessment is required when: A back-channel presentation is used. Before issuing an assertion to the RP in exchange for the assertion reference, the IdP needs to ensure that the RP making the exchange request is the same RP that the assertion reference was intended for. Otherwise, an attacker could substitute an assertion reference for one RP in order to get an assertion for a different RP, or trick the subscriber into authorizing one RP only to authorize the attacker's RP. The IdP can do this by associating a specific RP with the assertion reference when the reference is created.
FCP-1	Front-Channel Assertion Replay Protection	The RP SHALL use the assertion identifier to ensure that a given assertion is presented at most once during the assertion's validity time window.	Determine whether the RP uses the assertion identifier to prevent replay within the assertion's validity time window.	Satisfied by FAL1-5.	4.11.2 A	RP	ALL	<i>Assessment is required when: Front-channel presentation is used.</i> Front-channel presentation passes the full assertion through the subscriber's browser (user agent), increasing the risk of capture and replay. This requirement mandates that the RP track assertion identifiers to ensure each assertion is accepted at most once within its validity window.
FCP-2	RP Front-Channel Injection Protection	The RP SHALL protect itself against the injection of manufactured or captured assertions by using XSS and CSRF protection, rejecting assertions outside of the correct stage of a federation transaction, or other accepted techniques discussed in Sec. 3.11.1.	Determine whether the RP employs best practices for its platform to protect against the injection of assertions.	Examine the RP's federation implementation for XSS and CSRF protections, session-binding of federation transactions, and other injection countermeasures appropriate to the platform Test by capturing an assertion for the RP and injecting it into an unrelated active session at the RP. Ensure that the RP does not accept the injected assertion.	4.11.2 B	RP	ALL	Assessment is required when: Front-channel presentation is used. The assertion needs to be delivered to the RP in some fashion, and for many protocols, this happens through a front-channel redirect through the subscriber's browser. The RP needs to ensure that any assertions presented to it are legitimate by protecting itself against common injection attacks. The techniques for protection vary by RP application and deployment model, but there are many resources and documented best practices for different applications and platforms. Without these protections, an attacker could convince an RP to accept an injected (but otherwise valid) assertion and gain access to the subscriber's account at an RP.

NIST SP 800-63-4 Conformance Criteria v0.1: 63C

Control Identifier	Control Name	Control Text	Objective	Assessment Method	Index	Target	Profile/XAL Level	Discussion
FCP-3	Subscriber Front-Channel Protection	Conveyance of the assertion from the IdP to the subscriber and from the subscriber to the RP SHALL be made over an authenticated protected channel.	Determine whether the connections between the subscriber and the RP as well as the subscriber and IdP take place over an authenticated protected channel.	Examine the assessed party's front-channel federation endpoints to confirm they require authenticated protected channels (e.g., HTTPS/TLS) and that connections over non-protected channels are refused. Test by initiating a front-channel federation transaction targeting the assessed party's endpoints. Verify the connection uses an authenticated protected channel. Attempt to connect to the assessed party's front-channel endpoints over a non-protected channel (e.g., plain HTTP) and verify the request is rejected, or the connection is refused.	4.11.2 C	IdP/RP	ALL	<i>Assessment is required when: Front-channel presentation is used.</i>
FCP-4	Front-Channel Personal Information Protection	As a consequence, an IdP that uses HTTP redirects for the front-channel presentation of assertions SHALL encrypt all personal information in the assertion, as discussed in Sec. 3.13.3.	Determine whether any personal information in assertions that is passed through the front channel is encrypted.	Examine the IdP's assertion generation configuration to confirm that assertions delivered via front-channel presentation encrypt all personal information. For encryption mechanism requirements, see ENCA-1. Test by generating a test assertion containing personal information via a front-channel presentation mechanism. Examine the assertion payload as transmitted through the front channel and verify that all personal information is encrypted.	4.11.2 D	IdP	ALL	<i>Assessment is required when: Front-channel presentation is used.</i> Front-channel presentation passes the assertion through the subscriber's browser, exposing it to intermediaries. Encryption ensures that even if the assertion is intercepted, personal information remains protected. ENCA-1 assesses the encryption mechanism; this control verifies that encryption is applied when front-channel delivery is used.
IABSCW-1	Wallet Attribute Bundle Issuance Process	When the CSP issues attribute bundles to the subscriber-controlled wallet, the process SHALL include the following steps: (1) The subscriber proves their identity to the CSP's issuance functionality using the CSP's identity proofing process or by authenticating to the subscriber account. (2) The subscriber activates the wallet using an activation factor, which might entail authenticating to a hosted wallet service. (3) The wallet generates or chooses a signing key and corresponding verification key. The wallet proves possession of its signing key to the CSP. (4) The CSP creates one or more attribute bundles that include subscriber attributes and the wallet's verification key (or a reference to that key). (5) The wallet stores the attribute bundle for later presentation to RPs.	Determine whether the CSP's issuance process requires the subscriber to prove their identity and prove possession of a wallet-generated key before an attribute bundle is issued.	Examine the following: (1) The CSP's issuance process to confirm it requires subscriber identity verification (via identity proofing or authentication) before bundle creation. Identity proofing requirements are assessed under SP 800-63A; authentication requirements are assessed under SP 800-63B. (2) The CSP's documentation to confirm that the CSP has evaluated that the target wallet platform enforces activation factor requirements before permitting signing key operations. Wallet activation requirements are assessed separately under Section 5.4 controls. (3) The CSP's issuance protocol to confirm it requires and validates proof of possession of the wallet's signing key before creating the attribute bundle. (4) The CSP's bundle creation process to confirm the resulting attribute bundle includes subscriber attributes and the wallet's verification key or a reference to it. Attribute bundle content requirements are assessed under the ABUN series (Section 3.12.1). (5) The CSP's delivery mechanism to confirm the bundle is transmitted to the requesting wallet.	5.1 A	CSP	ALL	This is a process-level control covering the end-to-end issuance process from the CSP's perspective. SP 800-63C-4 uses the terms "signing key" and "verification key" throughout Section 5 rather than the "private key" and "public key" terminology used in other NIST cryptographic standards. The signing key is the wallet's private key used to sign assertions; the verification key is the corresponding public key. The CSP cannot observe wallet activation at runtime but can control which wallet platforms it issues to. Before issuing attribute bundles to a given wallet platform, the CSP should verify that the platform enforces activation requirements. This may involve reviewing wallet platform documentation, security certifications, or independent security evaluations.

NIST SP 800-63-4 Conformance Criteria v0.1: 63C

Control Identifier	Control Name	Control Text	Objective	Assessment Method	Index	Target	Profile/XAL Level	Discussion
IABSCW-2	Attribute Bundle Uniqueness	The CSP SHALL create a unique attribute bundle for each requesting wallet.	Determine whether the CSP creates a unique attribute bundle for each requesting wallet.	Examine the CSP's attribute bundle issuance process to verify that each bundle is uniquely bound to the requesting wallet (e.g., by including the wallet's verification key per IABSCW-1 #4). Test by requesting attribute bundles from the CSP using two different wallets for the same subscriber. Compare the bundles and verify they are distinct.	5.1 B	CSP	ALL	
IABSCW-3	Multi-CSP Attribute Bundle Assertion Conformance	The simultaneous presentation of attribute bundles from multiple CSPs in a single assertion is possible with some technologies. When this occurs, the assertion of multiple attribute bundles SHALL conform to the assertion requirements in this guideline.	Determine whether assertions containing attribute bundles from multiple CSPs conform to assertion requirements.	When an assertion contains attribute bundles from multiple CSPs, satisfied by the IdP-directed requirements in ARTCN-1 to ARTCN-6 and ARTCN-12 (Sec. 5.8).	5.1 C	IdP	ALL	<i>Assessment is required when: The wallet presents attribute bundles from multiple CSPs in a single assertion.</i> If a wallet allows combining attribute bundles from different CSPs into a single assertion (e.g., a driver's license from one CSP and professional credentials from another), each bundle must be individually validated per the assertion requirements, regardless of how many are combined.
INVABSCW-1	Attribute Bundle Invalidation Capability	The CSP SHALL provide a means of invalidating attribute bundles that are issued to a subscriber-controlled wallet.	Determine whether the CSP provides a means of invalidating attribute bundles issued to subscriber-controlled wallets.	Examine CSP documentation for a defined invalidation process covering at minimum the three scenarios identified in Sec. 5.1.1: subscriber account termination, wallet termination due to loss/theft/compromise, and attribute bundle compromise or disclosure to an attacker. Test by issuing an attribute bundle to a test wallet. Next, invoke the CSP's invalidation process for that bundle. Verify that the CSP's systems reflect the bundle as invalidated (e.g., marked as invalid in the CSP's status registry or list, removed from active bundle records, or otherwise flagged as invalid).	5.1.1 A	CSP	ALL	Attribute bundle invalidation is used when: -The subscriber account is terminated, thereby rendering downstream federation actions invalid; -The wallet needs to be terminated due to the device being lost, stolen, or compromised; or -The attribute bundle is disclosed to an attacker or otherwise compromised.
INVABSCW-2	Attribute Bundle Status Verification Privacy	The CSP SHOULD provide a means to independently verify the status of attribute bundles (i.e., whether a specific bundle has been revoked by the CSP). If such a service is offered, the service SHALL be deployed in a privacy-preserving way such that the CSP is not alerted to the use of a specific attribute bundle at a specific RP.	Determine whether the CSP's attribute bundle status verification service is deployed in a privacy-preserving manner that does not alert the CSP to the use of a specific attribute bundle at a specific RP.	Examine the architecture and design documentation for the status verification service. Verify that the service design does not enable the CSP to correlate a specific attribute bundle with a specific RP. Identify the privacy-preserving mechanism in use (e.g., status lists, batch download of revocation data).	5.1.1 B	CSP	ALL	<i>Assessment is required when: The CSP offers an attribute bundle status verification service.</i> Status verification mechanisms where the RP queries the CSP directly with a specific bundle identifier (e.g., standard OSCP) would fail this requirement because the CSP can correlate the querying RP's network identity with the specific bundle being checked, revealing which RP the subscriber visited. Privacy-preserving alternatives include mechanisms where the RP downloads a complete status dataset and checks bundle status locally, preventing the CSP from learning which specific bundle was checked. One example is the W3C Bitstring Status List.

NIST SP 800-63-4 Conformance Criteria v0.1: 63C

Control Identifier	Control Name	Control Text	Objective	Assessment Method	Index	Target	Profile/XAL Level	Discussion
TAGREE-1	Wallet Runtime Attribute Release	1. The release of subscriber attributes SHALL be managed using a runtime decision managed by the wallet, as described in Sec. 4.6.1.3.	Determine whether the wallet manages attribute release using runtime decisions as described in Sec. 4.6.1.3.	Satisfied by IDPRD-1 through IDPRD-8, treating the wallet as the IdP. These controls apply unconditionally in the wallet context, regardless of whether the RP is on an allowlist.	5.3 #1	IdP	ALL	Due to the architectures and design of subscriber-controlled wallets, the trust agreements that support federated transactions are less direct than with general-purpose IdPs. To maintain privacy outcomes and prevent the tracking of user transactions, CSPs and RPs do not typically have direct communication with each other. Unlike the general IdP case (Sec. 4.6.1.3), where allowlisting an RP can bypass the runtime decision, wallet attribute release always requires a runtime decision regardless of whether an allowlist is used. An allowlist in the wallet context may constrain which RPs can request attributes, but the subscriber still approves release at transaction time. TAGREE-2 establishes that the authorized party for this decision is the subscriber.
TAGREE-2	Wallet Authorized Party	2. The authorized party SHALL be the subscriber.	Determine whether the wallet designates the subscriber as the authorized party for attribute release decisions.	Examine the wallet documentation to verify that the subscriber is the party making the attribute release decisions.	5.3 #2	IdP	ALL	In the general IdP case, the trust agreement identifies the authorized party, which may be the subscriber, an administrator, or another surrogate. For subscriber-controlled wallets, the authorized party is always the subscriber.
TAGREE-3	Wallet Runtime Decision Disclosure Terms	3. The following terms SHALL be disclosed to the subscriber during the runtime decision: (a) The set of subscriber attributes, derived attributes, and attribute bundles that the RP will request (a subset of the attributes made available). (b) The purpose of each attribute requested by the RP.	Determine whether the wallet discloses the required terms to the subscriber during the runtime decision.	Examine the runtime decision screen(s) to verify that it is designed to display the required disclosure terms. Test by initiating a transaction that triggers a runtime decision. Verify that the following information is disclosed to the subscriber: (1) the attributes the RP will request (see also IDPRD-3), and (2) the purpose of the requested attributes	5.3 #3	IdP	ALL	All information disclosed to the subscriber needs to be conveyed in a manner that is understandable and actionable, as discussed in Sec. 8.
CR-1	Federation Authority Wallet Ecosystem Trust Agreement Contents	Such trust agreements SHALL contain: (a) The set of subscriber attributes and derived attributes that the CSP makes available to wallets in attribute bundles. (b) The set of subscriber attributes and derived attributes that the wallet can make available to the RP. (c) The population of subscriber accounts that the CSP can represent. (d) The IALs or issuance processes of subscriber accounts that are associated with the attribute bundles from the CSP. (e) The issuance process related to CSP attribute bundles. (f) The FALs supported by subscriber-controlled wallets. (g) The allowable purposes for each attribute RPs may request. (h) Expectations of RPs for the protection and management of subscriber data provided through attribute bundles.	Determine whether the federation authority's trust agreement artifacts for a subscriber-controlled wallet ecosystem contains the required terms.	Examine the federation authority trust agreement artifact(s) to verify all required terms are present.	5.3.1 A	Federation Authority	ALL	Assessment is required when: The trust relationship between the RP and CSP is facilitated by a federation authority. In subscriber-controlled wallet ecosystems, the CSP and RP typically do not communicate directly. A federation authority can bridge this gap by defining ecosystem-wide trust agreement artifact(s) that govern the relationships among RPs, CSPs, and wallets.

NIST SP 800-63-4 Conformance Criteria v0.1: 63C

Control Identifier	Control Name	Control Text	Objective	Assessment Method	Index	Target	Profile/XAL Level	Discussion
CR-2	CSP Publication of Wallet Ecosystem Information	CSPs SHALL publish the following information to a trusted location for RPs to evaluate: (a) The set of subscriber attributes and derived attributes that the CSP makes available to wallets in attribute bundles. (b) The set of subscriber attributes and derived attributes that the wallet can make available to the RP. (c) The population of subscriber accounts that the CSP can represent. (d) The IALs or issuance processes of subscriber accounts associated with the attribute bundles from the CSP.	Determine whether the CSP publishes the required information to a location accessible to RPs for evaluation.	Examine the CSP-published information at the identified location to verify all required information is present. The assessor should verify the location is accessible to RPs and that the information is current.	5.3.1 B	CSP	ALL	Assessment is required when: Trust is established unilaterally by RP evaluation of publicly available CSP information (i.e., no federation authority facilitates the trust relationship). The CSP defines the boundaries of attribute disclosure through its trust agreement artifact(s) with the wallet (see Sec. 5.3.2). The bundle may contain more attributes than any single RP is authorized to receive; selective disclosure technology allows the wallet to reveal different subsets to different RPs without reissuance. "The set of subscriber attributes and derived attributes that the CSP makes available to wallets in attribute bundles" reflects the full set issued by the CSP, while "The set of subscriber attributes and derived attributes that the wallet can make available to the RP" reflects the subset the wallet is authorized to disclose. This information may also be published through a federation authority's discovery service (see Sec. 5.3.1).
CSCW-1	CSP-Wallet Trust Agreement	There SHALL be a trust agreement between the CSP and the subscriber-controlled wallets into which they issue attribute bundles.	Determine whether a trust agreement exists between the CSP and the subscriber-controlled wallets to which it issues attribute bundles.	For CSPs: Examine documentation to identify trust agreement artifact(s) governing the relationship with subscriber-controlled wallets. Verify the agreement exists prior to issuance of attribute bundles. For wallets (IdPs): Examine documentation to identify trust agreement artifact(s) governing the relationship with the CSP(s) from which it receives attribute bundles.	5.3.2 A	CSP/IdP	ALL	CSCW-2 specifies the minimum required contents of this trust agreement.
CSCW-2	CSP-Wallet Trust Agreement Requirements	At a minimum, this trust agreement SHALL include the following: (1) The set of subscriber attributes and derived attributes that the CSP makes available to wallets in attribute bundles. (2) The set of subscriber attributes and derived attributes that the wallet can make available to the RP. (3) Any processes the subscriber-controlled wallet needs to implement to support the issuance of attribute bundles (e.g., PAD, data collection, risk scoring). (4) Data storage and security practices for the wallet service. (5) The activation factors or AALs that subscribers use to access the wallet service prior to the generation of any assertion. (6) The FALs supported by subscriber-controlled wallets. (7) The allowable purposes or any restrictions that the wallets need to enforce related to the release of attributes to RP.	Determine whether the trust agreement between the CSP and subscriber-controlled wallets contains the minimum required terms.	For CSPs: Examine CSP-published information to verify that terms (1), (3), and (7) are present. For wallets (IdPs): Examine wallet-published information to verify terms (2), (4), (5), and (6) are present.	5.3.2 B	CSP/IdP	ALL	The trust agreement may be composed of information published independently by each party. The CSP publishes what it issues and the constraints it imposes on wallets. The wallet publishes its own capabilities and security practices. Together these constitute the trust agreement.

NIST SP 800-63-4 Conformance Criteria v0.1: 63C

Control Identifier	Control Name	Control Text	Objective	Assessment Method	Index	Target	Profile/XAL Level	Discussion
RSCW-1	Wallet Disclosure to RPs	Subscriber-controlled wallets SHALL disclose to RPs: (1) Activation or authentication methods they use to authenticate subscribers prior to presentation of an assertion. (2) Security features of how the wallet protects the attribute bundles. (3) Key management information. (4) Indications of the integrity of the subscriber-controlled wallet's software.	Determine whether the wallet discloses all required information to RPs.	Examine wallet-published documentation, metadata, or runtime disclosures to verify all four required items are disclosed to RPs. Items (1) and (2) may already be documented under CSCW-2 terms (5) and (4) respectively. Verify that the same information is made available to RPs, not only to the CSP. Items (3) and (4) are unique to this control.	5.3.3 A	IdP	ALL	The RP needs this information to make trust decisions about the wallet presenting attribute bundles. Software integrity indications can be provided through platform-specific attestation mechanisms.
FAL3SCW-1	FAL3 Hosted Wallet: HoK or Bound Authenticator	To reach FAL3, federation transactions with a subscriber-controlled wallet on a hosted service SHALL use either a holder-of-key assertion (see Sec. 3.15) or a bound authenticator (see Sec. 3.16).	Determine whether federation transactions with a hosted subscriber-controlled wallet at FAL3 use either a holder-of-key assertion or a bound authenticator.	For holder-of-key assertions, satisfied by HKA-1 through HKA-5. For assertions that use bound authenticators, satisfied by BAUTH-1 through BAUTH-8.	5.3.4 A	IdP/RP	FAL3	<i>Assessment is required when: A subscriber-controlled wallet on a hosted service is used at FAL3.</i> Device-based subscriber-controlled wallets inherently hold signing keys that can satisfy HoK requirements. Hosted wallets do not, because the subscriber does not directly control the key material. This control requires hosted wallets to bridge that gap through either an additional HoK authenticator separate from the wallet's signing key, or a bound authenticator at the RP. FAL3SCW-2 requires all other FAL3 requirements (Sec. 2.4) to also be met.
FAL3SCW-2	Wallet FAL3 Compliance	All requirements for FAL3 in Sec. 2.4 SHALL be met.	Determine whether federation transactions involving a subscriber-controlled wallet meet all FAL3 requirements specified in Sec. 2.4.	Satisfied by FAL3-1 through FAL3-5.	5.3.4 B	CSP/IdP/RP	FAL3	
WACT-1	Wallet Activation for Signing Operations	The subscriber-controlled wallet SHALL require the presentation of an activation factor from the subscriber for the following actions that result in the creation of a signed artifact from the wallet's signing keys: providing proof of possession of the wallet's signing key to the CSP during the issuance process; and signing the assertion for presentation to the RP.	Determine whether the subscriber-controlled wallet requires presentation of an activation factor from the subscriber before performing signing operations with the wallet's signing keys.	Examine the wallet platform's security architecture documentation to confirm that signing-key operations are gated behind the presentation of an activation factor. Confirm that the architecture does not allow access to the signing key without activation. Test by doing the following: (1) During an attribute bundle issuance flow with a CSP, observe that the wallet prompts the subscriber for an activation factor before completing proof-of-possession of the signing key. (2) During a federation transaction with an RP, observe that the wallet prompts the subscriber for an activation factor before signing the assertion for presentation. (3) For each operation above, dismiss or cancel the activation prompt and confirm that the signing operation does not proceed.	5.4 A	IdP	ALL	The activation factor ensures the subscriber is present and consenting before any signing operation occurs. If the activation factor is a secret (e.g., PIN or password), it must meet the activation secret requirements in SP 800-63B Sec. 3.2.10. If the activation factor is biometric, it must meet the requirements in SP 800-63B Sec. 3.2.3. WACT-2 addresses the requirement that wallet activation be separate from device unlock for device-based wallets.

NIST SP 800-63-4 Conformance Criteria v0.1: 63C

Control Identifier	Control Name	Control Text	Objective	Assessment Method	Index	Target	Profile/XAL Level	Discussion
WACT-2	Wallet Activation Separation from Device Unlock	For subscriber-controlled wallets that run on a device that the subscriber controls, the submission of the activation factor SHALL be a separate operation from the unlocking of the host device (e.g., smartphone), although the same activation factor used to unlock the host device MAY be used in the activation operation. Organizations MAY relax this requirement for subscriber-controlled wallets managed by or on behalf of the CSP (e.g., via mobile device management) and that are constrained to have short, organization-determined inactivity timeouts and device activation factors that meet the above requirements.	Determine whether the subscriber-controlled wallet requires a separate activation operation from host device unlock, or whether the organization qualifies for the MDM relaxation.	Examine the wallet's security architecture documentation to confirm that wallet activation is implemented as an operation distinct from host device unlock. Examine documentation to verify that: (1) The wallet is managed by or on behalf of the CSP (e.g., via MDM); (2) The device is constrained to short, organization-determined inactivity timeouts; and (3) The device activation factors meet the requirements in Sec. 3.2.10 of SP 800-63B-4, if the organization claims the MDM relaxation. If all three conditions are met, device-level controls satisfy the separation requirement. If any condition is not met, the relaxation does not apply, and the base requirement must be assessed. Test by unlocking the host device (e.g., smartphone) using the device unlock mechanism if the MDM relaxation is not claimed or applicable. Test by Immediately initiate a wallet signing operation (issuance or assertion presentation per WACT-1) if the MDM relaxation is not claimed or applicable. Test by confirming the wallet requires a separate activation prompt before proceeding - device unlock alone does not satisfy the wallet activation requirement if the MDM relaxation is not claimed or applicable.	5.4 B	IdP	ALL	<i>Assessment is required when: The subscriber-controlled wallet runs on a device controlled by the subscriber (i.e., not a hosted wallet).</i> The requirement permits the same activation factor (e.g., the same fingerprint or PIN) to be used for both device unlock and wallet activation, provided the wallet requires its own distinct activation event. Activation factor requirements for authenticators are discussed in Sec. 3.2.10 of SP 800-63B-4. The MDM relaxation applies to enterprise or government scenarios where the CSP controls both the identity credential and the device environment. In such cases, device management policies can enforce equivalent security properties at the device level, making a separate wallet activation event redundant. This relaxation does not apply to consumer scenarios where the CSP has no management authority over the subscriber's device.
KS-1	Wallet Signing Key Sync and Sharing Prohibition	Keys used for signing assertions SHALL NOT be synced or shared across devices.	Determine whether wallet signing keys used for assertions are prohibited from being synced or shared across devices.	Examine the wallet's key management architecture, configuration, and subscriber-facing key management features to confirm that signing keys are generated and stored per-device and that no mechanism exists to sync, replicate, or share signing keys across devices (e.g., cloud key sync, cross-device backup, or key export functionality).	5.4.1 A	IdP	ALL	CKS-1 covers general secure key storage requirements under FIPS 140; this control adds the wallet-specific prohibition on key syncing across devices. Non-exportable key storage becomes a SHALL for wallets whose signing key is used as a holder-of-key authenticator at FAL3 (see KS-2). The definition of non-exportable key storage is established in CKS-2.
KS-2	Wallet HoK Signing Key Non-Exportable Storage	If the wallet's signing key is used as a holder-of-key authenticator for FAL3, the key SHALL be stored in non-exportable key storage, as discussed in Sec. 3.6.2.	Determine whether the wallet's signing key, when used as a holder-of-key authenticator for FAL3, is stored in non-exportable key storage.	This is a summative control. Compliance is demonstrated when the requirements of the following controls have been met: (a) CKS-2: Non-Exportable Key Storage Definition (b) CKS-3: Non-Exportable Key Isolation (c) CKS-4: Non-Exportable Storage Immutability	5.4.1 B	IdP	FAL3	Assessment is required when: The wallet's signing key is used as a holder-of-key authenticator for FAL3. KS-1 prohibits key syncing across devices for all wallet signing keys. This control elevates the storage requirement to non-exportable for the specific case of HoK at FAL3.

NIST SP 800-63-4 Conformance Criteria v0.1: 63C

Control Identifier	Control Name	Control Text	Objective	Assessment Method	Index	Target	Profile/XAL Level	Discussion
DISCR-1	CSP Verification Key Determination	To perform a federation transaction with a subscriber-controlled wallet, the RP SHALL first determine the attribute bundle verification key of the CSP through a secure process as stated by the trust agreement.	Determine whether the RP obtains the CSP's attribute bundle verification key through a secure process defined in the trust agreement artifact(s) prior to performing federation transactions with a subscriber-controlled wallet.	Examine the trust agreement artifact(s) to identify the process specified for the RP to obtain the CSP's attribute bundle verification key (e.g., retrieval from a URL controlled by the CSP, manual configuration, or retrieval through a federation authority). Review the RP's configuration to confirm that the CSP's verification key was obtained through the specified process. Confirm that the process used to obtain the key provides authentication of the source (e.g., authenticated protected channel, manual out-of-band verification, or federation authority trust chain).	5.5 A	RP	ALL	This control is the wallet-specific counterpart to DR-1, which covers the RP's association of assertion validation keys with the IdP's identifier. In the wallet model, the trust anchor is the CSP's signature on the attribute bundle rather than the IdP's assertion signature. Sec. 5.5 describes several mechanisms: retrieval from a URL known to be controlled by the CSP, manual configuration before deployment, or facilitation by a third-party discovery and registration service (such as a federation authority) in multi-lateral trust agreement artifact(s). ARTVL-1 covers the RP's validation of the attribute bundle signature and depends on this control being satisfied. For network-based key retrieval, DR-2 requirements for authenticated protected channels also apply.
WAAD-1	Wallet Subscriber Transaction Authorization	The decision of whether a federation transaction proceeds and, therefore, an assertion is issued and attributes are released to the RP SHALL be determined by the subscriber acting in the role of the authorized party.	Determine whether the subscriber-controlled wallet ensures that the subscriber, acting as the authorized party, controls the decision of whether a federation transaction proceeds and attributes are released to the RP.	Satisfied by TAGREE-1 and TAGREE-2.	5.6 A	IdP	ALL	
WAAD-2	Wallet Remembered Decision Disclosure	If [the subscriber-controlled wallet provides a mechanism to remember a disclosure decision by the authorized party (i.e., the subscriber) to apply to future requests from the same RP], the subscriber-controlled wallet SHALL disclose to the authorized party that the storage mechanism is in use.	Determine whether the subscriber-controlled wallet discloses to the subscriber that a mechanism to remember their authorization decision is in use.	Satisfied by IDPRD-7, applied to the wallet as the party implementing the runtime decision.	5.6 B	IdP	ALL	Assessment is required when: The subscriber-controlled wallet provides a mechanism to remember a subscriber's disclosure decision for future requests from the same RP.
WAAD-3	Wallet Remembered Decision Revocation	If [the subscriber-controlled wallet provides a mechanism to remember a disclosure decision by the authorized party (i.e., the subscriber) to apply to future requests from the same RP], the subscriber-controlled wallet... SHALL allow the authorized party to revoke such remembered access at a future time.	Determine whether the subscriber-controlled wallet allows the subscriber to revoke a previously remembered authorization decision.	Satisfied by IDPRD-8, applied to the wallet as the party implementing the runtime decision.	5.6 C	IdP	ALL	Assessment is required when: The subscriber-controlled wallet provides a mechanism to remember a subscriber's disclosure decision for future requests from the same RP.

NIST SP 800-63-4 Conformance Criteria v0.1: 63C

Control Identifier	Control Name	Control Text	Objective	Assessment Method	Index	Target	Profile/XAL Level	Discussion
WAAD-4	CSP Wallet Subscriber Redress	The CSP SHALL provide secure and effective means of redress of subscriber complaints or problems (e.g., subscriber identifies an inaccurate attribute value, the need to invalidate attribute bundles that were previously issued to a subscriber-controlled wallet).	Determine whether the CSP provides secure and effective means of redress for subscriber complaints or problems related to attribute bundles issued to a subscriber-controlled wallet.	The base CSP redress mechanism is satisfied by RR-6. Examine the CSP's redress documentation and procedures for coverage of wallet-specific scenarios, including correction of inaccurate attribute values in issued bundles and invalidation of previously issued attribute bundles (e.g., due to compromise, account termination, or subscriber request). Verify that these redress mechanisms protect the integrity of the redress process (e.g., authenticating the subscriber before modifying or invalidating bundles) and produce effective outcomes for the subscriber.	5.6 D	CSP	ALL	
AREQ-1	Wallet Assertion Request Contents	When federation transactions are initiated by the RP, the RP's request for an assertion SHALL contain: (1) An identifier for the RP (2) A cryptographic nonce (3) The set of identity attributes, derived attributes, and attribute bundles requested by the RP and their purpose of use at the RP.	Determine whether the RP's requests for assertions from subscriber-controlled wallets contain all required elements.	Examine the RP's wallet federation configuration to confirm it includes its identifier, a cryptographic nonce, and the set of requested attributes, with the purpose of use, in all assertion requests to subscriber-controlled wallets. Test by initiating a federation transaction between an RP and a subscriber-controlled wallet and capturing the RP's assertion request. Verify that it contains: (1) a unique identifier for the RP; (2) b. a cryptographic nonce; (3) the set of identity attributes, derived attributes, and attribute bundles requested by the RP and their purpose of use at the RP.	5.7 A	RP	ALL	
ARTCN-1	Wallet Assertion Contents	Assertions from a subscriber-controlled wallet SHALL contain: (1) A signed attribute bundle from the CSP. (2) Audience identifier: An identifier for the party that is intended to consume the assertion (i.e., the RP). (3) Issuance time: A timestamp that indicates when the wallet issued the assertion. (4) Validity time window: A period of time outside of which the assertion SHALL NOT be accepted as valid by the RP for the purposes of authenticating the subscriber and starting an authenticated session at the RP. This is usually communicated by means of an expiration timestamp for the assertion in addition to the issuance timestamp. (5) Assertion identifier: A value that uniquely identifies this assertion and is used to prevent attackers from replaying prior assertions. For example, this can be a unique nonce generated by the wallet and included in the assertion. (6) Signature: A digital signature that uses asymmetric cryptography and covers the entire assertion.	Determine whether assertions from a subscriber-controlled wallet contain all required elements.	Test by initiating a federation transaction and capture the wallet's assertion. Verify the assertion contains all required elements.	5.8 A	IdP	ALL	RP enforcement of the validity time window is assessed under ARTVL-3 item 3.

NIST SP 800-63-4 Conformance Criteria v0.1: 63C

Control Identifier	Control Name	Control Text	Objective	Assessment Method	Index	Target	Profile/XAL Level	Discussion
ARTCN-2	Wallet Assertion xAL and Activation Information	The following aspects of the federation transaction SHALL be provided through information contained in the assertion contents or the applicable trust agreement: (1) The IAL of the subscriber account being represented in the assertion, an indication of the issuance processes, or an indication that no IAL is asserted. (2) The nature of the activation method used to activate the wallet. (3) The wallet's intended FAL of the federation process that is represented by the assertion.	Determine whether the required IAL, activation method, and FAL information is conveyed through the wallet assertion contents or the applicable trust agreement artifact(s).	Examine sample assertions and/or trust agreement artifact(s) to confirm they convey all required information.	5.8 B	IdP	ALL	
ARTCN-3	Hosted Wallet AAL Reporting	If a subscriber-controlled wallet is hosted as a remote service, the AAL of the subscriber's current session at the hosted wallet service SHALL be provided through information contained in the assertion contents or the applicable trust agreement.	Determine whether the AAL of the subscriber's current session at the hosted wallet service is conveyed through the assertion contents or the applicable trust agreement artifact(s).	Examine sample assertions and/or trust agreement artifact(s) to confirm the AAL of the subscriber's session at the hosted wallet service is conveyed.	5.8 C	IdP	ALL	Assessment is required when: The subscriber-controlled wallet is hosted as a remote service.
ARTCN-4	Wallet Assertion Nonce Inclusion	At FAL2 and above, the assertion SHALL include: 1. Nonce: A cryptographic nonce from the RP's federation request.	Determine whether the wallet's assertion includes the cryptographic nonce from the RP's federation request at FAL2 and above.	Satisfied by ARTC-7.	5.8 D	IdP	FAL2/FAL3	In the errata publication, this control will be changed to: At FAL2 and above, the assertion SHALL include the cryptographic nonce from the RP's federation request.
ARTCN-5	Wallet FAL3 Assertion Mechanism Indicator	At FAL3, the assertion SHALL include one of the following: the public key, key identifier, or other identifier for a holder-of-key assertion. This MAY be the same key that the subscriber-controlled wallet uses to sign the assertion; or, an indicator that the verification of a bound authenticator is required to process this assertion.	Determine whether the wallet's assertion at FAL3 includes either a holder-of-key identifier or a bound authenticator indicator.	Test by initiating a federation transaction at FAL3 with a subscriber-controlled wallet. Capture the assertion and verify it contains either: (a) a public key, key identifier, or other identifier for a holder-of-key assertion, or (b) an indicator that verification of a bound authenticator is required.	5.8 E	IdP	FAL3	ARTC-8 establishes the equivalent requirement for traditional federation (Sec. 4.9 H). In the wallet model, the wallet's own signing key may also serve as the holder-of-key authenticator, since the attribute bundle from the CSP already binds that key to the subscriber.
ARTCN-6	Wallet Assertion Authentication Secret Prohibition	Assertions SHALL NOT contain subscriber authentication secrets (e.g., passwords).	Determine whether wallet assertions are free of subscriber authentication secrets.	Satisfied by ARTC-9.	5.8 F	IdP	ALL	
ARTCN-7	Attribute Bundle Contents	The signed attribute bundle from the CSP SHALL contain: (1) Keys: A verification key or key identifier for the key used by the subscriber controlled wallet to sign assertions. (2) Issuer identifier: An identifier for the issuer of the attribute bundle (i.e., the CSP). (3) Issuance time: A timestamp that indicates when the CSP issued the attribute bundle. (4) IAL: Indicator of the IAL of the subscriber account being represented in the attribute bundle or an indication that no IAL is asserted. (5) Signature: A digital signature that uses asymmetric cryptography and covers the entire attribute bundle. (6) Attribute values and derived attribute values: Information about the subscriber.	Determine whether signed attribute bundles from the CSP contain all required elements.	Test by obtaining a signed attribute bundle issued by the CSP to a subscriber-controlled wallet. Verify the bundle contains all required elements.	5.8 G	CSP	ALL	

NIST SP 800-63-4 Conformance Criteria v0.1: 63C

Control Identifier	Control Name	Control Text	Objective	Assessment Method	Index	Target	Profile/XAL Level	Discussion
ARTCN-8	Wallet Assertion Subscriber Identification	If the RP subscriber account does not use an ephemeral provisioning process (see Sec. 4.6.5) or an account resolution process (see Sec. 3.8.2), the subscriber SHALL be identified in the assertion using a federated identifier (see Sec. 3.4).	Determine whether the subscriber is identified in the wallet assertion using a federated identifier when neither ephemeral provisioning nor account resolution is used.	This is a functional requirement describing when a federated identifier is used. Assessment of federated identifier handling is covered under the RP subscriber account controls in Sec. 3.8.	5.8 H	RP	ALL	Assessment is required when: The RP subscriber account does not use an ephemeral provisioning process or an account resolution process.
ARTCN-9	Wallet Federated Identifier Issuer	The issuer identifier SHALL be of the CSP that issued the signed attribute bundle.	Determine whether the RP uses the CSP's issuer identifier as the issuer component of the federated identifier.	Test by presenting a wallet assertion where the wallet's issuer identifier in the outer assertion differs from the CSP's issuer identifier in the signed attribute bundle. Confirm that the RP constructs the federated identifier using the CSP's issuer identifier.	5.8 I	RP	ALL	<i>Assessment is required when: The subscriber is identified in the assertion using a federated identifier.</i> When wallets act as an IdP, the assertion has two issuers: the wallet (outer assertion) and the CSP (signed attribute bundle). The federated identifier must use the CSP as the issuer component because the CSP is the authority over the subscriber account and the subject identifier.
ARTCN-10	Wallet Subject Identifier in Signed Attribute Bundle	The subject identifier SHALL be contained in the signed attribute bundle.	Determine whether the CSP includes the subject identifier within the signed attribute bundle issued to the wallet.	Examine the CSP's attribute bundle issuance process and configuration to confirm that the subject identifier is included as a field within the signed attribute bundle. Test by requesting issuance of an attribute bundle from the CSP and inspect its signed contents to confirm the subject identifier is present inside the bundle (rather than in the outer wallet assertion).	5.8 J	CSP	ALL	Assessment is required when: The subscriber is identified in the assertion using a federated identifier.
ARTCN-11	Wallet Subject Identifier Namespace Processing	The subject identifier SHALL be... processed in the namespace of the CSP that issued the attribute bundle.	Determine whether the RP scopes the subject identifier to the namespace of the CSP that issued the signed attribute bundle.	Examine the RP's assertion processing logic to confirm that subject identifiers extracted from CSP-signed attribute bundles are paired with the CSP's issuer identifier when resolving to an RP subscriber account. Test by presenting assertions from two different CSPs containing attribute bundles with the same subject identifier value. Confirm the RP treats them as different subscribers.	5.8 K	RP	ALL	Assessment is required when: The subscriber is identified in the assertion using a federated identifier. See ARTC-11 for the equivalent requirement for non-wallet federation.
ARTCN-12	Attribute Bundle Validity Window Enforcement	The signed attribute bundle from the CSP SHOULD contain a validity time window, which is defined as a period of time outside of which the attribute bundle SHALL NOT be accepted as valid by the RP for the purposes of authenticating the subscriber and starting an authenticated session at the RP.	Determine whether the RP rejects signed attribute bundles presented outside their validity time window.	Test by presenting an assertion from a wallet that contains an attribute bundle with an expired validity time window to the RP. Confirm the RP rejects it and does not establish an authenticated session.	5.8 L	RP	ALL	<i>Assessment is required when: The signed attribute bundle contains a validity time window.</i>

NIST SP 800-63-4 Conformance Criteria v0.1: 63C

Control Identifier	Control Name	Control Text	Objective	Assessment Method	Index	Target	Profile/XAL Level	Discussion
ARTCN-13	Wallet Selective Disclosure	Attributes SHALL be made available to the RP using a selective disclosure method if such a method is made available by the underlying attribute bundle. In selective disclosure, a subset of attributes is revealed rather than the entire set.	Determine whether the wallet uses selective disclosure when presenting attributes to the RP, when the attribute bundle supports it.	Examine the wallet's assertion presentation logic to confirm that when the underlying attribute bundle supports selective disclosure, the wallet uses it to present only the attributes requested by the RP rather than the full bundle contents. Test by initiating a federation transaction where the RP requests a subset of the attributes available in the attribute bundle. Confirm the wallet presents only the requested subset.	5.8 M	IdP	ALL	<i>Assessment is required when: The underlying attribute bundle supports selective disclosure.</i> This requirement ensures that the wallet does not over-disclose attributes to the RP.
ARTCN-14	Unsigned Attributes as Self-Asserted	Identity attributes that are in the assertion but outside of a signed attribute bundle SHALL be considered self-asserted.	Determine whether the RP treats identity attributes present in the assertion but outside of a signed attribute bundle as self-asserted.	Examine the RP's assertion processing logic or documentation to confirm that attributes outside a signed attribute bundle are classified as self-asserted and not treated as CSP-verified for access or trust decisions.	5.8 N	RP	ALL	The RP may validate these additional attributes using its own validation process.
ARTPT-1	Wallet Assertion Presentation Channel Protection	Assertions SHALL be presented to the RP through an authenticated protected channel.	Determine whether assertions from a subscriber-controlled wallet are presented to the RP over an authenticated protected channel.	For network-based assertion presentations, this control is satisfied by PSI-1. Examine the presentation protocol specification and implementation documentation to confirm that the protocol establishes an authenticated protected channel for assertion presentation, for each wallet and non-network presentation method that will be utilized.	5.9 A	IdP/RP	ALL	
ARTPT-2	Wallet Presentation Nonce Inclusion	The presentation SHALL include the cryptographic nonce from the RP's request, if present (this is required at FAL2 and above).	Determine whether the wallet includes the RP's cryptographic nonce in the assertion presentation.	Satisfied by ARTCN-4.	5.9 B	IdP	ALL	Assessment is required when: The RP sends a cryptographic nonce in its federation request (required at FAL2 and above).
ARTPT-3	Wallet Presentation Nonce Verification	The RP SHALL verify the nonce in accordance with the federation protocol.	Determine whether the RP verifies the cryptographic nonce in the wallet's presentation.	Satisfied by ARTVL-3, item 5.	5.9 C	RP	ALL	Assessment is required when: The RP sends a cryptographic nonce in its federation request (required at FAL2 and above).
ARTPT-4	Wallet Assertion Injection Protection	The RP SHALL protect itself against the injection of manufactured or captured assertions by using XSS and CSRF protection, rejecting assertions outside of the correct stage of a federation transaction, or other accepted techniques discussed in Sec. 3.11.1.	Determine whether the RP protects itself against injection of manufactured or captured wallet assertions.	Satisfied by FCP-2.	5.9 D	RP	ALL	
ARTVL-1	Wallet Attribute Bundle Signature Validation	The RP SHALL validate the signature on all signed attribute bundles in the assertion using the verification key from the CSP that issued the signed attribute bundle.	Determine whether the RP validates the signature on all signed attribute bundles in the assertion using the verification key from the CSP that issued the bundle.	Satisfied by ABUN-2.	5.10 A	RP	ALL	ABUN-2 establishes the requirement for RPs to validate CSP signatures on attribute bundles. This control applies that requirement to subscriber-controlled wallet scenarios.
ARTVL-2	Wallet Assertion Signature Validation	The RP SHALL validate the signature of the assertion using the verification key of the subscriber controlled wallet contained in the signed attribute bundle.	Determine whether the RP validates the wallet's assertion signature using the wallet's verification key contained in the signed attribute bundle.	Satisfied by ABUN-3.	5.10 B	RP	ALL	

NIST SP 800-63-4 Conformance Criteria v0.1: 63C

Control Identifier	Control Name	Control Text	Objective	Assessment Method	Index	Target	Profile/XAL Level	Discussion
ARTVL-3	Wallet Assertion Validation Checklist	The RP SHALL validate the assertion by checking that all the following are true: (1) Bundle verification: Ensure that the bundle was issued to the wallet that is presenting the assertion to the RP. (2) Issuer verification: If a specific wallet was requested by the RP, ensure that the assertion was issued by the requested wallet. (3) Time validation: Ensure that the validity time window is within acceptable limits of the current timestamp. (4) Audience restriction: Ensure that this RP is the intended recipient of the assertion. (5) Nonce: Ensure that the cryptographic nonce included in the RP's request is also included in the presentation. (6) Transaction terms: Ensure that the IAL, AAL, and FAL represented by the assertion are allowable under the applicable trust agreement and are suitable for the RP's needs. (7) Assertion identifier: Ensure that the assertion has not been replayed within its validity time window at this RP by validating a transaction specific assertion identifier, such as a wallet-provided nonce.	Determine whether the RP validates all required elements of a wallet assertion before accepting it.	Examine the RP assertion validation documentation to confirm that all requirements are checked. Test the RP system to validate all assertions are checked for the required elements and reject if they are not present.	5.10 C	RP	ALL	
RPSUBA-1	Wallet Account Resolution Attribute Minimization	If a federated identifier is not present (e.g., in the case of mDL), the RP will need to request the necessary attributes to resolve the subscriber to the RP subscriber account for each federated transaction. This attribute set SHALL be the minimum necessary to achieve accurate resolution.	Determine whether the RP requests only the minimum attributes necessary for accurate account resolution when a federated identifier is not present.	Examine the set of attributes that the RP requests from the wallet for account resolution. Confirm that each requested attribute is necessary for accurate resolution and that no extraneous attributes are included.	5.11 A	RP	ALL	<i>Assessment is required when: A federated identifier is not present in the wallet assertion and account resolution is used.</i> ACCR-1 requires that the requested attributes are sufficient for unique resolution; this control requires that they are no more than necessary. Together they establish the bound: request enough to resolve accurately, but nothing beyond that. This supports the data minimization principles in Sec. 7.
RPSUBA-2	Wallet Federated Identifier Linking	Linking to multiple federated identifiers SHALL be managed as discussed in Sec. 3.8.1.	Determine whether linking to multiple federated identifiers in the wallet context is managed in accordance with Sec. 3.8.1.	Satisfied by ACCL-1 and ACCL-2.	5.11 B	RP	ALL	
RPSUBA-3	RP Subscriber Information Management Disclosure	The RP SHALL disclose its practices for managing subscriber information as part of the trust agreement.	Determine whether the RP discloses its practices for managing subscriber information as part of the trust agreement artifact(s).	Examine the trust agreement artifact(s) to confirm the RP's practices for managing subscriber information are disclosed, including how subscriber data is collected, stored, used, and disposed of.	5.11 C	RP	ALL	
RPSUBA-4	Wallet RP Subscriber Account Redress	The RP SHALL provide effective means of redress to the subscriber for correcting information in the RP subscriber account. See Sec. 3.5.3 for additional requirements and considerations for redress mechanisms.	Determine whether the RP provides effective means of redress to the subscriber for correcting information in the RP subscriber account.	Satisfied by RR-1.	5.11 D	RP	ALL	